

PANDUAN PRAKTIS

CYBER SECURITY AWARENESS

Melindungi Data, Sistem, dan Layanan
Digital dari Ancaman Siber



KENALI

Ancaman Siber
di Sekitar Kita



LINDUNGI

Data, Akun, dan
Perangkat Anda



WASPADA

Terhadap Teknik
Rekayasa Sosial



AMAN

Budaya Aman
Dimulai dari Kita



KEAMANAN
INFORMASI



PERLINDUNGAN
DATA PRIBADI



KEAMANAN
SISTEM



KEAMANAN
AKUN



BUDAYA
AMAN

SADAR • WASPADA • LINDUNGI • AMAN

Keamanan Siber Adalah Tanggung Jawab Kita Bersama

PANDUAN PRAKTIS

CYBER SECURITY AWARENESS

Melindungi Data, Sistem, dan Layanan Digital
dari Ancaman Siber



Hendrawan Aprillia Ashari, S.T., M.Kom.

**DINAS KOMUNIKASI, INFORMATIKA DAN STATISTIK
KABUPATEN BREBES**

2026

HAK CIPTA

PANDUAN PRAKTIS

CYBER SECURITY AWARENESS

Melindungi Data, Sistem, dan Layanan Digital dari Ancaman Siber

Penulis:

Hendrawan Aprillia Ashari, S.T., M.Kom.

© 2026 Hendrawan Aprillia Ashari

Hak cipta dilindungi sesuai dengan ketentuan peraturan perundang-undangan. Dilarang memperbanyak, mendistribusikan, menerbitkan kembali, menyimpan dalam media apa pun, atau mengubah sebagian maupun seluruh isi buku ini untuk tujuan komersial tanpa izin tertulis dari pemegang hak cipta, kecuali penggunaan yang diperbolehkan berdasarkan ketentuan peraturan perundang-undangan.

Buku ini disusun sebagai **panduan praktis cyber security awareness** bagi Aparatur Sipil Negara (ASN), Pegawai Non ASN, Operator Aplikasi, Administrator Sistem, Helpdesk, serta seluruh pegawai yang menggunakan komputer dan layanan digital dalam mendukung pelaksanaan tugas sehari-hari. Materi dalam buku ini bertujuan meningkatkan pemahaman, kesadaran, dan budaya keamanan siber sehingga setiap pengguna mampu berperan aktif dalam melindungi data, sistem, dan layanan digital organisasi.

Pembahasan dalam buku ini berfokus pada aspek **cyber security awareness, keamanan informasi, perlindungan data, keamanan akun dan kredensial, phishing, malware,**

ransomware, social engineering, keamanan email, keamanan perangkat, firewall, IDS/IPS, Web Application Firewall (WAF), Access Control List (ACL), Defense in Depth, Least Privilege, Security by Design, serta incident response sebagai dasar penerapan keamanan informasi di lingkungan organisasi.

Buku ini merupakan **panduan edukatif** dan tidak dimaksudkan sebagai pedoman teknis implementasi, standar operasional prosedur (SOP), maupun acuan konfigurasi sistem keamanan tertentu. Setiap organisasi tetap perlu menyesuaikan penerapan keamanan siber dengan kebijakan, regulasi, dan kebutuhan operasional masing-masing.

Contoh nama pengguna, alamat surel, nomor identitas, alamat IP, nama domain, konfigurasi sistem, ilustrasi insiden, maupun data lain yang digunakan dalam buku ini merupakan **contoh pembelajaran atau data yang telah disamarkan**, kecuali dinyatakan lain. Kemiripan dengan data sebenarnya bersifat tidak disengaja.

INFORMASI BUKU

Keterangan	Informasi
Judul	Panduan Praktis Cyber Security Awareness
Subjudul	Melindungi Data, Sistem, dan Layanan Digital dari Ancaman Siber
Penulis	Hendrawan Aprillia Ashari, S.T., M.Kom.
Instansi	Dinas Komunikasi, Informatika dan Statistik Kabupaten Brebes
Tahun Terbit	2026
Edisi	Edisi Pertama
Ukuran Buku	A5

Dinas Komunikasi, Informatika dan Statistik

Kabupaten Brebes, Provinsi Jawa Tengah

KATA PENGANTAR

Puji syukur ke hadirat Tuhan Yang Maha Esa atas segala rahmat dan karunia-Nya sehingga buku **Panduan Praktis Cyber Security Awareness: Melindungi Data, Sistem, dan Layanan Digital dari Ancaman Siber** ini dapat diselesaikan dengan baik.

Transformasi digital telah memberikan banyak manfaat dalam meningkatkan efisiensi, efektivitas, dan kualitas pelayanan di berbagai sektor, termasuk instansi pemerintah. Namun, di balik berbagai kemudahan tersebut, ancaman siber juga berkembang semakin kompleks. Serangan seperti *phishing*, *ransomware*, pencurian kredensial, kebocoran data, hingga rekayasa sosial tidak hanya menargetkan infrastruktur teknologi, tetapi juga memanfaatkan kelengahan pengguna sebagai titik awal serangan.

Keamanan siber bukan lagi menjadi tanggung jawab administrator sistem atau tim teknologi informasi semata. Setiap pegawai yang menggunakan komputer, perangkat bergerak, jaringan, maupun aplikasi memiliki peran penting dalam menjaga keamanan informasi. Satu tindakan yang kurang hati-hati, seperti membuka lampiran email yang mencurigakan atau menggunakan kata sandi yang lemah, dapat berdampak pada terganggunya layanan organisasi serta membahayakan kerahasiaan data.

Buku ini disusun sebagai panduan praktis yang membahas konsep dasar keamanan siber, perkembangan ancaman siber, jenis-jenis serangan yang umum terjadi, kesalahan yang sering menyebabkan insiden keamanan, prinsip-prinsip pertahanan siber, teknologi keamanan informasi, serta langkah-langkah penanganan insiden (*Incident Response*). Materi disajikan dengan bahasa yang sederhana, ringkas, dan mudah dipahami

sehingga dapat digunakan sebagai bahan pelatihan maupun referensi dalam pelaksanaan tugas sehari-hari.

Penulis menyadari bahwa buku ini masih memiliki keterbatasan dan masih dapat dikembangkan seiring dengan perkembangan teknologi serta dinamika ancaman siber yang terus berubah. Oleh karena itu, kritik, saran, dan masukan yang membangun sangat diharapkan demi penyempurnaan buku ini pada edisi berikutnya.

Akhir kata, semoga buku ini dapat memberikan manfaat, meningkatkan kesadaran keamanan siber, serta mendorong terciptanya budaya keamanan informasi di lingkungan kerja. Dengan kesadaran dan partisipasi seluruh pengguna, kita dapat bersama-sama melindungi data, sistem, dan layanan digital dari berbagai ancaman siber.

Brebes, 2026

Penulis

Hendrawan Aprillia Ashari, S.T., M.Kom.

DAFTAR ISI

BAB 1 PENDAHULUAN	1
1.1 Latar Belakang	1
1.2 Tujuan Penulisan	3
1.3 Sasaran Pembaca	5
1.4 Ruang Lingkup Pembahasan.....	7
1.5 Pentingnya Cyber Security Awareness	10
1.6 Tanggung Jawab Bersama dalam Keamanan Siber	12
BAB 2 MEMAHAMI ANCAMAN SIBER	16
2.1 Apa itu Cyber Security	16
2.2 Perkembangan Ancaman Siber	18
2.3 Mengapa Organisasi Menjadi Target.....	22
2.4 Dampak Serangan Siber	26
2.5 Siklus Serangan Siber (Cyber Kill Chain).....	29
2.6 Sepuluh Serangan Siber yang Paling Umum	34
2.6.1 Phishing	36
2.6.2 Ransomware	40
2.6.3 Malware dan Trojan.....	45
2.6.4 Credential Attack.....	50
2.6.5 Distributed Denial of Service (DDoS)	55
2.6.6 Web Exploitation	60
2.6.7 Insider Threat	66
2.6.8 Supply Chain Attack	73

2.6.9 Business Email Compromise (BEC)	78
2.6.10 Zero-Day Exploit.....	83
BAB 3 PENYEBAB UTAMA INSIDEN KEAMANAN SIBER.....	90
3.1 Faktor Manusia (Human Error)	90
3.2 Password yang Lemah	97
3.3 Penggunaan Password yang Sama	104
3.4 Tidak Menggunakan Multi-Factor Authentication (MFA)	109
3.5 Membuka Tautan dan Lampiran yang Mencurigakan.....	117
3.6 Sistem yang Tidak Diperbarui.....	125
3.7 Hak Akses yang Berlebihan	133
3.8 Salah Konfigurasi Sistem	140
3.9 Kurangnya Backup Data	149
3.10 Kurangnya Kesadaran Keamanan Siber	157
3.11 Studi Kasus Sederhana	165
BAB 4 MEMBANGUN PERTAHANAN SIBER.....	171
4.1 Konsep Defense in Depth.....	171
4.2 Firewall	174
4.3 Intrusion Detection System (IDS)	184
4.4 Intrusion Prevention System (IPS)	194
4.5 Web Application Firewall (WAF)	205
4.6 Endpoint Detection and Response (EDR)	216
4.7 Security Information and Event Management (SIEM).....	226
4.8 Access Control List (ACL)	238

4.9 Prinsip Least Privilege.....	247
4.10 Attack Surface.....	257
4.11 Filosofi Default Deny (Tutup Semua, Buka yang Dibutuhkan).....	267
4.12 Security by Design.....	277
4.13 Zero Trust.....	288
4.14 CIA Triad (Confidentiality, Integrity, Availability).....	300
BAB 5 MENJADI PENGGUNA YANG AMAN	313
5.1 Password yang Aman	313
5.2 Multi-Factor Authentication (MFA)	320
5.3 Menggunakan Email Secara Aman.....	331
5.4 Mengenali Email Phishing.....	341
5.5 Browsing Internet Secara Aman	350
5.6 Menggunakan Media Sosial dengan Aman	361
5.7 Mengamankan Laptop dan Komputer	372
5.8 Mengamankan Smartphone	381
5.9 Menggunakan USB Flashdisk dengan Aman.....	392
5.10 Backup Data	400
5.11 Melindungi Data Organisasi	407
5.12 Bekerja dari Luar Kantor (Remote Working)	418
5.13 Hal yang Harus Dilakukan (Do's)	426
5.14 Hal yang Harus Dihindari (Don'ts)	435
BAB 6 PENANGANAN INSIDEN KEAMANAN SIBER	445
6.1 Apa itu Incident Response.....	445

6.2 Preparation	455
6.3 Identification	464
6.4 Containment	475
6.5 Eradication	482
6.6 Recovery	492
6.7 Lessons Learned	505
6.8 Melaporkan Insiden Keamanan Siber	533
6.9 Apa yang Harus Dilakukan Saat Terjadi Serangan	545
BAB 7 MEMBANGUN BUDAYA KEAMANAN SIBER	559
7.1 Cyber Security adalah Tanggung Jawab Bersama.....	559
7.2 Peran ASN	573
7.3 Peran Pegawai Non ASN.....	584
7.4 Peran Operator Aplikasi	599
7.5 Peran Helpdesk	615
7.6 Peran Administrator Sistem	635
7.7 Komitmen Membangun Budaya Cyber Security.....	659
7.8 Ringkasan Buku	676
LAMPIRAN.....	693
Daftar Pustaka	693

BAB 1 PENDAHULUAN

1.1 Latar Belakang

Perkembangan teknologi informasi telah membawa perubahan yang sangat besar dalam berbagai aspek kehidupan, termasuk penyelenggaraan pemerintahan, pelayanan publik, pendidikan, kesehatan, maupun dunia usaha. Pemanfaatan komputer, jaringan, internet, komputasi awan (*cloud computing*), dan berbagai layanan digital telah meningkatkan efisiensi, kecepatan, serta kualitas layanan kepada masyarakat. Hampir seluruh proses administrasi, komunikasi, penyimpanan dokumen, dan pengolahan data saat ini dilakukan secara elektronik sehingga ketergantungan terhadap teknologi informasi semakin tinggi.

Di sisi lain, transformasi digital juga meningkatkan risiko terhadap keamanan informasi. Semakin banyak sistem, perangkat, aplikasi, dan layanan yang terhubung ke internet, semakin besar pula peluang dimanfaatkannya celah keamanan oleh pihak yang tidak bertanggung jawab. Ancaman siber saat ini tidak hanya menasar perusahaan besar atau lembaga pemerintah pusat, tetapi juga pemerintah daerah, rumah sakit, sekolah, perguruan tinggi, usaha kecil dan menengah, hingga individu. Oleh karena itu, setiap organisasi perlu memiliki kemampuan untuk mengelola risiko keamanan siber secara terstruktur dan berkelanjutan (Pascoe et al., 2024).

Serangan siber juga mengalami perkembangan yang sangat pesat, baik dari sisi jumlah maupun tingkat kompleksitasnya. Pelaku kejahatan siber memanfaatkan berbagai teknik, seperti

phishing, *ransomware*, pencurian kredensial, eksploitasi kerentanan aplikasi, hingga serangan terhadap rantai pasok (*supply chain attack*). Tujuan serangan tidak lagi sekadar mengganggu layanan, tetapi juga mencuri data, memperoleh keuntungan finansial, melakukan pemerasan, merusak reputasi organisasi, bahkan mengganggu pelayanan publik. Kondisi ini menunjukkan bahwa keamanan siber telah menjadi bagian penting dari tata kelola organisasi modern.

Meskipun teknologi keamanan terus berkembang, berbagai penelitian dan laporan insiden menunjukkan bahwa faktor manusia (*human factor*) masih menjadi salah satu penyebab utama keberhasilan serangan siber. Penggunaan kata sandi yang lemah, membuka tautan atau lampiran dari surat elektronik yang mencurigakan, menggunakan perangkat lunak yang tidak diperbarui, serta kurangnya kepedulian terhadap prosedur keamanan merupakan contoh kesalahan yang sering dimanfaatkan oleh pelaku serangan. Oleh karena itu, peningkatan kesadaran dan perilaku aman pengguna menjadi bagian yang tidak terpisahkan dari strategi keamanan siber organisasi.

Keamanan siber bukan hanya menjadi tanggung jawab unit teknologi informasi atau administrator sistem. Seluruh pegawai yang menggunakan komputer, perangkat bergerak, surat elektronik, maupun aplikasi organisasi memiliki peran penting dalam menjaga kerahasiaan, integritas, dan ketersediaan informasi. Setiap individu merupakan bagian dari sistem pertahanan organisasi, sehingga pemahaman mengenai ancaman siber dan praktik kerja yang aman perlu dimiliki oleh seluruh pegawai tanpa terkecuali (Pascoe et al., 2024).

Di Indonesia, pentingnya pelindungan informasi juga telah

diatur melalui berbagai peraturan perundang-undangan, di antaranya Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi dan Peraturan Pemerintah Nomor 71 Tahun 2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik (**Republik Indonesia, 2022; Republik Indonesia, 2019**). Regulasi tersebut menegaskan bahwa setiap penyelenggara sistem elektronik memiliki tanggung jawab untuk melindungi data dan sistem yang dikelolanya sesuai dengan prinsip keamanan informasi dan pengelolaan risiko.

Buku **Panduan Praktis Cyber Security Awareness** ini disusun sebagai bahan pembelajaran bagi Aparatur Sipil Negara (ASN), Pegawai Non-ASN, operator aplikasi, administrator sistem, petugas helpdesk, serta seluruh pegawai yang menggunakan perangkat teknologi informasi dalam pelaksanaan tugas sehari-hari. Materi dalam buku ini disajikan secara ringkas, praktis, dan mudah dipahami dengan tujuan membangun kesadaran keamanan siber, mengenali berbagai bentuk ancaman, menerapkan kebiasaan kerja yang aman, serta memahami langkah-langkah dasar dalam mencegah dan menangani insiden keamanan informasi. Dengan meningkatnya kesadaran dan kepedulian seluruh pegawai, diharapkan organisasi mampu mengurangi risiko serangan siber serta menjaga keberlangsungan layanan digital kepada masyarakat.

1.2 Tujuan Penulisan

Buku **Panduan Praktis Cyber Security Awareness** ini disusun sebagai bahan pembelajaran dan referensi praktis untuk meningkatkan pemahaman serta kesadaran seluruh pengguna teknologi informasi terhadap pentingnya menjaga keamanan data, sistem, dan layanan digital. Seiring meningkatnya

pemanfaatan teknologi informasi dalam penyelenggaraan pemerintahan dan pelayanan publik, setiap pengguna memiliki peran penting dalam menjaga keamanan informasi serta mendukung keberlangsungan operasional organisasi (Pascoe et al., 2024).

Secara umum, tujuan penyusunan buku ini adalah memberikan pemahaman mengenai konsep dasar keamanan siber (*cyber security*), perkembangan ancaman siber, serta berbagai risiko yang dapat memengaruhi kerahasiaan (*confidentiality*), integritas (*integrity*), dan ketersediaan (*availability*) informasi. Pemahaman tersebut diharapkan mampu membantu pembaca mengenali berbagai bentuk ancaman yang sering terjadi serta memahami dampaknya terhadap organisasi (ISO/IEC, 2022).

Selain memberikan pemahaman konseptual, buku ini juga bertujuan membangun budaya **Cyber Security Awareness** di lingkungan kerja. Kesadaran keamanan siber merupakan salah satu faktor penting dalam mengurangi risiko insiden keamanan informasi, karena sebagian besar serangan siber memanfaatkan kelalaian atau kesalahan pengguna (*human error*). Dengan meningkatnya kesadaran seluruh pegawai, diharapkan setiap individu mampu menerapkan kebiasaan kerja yang aman, mengenali aktivitas yang mencurigakan, serta mengambil tindakan yang tepat ketika menghadapi potensi ancaman keamanan siber (CISA, 2023).

Buku ini juga bertujuan memperkenalkan berbagai prinsip dasar keamanan informasi, seperti **Defense in Depth**, **Least Privilege**, **Security by Design**, **Zero Trust**, penggunaan **Firewall**, **Intrusion Detection System (IDS)**, **Intrusion Prevention System**

(IPS), serta **Web Application Firewall (WAF)** sebagai bagian dari strategi pertahanan organisasi. Meskipun tidak membahas konfigurasi teknis secara mendalam, pembaca diharapkan memahami fungsi dan manfaat setiap konsep tersebut dalam mendukung keamanan sistem informasi.

Selain itu, buku ini diharapkan dapat menjadi panduan praktis bagi ASN, Pegawai Non-ASN, operator aplikasi, administrator sistem, petugas helpdesk, dan seluruh pegawai dalam menerapkan praktik keamanan informasi pada aktivitas sehari-hari, seperti penggunaan kata sandi yang kuat, pemanfaatan *Multi-Factor Authentication (MFA)*, pengamanan perangkat kerja, kewaspadaan terhadap *phishing*, serta pelaporan insiden keamanan secara cepat dan tepat.

Pada akhirnya, tujuan utama buku ini adalah membangun budaya keamanan siber yang berkelanjutan di lingkungan organisasi. Dengan meningkatnya pemahaman, kepedulian, dan partisipasi seluruh pengguna, organisasi diharapkan mampu mengurangi risiko serangan siber, melindungi aset informasi yang dimiliki, serta menjaga kepercayaan masyarakat terhadap layanan digital yang diselenggarakan.

1.3 Sasaran Pembaca

Buku **Panduan Praktis Cyber Security Awareness** ini disusun untuk seluruh pengguna teknologi informasi di lingkungan organisasi, khususnya instansi pemerintah, yang dalam pelaksanaan tugasnya memanfaatkan komputer, jaringan, internet, aplikasi, maupun layanan digital. Materi yang disajikan menggunakan bahasa yang sederhana dan mudah dipahami sehingga dapat dipelajari oleh pembaca dari berbagai latar

belakang, baik yang memiliki pengetahuan teknis maupun yang tidak memiliki keahlian di bidang teknologi informasi.

Sasaran utama buku ini adalah **Aparatur Sipil Negara (ASN)** sebagai penyelenggara pemerintahan yang setiap hari mengelola berbagai informasi dan layanan digital. Melalui buku ini, ASN diharapkan memahami pentingnya menjaga keamanan informasi, mengenali berbagai bentuk ancaman siber, serta menerapkan praktik kerja yang aman dalam menjalankan tugas dan memberikan pelayanan kepada masyarakat.

Selain ASN, buku ini juga ditujukan kepada **Pegawai Non-ASN** yang turut mendukung operasional organisasi. Meskipun tidak seluruhnya memiliki tanggung jawab teknis terhadap sistem informasi, setiap pegawai tetap memiliki kewajiban untuk menjaga kerahasiaan data, menggunakan perangkat teknologi secara bertanggung jawab, serta mematuhi kebijakan keamanan informasi yang berlaku di lingkungan kerja.

Buku ini juga ditujukan bagi **Operator Aplikasi** yang bertanggung jawab dalam mengoperasikan berbagai sistem informasi organisasi. Operator aplikasi perlu memahami risiko keamanan yang dapat timbul selama penggunaan aplikasi, seperti pencurian kredensial, serangan *phishing*, maupun penyalahgunaan hak akses. Dengan meningkatnya kesadaran keamanan siber, operator diharapkan mampu mengidentifikasi aktivitas yang tidak wajar serta segera melaporkan potensi insiden keamanan kepada pihak yang berwenang.

Bagi **Administrator Sistem**, buku ini memberikan pemahaman mengenai konsep-konsep dasar keamanan siber yang mendukung pengelolaan infrastruktur teknologi informasi secara aman. Meskipun pembahasannya tidak berfokus pada

konfigurasi teknis, administrator sistem diharapkan memahami pentingnya penerapan prinsip **Defense in Depth**, **Least Privilege**, **Access Control List (ACL)**, **Security by Design**, serta pengelolaan hak akses sebagai bagian dari upaya mengurangi risiko serangan siber.

Selanjutnya, buku ini juga ditujukan kepada **Petugas Helpdesk** sebagai garda terdepan dalam menerima laporan gangguan maupun insiden keamanan informasi. Pemahaman mengenai jenis-jenis ancaman siber, teknik rekayasa sosial (*social engineering*), serta prosedur pelaporan insiden akan membantu petugas helpdesk dalam memberikan respons awal yang cepat dan tepat sebelum insiden berkembang menjadi lebih besar.

Pada akhirnya, buku ini ditujukan kepada **seluruh pegawai yang menggunakan komputer, perangkat bergerak, surat elektronik, internet, maupun aplikasi organisasi**. Keamanan siber merupakan tanggung jawab bersama (*shared responsibility*), sehingga setiap individu memiliki peran penting dalam menjaga kerahasiaan, integritas, dan ketersediaan informasi organisasi. Meningkatnya kesadaran dan kepedulian seluruh pengguna akan memperkuat budaya keamanan informasi serta membantu organisasi mengurangi risiko terjadinya insiden keamanan siber (Pascoe et al., 2024; ISO/IEC, 2022).

1.4 Ruang Lingkup Pembahasan

Buku **Panduan Praktis Cyber Security Awareness** ini membahas konsep-konsep dasar keamanan siber (*cyber security*) yang diperlukan oleh seluruh pengguna teknologi

informasi dalam mendukung pelaksanaan tugas sehari-hari. Pembahasan difokuskan pada peningkatan kesadaran (*awareness*), pemahaman terhadap ancaman siber, serta penerapan praktik keamanan informasi yang dapat dilakukan oleh setiap individu untuk mengurangi risiko terjadinya insiden keamanan (Pascoe et al., 2024).

Materi dalam buku ini diawali dengan pengenalan mengenai perkembangan ancaman siber, karakteristik serangan yang sering terjadi, serta dampaknya terhadap organisasi. Pembaca akan diperkenalkan pada berbagai jenis serangan yang umum ditemukan, seperti *phishing*, *ransomware*, *malware*, pencurian kredensial (*credential attack*), *Distributed Denial of Service (DDoS)*, eksploitasi aplikasi web, *Business Email Compromise (BEC)*, hingga *supply chain attack*. Pembahasan dilakukan secara konseptual agar mudah dipahami oleh seluruh pembaca tanpa memerlukan latar belakang teknis yang mendalam.

Selanjutnya, buku ini membahas berbagai penyebab utama terjadinya insiden keamanan informasi, khususnya faktor manusia (*human error*) yang masih menjadi penyebab dominan dalam berbagai kasus serangan siber. Pembaca akan memahami pentingnya penggunaan kata sandi yang kuat, penerapan *Multi-Factor Authentication (MFA)*, pembaruan sistem secara berkala, pengelolaan hak akses, serta kewaspadaan terhadap berbagai bentuk rekayasa sosial (*social engineering*) yang memanfaatkan kelengahan pengguna (CISA, 2023).

Sebagai bagian dari upaya membangun pertahanan siber, buku ini juga memperkenalkan berbagai teknologi dan konsep keamanan informasi, seperti **Firewall**, **Intrusion Detection System (IDS)**, **Intrusion Prevention System (IPS)**, **Web**

Application Firewall (WAF), Endpoint Detection and Response (EDR), Security Information and Event Management (SIEM), Access Control List (ACL), Defense in Depth, Least Privilege, Security by Design, Zero Trust, serta konsep **Confidentiality, Integrity, and Availability (CIA Triad)**. Pembahasan difokuskan pada fungsi, manfaat, dan peran masing-masing teknologi dalam melindungi sistem informasi, bukan pada konfigurasi teknisnya.

Selain membahas konsep keamanan, buku ini memberikan panduan praktis mengenai kebiasaan bekerja yang aman, seperti penggunaan perangkat kerja secara bertanggung jawab, pengamanan akun pengguna, perlindungan data organisasi, penggunaan media penyimpanan eksternal, keamanan surat elektronik, keamanan perangkat bergerak, serta praktik aman ketika bekerja dari luar kantor (*remote working*). Pembahasan tersebut diharapkan dapat langsung diterapkan oleh pembaca dalam aktivitas sehari-hari.

Pada bagian akhir, buku ini membahas konsep dasar **Incident Response**, yaitu langkah-langkah yang perlu dilakukan organisasi ketika menghadapi insiden keamanan siber. Pembaca akan diperkenalkan dengan tahapan **Preparation, Identification, Containment, Eradication, Recovery**, dan **Lessons Learned**, sehingga memahami pentingnya respons yang cepat, terstruktur, dan terdokumentasi dalam meminimalkan dampak serangan siber (Nelson et al., 2025).

Buku ini tidak membahas konfigurasi perangkat keamanan, teknik eksploitasi sistem, maupun langkah-langkah teknis yang bersifat ofensif. Seluruh materi difokuskan pada peningkatan kesadaran keamanan siber (*Cyber Security Awareness*) sebagai bagian dari upaya membangun budaya keamanan informasi yang

kuat di lingkungan organisasi. Dengan ruang lingkup tersebut, buku ini diharapkan dapat menjadi panduan praktis yang mudah dipahami sekaligus menjadi referensi dasar bagi seluruh pegawai dalam menerapkan prinsip-prinsip keamanan siber pada lingkungan kerja.

1.5 Pentingnya Cyber Security Awareness

Perkembangan teknologi informasi telah memberikan banyak manfaat bagi organisasi dalam meningkatkan efisiensi kerja, mempercepat proses bisnis, serta mendukung penyelenggaraan layanan digital. Namun, di balik berbagai kemudahan tersebut, ancaman siber juga berkembang semakin cepat. Berbagai jenis serangan, seperti *phishing*, *ransomware*, pencurian kredensial, *malware*, hingga rekayasa sosial (*social engineering*), terus mengalami peningkatan baik dari sisi jumlah maupun tingkat kompleksitasnya. Kondisi ini menjadikan keamanan siber sebagai salah satu aspek penting yang harus menjadi perhatian seluruh organisasi (Pascoe et al., 2024).

Banyak organisasi telah menginvestasikan berbagai teknologi keamanan, seperti *firewall*, *Intrusion Detection System (IDS)*, *Intrusion Prevention System (IPS)*, *Endpoint Detection and Response (EDR)*, maupun *Security Information and Event Management (SIEM)*. Meskipun demikian, berbagai laporan menunjukkan bahwa teknologi saja tidak cukup untuk melindungi organisasi dari ancaman siber. Sebagian besar insiden keamanan masih diawali oleh kesalahan pengguna, seperti membuka tautan *phishing*, menggunakan kata sandi yang lemah, mengabaikan pembaruan sistem, atau memberikan informasi kepada pihak yang tidak berwenang (CISA, 2023).

Cyber Security Awareness merupakan upaya untuk membangun pengetahuan, kepedulian, dan perilaku yang benar dalam menggunakan teknologi informasi secara aman. Tujuan utamanya bukan menjadikan seluruh pegawai sebagai ahli keamanan siber, melainkan membentuk kebiasaan kerja yang mampu mengurangi risiko terjadinya insiden keamanan informasi. Pegawai yang memiliki kesadaran keamanan siber akan lebih berhati-hati dalam menerima surat elektronik, menggunakan perangkat kerja, mengelola kata sandi, mengakses internet, maupun menyimpan dan membagikan informasi organisasi.

Kesadaran keamanan siber juga berperan penting dalam mendukung penerapan prinsip **Confidentiality, Integrity, dan Availability (CIA Triad)**. Informasi yang bersifat rahasia harus terlindungi dari akses yang tidak berwenang, data harus tetap akurat dan tidak mengalami perubahan tanpa izin, serta sistem dan layanan harus tetap tersedia ketika dibutuhkan. Ketiga prinsip tersebut hanya dapat terwujud apabila didukung oleh perilaku pengguna yang bertanggung jawab dalam memanfaatkan teknologi informasi (ISO/IEC, 2022).

Di lingkungan pemerintahan, keamanan siber memiliki peran yang semakin penting karena berbagai layanan publik telah bergantung pada sistem elektronik. Kebocoran data, gangguan layanan, maupun penyalahgunaan informasi tidak hanya menimbulkan kerugian bagi organisasi, tetapi juga dapat mengurangi kepercayaan masyarakat terhadap pelayanan publik. Oleh karena itu, setiap pegawai perlu memahami bahwa keamanan informasi merupakan bagian dari tanggung jawab pekerjaan sehari-hari, bukan semata-mata tanggung jawab unit teknologi informasi atau administrator sistem.

Membangun budaya **Cyber Security Awareness** merupakan proses yang berkelanjutan. Organisasi perlu memberikan edukasi, pelatihan, simulasi, serta sosialisasi secara berkala agar seluruh pegawai mampu mengikuti perkembangan ancaman siber yang terus berubah. Selain meningkatkan kemampuan individu, kegiatan tersebut juga membantu organisasi membangun budaya keamanan informasi yang kuat sehingga setiap pengguna mampu menjadi bagian dari sistem pertahanan organisasi.

Pada akhirnya, keberhasilan penerapan keamanan siber tidak hanya ditentukan oleh kecanggihan teknologi yang digunakan, tetapi juga oleh tingkat kesadaran seluruh penggunanya. Organisasi yang memiliki budaya keamanan siber yang baik akan lebih siap menghadapi ancaman, lebih cepat mendeteksi aktivitas yang mencurigakan, serta lebih mampu meminimalkan dampak apabila terjadi insiden keamanan informasi. Dengan demikian, **Cyber Security Awareness** merupakan investasi penting dalam menjaga keberlangsungan layanan, melindungi aset informasi, dan mempertahankan kepercayaan publik terhadap organisasi.

1.6 Tanggung Jawab Bersama dalam Keamanan Siber

Keamanan siber merupakan tanggung jawab seluruh elemen organisasi, bukan hanya tanggung jawab unit teknologi informasi atau administrator sistem. Dalam lingkungan kerja yang semakin bergantung pada teknologi digital, setiap pegawai berinteraksi dengan data, perangkat, jaringan, maupun aplikasi yang berpotensi menjadi sasaran serangan siber. Oleh karena itu,

keberhasilan penerapan keamanan siber sangat dipengaruhi oleh kepedulian dan partisipasi aktif seluruh pengguna dalam menerapkan praktik kerja yang aman (Pascoe et al., 2024).

Sering kali muncul anggapan bahwa keamanan siber sepenuhnya merupakan tanggung jawab administrator sistem karena mereka bertugas mengelola server, jaringan, dan perangkat keamanan. Padahal, berbagai laporan menunjukkan bahwa sebagian besar insiden keamanan diawali oleh tindakan pengguna, seperti mengklik tautan *phishing*, menggunakan kata sandi yang lemah, membagikan informasi sensitif kepada pihak yang tidak berwenang, atau mengabaikan pembaruan perangkat lunak. Kondisi tersebut menunjukkan bahwa pengguna merupakan salah satu lapisan pertahanan terpenting dalam menjaga keamanan organisasi (CISA, 2023).

Setiap pegawai memiliki tanggung jawab untuk menjaga kerahasiaan akun pengguna, menggunakan kata sandi yang kuat, menerapkan **Multi-Factor Authentication (MFA)** apabila tersedia, mengunci komputer saat meninggalkan meja kerja, serta memastikan data organisasi tidak disimpan atau dibagikan melalui media yang tidak aman. Tindakan sederhana tersebut dapat secara signifikan mengurangi peluang keberhasilan serangan siber yang memanfaatkan kelalaian pengguna.

Operator aplikasi memiliki tanggung jawab untuk menggunakan aplikasi sesuai dengan kewenangannya, menjaga kerahasiaan akun, serta segera melaporkan apabila menemukan aktivitas yang tidak wajar. Administrator sistem bertanggung jawab memastikan sistem tetap aman melalui pengelolaan hak akses, pembaruan keamanan, pemantauan sistem, pencadangan data, serta penerapan berbagai mekanisme

pengamanan sesuai dengan prinsip **Defense in Depth** dan **Least Privilege**. Sementara itu, petugas helpdesk memiliki peran penting sebagai titik awal penerimaan laporan gangguan maupun insiden keamanan sehingga mampu memberikan respons awal secara cepat dan meneruskan laporan kepada pihak yang berwenang.

Pimpinan organisasi juga memiliki peran yang sangat penting dalam membangun budaya keamanan siber. Dukungan kebijakan, penyediaan sumber daya, pelaksanaan pelatihan secara berkala, serta penegakan aturan keamanan informasi merupakan faktor yang menentukan keberhasilan penerapan keamanan siber. Tanpa komitmen dari pimpinan, penerapan teknologi keamanan yang canggih sekalipun tidak akan memberikan perlindungan yang optimal (Pascoe et al., 2024).

Selain tanggung jawab individu, organisasi perlu menerapkan kebijakan keamanan informasi yang jelas dan mudah dipahami oleh seluruh pegawai. Kebijakan tersebut mencakup penggunaan perangkat teknologi informasi, pengelolaan akun pengguna, klasifikasi informasi, penggunaan media penyimpanan, akses jaringan, pelaporan insiden, hingga prosedur penanganan ketika terjadi pelanggaran keamanan. Kebijakan yang disosialisasikan secara konsisten akan membantu membentuk perilaku kerja yang aman dan mengurangi risiko kesalahan manusia.

Pada akhirnya, keamanan siber merupakan bentuk **tanggung jawab bersama (*shared responsibility*)**. Teknologi keamanan seperti *Firewall*, *Intrusion Detection System (IDS)*, *Intrusion Prevention System (IPS)*, *Web Application Firewall (WAF)*, maupun *Endpoint Detection and Response (EDR)* hanya akan memberikan perlindungan yang optimal apabila didukung oleh

perilaku pengguna yang sadar akan pentingnya keamanan informasi. Ketika seluruh pegawai memahami perannya masing-masing dan bekerja sama dalam menjaga keamanan data, sistem, dan layanan digital, organisasi akan memiliki ketahanan yang lebih baik dalam menghadapi berbagai ancaman siber.

Budaya keamanan siber yang kuat tidak dibangun melalui teknologi semata, tetapi melalui komitmen seluruh anggota organisasi untuk menjadikan keamanan informasi sebagai bagian dari aktivitas kerja sehari-hari. Kesadaran, kepatuhan terhadap kebijakan, serta kemauan untuk melaporkan setiap aktivitas yang mencurigakan merupakan fondasi utama dalam menciptakan lingkungan kerja yang aman dan terpercaya.

BAB 2 MEMAHAMI ANCAMAN SIBER

2.1 Apa itu Cyber Security

Perkembangan teknologi informasi telah menjadikan komputer, jaringan, aplikasi, perangkat bergerak, dan layanan digital sebagai bagian yang tidak terpisahkan dari aktivitas organisasi. Berbagai data penting, seperti data pegawai, dokumen organisasi, informasi keuangan, surat elektronik, hingga layanan publik, kini disimpan dan diproses secara digital. Kondisi tersebut memberikan banyak manfaat, namun sekaligus meningkatkan risiko terhadap berbagai ancaman siber yang dapat mengganggu operasional organisasi.

Secara sederhana, **Cyber Security** atau **keamanan siber** adalah serangkaian upaya untuk melindungi komputer, jaringan, aplikasi, perangkat digital, serta data dari berbagai ancaman yang dapat menyebabkan kerusakan, pencurian, penyalahgunaan, maupun gangguan terhadap layanan. Tujuan utama keamanan siber adalah memastikan bahwa sistem informasi tetap aman, andal, dan dapat digunakan sesuai dengan fungsinya (Pascoe et al., 2024).

Keamanan siber tidak hanya berkaitan dengan penggunaan perangkat keamanan seperti *firewall*, antivirus, atau sistem deteksi intrusi. Cyber Security merupakan kombinasi antara **manusia (people)**, **proses (process)**, dan **teknologi (technology)** yang bekerja bersama untuk mengurangi risiko keamanan informasi. Teknologi yang canggih tidak akan memberikan perlindungan yang optimal apabila pengguna tidak memahami cara menggunakannya dengan benar atau organisasi tidak memiliki kebijakan keamanan yang memadai.

Dalam praktiknya, keamanan siber memiliki tujuan untuk melindungi tiga aspek utama keamanan informasi yang dikenal sebagai **CIA Triad**, yaitu **Confidentiality (Kerahasiaan)**, **Integrity (Integritas)**, dan **Availability (Ketersediaan)**. Ketiga prinsip tersebut menjadi dasar dalam perancangan, pengelolaan, dan pengamanan sistem informasi di berbagai organisasi.

- **Confidentiality (Kerahasiaan)** memastikan bahwa informasi hanya dapat diakses oleh pihak yang memiliki hak atau kewenangan.
- **Integrity (Integritas)** memastikan bahwa data tetap akurat, utuh, dan tidak mengalami perubahan tanpa izin.
- **Availability (Ketersediaan)** memastikan bahwa sistem, aplikasi, dan informasi tetap tersedia ketika dibutuhkan oleh pengguna yang berwenang.

Selain melindungi data, Cyber Security juga bertujuan menjaga keberlangsungan layanan (*business continuity*), melindungi aset organisasi, mengurangi risiko kerugian finansial, menjaga reputasi organisasi, serta memenuhi ketentuan hukum dan regulasi yang berlaku. Bagi instansi pemerintah, keamanan siber menjadi sangat penting karena gangguan terhadap sistem informasi dapat berdampak langsung pada pelayanan publik dan kepercayaan masyarakat.

Ancaman terhadap keamanan siber terus berkembang dari waktu ke waktu. Pelaku serangan memanfaatkan berbagai teknik, seperti *phishing*, *ransomware*, *malware*, pencurian kredensial, eksploitasi aplikasi web, hingga rekayasa sosial (*social engineering*) untuk memperoleh akses tidak sah terhadap sistem informasi. Oleh karena itu, organisasi tidak dapat hanya

mengandalkan satu mekanisme perlindungan, tetapi perlu menerapkan pendekatan keamanan yang berlapis (*Defense in Depth*) serta melakukan pengelolaan risiko secara berkelanjutan melalui tata kelola keamanan yang baik (Pascoe et al., 2024).

Perlu dipahami bahwa keamanan siber bukan hanya menjadi tanggung jawab administrator sistem atau unit teknologi informasi. Setiap pegawai yang menggunakan komputer, perangkat bergerak, surat elektronik, maupun aplikasi organisasi memiliki peran penting dalam menjaga keamanan informasi. Kesadaran pengguna dalam menggunakan teknologi secara aman merupakan salah satu faktor yang paling menentukan keberhasilan organisasi dalam menghadapi ancaman siber.

Dengan demikian, Cyber Security bukan sekadar penggunaan teknologi keamanan, melainkan sebuah proses berkelanjutan yang melibatkan kebijakan, teknologi, sumber daya manusia, serta budaya organisasi untuk melindungi informasi dan layanan digital dari berbagai ancaman yang terus berkembang. Penerapan keamanan siber yang baik akan membantu organisasi menjaga kerahasiaan data, mempertahankan keberlangsungan layanan, serta meningkatkan kepercayaan pengguna terhadap sistem informasi yang dikelolanya.

2.2 Perkembangan Ancaman Siber

Perkembangan teknologi informasi yang semakin pesat telah membawa perubahan besar dalam cara organisasi mengelola data, menjalankan proses bisnis, dan memberikan layanan kepada masyarakat. Pemanfaatan layanan *cloud computing*, perangkat bergerak (*mobile devices*), Internet of Things (IoT), kecerdasan buatan (*Artificial Intelligence*), hingga sistem kerja

jarak jauh (*remote working*) telah meningkatkan efisiensi dan produktivitas. Namun, di sisi lain, perkembangan tersebut juga memperluas peluang bagi pelaku kejahatan siber untuk melakukan berbagai bentuk serangan terhadap individu maupun organisasi (Pascoe et al., 2024).

Pada awal perkembangan internet, sebagian besar serangan siber dilakukan untuk menunjukkan kemampuan teknis, mencari popularitas, atau sekadar mengganggu sistem komputer. Serangan seperti penyebaran virus komputer, *website defacement*, maupun gangguan layanan (*Denial of Service*) menjadi ancaman yang sering ditemukan. Seiring berkembangnya teknologi dan meningkatnya nilai ekonomi data digital, motif serangan berubah menjadi pencurian informasi, pemerasan, keuntungan finansial, spionase, hingga sabotase terhadap infrastruktur penting.

Saat ini, ancaman siber berkembang dengan tingkat kompleksitas yang jauh lebih tinggi. Pelaku serangan tidak lagi bekerja secara individu, tetapi sering kali merupakan bagian dari kelompok kejahatan siber yang terorganisasi. Mereka memanfaatkan berbagai teknik, seperti **phishing**, **ransomware**, pencurian kredensial, eksploitasi kerentanan aplikasi, serangan terhadap rantai pasok (*supply chain attack*), hingga pemanfaatan kecerdasan buatan untuk membuat serangan menjadi lebih meyakinkan dan sulit dideteksi. Perkembangan ini menunjukkan bahwa ancaman siber terus beradaptasi mengikuti perkembangan teknologi dan perilaku pengguna (ENISA, 2024).

Salah satu karakteristik ancaman siber modern adalah pemanfaatan **rekayasa sosial (*social engineering*)**. Dalam banyak kasus, pelaku serangan tidak langsung menyerang sistem

teknologi, tetapi terlebih dahulu memanipulasi pengguna agar secara sukarela memberikan informasi penting, seperti nama pengguna, kata sandi, kode OTP, maupun data pribadi. Teknik ini dianggap efektif karena lebih mudah memanfaatkan kelemahan manusia dibandingkan harus menembus sistem keamanan yang telah diterapkan organisasi (CISA, 2023).

Perkembangan layanan digital juga menyebabkan meningkatnya jumlah perangkat yang terhubung ke internet. Komputer, telepon pintar, kamera pengawas, printer jaringan, perangkat IoT, hingga berbagai layanan berbasis *cloud* menjadi bagian dari infrastruktur organisasi. Setiap perangkat yang terhubung ke jaringan berpotensi menjadi titik masuk (*entry point*) bagi pelaku serangan apabila tidak dikelola dan diamankan dengan baik. Semakin banyak perangkat yang digunakan, semakin luas pula **attack surface** yang harus dilindungi oleh organisasi.

Laporan **Verizon Data Breach Investigations Report (DBIR)** menunjukkan bahwa pencurian kredensial, eksploitasi kerentanan, penyalahgunaan hak akses, dan *phishing* masih menjadi metode yang paling sering digunakan dalam berbagai insiden kebocoran data. Hal ini menunjukkan bahwa meskipun teknologi keamanan terus berkembang, faktor manusia tetap menjadi salah satu sasaran utama pelaku serangan. Oleh karena itu, peningkatan kesadaran keamanan siber (*Cyber Security Awareness*) menjadi salah satu langkah yang paling efektif dalam mengurangi risiko terjadinya insiden keamanan informasi (Verizon, 2025).

Perubahan pola kerja juga turut memengaruhi perkembangan ancaman siber. Penerapan kerja dari rumah (*Work From Home*),

penggunaan perangkat pribadi (*Bring Your Own Device/BYOD*), serta meningkatnya penggunaan layanan *cloud* menyebabkan batas antara jaringan internal organisasi dan jaringan publik menjadi semakin tipis. Kondisi tersebut menuntut organisasi untuk menerapkan pendekatan keamanan yang lebih adaptif, seperti **Zero Trust**, **Multi-Factor Authentication (MFA)**, pemantauan keamanan secara berkelanjutan, serta penerapan prinsip **Least Privilege** dalam pengelolaan hak akses (Pascoe et al., 2024).

Melihat perkembangan tersebut, dapat disimpulkan bahwa ancaman siber akan terus berkembang seiring dengan perkembangan teknologi informasi. Tidak ada organisasi yang sepenuhnya kebal terhadap serangan siber. Oleh karena itu, setiap organisasi perlu menerapkan strategi keamanan yang bersifat proaktif melalui kombinasi teknologi, kebijakan, proses, dan peningkatan kompetensi sumber daya manusia. Organisasi yang mampu membangun budaya keamanan siber yang baik akan memiliki kemampuan yang lebih tinggi dalam mencegah, mendeteksi, merespons, dan memulihkan diri dari berbagai bentuk serangan siber.



Gambar 2.1 Evolusi Perkembangan Ancaman Siber dari Masa ke Masa

Keterangan: Ilustrasi ini menunjukkan evolusi ancaman siber dari era awal hingga saat ini. Setiap periode memiliki karakteristik ancaman utama yang semakin kompleks dan berdampak luas.

2.3 Mengapa Organisasi Menjadi Target

Hampir setiap organisasi saat ini bergantung pada teknologi informasi dalam menjalankan aktivitasnya. Data pegawai, data pelanggan, dokumen penting, surat elektronik, aplikasi pelayanan, hingga sistem keuangan tersimpan dalam bentuk digital. Semakin besar ketergantungan terhadap teknologi, semakin besar pula peluang organisasi menjadi sasaran serangan siber. Pelaku kejahatan tidak selalu memilih organisasi berdasarkan ukuran atau tingkat kemajuannya, tetapi lebih sering berdasarkan **nilai aset yang dimiliki** dan **tingkat kerentanannya** (Verizon, 2025; ENISA, 2024).

Salah satu alasan utama organisasi menjadi target adalah **data memiliki nilai ekonomi yang tinggi**. Data pribadi, informasi keuangan, dokumen internal, hingga informasi strategis dapat diperjualbelikan di pasar gelap (*dark web*) atau digunakan untuk berbagai tindak kejahatan, seperti pencurian identitas, penipuan,

maupun pemerasan. Bagi organisasi pemerintah, kebocoran data juga dapat mengganggu pelayanan publik dan menurunkan kepercayaan masyarakat.

Selain data, organisasi juga menjadi target karena memiliki **layanan digital yang harus selalu tersedia**. Serangan seperti **Distributed Denial of Service (DDoS)** atau **ransomware** dapat menghentikan operasional organisasi dalam waktu singkat. Ketika layanan publik tidak dapat diakses, proses bisnis terganggu, produktivitas menurun, dan kerugian finansial maupun reputasi dapat meningkat secara signifikan (CISA, 2023).

Faktor lain yang sering dimanfaatkan oleh pelaku serangan adalah **kelemahan manusia (*human factor*)**. Banyak insiden keamanan tidak diawali oleh kegagalan teknologi, melainkan karena pengguna membuka email *phishing*, menggunakan kata sandi yang lemah, membagikan akun kepada orang lain, atau mengabaikan pembaruan perangkat lunak. Oleh karena itu, peningkatan kesadaran keamanan siber (*Cyber Security Awareness*) menjadi salah satu bentuk pertahanan yang paling efektif.

Organisasi yang memiliki sistem informasi yang kompleks juga menghadapi risiko yang lebih tinggi. Penggunaan berbagai aplikasi, server, perangkat bergerak, layanan *cloud*, jaringan nirkabel, hingga perangkat Internet of Things (IoT) memperluas **attack surface**, yaitu seluruh titik yang dapat dimanfaatkan oleh pelaku untuk memperoleh akses ke sistem. Semakin luas *attack surface*, semakin besar pula kebutuhan organisasi untuk menerapkan pengamanan secara menyeluruh.

Tidak hanya organisasi besar yang menjadi sasaran serangan. Banyak organisasi kecil dan menengah juga menjadi target karena

sering kali memiliki tingkat keamanan yang lebih rendah. Pelaku serangan mengetahui bahwa organisasi dengan sumber daya terbatas cenderung belum menerapkan pembaruan keamanan, autentikasi berlapis, pencadangan data, maupun pengelolaan hak akses secara memadai. Kondisi tersebut menjadikan organisasi lebih mudah ditembus dibandingkan organisasi yang memiliki sistem keamanan yang matang.

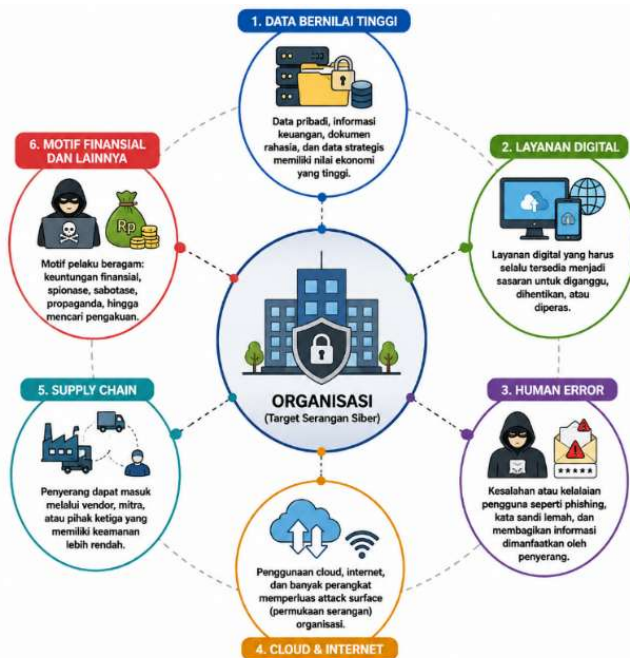
Dalam beberapa kasus, organisasi menjadi target bukan karena nilai data yang dimiliki, melainkan karena posisinya sebagai bagian dari **rantai pasok (supply chain)**. Penyerang dapat memanfaatkan vendor, penyedia layanan, atau mitra kerja yang memiliki tingkat keamanan lebih rendah untuk memperoleh akses ke organisasi utama. Oleh sebab itu, keamanan siber tidak hanya bergantung pada sistem internal, tetapi juga pada keamanan seluruh pihak yang terhubung dengan organisasi.

Motivasi pelaku serangan juga sangat beragam. Sebagian bertujuan memperoleh keuntungan finansial melalui pemerasan atau pencurian data. Sebagian lainnya melakukan spionase, sabotase, pencurian kekayaan intelektual, penyebaran propaganda, maupun gangguan terhadap layanan publik. Dalam beberapa kasus, serangan dilakukan hanya untuk menguji kemampuan atau mencari pengakuan di komunitas pelaku kejahatan siber.

Melihat kondisi tersebut, setiap organisasi perlu memahami bahwa ancaman siber bukan lagi pertanyaan **"apakah akan diserang"**, tetapi **"kapan serangan akan terjadi dan seberapa siap organisasi menghadapinya"**. Oleh karena itu, organisasi perlu membangun strategi keamanan yang mencakup teknologi, kebijakan, proses, serta peningkatan kompetensi seluruh

pegawai. Pendekatan ini akan meningkatkan kemampuan organisasi dalam mencegah, mendeteksi, merespons, dan memulihkan diri dari berbagai insiden keamanan siber.

Pada akhirnya, aset terpenting yang harus dilindungi bukan hanya perangkat keras atau aplikasi, melainkan **informasi, layanan, dan kepercayaan masyarakat**. Organisasi yang mampu menjaga ketiga aspek tersebut akan memiliki ketahanan siber (*cyber resilience*) yang lebih baik dalam menghadapi perkembangan ancaman yang terus berubah.



Gambar 2.2 Faktor Penyebab Organisasi Menjadi Target Serangan Siber

Organisasi dapat menjadi target serangan siber karena berbagai faktor yang saling berkaitan. Memahami faktor-faktor ini membantu meningkatkan kewaspadaan dan memperkuat pertahanan siber.

2.4 Dampak Serangan Siber

Serangan siber tidak hanya menyebabkan gangguan terhadap sistem komputer, tetapi juga dapat memberikan dampak yang luas terhadap operasional, keuangan, reputasi, hingga kepercayaan masyarakat terhadap suatu organisasi. Dalam banyak kasus, dampak yang ditimbulkan justru jauh lebih besar dibandingkan biaya yang diperlukan untuk menerapkan langkah-langkah pencegahan. Oleh karena itu, setiap organisasi perlu memahami berbagai konsekuensi yang dapat terjadi apabila keamanan siber tidak dikelola dengan baik (IBM, 2024).

Salah satu dampak yang paling sering terjadi adalah **kebocoran data (data breach)**. Pelaku serangan dapat memperoleh akses terhadap data pribadi, dokumen internal, informasi keuangan, maupun data strategis organisasi. Kebocoran data tidak hanya menimbulkan kerugian bagi organisasi, tetapi juga dapat merugikan individu yang datanya disalahgunakan untuk pencurian identitas, penipuan, atau tindak kejahatan lainnya. Di Indonesia, perlindungan data pribadi telah diatur dalam **Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi**, sehingga organisasi memiliki kewajiban untuk melindungi data yang dikelolanya.

Dampak berikutnya adalah **terhentinya layanan (service disruption)**. Serangan seperti **Distributed Denial of Service (DDoS)** atau **ransomware** dapat menyebabkan aplikasi, website, maupun layanan digital tidak dapat digunakan dalam waktu tertentu. Bagi instansi pemerintah, kondisi ini dapat menghambat pelayanan kepada masyarakat, memperlambat proses administrasi, dan mengurangi produktivitas pegawai.

Serangan siber juga dapat menyebabkan **kerugian finansial**.

Organisasi mungkin harus mengeluarkan biaya untuk memulihkan sistem, melakukan investigasi insiden, mengganti perangkat yang terdampak, memulihkan data dari cadangan (*backup*), hingga meningkatkan sistem keamanan setelah insiden terjadi. Selain biaya langsung, organisasi juga dapat mengalami kerugian akibat terhentinya operasional, hilangnya peluang bisnis, maupun tuntutan hukum dari pihak yang dirugikan (IBM, 2024).

Selain kerugian materi, organisasi juga dapat mengalami **kerusakan reputasi**. Masyarakat akan kehilangan kepercayaan apabila organisasi gagal melindungi informasi yang dipercayakan kepadanya. Dalam sektor pemerintahan, hilangnya kepercayaan publik dapat berdampak pada menurunnya kualitas pelayanan dan citra institusi. Reputasi yang telah dibangun selama bertahun-tahun dapat rusak hanya karena satu insiden keamanan yang tidak ditangani dengan baik.

Dampak lain yang tidak kalah penting adalah **gangguan terhadap operasional organisasi**. Pegawai tidak dapat mengakses aplikasi, surat elektronik, maupun dokumen yang dibutuhkan untuk bekerja. Aktivitas pelayanan menjadi terhambat, proses pengambilan keputusan melambat, dan berbagai pekerjaan harus ditunda hingga sistem berhasil dipulihkan. Dalam beberapa kasus, organisasi bahkan harus menghentikan sebagian aktivitasnya untuk mencegah penyebaran serangan ke sistem lain.

Serangan siber juga dapat menyebabkan **penyalahgunaan identitas dan akun pengguna**. Kredensial yang berhasil dicuri dapat digunakan pelaku untuk mengakses sistem, mengirimkan email palsu, mencuri informasi tambahan, atau melakukan

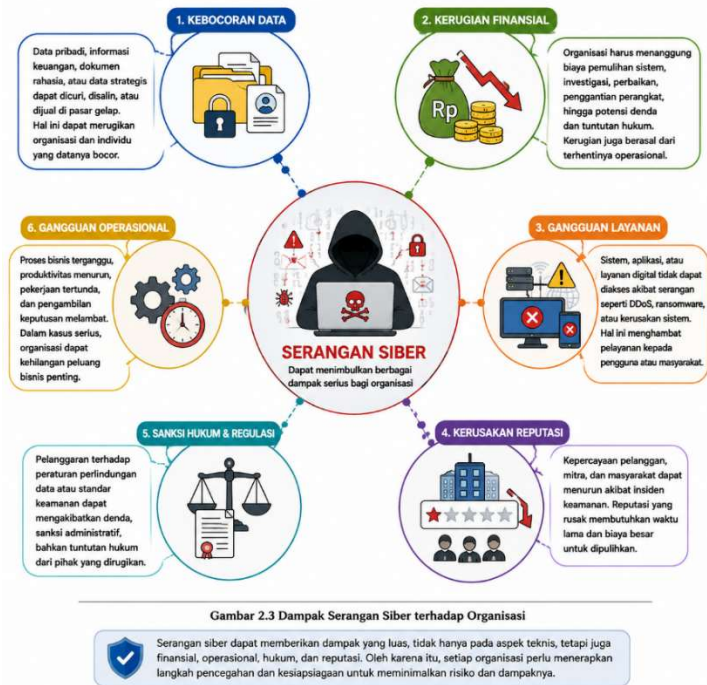
tindakan yang seolah-olah berasal dari pengguna yang sah. Oleh karena itu, penerapan **Multi-Factor Authentication (MFA)** dan pengelolaan kata sandi yang baik menjadi langkah penting untuk mengurangi risiko penyalahgunaan akun.

Bagi organisasi yang menyediakan layanan publik, serangan siber juga dapat berdampak pada **keamanan nasional dan pelayanan masyarakat**. Gangguan terhadap sistem pemerintahan, rumah sakit, infrastruktur jaringan, maupun layanan publik lainnya dapat memengaruhi kehidupan masyarakat secara luas. Oleh sebab itu, banyak negara menempatkan keamanan siber sebagai bagian dari strategi nasional dalam melindungi infrastruktur kritis.

Melihat besarnya dampak yang dapat ditimbulkan, organisasi perlu menerapkan pendekatan keamanan yang bersifat proaktif. Penerapan kebijakan keamanan informasi, peningkatan kesadaran pegawai, penggunaan teknologi keamanan, pencadangan data secara berkala, serta penyusunan prosedur **Incident Response** merupakan langkah penting untuk mengurangi risiko dan meminimalkan dampak apabila terjadi serangan siber. Organisasi yang siap menghadapi insiden akan mampu memulihkan layanan lebih cepat dan mengurangi kerugian yang ditimbulkan.

Pada akhirnya, dampak serangan siber tidak hanya diukur dari jumlah data yang hilang atau biaya yang dikeluarkan, tetapi juga dari kemampuan organisasi dalam menjaga keberlangsungan layanan, melindungi aset informasi, serta mempertahankan kepercayaan masyarakat. Oleh karena itu, investasi pada keamanan siber harus dipandang sebagai investasi untuk menjaga keberlangsungan organisasi di era

digital.



2.5 Siklus Serangan Siber (Cyber Kill Chain)

Serangan siber umumnya tidak terjadi secara tiba-tiba. Sebagian besar serangan dilakukan melalui serangkaian tahapan yang direncanakan dengan baik. Dengan memahami tahapan tersebut, organisasi dapat mengetahui pada bagian mana serangan dapat dicegah, dideteksi, atau dihentikan sebelum menimbulkan kerugian yang lebih besar.

Salah satu model yang paling banyak digunakan untuk menjelaskan tahapan serangan adalah **Cyber Kill Chain** yang

diperkenalkan oleh **Lockheed Martin**. Model ini menggambarkan bagaimana seorang penyerang mempersiapkan, melaksanakan, hingga mencapai tujuan akhirnya dalam suatu serangan siber. Konsep ini banyak digunakan dalam dunia keamanan siber sebagai dasar untuk membangun strategi pertahanan (*Defense in Depth*) dan meningkatkan kemampuan deteksi dini (Lockheed Martin, 2011).

Secara umum, Cyber Kill Chain terdiri atas tujuh tahapan, yaitu **Reconnaissance, Weaponization, Delivery, Exploitation, Installation, Command and Control (C2), dan Actions on Objectives**.

1. Reconnaissance (Pengintaian)

Tahap pertama adalah **Reconnaissance**, yaitu proses pengumpulan informasi mengenai target. Penyerang mencari informasi melalui website organisasi, media sosial, mesin pencari, dokumen publik, maupun sumber informasi lainnya. Informasi seperti alamat email pegawai, struktur organisasi, teknologi yang digunakan, hingga alamat IP dapat dimanfaatkan untuk merencanakan serangan.

Contohnya, penyerang mengumpulkan alamat email pegawai dari website resmi organisasi untuk dijadikan target serangan *phishing*.

2. Weaponization (Persiapan Serangan)

Setelah memperoleh informasi yang cukup, penyerang mulai menyiapkan "senjata" yang akan digunakan. Tahap ini dapat berupa pembuatan dokumen berbahaya, malware, tautan palsu, maupun eksploitasi terhadap kerentanan tertentu.

Sebagai contoh, pelaku membuat file Microsoft Word yang mengandung malware dan diberi nama **Surat Undangan Rapat.docx** agar terlihat meyakinkan.

3. Delivery (Pengiriman)

Pada tahap **Delivery**, senjata yang telah disiapkan dikirim kepada target. Media yang digunakan dapat berupa email, pesan instan, USB flashdisk, website palsu, hingga media sosial.

Tahapan ini merupakan salah satu titik yang paling sering dimanfaatkan dalam serangan **phishing**, di mana korban menerima email yang tampak berasal dari pihak yang dipercaya.

4. Exploitation (Eksplotasi)

Tahap berikutnya adalah **Exploitation**, yaitu ketika korban melakukan tindakan yang memungkinkan serangan berhasil, misalnya membuka lampiran berbahaya, mengklik tautan palsu, atau sistem memiliki kerentanan yang belum diperbaiki (*unpatched vulnerability*).

Pada tahap inilah malware mulai dijalankan atau celah keamanan berhasil dieksploitasi sehingga penyerang memperoleh akses awal ke sistem.

5. Installation (Instalasi)

Setelah berhasil masuk ke sistem, penyerang akan memasang malware atau program lain agar tetap memiliki akses ke perangkat korban. Malware tersebut dapat berupa **backdoor**, **remote access trojan (RAT)**, atau perangkat lunak lain yang memungkinkan penyerang kembali mengakses sistem di kemudian hari.

Apabila tahap ini berhasil, korban sering kali tidak menyadari bahwa perangkatnya telah dikendalikan oleh pihak lain.

6. Command and Control (C2)

Pada tahap **Command and Control (C2)**, perangkat korban mulai berkomunikasi dengan server milik penyerang melalui internet. Melalui koneksi tersebut, penyerang dapat mengirimkan perintah, mengunduh data, memasang malware tambahan, atau mengendalikan perangkat dari jarak jauh.

Aktivitas ini biasanya berlangsung secara tersembunyi sehingga sulit diketahui tanpa sistem pemantauan keamanan seperti **SIEM**, **EDR**, atau **IDS/IPS**.

7. Actions on Objectives (Mencapai Tujuan)

Tahap terakhir adalah **Actions on Objectives**, yaitu ketika penyerang melaksanakan tujuan utamanya. Tujuan tersebut dapat berupa mencuri data, mengenkripsi data menggunakan ransomware, memata-matai aktivitas organisasi, menghapus data, mengubah informasi, maupun menghentikan layanan digital.

Semakin lama penyerang berada di dalam sistem tanpa terdeteksi, semakin besar pula kerugian yang dapat ditimbulkan.

Pentingnya Memahami Cyber Kill Chain

Bagi organisasi, memahami tahapan Cyber Kill Chain sangat penting karena setiap tahap memberikan kesempatan untuk menghentikan serangan sebelum mencapai tujuan akhirnya. Misalnya, pelatihan **Cyber Security Awareness** dapat membantu pengguna mengenali email *phishing* pada tahap **Delivery**,

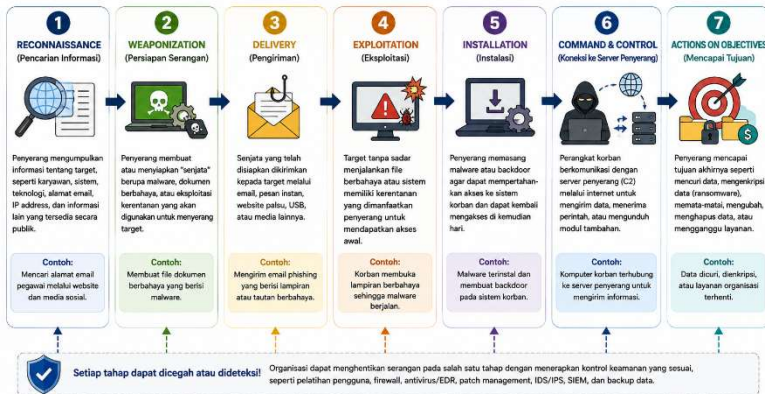
sementara pembaruan sistem (*patch management*) dapat mencegah keberhasilan tahap **Exploitation**. Di sisi lain, penggunaan **Endpoint Detection and Response (EDR)**, **Intrusion Detection System (IDS)**, **Intrusion Prevention System (IPS)**, serta **Security Information and Event Management (SIEM)** dapat membantu mendeteksi aktivitas mencurigakan pada tahap **Installation** maupun **Command and Control**.

Dengan memahami siklus serangan siber, organisasi tidak hanya mampu merespons ketika serangan terjadi, tetapi juga dapat menerapkan langkah-langkah pencegahan secara lebih efektif. Pendekatan ini merupakan salah satu dasar dalam membangun pertahanan siber yang berlapis (*Defense in Depth*) dan meningkatkan ketahanan organisasi terhadap ancaman yang terus berkembang.

SIKLUS SERANGAN SIBER (CYBER KILL CHAIN)

Serangan siber terjadi melalui serangkaian tahapan yang saling berhubungan.

Memahami setiap tahap membantu organisasi mencegah, mendeteksi, dan merespons lebih cepat.



Gambar 2.4 Siklus Serangan Siber (Cyber Kill Chain)

Sumber: Diadaptasi dari Lockheed Martin (2011) – Cyber Kill Chain

2.6 Sepuluh Serangan Siber yang Paling Umum

Ancaman siber terus berkembang seiring dengan meningkatnya penggunaan teknologi informasi di berbagai sektor. Organisasi pemerintah, perusahaan, institusi pendidikan, maupun masyarakat umum menghadapi berbagai jenis serangan yang dirancang untuk mencuri data, mengganggu layanan, memperoleh keuntungan finansial, atau merusak reputasi organisasi. Perkembangan teknologi seperti komputasi awan (*cloud computing*), Internet of Things (IoT), kecerdasan buatan (*Artificial Intelligence*), serta meningkatnya penggunaan layanan digital turut memperluas peluang bagi pelaku kejahatan siber untuk meluncurkan serangan.

Berdasarkan berbagai laporan keamanan siber internasional, seperti **Verizon Data Breach Investigations Report (DBIR)**, **ENISA Threat Landscape**, dan **Cybersecurity and Infrastructure Security Agency (CISA)**, sebagian besar insiden keamanan informasi berasal dari sejumlah pola serangan yang terus berulang. Walaupun teknik yang digunakan semakin canggih, keberhasilan serangan umumnya masih disebabkan oleh kombinasi antara kelemahan sistem, kesalahan konfigurasi, serta rendahnya kesadaran pengguna terhadap keamanan informasi (Verizon, 2025; ENISA, 2024).

Memahami berbagai jenis serangan siber merupakan langkah penting dalam membangun budaya keamanan informasi di lingkungan organisasi. Dengan mengenali karakteristik, cara kerja, serta dampak dari setiap jenis serangan, setiap pegawai diharapkan mampu mengidentifikasi ancaman sejak dini dan mengambil tindakan yang tepat untuk mencegah terjadinya insiden keamanan informasi.

Pada bagian ini akan dibahas sepuluh jenis serangan siber yang paling umum dijumpai pada organisasi maupun instansi pemerintah. Setiap jenis serangan akan dijelaskan secara ringkas meliputi pengertian, cara kerja, dampak yang ditimbulkan, serta langkah-langkah pencegahan yang dapat diterapkan oleh seluruh pegawai.

Serangan yang akan dibahas meliputi:

- **2.6.1 Phishing**
- **2.6.2 Ransomware**
- **2.6.3 Malware dan Trojan**
- **2.6.4 Credential Attack**
- **2.6.5 Distributed Denial of Service (DDoS)**
- **2.6.6 Web Exploitation**
- **2.6.7 Insider Threat**
- **2.6.8 Supply Chain Attack**
- **2.6.9 Business Email Compromise (BEC)**
- **2.6.10 Zero-Day Exploit**

Meskipun memiliki karakteristik yang berbeda, sebagian besar serangan tersebut bertujuan memperoleh akses tidak sah ke sistem, mencuri data, mengganggu operasional organisasi, atau memperoleh keuntungan finansial. Oleh karena itu, penerapan teknologi keamanan harus didukung oleh peningkatan **Cyber Security Awareness** seluruh pegawai sebagai lapisan pertahanan pertama terhadap berbagai ancaman siber.

Sepuluh Jenis Serangan Siber yang Paling Umum

Berikut adalah sepuluh jenis serangan siber yang paling sering menargetkan organisasi modern. Memahami berbagai jenis serangan ini merupakan langkah awal dalam meningkatkan kesadaran keamanan siber dan menerapkan tindakan pencegahan yang tepat.



2.6.1 Phishing

Pengertian

Phishing adalah teknik rekayasa sosial (*social engineering*) yang digunakan oleh pelaku kejahatan siber untuk menipu korban agar memberikan informasi sensitif, seperti **nama pengguna (username), kata sandi (password), kode One-Time Password (OTP), PIN, nomor kartu pembayaran, maupun data pribadi lainnya**. Serangan ini umumnya dilakukan melalui email, pesan singkat (SMS), aplikasi perpesanan, media sosial, atau website palsu yang dibuat menyerupai layanan resmi sehingga korban percaya dan tanpa sadar memberikan informasi yang diminta (CISA, 2023).

Berbeda dengan serangan yang memanfaatkan kelemahan teknis pada sistem komputer, phishing lebih berfokus pada **memanfaatkan kelemahan manusia**. Oleh

karena itu, peningkatan kesadaran keamanan siber (*Cyber Security Awareness*) menjadi salah satu cara paling efektif untuk mengurangi keberhasilan serangan phishing.

Cara Kerja

Secara umum, serangan phishing dilakukan melalui tahapan berikut:

1. Pelaku mengumpulkan informasi mengenai target, seperti alamat email, jabatan, atau organisasi tempat korban bekerja.
2. Pelaku membuat email, pesan, atau website yang menyerupai institusi resmi, misalnya bank, instansi pemerintah, atau penyedia layanan digital.
3. Korban menerima pesan yang berisi tautan (link) atau lampiran yang tampak meyakinkan.
4. Korban diminta untuk melakukan tindakan tertentu, seperti login, memperbarui data, membuka lampiran, atau mengunduh file.
5. Informasi yang dimasukkan korban akan dikirim kepada pelaku atau perangkat korban akan terinfeksi malware.

Contoh Kasus

Seorang pegawai menerima email yang tampak berasal dari administrator email organisasi dengan subjek **"Kuota Email Anda Hampir Penuh"**. Email tersebut meminta pegawai segera melakukan login melalui tautan yang disediakan agar akun tidak dinonaktifkan.

Karena tampilan website sangat mirip dengan halaman login resmi, pegawai memasukkan **username** dan **password**. Tanpa disadari, informasi tersebut langsung dikirim kepada pelaku. Dalam waktu singkat, akun email korban berhasil diambil alih dan digunakan untuk mengirim email phishing kepada pegawai lainnya.

Dampak

Serangan phishing dapat menimbulkan berbagai dampak, antara lain:

- Pencurian akun pengguna.
- Kebocoran data pribadi maupun data organisasi.
- Penyebaran malware atau ransomware.
- Penyalahgunaan akun email organisasi.
- Kerugian finansial akibat penipuan.
- Gangguan operasional organisasi.
- Penurunan kepercayaan masyarakat terhadap organisasi.

Menurut **Verizon Data Breach Investigations Report (DBIR)**, phishing masih menjadi salah satu metode serangan yang paling banyak digunakan dalam berbagai insiden kebocoran data karena relatif mudah dilakukan dan memiliki tingkat keberhasilan yang tinggi apabila pengguna kurang waspada (Verizon, 2025).

Cara Pencegahan

Untuk mengurangi risiko serangan phishing, setiap pegawai disarankan untuk:

- Selalu memeriksa alamat email pengirim sebelum membuka pesan.
- Tidak langsung mempercayai email yang meminta informasi rahasia.
- Memastikan alamat website menggunakan domain resmi organisasi.
- Tidak mengklik tautan atau membuka lampiran dari pengirim yang tidak dikenal.
- Mengaktifkan Multi-Factor Authentication (MFA) pada seluruh akun penting.
- Menggunakan kata sandi yang kuat dan berbeda untuk setiap layanan.
- Melaporkan email mencurigakan kepada administrator sistem atau tim keamanan informasi.
- Mengikuti pelatihan **Cyber Security Awareness** secara berkala.

Tips Praktis untuk Pegawai

Sebelum membuka email atau mengklik tautan, biasanya melakukan pemeriksaan sederhana menggunakan prinsip "**STOP – LIHAT – PIKIR – TINDAK**".

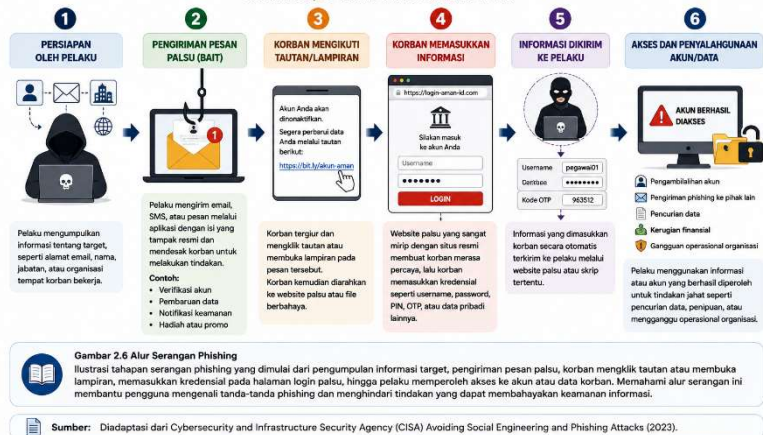
- **STOP** – Jangan terburu-buru membuka tautan atau lampiran.
- **LIHAT** – Periksa alamat pengirim, ejaan, dan alamat website tujuan.
- **PIKIR** – Apakah permintaan tersebut masuk akal? Apakah meminta password, OTP, atau data rahasia?

- **TINDAK** – Jika ragu, hubungi pengirim melalui saluran resmi atau laporkan kepada administrator sistem.

Ingatlah bahwa organisasi **yang sah tidak akan meminta password, PIN, maupun kode OTP melalui email atau pesan instan**. Sikap waspada dari setiap pegawai merupakan lapisan pertahanan pertama dalam mencegah keberhasilan serangan phishing.

ALUR SERANGAN PHISHING

Berikut adalah tahapan umum serangan phishing yang memanfaatkan rekayasa sosial untuk memperoleh informasi sensitif korban.



2.6.2 Ransomware

Pengertian

Ransomware adalah jenis **malware** yang dirancang untuk mengenkripsi (*encrypt*) data atau mengunci akses ke sistem komputer sehingga tidak dapat digunakan oleh pemiliknya. Setelah proses enkripsi selesai, pelaku akan meminta korban membayar sejumlah uang tebusan (*ransom*) sebagai syarat untuk memperoleh kunci dekripsi

(*decryption key*) agar data dapat diakses kembali (CISA, 2023).

Dalam beberapa tahun terakhir, ransomware menjadi salah satu ancaman siber paling merugikan bagi organisasi di seluruh dunia. Selain mengenkripsi data, banyak kelompok ransomware modern juga mencuri data korban terlebih dahulu, kemudian mengancam akan mempublikasikan data tersebut apabila uang tebusan tidak dibayarkan. Teknik ini dikenal sebagai **double extortion** dan semakin meningkatkan tekanan terhadap korban.

Cara Kerja

Secara umum, serangan ransomware berlangsung melalui tahapan berikut:

1. Pelaku memperoleh akses awal ke sistem melalui phishing, eksploitasi kerentanan, Remote Desktop Protocol (RDP) yang tidak aman, atau kredensial yang berhasil dicuri.
2. Setelah berhasil masuk, pelaku meningkatkan hak akses (privilege escalation) dan bergerak ke sistem lain di dalam jaringan (lateral movement).
3. Data penting dicuri sebagai persiapan pemerasan.
4. Malware ransomware dijalankan untuk mengenkripsi file pada komputer maupun server.
5. Korban menerima pesan yang berisi informasi bahwa seluruh data telah dienkripsi beserta instruksi pembayaran uang tebusan.

Contoh Kasus

Seorang pegawai menerima email berisi lampiran dokumen yang mengaku sebagai surat undangan resmi. Setelah lampiran dibuka, malware mulai berjalan tanpa disadari. Beberapa jam kemudian, seluruh file pada komputer korban tidak dapat dibuka dan berubah menjadi format yang tidak dikenal. Pada layar muncul pesan bahwa seluruh data telah dienkripsi dan hanya dapat dipulihkan apabila korban membayar uang tebusan menggunakan mata uang kripto.

Dalam kasus lain, ransomware berhasil menyebar ke server file organisasi sehingga seluruh pegawai kehilangan akses terhadap dokumen kerja. Selain menghentikan operasional, organisasi juga menghadapi ancaman kebocoran data karena pelaku telah menyalin data penting sebelum proses enkripsi dilakukan.

Dampak

Serangan ransomware dapat menimbulkan dampak yang sangat serius, antara lain:

- Hilangnya akses terhadap data penting.
- Gangguan operasional organisasi.
- Terhentinya pelayanan kepada masyarakat.
- Kerugian finansial akibat proses pemulihan sistem.
- Kebocoran data sensitif melalui teknik double extortion.
- Kerusakan reputasi organisasi.
- Menurunnya kepercayaan masyarakat dan mitra kerja.

Laporan IBM Cost of a Data Breach Report

menunjukkan bahwa serangan ransomware sering kali menyebabkan waktu pemulihan yang lama dan biaya penanganan yang sangat besar, terutama apabila organisasi tidak memiliki strategi pencadangan (*backup*) yang baik (IBM, 2024).

Cara Pencegahan

Untuk mengurangi risiko serangan ransomware, organisasi disarankan untuk:

- Melakukan backup data secara berkala dan menyimpan salinan cadangan secara offline atau immutable backup.
- Mengaktifkan Multi-Factor Authentication (MFA) pada seluruh akun penting.
- Memperbarui sistem operasi dan aplikasi secara rutin (patch management).
- Menggunakan antivirus atau Endpoint Detection and Response (EDR) yang selalu diperbarui.
- Membatasi hak akses pengguna sesuai prinsip Least Privilege.
- Menonaktifkan layanan yang tidak diperlukan, seperti RDP yang terbuka ke internet.
- Melakukan pelatihan Cyber Security Awareness secara berkala agar pegawai mampu mengenali email phishing dan file berbahaya.
- Menyusun prosedur **Incident Response** apabila terjadi serangan ransomware.

Tips Praktis untuk Pegawai

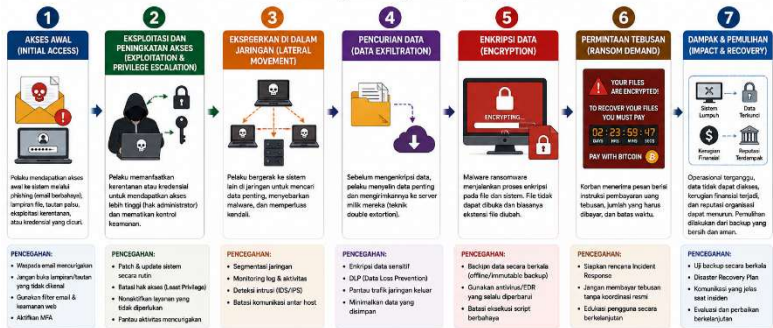
Setiap pegawai memiliki peran penting dalam mencegah serangan ransomware. Beberapa kebiasaan sederhana yang perlu diterapkan antara lain:

- Jangan membuka lampiran email yang tidak dikenal.
- Jangan mengunduh perangkat lunak dari sumber yang tidak resmi.
- Simpan dokumen penting pada lokasi yang telah dicadangkan oleh organisasi.
- Segera laporkan apabila komputer menunjukkan gejala tidak normal, seperti file yang tiba-tiba berubah nama, komputer menjadi sangat lambat, atau muncul pesan yang tidak biasa.
- Jangan pernah membayar uang tebusan tanpa koordinasi dengan pimpinan dan tim keamanan informasi, karena pembayaran tidak menjamin data akan dipulihkan.

Ingatlah bahwa **backup yang baik merupakan pertahanan terbaik terhadap ransomware**. Organisasi yang memiliki cadangan data yang teruji umumnya dapat memulihkan layanan lebih cepat tanpa harus bergantung pada pelaku serangan.

ALUR SERANGAN RANSOMWARE

Ransomware adalah malware yang mengenkripsi data atau mengunci akses ke sistem, kemudian meminta uang tebusan agar data dapat dipulihkan.



Gambar 2.7 Alur Serangan Ransomware

Ilustrasi tahapan umum serangan ransomware dimulai dari masuknya malware melalui email phishing atau eksploitasi kerentanan, penyebaran ke jaringan internal, pencurian data, proses enkripsi file, hingga munculnya permintaan pembayaran uang tebusan. Memahami alur serangan ransomware membantu organisasi menerapkan langkah-langkah pencegahan seperti pembaruan sistem, pencadangan data (backup), penggunaan autentikasi multifaktor, dan peningkatan kesadaran keamanan siber.



Sumber: Diadaptasi dari Cybersecurity and Infrastructure Security Agency (CISA) Stop Ransomware Guide (2023), National Institute of Standards and Technology (NIST) Cybersecurity Framework 2.0 (2024), dan IBM Cost of a Data Breach Report (2024).

2.6.3 Malware dan Trojan

Pengertian

Malware (*malicious software*) adalah istilah umum yang digunakan untuk menyebut berbagai jenis perangkat lunak berbahaya yang dirancang untuk merusak, mengganggu, mencuri informasi, atau memperoleh akses tidak sah ke sistem komputer. Malware dapat berupa virus, worm, trojan, spyware, ransomware, rootkit, keylogger, maupun jenis perangkat lunak berbahaya lainnya yang memiliki tujuan berbeda-beda (CISA, 2023).

Salah satu jenis malware yang paling sering digunakan dalam serangan siber adalah **Trojan** atau **Trojan Horse**. Berbeda dengan virus yang mampu menggandakan diri, trojan menyamar sebagai aplikasi atau dokumen yang tampak aman sehingga pengguna secara sukarela menginstalnya. Setelah berhasil dijalankan, trojan akan

membuka akses bagi pelaku untuk mengendalikan perangkat korban, mencuri data, memasang malware lain, atau melakukan aktivitas berbahaya tanpa diketahui oleh pengguna.

Karena malware dan trojan sering memanfaatkan kelengahan pengguna, peningkatan **Cyber Security Awareness** merupakan salah satu langkah penting dalam mencegah infeksi pada perangkat maupun jaringan organisasi.

Cara Kerja

Secara umum, malware dan trojan bekerja melalui tahapan berikut:

1. Pelaku menyebarkan malware melalui email phishing, lampiran dokumen, website berbahaya, perangkat USB, atau aplikasi bajakan.
2. Korban mengunduh atau menjalankan file yang telah terinfeksi.
3. Malware mulai berjalan di latar belakang tanpa disadari pengguna.
4. Trojan membuka koneksi ke server milik pelaku (Command and Control/C2 Server).
5. Pelaku memperoleh akses ke komputer korban untuk mencuri data, memasang malware tambahan, atau mengendalikan sistem dari jarak jauh.

Contoh Kasus

Seorang pegawai mengunduh aplikasi gratis dari situs yang tidak resmi karena membutuhkan perangkat lunak untuk mengedit dokumen. Setelah aplikasi diinstal, komputer tetap dapat digunakan seperti biasa sehingga korban tidak menyadari adanya masalah.

Beberapa hari kemudian, administrator menemukan bahwa komputer tersebut secara rutin mengirimkan data ke alamat IP asing. Setelah dilakukan investigasi, diketahui bahwa aplikasi yang diunduh telah mengandung trojan yang secara diam-diam mencuri kredensial login dan dokumen penting milik organisasi.

Contoh lain adalah penggunaan **flashdisk** yang sebelumnya telah terinfeksi malware. Ketika perangkat tersebut dihubungkan ke komputer kantor tanpa dilakukan pemindaian antivirus, malware dapat menyebar ke perangkat lain melalui jaringan internal.

Dampak

Infeksi malware dan trojan dapat menyebabkan berbagai kerugian, antara lain:

- Pencurian data pribadi maupun data organisasi.
- Pencurian username dan password.
- Pengambilalihan komputer dari jarak jauh (Remote Access Trojan/RAT).
- Instalasi malware lain, termasuk ransomware.
- Gangguan operasional sistem.

- Penurunan kinerja komputer.
- Penyebaran malware ke perangkat lain dalam jaringan.
- Kerugian finansial dan reputasi organisasi.

Menurut **ENISA Threat Landscape**, malware masih menjadi salah satu ancaman utama terhadap organisasi karena mampu menjadi pintu masuk bagi berbagai jenis serangan lanjutan, termasuk ransomware dan pencurian data (ENISA, 2024).

Cara Pencegahan

Untuk mengurangi risiko infeksi malware dan trojan, organisasi disarankan untuk:

- Menginstal aplikasi hanya dari sumber resmi.
- Memastikan antivirus atau Endpoint Detection and Response (EDR) selalu aktif dan diperbarui.
- Tidak menggunakan perangkat lunak bajakan (cracked software).
- Memindai flashdisk atau media penyimpanan eksternal sebelum digunakan.
- Melakukan pembaruan (patch) sistem operasi dan aplikasi secara berkala.
- Membatasi hak instalasi perangkat lunak hanya kepada administrator.
- Memblokir eksekusi file yang tidak dikenal melalui kebijakan keamanan organisasi.
- Memberikan pelatihan keamanan informasi kepada

seluruh pegawai.

Tips Praktis untuk Pegawai

Untuk menghindari infeksi malware dan trojan, biasakan menerapkan kebiasaan berikut:

- Unduh aplikasi hanya dari situs resmi pengembang.
- Jangan menjalankan file dengan ekstensi yang mencurigakan, seperti .exe, .bat, .scr, atau .js yang dikirim melalui email atau aplikasi pesan.
- Jangan menggunakan perangkat lunak bajakan.
- Lakukan pemindaian antivirus terhadap flashdisk sebelum membuka isinya.
- Laporkan kepada administrator apabila komputer tiba-tiba menjadi lambat, sering muncul jendela yang tidak dikenal, atau antivirus dinonaktifkan tanpa alasan yang jelas.
- Jangan menghubungkan perangkat pribadi ke komputer organisasi tanpa izin.

Ingatlah bahwa **sebagian besar infeksi malware terjadi karena tindakan pengguna**, bukan semata-mata karena kelemahan teknologi. Oleh karena itu, kewaspadaan setiap pegawai merupakan bagian penting dari pertahanan keamanan informasi organisasi.

ALUR INFEKSI MALWARE DAN TROJAN

Malware dan trojan menyusup ke perangkat korban melalui berbagai cara, dijalankan tanpa disadari, kemudian membuka akses bagi pelaku untuk mencuri data, memasang malware lain, atau mengendalikan sistem dari jarak jauh.



Gambar 2.8 Alur Infeksi Malware dan Trojan

Ilustrasi proses infeksi malware dan trojan yang dimulai dari pengguna mengunduh atau membuka file berbahaya, malware dijalankan pada perangkat korban, membuka koneksi ke server pelaku (Command and Control/C2 Server), kemudian mencuri data, memasang malware tambahan, atau memberikan akses jarak jauh kepada pelaku. Memahami alur infeksi ini membantu pengguna menerapkan kebiasaan yang aman, seperti mengunduh aplikasi dari sumber resmi, menggunakan antivirus, dan menghindari membuka file yang tidak dikenal.

Sumber: Diadaptasi dari Cybersecurity and Infrastructure Security Agency (CISA) (2023), NSA, dan NIST Cybersecurity Framework 2.0 (2024).

C2 Server : Command and Control Server yang digunakan pelaku untuk mengendalikan perangkat korban
DDoS : Distributed Denial of Service (serangan untuk membuat layanan tidak tersedia)

2.6.4 Credential Attack

Pengertian

Credential Attack adalah serangan siber yang bertujuan memperoleh atau menyalahgunakan **kredensial pengguna**, seperti **username, password, PIN, One-Time Password (OTP)**, token autentikasi, maupun **session cookie**, untuk mendapatkan akses tidak sah ke sistem atau aplikasi. Berbeda dengan eksploitasi kerentanan perangkat lunak, serangan ini berfokus pada pencurian atau penyalahgunaan identitas pengguna yang sah sehingga aktivitas pelaku tampak seperti dilakukan oleh pengguna yang memiliki hak akses (Verizon, 2025).

Credential attack menjadi salah satu ancaman yang paling sering terjadi karena banyak pengguna masih menggunakan kata sandi yang lemah, menggunakan password yang sama pada beberapa layanan, atau tanpa

sadar menyerahkan kredensialnya melalui serangan *phishing*. Apabila berhasil memperoleh kredensial, pelaku dapat masuk ke sistem tanpa perlu mengeksploitasi kelemahan teknis.

Cara Kerja

Secara umum, serangan credential attack berlangsung melalui tahapan berikut:

1. Pelaku memperoleh kredensial melalui phishing, malware, kebocoran data, atau pembelian data hasil peretasan di internet.
2. Pelaku mencoba menggunakan kredensial tersebut untuk masuk ke berbagai aplikasi atau layanan organisasi.
3. Jika berhasil login, pelaku akan memanfaatkan hak akses pengguna untuk mencuri data, mengubah konfigurasi, atau melakukan aktivitas lain tanpa diketahui.
4. Dalam beberapa kasus, pelaku meningkatkan hak akses (privilege escalation) agar dapat mengendalikan sistem secara lebih luas.

Beberapa teknik credential attack yang umum digunakan antara lain:

- **Brute Force Attack**
- **Dictionary Attack**
- **Password Spraying**
- **Credential Stuffing**
- **Keylogging**

- **Session Hijacking**

Contoh Kasus

Seorang pegawai menggunakan password yang sama untuk akun email pribadi dan akun email kantor. Setelah salah satu layanan daring mengalami kebocoran data, kombinasi alamat email dan password tersebut beredar di internet.

Pelaku kemudian menggunakan teknik **credential stuffing** untuk mencoba kombinasi username dan password tersebut pada akun email organisasi. Karena password yang digunakan sama, pelaku berhasil masuk ke akun korban tanpa harus melakukan peretasan terhadap sistem organisasi.

Contoh lain adalah seorang pegawai yang menerima email phishing dan memasukkan username, password, serta kode OTP pada halaman login palsu. Dalam hitungan menit, akun korban berhasil diambil alih dan digunakan untuk mengakses berbagai sistem internal organisasi.

Dampak

Credential attack dapat menyebabkan berbagai kerugian, antara lain:

- Pengambilalihan akun (*Account Takeover*).
- Kebocoran data organisasi.
- Penyalahgunaan hak akses pengguna.
- Perubahan atau penghapusan data penting.
- Penyebaran malware atau ransomware.

- Penyalahgunaan akun email untuk melakukan phishing lanjutan.
- Gangguan operasional organisasi.
- Kerusakan reputasi dan hilangnya kepercayaan publik.

Menurut **Verizon Data Breach Investigations Report (DBIR)**, penggunaan kredensial yang dicuri (*stolen credentials*) masih menjadi salah satu penyebab utama terjadinya pelanggaran data (*data breach*) pada berbagai sektor industri (Verizon, 2025).

Cara Pencegahan

Untuk mengurangi risiko credential attack, organisasi disarankan untuk:

- Mengaktifkan **Multi-Factor Authentication (MFA)** pada seluruh layanan penting.
- Menggunakan password yang kuat, unik, dan berbeda untuk setiap akun.
- Menggunakan **password manager** untuk menyimpan kata sandi secara aman.
- Mengganti password secara berkala apabila terdapat indikasi kebocoran.
- Memantau aktivitas login yang tidak biasa.
- Membatasi jumlah percobaan login (*account lockout policy*).
- Melakukan pelatihan keamanan informasi secara berkala.

- Menggunakan solusi **Identity and Access Management (IAM)** sesuai kebutuhan organisasi.

Tips Praktis untuk Pegawai

Beberapa kebiasaan sederhana berikut dapat membantu mencegah credential attack:

- Jangan pernah membagikan password kepada siapa pun.
- Jangan menggunakan password yang sama untuk beberapa layanan.
- Aktifkan **Multi-Factor Authentication (MFA)** apabila tersedia.
- Jangan menyimpan password pada kertas, file teks, atau browser tanpa perlindungan.
- Segera ubah password apabila menerima pemberitahuan adanya kebocoran data.
- Laporkan aktivitas login yang mencurigakan kepada administrator sistem.

Ingatlah bahwa **password merupakan kunci utama untuk mengakses informasi organisasi**. Menjaga kerahasiaan kredensial merupakan tanggung jawab setiap pengguna.

ALUR CREDENTIAL ATTACK

Credential attack adalah serangan untuk memperoleh atau menyalahgunakan kredensial (username, password, OTP, dll.) guna mendapatkan akses tidak sah ke sistem atau data organisasi.



Sumber: Diadaptasi dari National Institute of Standards and Technology (NIST) Digital Identity Guidelines SP 800-63 (2024), Cybersecurity and Infrastructure Security Agency (CISA) Identity and Access Management Best Practices (2023), dan Verizon Data Breach Investigations Report (DBIR) (2025).

2.6.5 Distributed Denial of Service (DDoS)

Pengertian

Distributed Denial of Service (DDoS) adalah serangan yang bertujuan membuat suatu sistem, server, aplikasi, atau layanan jaringan tidak dapat melayani pengguna yang sah dengan cara membanjiri target menggunakan lalu lintas (*traffic*) atau permintaan dalam jumlah sangat besar.

Berbeda dengan **Denial of Service (DoS)** yang umumnya berasal dari satu sumber, serangan **DDoS** dilakukan menggunakan banyak perangkat secara bersamaan. Perangkat-perangkat tersebut dapat berupa komputer, server, perangkat IoT, atau perangkat lain yang sebelumnya telah terinfeksi malware dan dikendalikan oleh pelaku. Kumpulan perangkat yang digunakan untuk melakukan serangan ini sering disebut **botnet**.

Tujuan utama serangan DDoS bukan selalu untuk mencuri data. Serangan ini lebih sering digunakan untuk **mengganggu ketersediaan layanan (*availability*)**, sehingga pengguna yang sah tidak dapat mengakses sistem atau layanan yang diserang.

Cara Kerja

Secara sederhana, serangan DDoS dapat berlangsung melalui tahapan berikut:

1. Pelaku menguasai sejumlah besar perangkat yang rentan dan membentuk **botnet**.
2. Perangkat yang telah dikuasai menunggu perintah dari pelaku.
3. Pelaku memberikan perintah kepada botnet untuk menyerang target tertentu.
4. Ribuan atau bahkan jutaan perangkat mengirimkan permintaan ke target secara bersamaan.
5. Server atau jaringan target menerima beban yang sangat besar.
6. Sumber daya server seperti CPU, RAM, bandwidth, atau koneksi jaringan menjadi penuh.
7. Layanan menjadi lambat atau tidak dapat diakses oleh pengguna yang sah.

Serangan DDoS dapat dilakukan dengan berbagai metode. Beberapa di antaranya berusaha memenuhi kapasitas jaringan (*volumetric attack*), sementara metode lainnya membebani protokol jaringan atau aplikasi dengan

permintaan dalam jumlah besar.

Contoh Kasus

Sebuah organisasi memiliki website layanan publik yang biasanya menerima beberapa ratus permintaan per menit. Pada suatu waktu, server tiba-tiba menerima jutaan permintaan dari berbagai alamat IP dalam waktu yang sangat singkat.

Akibatnya, bandwidth internet organisasi menjadi penuh dan sumber daya server mengalami beban yang sangat tinggi. Pengguna yang sebenarnya ingin mengakses layanan tidak dapat membuka website atau mengalami waktu respons yang sangat lama.

Setelah dilakukan pemeriksaan, diketahui bahwa sebagian besar lalu lintas tersebut bukan berasal dari pengguna normal, tetapi merupakan bagian dari serangan DDoS yang menggunakan banyak perangkat dari berbagai lokasi.

Dampak

Serangan DDoS dapat menyebabkan berbagai dampak terhadap organisasi, antara lain:

- Website atau aplikasi tidak dapat diakses.
- Gangguan terhadap layanan digital organisasi.
- Menurunnya produktivitas pegawai.
- Gangguan pelayanan kepada masyarakat.
- Peningkatan penggunaan bandwidth.
- Beban tinggi pada server dan perangkat jaringan.

- Kerugian finansial akibat terhentinya layanan.
- Menurunnya kepercayaan pengguna.
- Kerusakan reputasi organisasi.

Pada organisasi yang menyediakan layanan publik secara daring, dampak DDoS dapat menjadi lebih serius karena masyarakat bergantung pada ketersediaan layanan tersebut.

Cara Pencegahan

Beberapa langkah yang dapat diterapkan organisasi untuk mengurangi risiko DDoS antara lain:

- Menggunakan **firewall** dan perangkat keamanan jaringan yang memiliki kemampuan mitigasi DDoS.
- Menggunakan layanan **DDoS Protection** apabila layanan organisasi membutuhkan tingkat ketersediaan yang tinggi.
- Membatasi lalu lintas yang tidak diperlukan (*traffic filtering*).
- Menerapkan **rate limiting** pada aplikasi yang sesuai.
- Memantau penggunaan bandwidth dan pola lalu lintas jaringan.
- Menggunakan sistem monitoring untuk mendeteksi lonjakan traffic secara dini.
- Menyiapkan kapasitas jaringan dan server sesuai kebutuhan layanan.
- Menyusun prosedur **Incident Response** untuk

menghadapi serangan DDoS.

- Berkoordinasi dengan penyedia layanan internet apabila terjadi serangan dalam skala besar.

Tips Praktis untuk Pegawai

Pegawai mungkin tidak mengendalikan perangkat jaringan secara langsung, tetapi tetap memiliki peran dalam membantu organisasi menghadapi serangan DDoS.

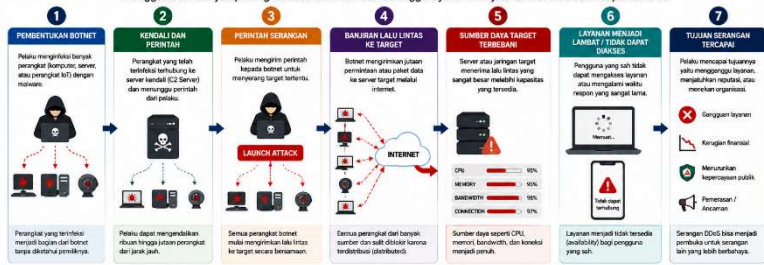
Beberapa hal yang dapat dilakukan antara lain:

- Segera melaporkan apabila website atau aplikasi organisasi tiba-tiba tidak dapat diakses.
- Jangan menganggap gangguan layanan sebagai masalah biasa tanpa melaporkannya kepada tim terkait.
- Jangan mencoba melakukan pengujian jaringan secara sembarangan ketika sedang terjadi gangguan.
- Ikuti prosedur komunikasi yang telah ditetapkan organisasi ketika terjadi gangguan layanan.
- Gunakan kanal layanan alternatif apabila telah disediakan oleh organisasi.

Perlu dipahami bahwa **DDoS terutama menyerang aspek ketersediaan layanan (*availability*)**. Oleh karena itu, pemantauan jaringan dan kesiapan organisasi dalam merespons lonjakan traffic menjadi bagian penting dari pertahanan terhadap serangan ini.

ALUR SERANGAN DISTRIBUTED DENIAL OF SERVICE (DDoS)

DDoS adalah serangan yang membanjiri target dengan lalu lintas atau permintaan dalam jumlah sangat besar menggunakan banyak perangkat secara bersamaan sehingga layanan menjadi lambat atau tidak dapat diakses.



Gambar 2.10 Alur Serangan Distributed Denial of Service (DDoS)

Rutasi serangan DDoS yang dimulai dari pembentukan botnet melalui infeksi malware, perangkat yang terinfeksi menerima perintah dari pelaku, kemudian secara bersamaan mengirimkan lalu lintas dalam jumlah sangat besar ke server target. Beban yang berlebihan menghabiskan sumber daya jaringan dan server sehingga layanan menjadi lambat atau tidak dapat diakses oleh pengguna yang sah.

LANGKAH PENCEGAHAN DAN MITIGASI DDoS

- Gunakan layanan DDoS Protection: Membutuhkan layanan penyedia Internet atau cloud yang memiliki mitigasi DDoS.
- Gunakan Firewall dan IDS/IPS: Filter lalu lintas berbahaya dan deteksi pola serangan lebih awal.
- Monitoring dan Deteksi Dini: Pantau trafik jaringan secara real-time untuk mendeteksi serangan trafik.
- Rate Limiting dan Traffic Filtering: Batasi jumlah permintaan dari satu sumber dan filter trafik yang mencurigakan.
- Pemecahan Kapasitas: Pastikan kapasitas bandwidth dan server sesuai dengan kebutuhan layanan.
- Stapakan Rencana Response Incident: Miliki prosedur tanggap insiden dan koordinasi dengan penyedia layanan Internet.



Sumber: Diadaptasi dari Cybersecurity and Infrastructure Security Agency (CISA) - Understanding Denial-of-Service Attacks (2023); NIST Cybersecurity Framework (CSF) 2.0 (2024), dan ENISA Threat Landscape 2024.

Keterangan istilah:
 • Botnet : Rumpukan perangkat yang terinfeksi dan dikendalikan pelaku.
 • C2 Server : Command and Control Server (server kendali pelaku).
 • Availability : Ketersediaan layanan untuk pengguna yang sah.

2.6.6 Web Exploitation

Pengertian

Web Exploitation adalah tindakan memanfaatkan kelemahan pada website atau aplikasi web untuk memperoleh akses, memanipulasi data, menjalankan fungsi yang tidak semestinya, atau mengganggu layanan. Kelemahan tersebut dapat berasal dari kesalahan pemrograman, konfigurasi keamanan yang tidak tepat, komponen perangkat lunak yang rentan, maupun penerapan mekanisme autentikasi dan kontrol akses yang tidak memadai.

Aplikasi web menjadi salah satu target penting karena umumnya dapat diakses melalui internet dan berhubungan langsung dengan data serta layanan organisasi. NIST menjelaskan bahwa server web yang digunakan untuk layanan publik merupakan salah satu host yang paling sering

menjadi sasaran serangan sehingga pengamanan web server dan aplikasi web menjadi bagian penting dari keamanan organisasi.

OWASP Top 10 mengelompokkan sejumlah risiko penting pada aplikasi web, termasuk **Broken Access Control, Injection, Security Misconfiguration, Vulnerable and Outdated Components, Identification and Authentication Failures**, serta **Server-Side Request Forgery (SSRF)**.

Cara Kerja

Web exploitation biasanya dimulai dengan pencarian terhadap website atau aplikasi yang dapat diakses dari jaringan. Pelaku kemudian mencoba menemukan kelemahan pada fungsi, parameter, autentikasi, konfigurasi, atau komponen yang digunakan aplikasi.

Secara umum, prosesnya dapat berlangsung sebagai berikut:

1. Pelaku melakukan **reconnaissance** untuk mengetahui teknologi dan layanan yang digunakan oleh aplikasi.
2. Pelaku mencari endpoint, parameter, formulir, API, atau fungsi aplikasi yang dapat diakses.
3. Pelaku mengidentifikasi kemungkinan kelemahan pada aplikasi atau konfigurasi server.
4. Pelaku mencoba mengeksploitasi kelemahan tersebut.
5. Apabila eksploitasi berhasil, pelaku dapat memperoleh akses atau kemampuan yang seharusnya tidak dimiliki.

6. Akses tersebut kemudian dapat digunakan untuk mencuri data, mengubah data, menjalankan perintah, atau menjadi pintu masuk untuk serangan lanjutan.

Salah satu contoh adalah injection, ketika input pengguna yang tidak divalidasi dengan baik diproses oleh interpreter sehingga data berbahaya dapat dianggap sebagai bagian dari perintah atau query. OWASP mencantumkan SQL Injection dan Cross-Site Scripting (XSS) sebagai contoh penting dalam kategori Injection.

Contoh lainnya adalah **Broken Access Control**, ketika pengguna dapat mengakses data atau fungsi yang sebenarnya berada di luar hak aksesnya. Hal tersebut dapat terjadi, misalnya, ketika aplikasi hanya mengandalkan parameter yang dikirim oleh pengguna tanpa melakukan pemeriksaan otorisasi di sisi server.

Contoh Kasus

Sebuah organisasi memiliki aplikasi web yang digunakan pegawai untuk mengakses data administrasi. Setelah melakukan login, pengguna mendapatkan alamat halaman tertentu yang berisi informasi miliknya.

Apabila aplikasi tidak melakukan pemeriksaan hak akses dengan benar, pengguna dapat mencoba mengakses data milik pengguna lain hanya dengan mengubah parameter tertentu pada permintaan. Jika server tidak melakukan validasi kepemilikan data, informasi pengguna lain dapat ditampilkan.

Kasus tersebut merupakan contoh **Broken Access Control**. Masalahnya bukan pada password pengguna,

tetapi pada mekanisme aplikasi dalam menentukan apakah pengguna yang telah login memang memiliki hak untuk mengakses data tersebut. OWASP menjelaskan bahwa kegagalan kontrol akses dapat menyebabkan pengungkapan, perubahan, atau penghapusan data yang tidak diizinkan.

Contoh lainnya adalah aplikasi yang langsung menggunakan input pengguna dalam query database tanpa validasi dan parameterisasi yang tepat. Kondisi tersebut dapat membuka peluang terjadinya **SQL Injection**.

Dampak

Web exploitation dapat memberikan dampak yang serius terhadap organisasi, antara lain:

- Pencurian data pengguna.
- Kebocoran data pribadi.
- Perubahan atau penghapusan data.
- Pengambilalihan akun.
- Pengambilalihan fungsi administratif.
- Penyisipan konten berbahaya.
- Penyebaran malware.
- Gangguan terhadap layanan aplikasi.
- Kerusakan reputasi organisasi.
- Kerugian finansial.
- Menjadi pintu masuk bagi serangan lanjutan.

Dalam konteks organisasi yang mengelola data pribadi, eksploitasi aplikasi web dapat menjadi masalah yang sangat serius karena aplikasi dapat menjadi jalur langsung menuju database dan sistem internal.

Cara Pencegahan

Pencegahan web exploitation membutuhkan kombinasi antara keamanan aplikasi, server, jaringan, dan proses pengembangan.

Beberapa langkah yang dapat diterapkan antara lain:

- Melakukan **secure coding** sejak tahap pengembangan.
- Melakukan validasi dan sanitasi terhadap input pengguna.
- Menggunakan **parameterized query** untuk mencegah SQL Injection.
- Menerapkan kontrol akses pada sisi server.
- Memastikan setiap pengguna hanya dapat mengakses data sesuai kewenangannya.
- Melakukan pembaruan framework, library, dan komponen aplikasi.
- Menghapus komponen dan layanan yang tidak diperlukan.
- Menonaktifkan directory listing.
- Tidak menyimpan file konfigurasi, backup, atau repository seperti .git di web root.
- Menggunakan HTTPS.

- Menerapkan logging dan monitoring terhadap aktivitas aplikasi.
- Melakukan pengujian keamanan aplikasi secara berkala.
- Menggunakan **Web Application Firewall (WAF)** sebagai lapisan pertahanan tambahan.

OWASP merekomendasikan agar kontrol akses diterapkan di sisi server dan seluruh permintaan terhadap fungsi yang membutuhkan otorisasi harus diverifikasi. OWASP juga merekomendasikan pengujian kontrol akses secara fungsional dan integrasi.

Tips Praktis untuk Pegawai

Pegawai yang menggunakan aplikasi web juga memiliki peran dalam menjaga keamanan.

Beberapa kebiasaan yang perlu diterapkan antara lain:

- Jangan membagikan username dan password.
- Jangan mencoba mengakses menu atau data yang bukan menjadi kewenangan.
- Jangan memodifikasi parameter URL untuk mencoba mendapatkan akses ke data pengguna lain.
- Jangan memasukkan data sensitif ke dalam website yang tidak dikenal.
- Pastikan alamat website sudah benar sebelum melakukan login.
- Laporkan apabila menemukan data pengguna lain yang dapat diakses tanpa semestinya.

- Laporkan apabila aplikasi menampilkan pesan error yang mengandung informasi teknis atau informasi sistem.
- Jangan mengabaikan perubahan tampilan atau perilaku aplikasi yang mencurigikan.

Kesadaran pengguna menjadi bagian penting dalam keamanan aplikasi. Kerentanan teknis memang perlu diperbaiki oleh pengembang dan administrator sistem, tetapi perilaku pengguna yang tepat dapat membantu mempercepat deteksi dan pelaporan masalah keamanan.

ALUR WEB EXPLOITATION

Web exploitation adalah tindakan memanfaatkan kelemahan pada website atau aplikasi web untuk memperoleh akses tidak sah, memanipulasi data, menjalankan fungsi yang tidak semestinya, atau mengganggu layanan.



Gambar 2.11 Alur Web Exploitation

Ilustrasi tahapan umum web exploitation yang dimulai dari pengintaian aplikasi web, identifikasi endpoint dan kelemahan, percobaan eksploitasi, keberhasilan memperoleh akses dan menjalankan fungsi yang tidak semestinya, hingga prinsip pencurian data dan manipulasi data. Pemahaman terhadap alur tersebut membantu organisasi menerapkan penanganan aplikasi, validasi input, kontrol akses, pembaruan komponen, logging, monitoring, dan Web Application Firewall (WAF).



Sumber:

- OWASP Top 10-2021 - <https://owasp.org/Top10/2021/>
- OWASP A03-2021 - Broken Access Control - https://owasp.org/Top10/2021/A03-2021/broken_Access_Control/
- OWASP A03-2021 - Injection - <https://owasp.org/Top10/2021/A03-2021/injection/>
- NIST SP 800-89 - Guide to Secure Web Services (2007)
- NIST SP 800-44 - Guidelines on Securing Public Web Services (2002)

LANGKAH PENCEGAHAN UTAMA

- Validasi dan kontrol seluruh input pengguna.
- Gunakan parameterized query untuk mencegah SQL Injection.
- Terapkan kontrol akses di sisi server (authentication).
- Periksa setiap pengguna harus dapat mengakses data sesuai kewenangannya.
- Lakukan pembaruan framework, library, dan komponen.
- Nonaktifkan layanan dan fitur yang tidak diperlukan.
- Gunakan HTTPS dan enkripsi data.
- Lakukan logging dan monitoring secara rutin.
- Uji keamanan aplikasi secara berkala (vulnerability assessment & penetration test).
- Gunakan Web Application Firewall (WAF).
- Uji praktik secure coding dan standar OWASP.



Keterangannya adalah:

- Endpoint: URL akhir aplikasi seperti halaman, API, atau layanan yang dapat diakses.
- Exploit: Kode, perintah, atau teknik yang memanfaatkan kelemahan.
- WAF: Web Application Firewall, perangkat keamanan untuk melindungi aplikasi web.
- XSS: Cross-Site Scripting, penyisipan script berbahaya pada halaman web.
- SQL Injection: Teknik manipulasi perintah SQL berbahaya melalui input aplikasi.

2.6.7 Insider Threat

Pengertian

Insider Threat adalah ancaman yang berasal dari seseorang yang memiliki akses sah atau pengetahuan khusus terhadap organisasi, tetapi menggunakan akses tersebut dengan cara yang dapat membahayakan keamanan.

organisasi, data, sistem, fasilitas, atau sumber daya lainnya. Ancaman ini dapat dilakukan **dengan sengaja maupun tidak sengaja**. CISA menekankan bahwa insider threat dapat berupa tindakan berbahaya, kelalaian, maupun kesalahan yang berdampak terhadap kerahasiaan, integritas, dan ketersediaan organisasi.

Yang perlu dipahami adalah bahwa **insider threat tidak selalu berarti pegawai yang berniat jahat**. Seorang pegawai dapat menjadi sumber risiko karena salah mengirim dokumen, menggunakan perangkat organisasi secara tidak aman, membagikan kredensial, atau mengakses informasi yang sebenarnya tidak diperlukan untuk pekerjaannya.

NIST juga mendefinisikan *insider* sebagai seseorang yang memiliki akses resmi terhadap sumber daya organisasi, termasuk personel, fasilitas, informasi, peralatan, jaringan, dan sistem.

Jenis Insider Threat

Secara umum, insider threat dapat dikelompokkan menjadi beberapa bentuk:

1. Malicious Insider

Pegawai atau pihak internal yang dengan sengaja menyalahgunakan akses untuk mencuri data, merusak sistem, melakukan penipuan, atau memberikan informasi kepada pihak yang tidak berwenang.

2. Negligent Insider

Pengguna yang melakukan tindakan tidak aman karena kelalaian atau kurangnya kesadaran keamanan. Contohnya

menggunakan password yang sama, meninggalkan komputer dalam kondisi login, atau mengirim dokumen sensitif kepada penerima yang salah.

3. Compromised Insider

Akun atau perangkat milik pengguna yang sah telah diambil alih oleh pihak luar. Aktivitas yang dilakukan menggunakan akun tersebut terlihat seperti aktivitas pengguna internal, padahal sebenarnya dikendalikan oleh penyerang.

4. Unintentional Insider

Pengguna melakukan kesalahan tanpa bermaksud membahayakan organisasi, misalnya salah mengirim email yang berisi data sensitif atau mengunggah dokumen ke layanan penyimpanan publik.

CISA juga menekankan bahwa insider threat dapat bersifat **intentional maupun unintentional**, dan sebagian ancaman dapat berasal dari perilaku lalai atau tidak disengaja.

Cara Kerja

Insider threat biasanya memanfaatkan **akses yang memang sudah diberikan kepada pengguna**. Oleh karena itu, serangan ini dapat lebih sulit dikenali dibandingkan serangan dari pihak luar.

Contoh alurnya:

1. Pengguna memperoleh akses sesuai dengan tugas dan tanggung jawabnya.

2. Pengguna memiliki akses terhadap sistem, aplikasi, jaringan, atau data tertentu.
3. Akses tersebut kemudian digunakan secara tidak semestinya.
4. Aktivitas dapat berupa pengambilan data, perubahan data, penghapusan data, penyalahgunaan sistem, atau pembagian informasi kepada pihak yang tidak berwenang.
5. Apabila tidak terdapat monitoring dan kontrol yang memadai, aktivitas tersebut dapat berlangsung dalam waktu lama tanpa terdeteksi.

Pada kasus akun yang telah dikompromikan, pelaku dari luar dapat menggunakan kredensial pengguna yang sah sehingga aktivitasnya tampak seperti aktivitas normal pengguna internal.

Contoh Kasus

Seorang pegawai memiliki akses terhadap folder yang berisi dokumen administrasi organisasi. Pegawai tersebut kemudian menyalin sejumlah dokumen ke USB pribadi tanpa izin dan menyimpannya di luar lingkungan organisasi.

Pada kasus lain, seorang pegawai secara tidak sengaja mengirim dokumen yang berisi data pribadi kepada alamat email yang salah. Tidak terdapat niat untuk membocorkan informasi, tetapi tindakan tersebut tetap dapat menyebabkan terjadinya insiden keamanan informasi.

Contoh lainnya adalah akun seorang pegawai berhasil dicuri melalui phishing. Pelaku kemudian menggunakan

akun tersebut untuk mengakses sistem internal. Dari sisi sistem, aktivitas tersebut terlihat seperti login dari pengguna yang sah.

Dampak

Insider threat dapat menyebabkan:

- Kebocoran data pribadi.
- Pencurian informasi organisasi.
- Penghapusan atau perubahan data.
- Penyalahgunaan hak akses.
- Gangguan operasional.
- Kerugian finansial.
- Pelanggaran kebijakan keamanan.
- Masalah kepatuhan terhadap peraturan.
- Kerusakan reputasi organisasi.
- Hilangnya kepercayaan masyarakat.

Risiko insider threat menjadi semakin besar apabila organisasi memberikan hak akses yang terlalu luas dan tidak melakukan pemeriksaan terhadap aktivitas pengguna.

Cara Pencegahan

Pencegahan insider threat tidak berarti organisasi harus mencurigai seluruh pegawai. Pendekatan yang lebih tepat adalah membangun **kontrol keamanan yang dapat mencegah, mendeteksi, dan menangani penyalahgunaan akses.**

Beberapa langkah yang dapat diterapkan antara lain:

- Menerapkan prinsip **Least Privilege**.
- Memberikan akses berdasarkan kebutuhan pekerjaan.
- Melakukan **review hak akses** secara berkala.
- Menonaktifkan akun segera setelah pegawai atau pihak ketiga tidak lagi membutuhkan akses.
- Menggunakan **Multi-Factor Authentication (MFA)**.
- Menerapkan logging dan monitoring aktivitas penting.
- Menggunakan sistem **Identity and Access Management (IAM)** sesuai kebutuhan.
- Menerapkan pemisahan tugas (*separation of duties*).
- Melindungi data sensitif dengan mekanisme kontrol akses dan enkripsi.
- Memberikan pelatihan keamanan informasi secara berkala.
- Menyediakan mekanisme pelaporan insiden yang jelas.

NIST menekankan pentingnya pelatihan agar pengguna mampu mengenali dan melaporkan indikator insider threat, social engineering, dan aktivitas mencurigakan melalui saluran organisasi yang telah ditetapkan.

Tips Praktis untuk Pegawai

Setiap pegawai dapat membantu mengurangi risiko insider threat dengan menerapkan kebiasaan berikut:

- Jangan mengakses data yang tidak diperlukan untuk

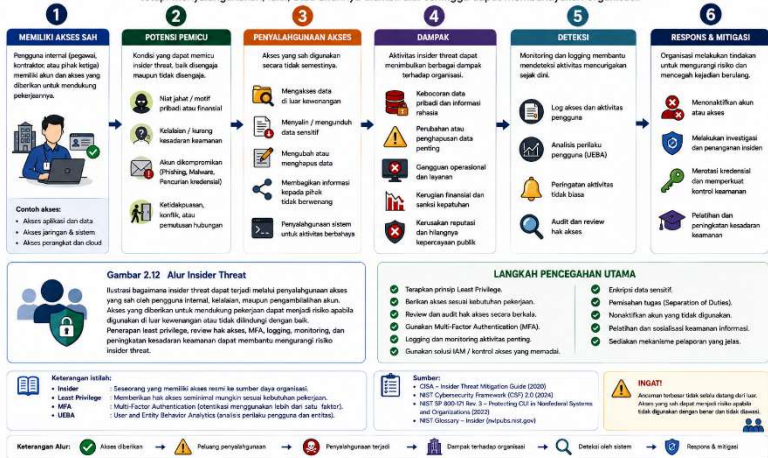
pekerjaan.

- Jangan membagikan username dan password.
- Jangan meminjamkan akun kepada orang lain.
- Jangan menyalin data organisasi ke perangkat pribadi tanpa izin.
- Jangan mengirim dokumen sensitif melalui layanan yang tidak disetujui organisasi.
- Pastikan penerima email sebelum mengirim dokumen penting.
- Kunci komputer ketika meninggalkan meja.
- Segera laporkan kehilangan perangkat organisasi.
- Laporkan aktivitas akun yang tidak dikenal.
- Jangan mengabaikan prosedur keamanan meskipun pekerjaan sedang membutuhkan penyelesaian dengan cepat.

Keamanan bukan hanya tentang mencegah orang luar masuk ke dalam sistem. Keamanan juga memastikan bahwa orang yang sudah memiliki akses menggunakan akses tersebut sesuai dengan kewenangannya.

ALUR INSIDER THREAT

Insider threat adalah ancaman yang berasal dari orang dalam organisasi yang memiliki akses sah, tetapi menyalahgunakan, lalai, atau akunnya diambil alih sehingga dapat membahayakan organisasi.



2.6.8 Supply Chain Attack

Pengertian

Supply Chain Attack adalah serangan siber yang memanfaatkan hubungan kepercayaan antara organisasi dengan pihak ketiga, pemasok, pengembang perangkat lunak, penyedia layanan, atau komponen teknologi yang digunakan dalam suatu sistem. Alih-alih menyerang organisasi secara langsung, pelaku dapat menargetkan bagian dari rantai pasok yang memiliki akses atau dipercaya oleh organisasi.

Rantai pasok teknologi informasi dapat mencakup perangkat keras, perangkat lunak, library, framework, layanan cloud, penyedia jasa teknologi, vendor, hingga proses distribusi dan pembaruan perangkat lunak. Karena satu komponen dapat digunakan oleh banyak organisasi, kompromi terhadap komponen tersebut berpotensi

memberikan dampak yang luas.

Cara Kerja

Secara umum, Supply Chain Attack dapat berlangsung melalui tahapan berikut:

1. Pelaku mengidentifikasi vendor, penyedia layanan, perangkat lunak, atau komponen yang digunakan oleh target.
2. Pelaku mencari kelemahan pada salah satu bagian rantai pasok.
3. Pelaku berhasil memperoleh akses atau memanipulasi komponen yang dipercaya.
4. Komponen yang telah dikompromikan kemudian didistribusikan kepada organisasi atau pengguna.
5. Organisasi menggunakan komponen tersebut tanpa menyadari adanya kompromi.
6. Pelaku memperoleh akses, menyebarkan malware, mencuri data, atau melakukan aktivitas berbahaya lainnya.

Serangan juga dapat terjadi melalui **pembaruan perangkat lunak**. Jika sistem pembaruan vendor telah dikompromikan, pembaruan yang sebenarnya dipercaya oleh organisasi dapat menjadi media penyebaran malware.

Contoh Kasus

Sebuah organisasi menggunakan aplikasi dari vendor pihak ketiga untuk mendukung kegiatan operasional. Organisasi tersebut secara rutin melakukan pembaruan

aplikasi karena menganggap pembaruan dari vendor sebagai sumber yang terpercaya.

Dalam suatu insiden, infrastruktur pengembangan atau distribusi milik vendor berhasil dikompromikan. Pelaku kemudian menyisipkan kode berbahaya ke dalam salah satu pembaruan aplikasi. Ketika organisasi memasang pembaruan tersebut, kode berbahaya ikut masuk ke lingkungan organisasi.

Dalam situasi seperti ini, organisasi tidak menjadi target secara langsung pada tahap awal. **Kepercayaan terhadap vendor dan proses pembaruan justru dimanfaatkan sebagai jalur masuk serangan.**

Dampak

Supply Chain Attack dapat menyebabkan dampak yang luas, antara lain:

- Masuknya malware melalui perangkat lunak yang dipercaya.
- Kebocoran data organisasi.
- Pengambilalihan sistem.
- Gangguan terhadap layanan.
- Kompromi terhadap banyak organisasi sekaligus.
- Kesulitan menentukan sumber awal serangan.
- Kerugian finansial.
- Kerusakan reputasi.
- Gangguan terhadap layanan yang bergantung pada

vendor.

- Risiko keamanan yang berasal dari pihak ketiga.

Salah satu karakteristik penting Supply Chain Attack adalah **dampaknya dapat meluas melebihi organisasi yang pertama kali dikompromikan**, terutama apabila komponen atau layanan yang diserang digunakan oleh banyak pelanggan.

Cara Pencegahan

Organisasi dapat mengurangi risiko Supply Chain Attack dengan menerapkan beberapa langkah berikut:

- Melakukan **vendor risk assessment** sebelum menggunakan layanan pihak ketiga.
- Mengetahui perangkat lunak, library, dan komponen yang digunakan organisasi.
- Menggunakan perangkat lunak dari sumber resmi dan terpercaya.
- Memastikan mekanisme pembaruan perangkat lunak menggunakan saluran resmi.
- Melakukan verifikasi integritas perangkat lunak apabila mekanisme tersebut tersedia.
- Membatasi akses vendor terhadap sistem organisasi.
- Menerapkan **Least Privilege** untuk akun pihak ketiga.
- Menggunakan MFA untuk akses vendor.
- Memantau aktivitas akun dan koneksi pihak ketiga.
- Melakukan evaluasi keamanan vendor secara berkala.

- Menyusun persyaratan keamanan dalam kontrak dengan pihak ketiga.
- Menyiapkan prosedur untuk menghentikan atau membatasi akses vendor ketika terjadi insiden.

NIST menempatkan risiko rantai pasok sebagai bagian penting dari pengelolaan risiko keamanan siber karena organisasi tidak hanya bergantung pada keamanan sistem internal, tetapi juga pada keamanan pihak dan komponen yang berada di luar kendali langsung organisasi.

Tips Praktis untuk Pegawai

Pegawai juga dapat membantu mengurangi risiko Supply Chain Attack dengan:

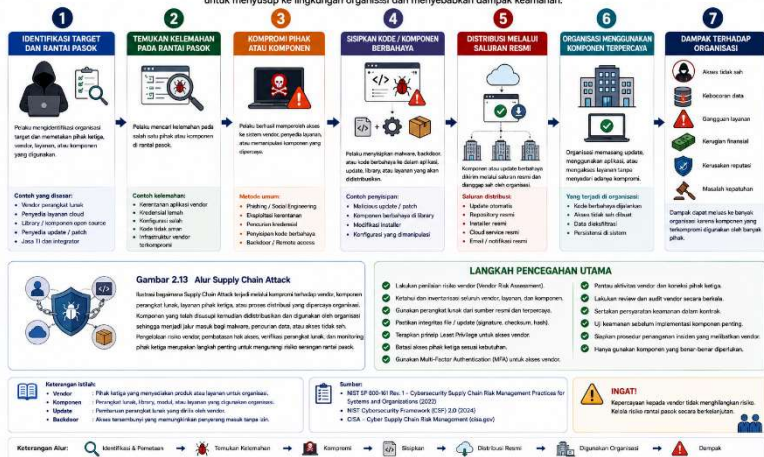
- Tidak menginstal aplikasi yang tidak disetujui organisasi.
- Tidak menggunakan software bajakan atau hasil modifikasi.
- Tidak mengunduh aplikasi dari website yang tidak terpercaya.
- Melakukan pembaruan aplikasi melalui mekanisme resmi.
- Tidak memberikan akses sistem kepada vendor tanpa prosedur yang ditetapkan.
- Tidak membagikan akun organisasi kepada teknisi atau pihak ketiga.
- Segera melaporkan aplikasi atau pembaruan yang menunjukkan perilaku mencurigakan.
- Memastikan permintaan akses dari vendor telah melalui

prosedur yang benar.

Perlu diingat bahwa **vendor yang dipercaya tetap harus dikelola risikonya**. Kepercayaan tidak berarti seluruh akses dan aktivitas pihak ketiga dapat diberikan tanpa pembatasan.

ALUR SUPPLY CHAIN ATTACK

Supply Chain Attack adalah serangan yang memanfaatkan pihak ketiga, vendor, atau komponen yang dipercaya untuk menyusup ke lingkungan organisasi dan menyebabkan dampak keamanan.



2.6.9 Business Email Compromise (BEC)

Pengertian

Business Email Compromise (BEC) adalah bentuk serangan rekayasa sosial yang menargetkan komunikasi bisnis, terutama email, dengan tujuan menipu pegawai agar melakukan tindakan yang menguntungkan pelaku. Tindakan tersebut dapat berupa melakukan transfer dana, mengubah rekening pembayaran, memberikan informasi rahasia, atau mengirim dokumen tertentu.

Dalam serangan BEC, pelaku biasanya menyamar

sebagai pihak yang dipercaya, misalnya pimpinan organisasi, pejabat, vendor, rekan kerja, atau mitra bisnis. Pelaku dapat menggunakan akun email yang telah diambil alih maupun membuat alamat email yang menyerupai alamat resmi.

FBI mengategorikan BEC sebagai salah satu bentuk kejahatan siber yang memanfaatkan komunikasi bisnis untuk melakukan penipuan finansial atau memperoleh informasi yang bernilai bagi pelaku.

Cara Kerja

Serangan BEC umumnya dilakukan melalui tahapan berikut:

1. Pelaku mengumpulkan informasi mengenai organisasi, pegawai, pimpinan, vendor, dan pola komunikasi.
2. Pelaku menentukan target yang memiliki kewenangan melakukan pembayaran atau mengakses informasi penting.
3. Pelaku memperoleh atau membuat akun email yang menyerupai pihak yang dipercaya.
4. Pelaku mengirim email dengan konteks yang tampak normal dan meyakinkan.
5. Korban diminta melakukan tindakan tertentu, misalnya transfer dana atau perubahan informasi rekening.
6. Korban melakukan tindakan berdasarkan email tersebut tanpa melakukan verifikasi melalui saluran komunikasi lain.

7. Pelaku memperoleh keuntungan atau informasi yang diinginkan.

BEC dapat dilakukan melalui beberapa pola, seperti **impersonation**, **account takeover**, penipuan perubahan rekening vendor, maupun penyalahgunaan identitas pimpinan.

Contoh Kasus

Seorang pegawai bagian keuangan menerima email yang tampak berasal dari pimpinan organisasi. Dalam email tersebut, pimpinan meminta agar pembayaran kepada salah satu vendor segera dilakukan karena dianggap mendesak.

Email tersebut terlihat meyakinkan karena menggunakan nama dan tanda tangan pimpinan. Pegawai kemudian menerima instruksi rekening baru yang diklaim sebagai rekening terbaru milik vendor.

Karena tidak melakukan konfirmasi melalui saluran komunikasi lain, pembayaran dilakukan ke rekening yang dikendalikan oleh pelaku.

Beberapa waktu kemudian, vendor yang sebenarnya menghubungi organisasi dan menyatakan bahwa pembayaran belum diterima. Setelah dilakukan pemeriksaan, diketahui bahwa email tersebut merupakan bagian dari serangan BEC.

Dampak

BEC dapat menyebabkan berbagai dampak terhadap organisasi, antara lain:

- Kerugian finansial akibat transfer dana kepada pelaku.

- Kebocoran informasi bisnis.
- Pencurian dokumen dan data organisasi.
- Penyalahgunaan akun email.
- Gangguan hubungan dengan vendor atau mitra.
- Kerusakan reputasi organisasi.
- Hilangnya kepercayaan terhadap komunikasi elektronik.
- Potensi masalah hukum dan kepatuhan.

Kerugian akibat BEC dapat menjadi sangat besar karena pelaku tidak selalu membutuhkan akses teknis tingkat tinggi. **Manipulasi terhadap manusia dan proses bisnis yang dipercaya dapat sudah cukup untuk menyebabkan kerugian.**

Cara Pencegahan

Organisasi dapat mengurangi risiko BEC dengan menerapkan beberapa langkah berikut:

- Menerapkan **Multi-Factor Authentication (MFA)** pada akun email.
- Menggunakan proteksi email untuk mendeteksi pesan berbahaya dan penyamaran.
- Menerapkan **SPF, DKIM, dan DMARC** pada domain organisasi.
- Memberikan pelatihan *security awareness* kepada pegawai.
- Menerapkan prosedur verifikasi untuk transaksi keuangan.

- Melakukan konfirmasi perubahan rekening vendor melalui saluran komunikasi yang berbeda.
- Tidak menjadikan email sebagai satu-satunya dasar untuk transaksi bernilai besar.
- Menerapkan pemisahan tugas (*separation of duties*) pada proses pembayaran.
- Melakukan monitoring terhadap aktivitas akun email.
- Segera menonaktifkan atau mengamankan akun yang diduga telah dikompromikan.

Untuk transaksi penting, organisasi sebaiknya menerapkan prinsip **"verify before you trust"**. Permintaan yang tidak biasa, mendesak, atau berkaitan dengan perubahan rekening harus diverifikasi terlebih dahulu.

Tips Praktis untuk Pegawai

Pegawai dapat membantu mencegah BEC dengan menerapkan kebiasaan berikut:

- Jangan langsung percaya pada email hanya karena menggunakan nama pimpinan.
- Periksa alamat email pengirim secara lengkap.
- Waspadaai permintaan yang menggunakan kata-kata seperti **segera, rahasia**, atau **jangan hubungi siapa pun**.
- Jangan melakukan perubahan rekening vendor hanya berdasarkan email.
- Konfirmasi permintaan pembayaran melalui telepon atau kanal resmi lainnya.

- Jangan mengirim data sensitif hanya karena diminta melalui email.
- Perhatikan perubahan gaya bahasa atau pola komunikasi dari pengirim.
- Laporkan email mencurigikan kepada administrator atau tim keamanan informasi.

Jika sebuah email meminta uang, perubahan rekening, atau informasi sensitif, jangan hanya bertanya "apakah email ini terlihat asli?" tetapi tanyakan juga "apakah permintaan ini sudah diverifikasi melalui saluran lain?"



Gambar 2.14 Alur Business Email Compromise (BEC)

2.6.10 Zero-Day Exploit

Pengertian

Zero-Day Exploit adalah eksploitasi terhadap kerentanan pada perangkat lunak, perangkat keras, atau

sistem yang sebelumnya belum diketahui atau belum tersedia perbaikannya secara memadai. NIST mendefinisikan *zero-day exploit* sebagai serangan yang mengeksploitasi kerentanan perangkat keras, firmware, atau perangkat lunak yang sebelumnya belum diketahui.

Istilah **zero-day** mengacu pada kondisi ketika pengembang atau vendor belum memiliki waktu yang cukup untuk menyediakan perbaikan sebelum kerentanan tersebut dimanfaatkan. NIST juga menjelaskan bahwa *zero-day exploit* merupakan exploit yang memanfaatkan kerentanan pada saat kerentanan tersebut diketahui atau bahkan sebelumnya.

Hal inilah yang membuat zero-day menjadi ancaman serius. Pada kerentanan biasa, organisasi dapat mengandalkan informasi keamanan, pembaruan, dan *patch* yang telah tersedia. Pada zero-day, organisasi dapat menghadapi serangan ketika belum tersedia solusi perbaikan yang dapat langsung diterapkan.

Cara Kerja

Secara umum, serangan zero-day dapat berlangsung melalui tahapan berikut:

1. Pelaku menemukan atau memperoleh informasi mengenai kerentanan yang belum diketahui secara luas.
2. Pelaku mengembangkan atau memperoleh *exploit* yang dapat memanfaatkan kerentanan tersebut.
3. Pelaku menentukan sistem yang menggunakan perangkat lunak atau komponen yang rentan.

4. Pelaku mengirimkan atau menjalankan exploit terhadap target.
5. Kerentanan berhasil dimanfaatkan karena belum tersedia atau belum diterapkan *patch*.
6. Pelaku memperoleh akses atau kemampuan tertentu pada sistem korban.
7. Akses tersebut dapat digunakan untuk melakukan pencurian data, pemasangan malware, pengambilalihan sistem, atau aktivitas berbahaya lainnya.

Zero-day tidak selalu berarti sistem pasti berhasil ditembus. Keberhasilan eksploitasi tetap bergantung pada kondisi sistem, konfigurasi, mekanisme keamanan, serta karakteristik kerentanan yang digunakan.

Contoh Kasus

Sebuah organisasi menggunakan aplikasi yang tersedia untuk publik. Pada suatu waktu ditemukan bahwa terdapat kelemahan keamanan yang belum diketahui oleh vendor. Sebelum vendor mengetahui dan memperbaiki kelemahan tersebut, pelaku telah menemukan cara untuk memanfaatkannya.

Pelaku kemudian mengirimkan permintaan khusus kepada aplikasi tersebut. Karena aplikasi belum memiliki perlindungan terhadap pola serangan tersebut, permintaan dapat menyebabkan perilaku yang tidak semestinya dan memberikan akses kepada pelaku.

Dalam kondisi seperti ini, administrator organisasi mungkin belum dapat melakukan pembaruan karena **patch**

resmi dari vendor belum tersedia.

Kasus zero-day juga dapat terjadi pada perangkat jaringan, sistem operasi, browser, aplikasi bisnis, perangkat keamanan, maupun komponen perangkat lunak pihak ketiga. CISA dan lembaga mitra melaporkan bahwa zero-day masih digunakan oleh pelaku untuk mendapatkan akses ke jaringan organisasi dan target bernilai tinggi.

Dampak

Zero-Day Exploit dapat menyebabkan:

- Akses tidak sah ke sistem.
- Pencurian data.
- Pengambilalihan akun atau sistem.
- Instalasi malware.
- Pengubahan atau penghapusan data.
- Gangguan layanan.
- Penyebaran serangan ke sistem lain.
- Kebocoran informasi sensitif.
- Kerugian finansial.
- Kerusakan reputasi organisasi.

Risiko menjadi lebih besar ketika sistem yang rentan memiliki akses langsung ke internet atau digunakan sebagai komponen penting dalam infrastruktur organisasi.

Cara Pencegahan

Karena *patch* mungkin belum tersedia ketika serangan

zero-day terjadi, organisasi perlu menggunakan **pertahanan berlapis (*defense in depth*)**.

Beberapa langkah yang dapat diterapkan antara lain:

- Selalu memperbarui sistem dan aplikasi segera setelah *patch* keamanan resmi tersedia.
- Menggunakan **Web Application Firewall (WAF)** untuk aplikasi web yang sesuai.
- Menggunakan firewall dan sistem deteksi/pencegahan intrusi.
- Membatasi akses sistem yang tidak diperlukan.
- Menerapkan prinsip **Least Privilege**.
- Memisahkan sistem penting menggunakan segmentasi jaringan.
- Mengaktifkan logging dan monitoring.
- Menggunakan antivirus atau **Endpoint Detection and Response (EDR)**.
- Memantau informasi keamanan dari vendor dan lembaga keamanan siber.
- Menyiapkan prosedur *incident response* untuk menangani eksploitasi yang belum memiliki *patch*.
- Melakukan backup data secara berkala dan memastikan backup dapat dipulihkan.

NIST menjelaskan bahwa kerentanan merupakan kelemahan pada sistem, prosedur keamanan, kontrol internal, atau implementasi yang dapat dieksploitasi oleh

sumber ancaman.

Tips Praktis untuk Pegawai

Pegawai juga memiliki peran dalam mengurangi dampak zero-day, terutama karena banyak eksploitasi membutuhkan interaksi pengguna.

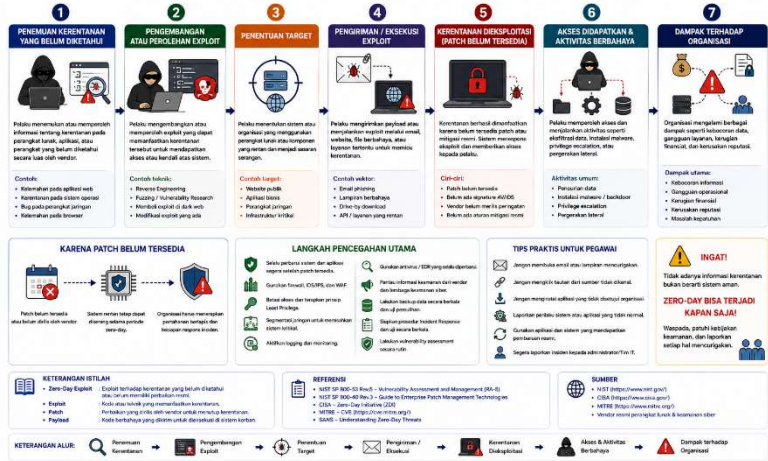
Beberapa kebiasaan yang perlu diterapkan:

- Jangan membuka lampiran email yang mencurigakan.
- Jangan mengklik tautan dari sumber yang tidak dikenal.
- Jangan menginstal aplikasi yang tidak disetujui organisasi.
- Gunakan aplikasi dan sistem yang mendapatkan pembaruan resmi.
- Segera laporkan aplikasi yang tiba-tiba mengalami perilaku tidak normal.
- Jangan mencoba menonaktifkan antivirus atau mekanisme keamanan organisasi.
- Laporkan pesan atau file mencurigakan kepada administrator.
- Ikuti prosedur keamanan ketika organisasi meminta penghentian sementara penggunaan aplikasi tertentu.

Yang paling penting, **tidak adanya pemberitahuan kerentanan bukan berarti sebuah sistem pasti aman**. Zero-day justru menggambarkan kondisi ketika kelemahan belum diketahui atau belum memiliki mitigasi yang memadai.

ALUR ZERO-DAY EXPLOIT

Zero-Day Exploit adalah serangan yang memanfaatkan kerentanan yang belum diketahui atau belum memiliki perbaikan (patch) resmi.



Gambar 2.15 Alur Zero-Day Exploit

BAB 3 PENYEBAB UTAMA INSIDEN KEAMANAN SIBER

3.1 Faktor Manusia (Human Error)

Faktor manusia merupakan salah satu aspek penting dalam keamanan siber. Sistem keamanan yang menggunakan firewall, antivirus, autentikasi, enkripsi, dan berbagai teknologi perlindungan tetap membutuhkan manusia untuk mengoperasikan dan menggunakannya dengan benar. Kesalahan pengguna dapat membuka peluang bagi penyerang untuk memperoleh akses terhadap sistem, data, atau layanan organisasi.

Human error dapat dipahami sebagai kesalahan, kelalaian, atau tindakan pengguna yang tidak sesuai dengan prosedur dan dapat meningkatkan risiko keamanan. Kesalahan tersebut tidak selalu dilakukan dengan sengaja. Seorang pegawai dapat menjadi penyebab terjadinya insiden karena kurang memahami risiko, terburu-buru, salah mengambil keputusan, atau tidak mengikuti prosedur keamanan.

NIST menekankan bahwa program pembelajaran keamanan siber seharusnya tidak hanya bertujuan memberikan pengetahuan, tetapi juga mendorong **perubahan perilaku** dan membangun budaya keamanan di dalam organisasi.

Dalam praktiknya, kesalahan manusia dapat muncul dalam berbagai aktivitas sehari-hari. Contohnya adalah membuka tautan phishing, menggunakan password yang lemah, membagikan kredensial, salah mengirim dokumen, menggunakan perangkat USB yang tidak dikenal, menginstal

aplikasi dari sumber tidak resmi, atau mengabaikan peringatan keamanan.

Bentuk Human Error

Beberapa bentuk kesalahan manusia yang sering ditemukan dalam lingkungan organisasi antara lain:

1. Membuka email atau tautan mencurigakan

Pegawai menerima email yang tampak berasal dari pihak yang dikenal kemudian membuka tautan atau lampiran tanpa melakukan pemeriksaan terlebih dahulu.

2. Menggunakan password yang lemah

Pengguna menggunakan password yang mudah ditebak, menggunakan password yang sama pada beberapa layanan, atau menyimpan password dengan cara yang tidak aman.

3. Salah mengirim informasi

Dokumen atau informasi yang seharusnya bersifat internal dikirim kepada penerima yang salah karena pengguna tidak memeriksa kembali alamat email.

4. Membagikan kredensial

Pengguna memberikan username atau password kepada orang lain untuk mempermudah pekerjaan. Praktik ini dapat menghilangkan kemampuan organisasi untuk mengetahui siapa yang sebenarnya menggunakan sebuah akun.

5. Mengabaikan pembaruan

Pengguna menunda pembaruan aplikasi atau sistem karena khawatir mengganggu pekerjaan, sehingga perangkat tetap menggunakan versi yang memiliki kerentanan.

6. Menggunakan perangkat atau aplikasi yang tidak resmi

Pegawai menginstal aplikasi dari sumber yang tidak

terpercaya atau menggunakan media penyimpanan yang tidak diketahui asalnya.

7. Salah melakukan konfigurasi

Administrator atau operator dapat melakukan kesalahan konfigurasi, misalnya memberikan hak akses terlalu luas atau mengaktifkan layanan yang sebenarnya tidak diperlukan.

Mengapa Human Error Terjadi?

Human error tidak selalu disebabkan oleh kurangnya pengetahuan. Beberapa kondisi yang dapat meningkatkan kemungkinan terjadinya kesalahan antara lain:

Kurangnya kesadaran keamanan.

Kurangnya pelatihan.

Tekanan pekerjaan.

Beban kerja yang tinggi.

Kelelahan.

Kebiasaan kerja yang tidak aman.

Prosedur yang terlalu rumit.

Instruksi yang tidak jelas.

Kurangnya pengawasan.

Sistem yang sulit digunakan.

Kurangnya budaya keamanan dalam organisasi.

Oleh karena itu, ketika terjadi kesalahan, organisasi sebaiknya tidak hanya mencari siapa yang melakukan kesalahan, tetapi juga mencari **mengapa kesalahan tersebut dapat terjadi**.

Pendekatan ini penting karena tujuan keamanan bukan sekadar memberikan hukuman kepada pengguna, tetapi memperbaiki proses agar kesalahan yang sama tidak kembali menyebabkan insiden.

Contoh Kasus

Seorang pegawai menerima email yang mengatasnamakan administrator sistem. Email tersebut menyatakan bahwa akun pegawai akan segera dinonaktifkan dan meminta pengguna melakukan login melalui tautan yang tersedia.

Karena sedang terburu-buru menyelesaikan pekerjaan, pegawai tersebut langsung membuka tautan dan memasukkan username serta password.

Setelah beberapa saat, pegawai baru menyadari bahwa alamat website tersebut berbeda dari alamat resmi organisasi. Ternyata halaman tersebut merupakan halaman login palsu yang digunakan untuk mencuri kredensial.

Dalam kasus tersebut, teknologi keamanan mungkin masih berjalan dengan normal. Namun, **keputusan pengguna untuk mempercayai email dan memasukkan kredensial menjadi salah satu faktor yang memungkinkan serangan terjadi.**

Dampak Human Error

Kesalahan manusia dapat menimbulkan berbagai dampak terhadap organisasi, antara lain:

Kebocoran data.

Pencurian kredensial.

Infeksi malware.

Pengambilalihan akun.

Kesalahan konfigurasi sistem.

Hilangnya atau rusaknya data.

Gangguan terhadap layanan.

Pelanggaran kebijakan keamanan.

Kerugian finansial.

Kerusakan reputasi organisasi.

Besarnya dampak sangat bergantung pada jenis kesalahan dan hak akses yang dimiliki pengguna. Kesalahan seorang pengguna biasa mungkin hanya berdampak pada satu perangkat, sedangkan kesalahan administrator dapat berpotensi memengaruhi banyak sistem.

Mengurangi Risiko Human Error

Mengurangi human error tidak cukup hanya dengan meminta pegawai untuk "**lebih berhati-hati**". Organisasi perlu membangun sistem dan budaya kerja yang membantu pegawai mengambil keputusan secara aman.

Beberapa langkah yang dapat diterapkan adalah:

Melaksanakan **Cyber Security Awareness** secara berkala.

Memberikan pelatihan sesuai peran dan tanggung jawab.

Membuat prosedur keamanan yang sederhana dan mudah dipahami.

Menerapkan **Multi-Factor Authentication (MFA)**.

Menerapkan prinsip **Least Privilege**.

Menggunakan perlindungan email terhadap phishing.

Melakukan backup data secara berkala.

Menggunakan endpoint protection atau EDR.

Memberikan peringatan ketika pengguna melakukan tindakan berisiko.

Melakukan simulasi phishing secara terukur.

Menyediakan mekanisme pelaporan insiden yang mudah.

Mengevaluasi penyebab kesalahan dan memperbaiki proses kerja.

NIST SP 800-50 Rev. 1 secara khusus merekomendasikan pendekatan pembelajaran yang berkelanjutan, termasuk evaluasi dan perbaikan program berdasarkan kebutuhan serta perubahan risiko organisasi (Merritt et al., 2024).

Peran Pegawai

Setiap pegawai merupakan bagian dari pertahanan keamanan organisasi. Kebiasaan sederhana yang dapat dilakukan antara lain:

Berhenti sejenak sebelum membuka email atau tautan yang mencurigakan.

Memeriksa alamat email pengirim.

Tidak memberikan password kepada orang lain.

Menggunakan MFA apabila tersedia.

Memeriksa kembali penerima sebelum mengirim dokumen sensitif.

Tidak menginstal aplikasi tanpa izin.

Tidak menggunakan perangkat USB yang tidak dikenal.

Mengikuti prosedur keamanan organisasi.

Segera melaporkan kesalahan yang telah terjadi.

Melaporkan aktivitas yang terlihat tidak normal.

Hal yang penting untuk dipahami adalah bahwa **melaporkan kesalahan dengan cepat lebih baik daripada menyembunyikannya**. Pelaporan dini memberikan kesempatan kepada tim IT atau keamanan untuk melakukan tindakan sebelum kesalahan berkembang menjadi insiden yang lebih besar.

Membangun Budaya Keamanan

Keamanan siber bukan hanya tanggung jawab administrator sistem atau tim IT. Setiap orang yang menggunakan komputer, aplikasi, email, jaringan, atau mengelola informasi organisasi memiliki peran dalam menjaga keamanan.

NIST mendefinisikan *awareness training* sebagai program dasar yang membantu seluruh personel memahami peran mereka dalam melindungi informasi, keamanan siber, dan aset privasi organisasi.

Karena itu, program **Cyber Security Awareness** sebaiknya tidak hanya dilakukan satu kali dalam bentuk sosialisasi. Organisasi perlu membangun pembelajaran yang berkelanjutan sehingga perilaku aman menjadi bagian dari kebiasaan kerja sehari-hari.

Temuan **Verizon 2026 Data Breach Investigations Report** juga menunjukkan bahwa unsur manusia yang tidak disengaja

tetap berkontribusi besar dalam insiden keamanan; laporan tersebut mencatat kontribusi *non-intentional human element* sebesar **62% dari seluruh breach** yang dianalisis (Verizon, 2026).

Dengan demikian, peningkatan kesadaran manusia bukan pelengkap keamanan teknologi, tetapi merupakan bagian penting dari strategi pertahanan organisasi.

3.2 Password yang Lemah

Password merupakan salah satu mekanisme autentikasi yang paling umum digunakan untuk melindungi akun, aplikasi, komputer, maupun layanan organisasi. Namun, password yang lemah dapat menjadi titik masuk bagi penyerang untuk memperoleh akses tidak sah.

Password yang lemah bukan hanya password yang pendek. Password dapat dianggap berisiko apabila mudah ditebak, menggunakan informasi pribadi, digunakan kembali pada banyak layanan, atau telah diketahui akibat kebocoran data. Ketika sebuah password digunakan pada beberapa layanan, kebocoran pada satu layanan dapat memungkinkan penyerang mencoba kredensial yang sama pada layanan lainnya.

NIST merekomendasikan penggunaan password yang panjang dan tidak mudah ditebak serta mendukung penggunaan *password manager* untuk membantu pengguna mengelola password yang unik pada berbagai layanan. NIST juga menekankan bahwa password sebaiknya tidak digunakan kembali pada sistem yang berbeda (NIST SP 800-63B).

Karakteristik Password yang Lemah

Beberapa karakteristik password yang meningkatkan risiko

keamanan antara lain:

- Terlalu pendek.
- Menggunakan nama pengguna.
- Menggunakan nama organisasi.
- Menggunakan nama anggota keluarga.
- Menggunakan tanggal lahir.
- Menggunakan nomor telepon.
- Menggunakan kata atau kombinasi yang mudah ditebak.
- Menggunakan pola seperti 123456, password, atau kombinasi sederhana lainnya.
- Menggunakan password yang sama untuk beberapa akun.
- Menggunakan password yang pernah mengalami kebocoran.
- Membagikan password kepada orang lain.
- Menyimpan password dalam bentuk yang mudah diketahui orang lain.

Penggunaan informasi pribadi sebagai password juga berisiko karena informasi tersebut dapat diperoleh dari media sosial, dokumen publik, maupun sumber informasi lainnya.

Bagaimana Password Lemah Disalahgunakan?

Penyerang dapat menggunakan berbagai teknik untuk memperoleh atau menebak password. Beberapa teknik yang umum antara lain:

1. Brute Force

Penyerang mencoba berbagai kombinasi karakter hingga menemukan password yang benar. Password yang pendek atau memiliki pola sederhana lebih rentan terhadap metode ini.

2. Dictionary Attack

Penyerang menggunakan daftar kata dan kombinasi password yang umum digunakan untuk mencoba mendapatkan password korban.

3. Credential Stuffing

Penyerang menggunakan kombinasi username dan password yang diperoleh dari kebocoran data untuk mencoba login ke layanan lain.

4. Password Spraying

Penyerang mencoba satu atau beberapa password yang umum terhadap banyak akun, dengan tujuan menghindari mekanisme pembatasan login pada satu akun.

5. Phishing

Penyerang menipu pengguna agar menyerahkan password secara langsung melalui website, email, atau pesan palsu.

Teknik-teknik tersebut menunjukkan bahwa keamanan password tidak hanya bergantung pada kerumitan password, tetapi juga pada bagaimana password digunakan dan dilindungi.

Contoh Kasus

Seorang pegawai menggunakan password yang sama untuk akun email pribadi dan akun organisasi. Password tersebut kemudian diketahui oleh pihak lain karena akun pribadi pegawai mengalami kebocoran data.

Penyerang mencoba kombinasi username dan password yang sama pada sistem organisasi. Karena pegawai menggunakan kembali password tersebut, penyerang berhasil mendapatkan akses ke akun organisasi.

Dalam kasus ini, sistem organisasi mungkin tidak mengalami kerentanan teknis. Masalah terjadi karena **penggunaan kembali password** menyebabkan kebocoran pada satu layanan berdampak pada layanan lainnya.

Dampak

Password yang lemah dapat menyebabkan:

- Pengambilalihan akun.
- Pencurian data.
- Penyalahgunaan email organisasi.
- Akses tidak sah terhadap aplikasi.
- Pencurian informasi pribadi.
- Penyebaran phishing dari akun yang telah diambil alih.
- Akses lebih lanjut ke sistem internal.
- Kerugian finansial.
- Kerusakan reputasi organisasi.

Risiko dapat menjadi lebih besar ketika akun yang menggunakan password lemah memiliki hak akses administratif atau dapat digunakan untuk mengakses berbagai sistem organisasi.

Cara Membuat Password yang Lebih Aman

Pengguna sebaiknya menggunakan password yang **panjang, unik, dan sulit ditebak**. NIST SP 800-63B memberikan perhatian besar pada panjang password dan menyarankan agar layanan tidak memaksakan aturan komposisi yang tidak memberikan manfaat keamanan yang sebanding, sementara password yang diketahui berasal dari kebocoran atau daftar password umum sebaiknya ditolak (NIST SP 800-63B).

Beberapa praktik yang dapat diterapkan:

- Gunakan password yang panjang.
- Gunakan password berbeda untuk setiap akun penting.
- Gunakan *passphrase* yang mudah diingat tetapi sulit ditebak.
- Gunakan **password manager** untuk menghasilkan dan menyimpan password unik.
- Jangan menggunakan informasi pribadi sebagai password.
- Jangan membagikan password.
- Jangan menggunakan kembali password yang telah diketahui mengalami kebocoran.
- Aktifkan **Multi-Factor Authentication (MFA)** apabila tersedia.
- Segera ganti password apabila terdapat indikasi akun telah dikompromikan.

Sebagai contoh, daripada menggunakan password sederhana seperti:

Budi123

lebih baik menggunakan *passphrase* unik yang panjang dan hanya digunakan untuk satu layanan. Untuk akun penting, password sebaiknya dibuat secara acak menggunakan *password manager*.

Password Manager

Penggunaan password yang berbeda untuk setiap layanan memang meningkatkan keamanan, tetapi dapat menjadi sulit apabila pengguna harus mengingat puluhan password.

Password manager dapat membantu menyimpan password secara aman dan menghasilkan password yang panjang serta unik untuk setiap layanan. Dengan demikian, pengguna tidak perlu menggunakan satu password yang sama untuk semua akun.

Namun, akun utama yang digunakan untuk mengakses password manager harus mendapatkan perlindungan yang sangat kuat, termasuk MFA apabila tersedia.

Multi-Factor Authentication

Password sebaiknya tidak menjadi satu-satunya lapisan perlindungan terhadap akun penting.

Multi-Factor Authentication (MFA) menambahkan faktor autentikasi lain sehingga pencurian password saja tidak selalu cukup untuk mendapatkan akses.

Contohnya:

Password

+

Faktor kedua

↓

Akses akun

Faktor kedua dapat berupa aplikasi autentikator, security key, atau mekanisme autentikasi lain yang didukung oleh organisasi.

MFA sangat penting terutama untuk akun email, administrator, VPN, layanan cloud, dan sistem yang menyimpan informasi sensitif.

Tips Praktis untuk Pegawai

Biasakan menerapkan prinsip berikut:

- Jangan menggunakan password yang sama untuk akun kantor dan akun pribadi.
- Jangan menggunakan nama, tanggal lahir, atau informasi pribadi sebagai password.
- Jangan memberikan password kepada rekan kerja.
- Jangan memasukkan password organisasi pada website yang tidak resmi.
- Gunakan password manager jika organisasi mengizinkannya.
- Aktifkan MFA.
- Jangan menyimpan password pada kertas yang ditempel

di monitor.

- Jangan menyimpan password dalam file teks biasa.
- Segera laporkan apabila menerima pemberitahuan login yang tidak dilakukan sendiri.
- Segera ubah password jika terdapat indikasi kebocoran.

Password adalah salah satu kunci utama menuju sistem organisasi. Menjaga password bukan sekadar kewajiban teknis, tetapi bagian dari tanggung jawab setiap pegawai dalam menjaga keamanan informasi.

3.3 Penggunaan Password yang Sama

Penggunaan password yang sama pada beberapa akun merupakan salah satu kebiasaan yang dapat meningkatkan risiko keamanan informasi. Kebiasaan ini biasanya dilakukan karena pengguna ingin lebih mudah mengingat password. Namun, apabila salah satu layanan mengalami kebocoran data dan password pengguna ikut diketahui oleh pihak lain, password tersebut dapat digunakan untuk mencoba masuk ke layanan lainnya.

Risiko ini menjadi semakin besar ketika password yang sama digunakan untuk **akun pribadi, email organisasi, aplikasi internal, VPN, layanan cloud, atau akun administratif.**

Mengapa Penggunaan Password yang Sama Berbahaya?

Masalah utama penggunaan password yang sama adalah adanya **efek domino**. Satu kebocoran dapat memberikan peluang kepada penyerang untuk menyerang layanan lainnya.

Sebagai contoh, seorang pegawai menggunakan kombinasi

berikut:

Layanan/Akun	Password yang Digunakan
Email pribadi	Password A
Media sosial	Password A
Email organisasi	Password A
VPN organisasi	Password A

Jika password pada email pribadi berhasil diperoleh penyerang, penyerang dapat mencoba kombinasi username dan password yang sama pada layanan organisasi.

Teknik seperti ini dikenal sebagai **Credential Stuffing**, yaitu penggunaan kombinasi kredensial yang diperoleh dari suatu sumber untuk mencoba login pada layanan lainnya.

Contoh Kasus

Seorang pegawai memiliki akun pada sebuah layanan internet dan menggunakan password yang sama dengan akun email organisasi.

Kemudian terjadi kebocoran data pada layanan tersebut. Data yang bocor berisi alamat email dan password pengguna.

Pelaku memperoleh data tersebut dan mencoba menggunakan kombinasi email dan password yang sama pada layanan email organisasi. Karena password digunakan kembali, pelaku berhasil mendapatkan akses ke akun organisasi.

Setelah akun berhasil dikuasai, pelaku dapat menggunakannya untuk membaca email, mencari informasi penting, mengirim email phishing kepada pegawai lain, atau

mencoba mengakses layanan organisasi lainnya.

Dampak

Penggunaan password yang sama dapat menyebabkan:

- Satu kebocoran berdampak pada banyak akun.
- Pengambilalihan akun organisasi.
- Kebocoran email dan dokumen.
- Penyalahgunaan akun untuk phishing.
- Akses tidak sah terhadap aplikasi internal.
- Akses terhadap VPN atau layanan cloud.
- Penyebaran serangan ke pengguna lain.
- Kerugian finansial dan reputasi organisasi.

Risiko akan semakin tinggi apabila password yang sama digunakan pada akun dengan **hak akses tinggi**, seperti administrator sistem.

Cara Pencegahan

Untuk mengurangi risiko penggunaan password yang sama, organisasi dan pengguna perlu menerapkan beberapa langkah:

- Gunakan password yang **unik untuk setiap layanan penting**.
- Jangan menggunakan password akun pribadi untuk akun organisasi.
- Jangan menggunakan password email untuk VPN atau aplikasi internal.
- Gunakan **password manager** untuk membantu

membuat dan menyimpan password yang berbeda.

- Aktifkan **Multi-Factor Authentication (MFA)**.
- Segera mengganti password apabila diketahui terjadi kebocoran.
- Jangan menggunakan kembali password yang sudah pernah digunakan pada layanan lain.
- Organisasi dapat melakukan pemeriksaan terhadap password yang telah diketahui mengalami kebocoran sesuai kebijakan keamanan yang berlaku.

NIST merekomendasikan agar password yang telah diketahui melalui kebocoran atau termasuk dalam daftar password yang umum digunakan tidak diterima sebagai password baru. Pendekatan tersebut membantu mengurangi risiko penggunaan kredensial yang telah diketahui oleh penyerang. (pages.nist.gov)

Password Unik untuk Setiap Layanan

Prinsip sederhana yang perlu diterapkan adalah:

Satu akun penting = satu password unik.

Contohnya:

Layanan/Akun	Password yang Digunakan
Email organisasi	Password unik A
VPN	Password unik B
Aplikasi internal	Password unik C
Cloud	Password unik D

Dengan pola tersebut, apabila salah satu password diketahui

oleh penyerang, kredensial tersebut tidak secara otomatis dapat digunakan untuk mengakses layanan lainnya.

Pengguna tidak harus menghafal seluruh password tersebut. **Password manager** dapat digunakan untuk menyimpan dan menghasilkan password yang berbeda untuk setiap layanan.

Peran Organisasi

Organisasi juga memiliki tanggung jawab untuk mengurangi risiko penggunaan password yang sama. Beberapa langkah yang dapat diterapkan antara lain:

- Menerapkan MFA pada akun penting.
- Mendeteksi dan memblokir password yang telah diketahui mengalami kebocoran.
- Menerapkan kebijakan password yang sesuai dengan kebutuhan organisasi.
- Melakukan monitoring terhadap aktivitas login yang mencurigakan.
- Menerapkan pembatasan percobaan login.
- Memberikan edukasi mengenai credential stuffing.
- Melakukan evaluasi keamanan akun secara berkala.
- Menggunakan sistem IAM untuk mengelola identitas dan akses.
- **Tips Praktis untuk Pegawai**

Biasakan melakukan pemeriksaan sederhana:

Apakah password akun kantor saya pernah digunakan pada layanan lain?

Jika jawabannya **ya**, sebaiknya segera gunakan password yang berbeda untuk akun organisasi.

Selain itu:

- Jangan menggunakan password email pribadi untuk email kantor.
- Jangan menggunakan password media sosial untuk aplikasi kantor.
- Jangan menggunakan password yang sama untuk VPN dan email.
- Gunakan password manager jika diperbolehkan organisasi.
- Aktifkan MFA.
- Segera laporkan notifikasi login yang tidak dikenali.
- Jangan memasukkan password organisasi pada website yang tidak resmi.

Jangan biarkan satu password menjadi kunci untuk seluruh kehidupan digital Anda.

3.4 Tidak Menggunakan Multi-Factor Authentication (MFA)

Multi-Factor Authentication (MFA) adalah mekanisme autentikasi yang meminta pengguna memberikan dua atau lebih faktor untuk membuktikan identitasnya sebelum memperoleh akses ke suatu akun atau sistem. Faktor tersebut dapat berupa sesuatu yang diketahui pengguna (*something you know*), sesuatu yang dimiliki pengguna (*something you have*), atau karakteristik

biologis pengguna (*something you are*).

Tidak menggunakan MFA membuat keamanan akun hanya bergantung pada satu faktor, biasanya username dan password. Apabila password berhasil dicuri melalui phishing, malware, kebocoran data, atau teknik lainnya, penyerang dapat langsung mencoba menggunakan password tersebut untuk mengambil alih akun.

CISA merekomendasikan organisasi untuk menggunakan MFA pada akun bisnis, terutama email, penyimpanan file, akses jarak jauh, serta akun dengan hak administratif. CISA juga menyarankan penggunaan MFA yang **phishing-resistant** apabila tersedia.

Mengapa Tidak Menggunakan MFA Berisiko?

Password memiliki beberapa kelemahan. Password dapat:

- Dicuri melalui phishing.
- Diperoleh dari kebocoran data.
- Ditebak melalui serangan terhadap password yang lemah.
- Dicuri oleh malware.
- Digunakan kembali oleh pengguna pada beberapa layanan.
- Diberikan kepada orang lain secara tidak sengaja.

Jika sebuah akun hanya menggunakan password, keberhasilan memperoleh password tersebut dapat langsung memberikan kesempatan kepada penyerang untuk mencoba masuk.

Sebaliknya, MFA menambahkan lapisan autentikasi tambahan. Dengan MFA, **password yang berhasil dicuri belum tentu cukup untuk mengambil alih akun** karena penyerang masih membutuhkan faktor autentikasi lainnya. CISA menjelaskan bahwa MFA dapat mengurangi risiko pengambilalihan akun meskipun password telah dikompromikan.

Contoh Kasus

Seorang pegawai menggunakan password yang kuat untuk akun email organisasi. Namun, pegawai tersebut tidak mengaktifkan MFA.

Suatu hari, pegawai menerima email phishing dan memasukkan username serta password pada halaman login palsu. Pelaku kemudian memperoleh kredensial tersebut.

Karena akun tidak menggunakan MFA, pelaku dapat langsung mencoba login menggunakan username dan password yang telah diperoleh.

Setelah berhasil masuk, pelaku dapat membaca email korban, mencari informasi organisasi, mengirim pesan phishing kepada pegawai lain, atau menggunakan akun tersebut untuk mencoba mendapatkan akses ke layanan lainnya.

Apabila MFA telah diterapkan, pelaku masih harus melewati faktor autentikasi kedua. Hal tersebut dapat menghentikan atau setidaknya mempersulit pengambilalihan akun.

Dampak

Tidak menggunakan MFA dapat meningkatkan risiko:

- Pengambilalihan akun.

- Pencurian email.
- Kebocoran dokumen.
- Pencurian data.
- Penyalahgunaan akun untuk phishing.
- Akses tidak sah terhadap aplikasi internal.
- Penyalahgunaan VPN atau akses jarak jauh.
- Kompromi terhadap akun administrator.
- Serangan lanjutan terhadap sistem organisasi.

Risiko menjadi lebih tinggi pada akun yang memiliki akses terhadap informasi sensitif atau sistem penting.

Jenis Faktor Autentikasi

MFA menggunakan kombinasi faktor yang berbeda. Secara umum terdapat tiga kategori utama:

1. Something You Know

Sesuatu yang diketahui pengguna, misalnya:

- Password.
- PIN.
- Passphrase.

2. Something You Have

Sesuatu yang dimiliki pengguna, misalnya:

- Smartphone.
- Aplikasi authenticator.

- Security key.
- Smart card.

3. Something You Are

Karakteristik biologis pengguna, misalnya:

- Sidik jari.
- Pengenalan wajah.
- Karakteristik biometrik lainnya.

MFA bekerja dengan menggabungkan minimal dua faktor yang berbeda sehingga kompromi terhadap satu faktor tidak otomatis memberikan akses penuh kepada penyerang.

Tidak Semua MFA Memiliki Tingkat Keamanan yang Sama

Hal yang juga perlu dipahami adalah **MFA bukan berarti semua metode MFA memiliki tingkat perlindungan yang sama.**

CISA merekomendasikan organisasi untuk mengarah pada **phishing-resistant MFA**. FIDO/WebAuthn merupakan salah satu pendekatan yang tersedia luas untuk memberikan perlindungan terhadap phishing.

Secara sederhana, organisasi dapat mempertimbangkan:

Lebih kuat:

- FIDO/WebAuthn.
- Security key.
- Passkey yang menggunakan autentikasi phishing-resistant.

Pilihan yang masih memberikan perlindungan tambahan:

- Authenticator app.
- Number matching.
- One-time password (OTP).

Lebih lemah:

- Kode yang dikirim melalui SMS atau email.

Bukan berarti MFA berbasis SMS tidak berguna. **MFA apa pun umumnya lebih baik daripada hanya menggunakan password**, tetapi organisasi sebaiknya meningkatkan metode autentikasi menuju mekanisme yang lebih tahan terhadap phishing jika memungkinkan.

Akun yang Sebaiknya Menggunakan MFA

Organisasi sebaiknya memprioritaskan MFA pada akun yang memiliki risiko tinggi, seperti:

- Email organisasi.
- Akun administrator.
- VPN.
- Remote access.
- Cloud service.
- Sistem keuangan.
- Sistem yang menyimpan data pribadi.
- Sistem yang menyimpan informasi penting organisasi.
- Aplikasi dengan akses ke banyak sistem lainnya.

CISA secara khusus merekomendasikan MFA untuk email, penyimpanan file, akses jarak jauh, serta akun administratif dan pengguna yang menangani data sensitif.

Peran Organisasi

Penerapan MFA tidak boleh hanya menjadi tanggung jawab pengguna. Organisasi perlu membuat kebijakan dan menyediakan infrastruktur yang mendukung penerapan MFA.

Beberapa langkah yang dapat dilakukan:

- Mewajibkan MFA untuk akun penting.
- Memulai penerapan dari akun administrator.
- Menerapkan MFA pada email organisasi.
- Menerapkan MFA pada VPN dan remote access.
- Menggunakan MFA pada aplikasi yang menangani data sensitif.
- Memilih metode MFA yang sesuai dengan tingkat risiko.
- Mengarahkan penggunaan phishing-resistant MFA.
- Memberikan edukasi kepada pegawai.
- Menyediakan prosedur pemulihan akun yang aman.
- Melakukan monitoring terhadap aktivitas autentikasi.

Tips Praktis untuk Pegawai

Jika sebuah layanan organisasi menyediakan MFA, aktifkan dan gunakan sesuai kebijakan.

Beberapa hal yang perlu diperhatikan:

- Jangan menonaktifkan MFA tanpa alasan yang sah.

- Jangan memberikan kode MFA kepada orang lain.
- Jangan menyetujui permintaan login yang tidak Anda lakukan.
- Jika menerima permintaan MFA secara tiba-tiba, segera laporkan.
- Gunakan authenticator yang disetujui organisasi.
- Jika tersedia, gunakan metode MFA yang tahan terhadap phishing.
- Lindungi perangkat yang digunakan sebagai faktor kedua.
- Segera laporkan kehilangan smartphone atau security key yang digunakan untuk MFA.

Jangan pernah menyetujui permintaan MFA hanya karena muncul di layar. Jika Anda tidak sedang melakukan login, permintaan tersebut dapat menjadi indikasi bahwa seseorang sedang mencoba menggunakan password Anda.

Kesimpulan

Password tetap menjadi bagian penting dari keamanan akun, tetapi **password saja tidak cukup untuk melindungi akun penting.** MFA memberikan lapisan perlindungan tambahan sehingga pencurian password tidak otomatis menghasilkan pengambilalihan akun.

Bagi organisasi, penerapan MFA sebaiknya dimulai dari akun dengan risiko paling tinggi dan secara bertahap diperluas ke seluruh layanan yang mendukungnya. Untuk perlindungan yang lebih kuat terhadap phishing, organisasi sebaiknya memiliki rencana menuju **phishing-resistant MFA** seperti

FIDO/WebAuthn.

3.5 Membuka Tautan dan Lampiran yang Mencurigakan

Email dan aplikasi pesan merupakan bagian penting dari aktivitas organisasi. Namun, keduanya juga sering dimanfaatkan oleh penyerang untuk menyebarkan **phishing**, **malware**, **ransomware**, dan berbagai bentuk rekayasa sosial.

Salah satu kebiasaan yang dapat meningkatkan risiko keamanan adalah **membuka tautan atau lampiran tanpa melakukan pemeriksaan terlebih dahulu**. Penyerang biasanya membuat pesan yang terlihat meyakinkan agar korban merasa perlu segera membuka tautan atau dokumen yang diberikan.

CISA memasukkan phishing sebagai salah satu bentuk *social engineering* yang dapat digunakan untuk memperoleh informasi sensitif, menyebarkan malware, atau mengarahkan korban ke website berbahaya.

Mengapa Tautan dan Lampiran Mencurigakan Berbahaya?

Tautan (*link*) dapat mengarahkan pengguna ke:

- Website phishing.
- Halaman login palsu.
- Website yang menyebarkan malware.
- Website yang mencoba mengeksploitasi kerentanan browser.
- Layanan yang digunakan untuk mencuri informasi.

Sementara itu, lampiran dapat berisi:

- Malware.
- Ransomware.
- Trojan.
- Script berbahaya.
- Dokumen yang memanfaatkan kerentanan aplikasi.
- File yang meminta pengguna mengaktifkan fungsi tertentu.

Masalahnya, file atau tautan berbahaya sering dibuat sedemikian rupa sehingga **terlihat seperti file atau website yang normal**.

Contoh Tautan yang Perlu Diwaspadai

Misalnya pengguna menerima email yang mengaku berasal dari layanan resmi:

"Akun Anda akan dinonaktifkan. Silakan login sekarang untuk mempertahankan akses."

Email tersebut menyediakan tombol:

LOGIN SEKARANG

Ketika tombol ditekan, pengguna diarahkan ke halaman login yang tampilannya menyerupai website resmi. Jika pengguna memasukkan username dan password, informasi tersebut dapat dikirim kepada pelaku.

Oleh karena itu, **tampilan website yang terlihat resmi bukan jaminan bahwa website tersebut benar-benar resmi**.

Contoh Lampiran yang Perlu Diwaspadai

Pegawai menerima email dari pengirim yang tidak dikenal dengan lampiran:

Invoice_2026.zip

Dokumen_Pembayaran.xlsm

Surat_Undangan.pdf.exe

Dokumen_Penting.js

Nama file dibuat agar terlihat seperti dokumen pekerjaan biasa. Padahal, file tersebut dapat mengandung program atau script berbahaya.

Perlu diperhatikan bahwa **ekstensi file merupakan salah satu indikator yang perlu diperiksa, tetapi bukan satu-satunya indikator keamanan**. File dengan ekstensi dokumen yang umum pun tetap dapat digunakan dalam serangan apabila berasal dari sumber yang tidak terpercaya atau memanfaatkan kerentanan tertentu.

Tanda-Tanda Tautan Mencurigakan

Sebelum mengklik tautan, perhatikan beberapa indikator berikut:

- Alamat website berbeda dari domain resmi.
- Domain menggunakan ejaan yang menyerupai organisasi resmi.
- Menggunakan URL yang sangat panjang atau tidak lazim.
- Menggunakan layanan pemendek URL tanpa konteks yang jelas.

- Pesan meminta pengguna segera melakukan login.
- Pesan meminta password atau kode OTP.
- Pesan memberikan tekanan waktu yang tidak wajar.
- Tautan tidak sesuai dengan konteks pesan.

Contohnya, sebuah organisasi menggunakan:

<https://portal.contoh.go.id>

Tetapi email justru mengarahkan pengguna ke:

<https://portal-contoh-login.example.com>

Walaupun nama **contoh** terlihat pada alamat tersebut, domain sebenarnya berbeda.

Tanda-Tanda Lampiran Mencurigakan

Beberapa indikator yang perlu diperhatikan:

- Pengirim tidak dikenal.
- Tidak sedang menunggu dokumen tersebut.
- Nama file tidak sesuai konteks.
- File menggunakan ekstensi yang tidak biasa.
- Lampiran meminta pengguna mengaktifkan *macro* atau fitur tertentu.
- Email menggunakan bahasa yang mendesak.
- Isi email tidak sesuai dengan kebiasaan komunikasi pengirim.
- File dikirim dari akun yang biasanya tidak pernah mengirim dokumen.

Cara Memeriksa Tautan

Jangan langsung mengklik tautan hanya karena tampilannya terlihat meyakinkan.

Pada komputer, pengguna dapat mengarahkan kursor ke tautan tanpa mengkliknya untuk melihat alamat tujuan yang sebenarnya.

Periksa:

Nama domain → apakah benar milik organisasi atau layanan yang dimaksud?

Jangan hanya melihat kata-kata yang ditampilkan pada tombol.

Contohnya:

Klik di sini untuk Login

Belum tentu mengarah ke:

<https://portal.organisasikita.go.id>

Karena alamat tujuan sebenarnya bisa berbeda.

Cara Menangani Lampiran

Jika menerima lampiran yang mencurigakan:

1. Jangan langsung membukanya.
2. Periksa pengirim.
3. Periksa konteks email.
4. Pastikan apakah memang sedang menunggu dokumen tersebut.
5. Konfirmasi kepada pengirim melalui saluran komunikasi

lain apabila diperlukan.

6. Jika tetap mencurigakan, laporkan kepada administrator atau tim keamanan informasi.
7. Jangan meneruskan file tersebut kepada pegawai lain sebelum dipastikan aman.

Contoh Kasus

Seorang pegawai menerima email yang mengatasnamakan bagian keuangan. Email tersebut meminta pegawai membuka dokumen pembayaran yang terlampir.

Karena nama pengirim terlihat familiar, pegawai langsung membuka lampiran.

Setelah beberapa saat, komputer menjadi lambat dan muncul aktivitas yang tidak biasa. Setelah diperiksa oleh administrator, diketahui bahwa lampiran tersebut mengandung malware.

Kesalahan utama bukan hanya karena malware berhasil dikirim, tetapi karena **lampiran dibuka tanpa melakukan verifikasi terhadap pengirim dan konteks dokumen.**

Cara Pencegahan

Organisasi dapat mengurangi risiko melalui kombinasi teknologi dan kesadaran pengguna:

- Menggunakan **email security gateway**.
- Mengaktifkan pemindaian malware pada lampiran.
- Menggunakan **sandboxing** untuk menganalisis file mencurigakan.

- Menerapkan proteksi terhadap phishing.
- Menggunakan antivirus atau EDR.
- Menerapkan kebijakan pemblokiran tipe file tertentu sesuai kebutuhan.
- Menggunakan SPF, DKIM, dan DMARC untuk meningkatkan perlindungan domain email.
- Memberikan pelatihan *Cyber Security Awareness*.
- Melakukan simulasi phishing secara berkala.
- Menyediakan mekanisme pelaporan email mencurigakan.

Tips Praktis untuk Pegawai

Gunakan prinsip sederhana:

Jangan terburu-buru membuka. Periksa sebelum percaya.

Sebelum membuka tautan atau lampiran, tanyakan:

1. **Siapa pengirimnya?**
Pastikan pesan benar-benar berasal dari orang, unit kerja, atau organisasi yang dikenal.
2. **Apakah saya memang sedang menunggu dokumen atau pesan ini?**
Jika tidak, lakukan verifikasi terlebih dahulu melalui kanal resmi sebelum membuka tautan atau lampiran.
3. **Apakah ada sesuatu yang tidak biasa?**
Perhatikan gaya bahasa, permintaan yang mendesak, alamat email pengirim, nama file, serta URL tujuan.
4. **Apakah tindakan yang diminta berisiko?**
Waspadai permintaan password, OTP, transfer uang,

perubahan rekening, atau data sensitif.

Jika masih ragu, **jangan klik dan jangan buka**. Hubungi pengirim melalui nomor telepon atau kanal komunikasi resmi yang sudah diketahui sebelumnya.

Jika Terlanjur Membuka

Kesalahan dapat terjadi. Yang paling penting adalah **segera melaporkannya**.

Jika sudah membuka tautan atau lampiran yang ternyata mencurigakan:

- Jangan panik.
- Jangan mencoba menghapus bukti atau file secara sembarangan.
- Putuskan koneksi jaringan jika terdapat indikasi perangkat telah terinfeksi dan prosedur organisasi menginstruksikannya.
- Segera hubungi administrator atau tim keamanan informasi.
- Berikan informasi mengenai email, tautan, atau file yang dibuka.
- Jika password telah dimasukkan pada halaman yang mencurigakan, segera laporkan dan lakukan pengamanan akun sesuai prosedur organisasi.

Jangan menyembunyikan kesalahan karena takut mendapatkan teguran. Semakin cepat insiden dilaporkan, semakin besar peluang organisasi membatasi dampaknya.

3.6 Sistem yang Tidak Diperbarui

Pembaruan sistem (*system update*) merupakan bagian penting dalam menjaga keamanan perangkat dan aplikasi. Sistem operasi, aplikasi, framework, library, perangkat jaringan, dan berbagai komponen teknologi dapat memiliki kerentanan keamanan yang ditemukan setelah perangkat lunak digunakan.

Sistem yang tidak diperbarui dapat tetap menggunakan versi yang memiliki kerentanan yang telah diketahui. Apabila informasi mengenai kerentanan tersebut sudah tersedia dan eksploitasi telah dibuat, penyerang dapat memanfaatkannya untuk memperoleh akses tidak sah, menjalankan kode, mencuri data, atau mengganggu layanan.

Karena itu, **patch management** merupakan bagian penting dari pengelolaan keamanan siber. Organisasi perlu mengetahui aset dan perangkat lunak yang digunakan, memantau pembaruan keamanan, melakukan pengujian yang diperlukan, kemudian menerapkan pembaruan sesuai tingkat risikonya.

Mengapa Sistem Harus Diperbarui?

Tidak semua pembaruan hanya memberikan fitur baru. Banyak pembaruan diterbitkan karena ditemukan:

- Kerentanan keamanan.
- Bug yang dapat menyebabkan sistem tidak stabil.
- Kelemahan pada mekanisme autentikasi.
- Kelemahan pada komponen jaringan.
- Masalah pada library atau komponen pihak ketiga.
- Kerentanan yang dapat dimanfaatkan untuk menjalankan

kode berbahaya.

Ketika vendor menerbitkan **security patch**, informasi mengenai kerentanan tersebut dapat diketahui oleh publik. Kondisi tersebut dapat meningkatkan perhatian penyerang terhadap sistem yang masih menggunakan versi lama.

Dengan demikian, menunda pembaruan keamanan terlalu lama dapat meningkatkan *attack surface* organisasi.

Contoh Sistem yang Perlu Diperbarui

Pengelolaan pembaruan tidak hanya berlaku untuk komputer pegawai. Organisasi perlu memperhatikan berbagai komponen, antara lain:

- Sistem operasi server.
- Sistem operasi komputer pengguna.
- Web server.
- Database server.
- Aplikasi web.
- Framework dan library.
- Browser.
- Antivirus dan EDR.
- Firewall.
- Router dan switch.
- Access point.
- Perangkat VPN.
- Hypervisor.

- Aplikasi cloud.
- Firmware perangkat.

Komponen pihak ketiga juga perlu diperhatikan karena aplikasi organisasi dapat menggunakan banyak library dan dependency yang berasal dari luar organisasi.

Contoh Kasus

Sebuah organisasi memiliki aplikasi web yang berjalan pada server dengan sistem operasi dan framework yang sudah lama tidak diperbarui.

Vendor telah menerbitkan pembaruan keamanan untuk memperbaiki kerentanan pada framework tersebut. Namun, administrator menunda pembaruan karena khawatir aplikasi mengalami gangguan.

Beberapa waktu kemudian, kerentanan tersebut dimanfaatkan oleh penyerang. Penyerang berhasil memperoleh akses ke aplikasi dan kemudian mencoba mendapatkan akses lebih jauh ke sistem organisasi.

Dalam kasus tersebut, **kerentanan teknis sebenarnya sudah diketahui dan pembaruan sudah tersedia**, tetapi risiko tetap muncul karena pembaruan tidak segera diterapkan.

Dampak

Sistem yang tidak diperbarui dapat meningkatkan risiko:

- Eksploitasi kerentanan yang telah diketahui.
- Akses tidak sah.
- Pencurian data.

- Infeksi malware.
- Ransomware.
- Pengambilalihan server.
- Gangguan layanan.
- Perubahan atau penghapusan data.
- Penyebaran serangan ke sistem lain.
- Pelanggaran terhadap kebijakan keamanan.
- Kerugian finansial dan reputasi.

Risikonya menjadi semakin besar apabila perangkat yang tidak diperbarui dapat diakses langsung dari internet atau memiliki akses ke sistem internal yang penting.

Mengapa Pembaruan Sering Ditunda?

Dalam praktiknya, organisasi dapat menunda pembaruan karena beberapa alasan:

- Takut aplikasi tidak kompatibel.
- Takut menyebabkan downtime.
- Tidak mengetahui bahwa pembaruan keamanan tersedia.
- Tidak memiliki inventaris aset yang lengkap.
- Tidak memiliki jadwal patching.
- Kekurangan sumber daya administrator.
- Tidak memiliki lingkungan pengujian.
- Menganggap sistem lama masih aman karena selama ini

tidak pernah mengalami masalah.

Alasan tersebut memang perlu dipertimbangkan, tetapi **menunda patch tanpa melakukan mitigasi juga memiliki risiko.**

Jika pembaruan belum dapat dilakukan, organisasi sebaiknya menerapkan mitigasi yang sesuai, misalnya membatasi akses, melakukan segmentasi jaringan, meningkatkan monitoring, atau menggunakan mekanisme perlindungan tambahan.

Patch Management

Patch management adalah proses untuk mengidentifikasi, memperoleh, menguji, menerapkan, dan memverifikasi pembaruan perangkat lunak atau firmware.

Proses sederhana dapat dilakukan melalui tahapan:

1. **Inventarisasi**

Mengetahui perangkat keras, sistem operasi, aplikasi, dan versi yang digunakan.

2. **Monitoring**

Memantau informasi pembaruan dan security advisory dari vendor.

3. **Penilaian Risiko**

Menentukan tingkat urgensi pembaruan berdasarkan tingkat kerentanan dan pentingnya aset.

4. **Pengujian**

Menguji pembaruan pada lingkungan yang sesuai sebelum diterapkan pada sistem produksi apabila diperlukan.

5. Implementasi

Menerapkan pembaruan sesuai jadwal dan prosedur organisasi.

6. Verifikasi

Memastikan sistem tetap berfungsi dan pembaruan telah berhasil diterapkan.

7. Dokumentasi

Mencatat perangkat yang telah diperbarui, waktu pembaruan, versi, dan hasil implementasi.

Prioritas Pembaruan

Tidak semua sistem harus diperlakukan dengan prioritas yang sama. Organisasi dapat mempertimbangkan beberapa faktor:

- Tingkat keparahan kerentanan.
- Apakah kerentanan sudah dieksploitasi secara aktif.
- Apakah perangkat dapat diakses dari internet.
- Nilai dan sensitivitas data.
- Tingkat kepentingan sistem terhadap operasional.
- Kemudahan eksploitasi.
- Ketersediaan patch atau mitigasi.

Sistem yang memiliki kerentanan kritis, terhubung ke internet, dan menangani data penting sebaiknya mendapatkan prioritas tinggi.

Peran Administrator

Administrator memiliki tanggung jawab penting dalam menjaga sistem tetap diperbarui.

Beberapa praktik yang dapat dilakukan:

- Membuat inventaris aset.
- Mengetahui versi sistem dan aplikasi.
- Berlangganan informasi keamanan dari vendor.
- Menetapkan prosedur patch management.
- Membuat jadwal pembaruan.
- Melakukan pengujian sebelum pembaruan sistem kritis.
- Membuat backup sebelum perubahan besar.
- Mendokumentasikan setiap pembaruan.
- Memastikan sistem yang sudah tidak didukung vendor segera ditangani.

Sistem yang sudah mencapai **End-of-Life (EOL)** juga perlu mendapat perhatian khusus karena vendor mungkin sudah tidak menyediakan pembaruan keamanan secara rutin.

Peran Pegawai

Pegawai juga memiliki peran dalam menjaga perangkat yang digunakan sehari-hari.

Beberapa kebiasaan yang perlu dilakukan:

- Jangan terus menunda notifikasi pembaruan keamanan.
- Restart komputer apabila diperlukan untuk menyelesaikan pembaruan.
- Jangan menonaktifkan mekanisme pembaruan tanpa

alasan yang sah.

- Jangan menggunakan aplikasi yang sudah tidak didukung.
- Laporkan apabila perangkat terus menampilkan kegagalan pembaruan.
- Jangan menginstal pembaruan dari website yang tidak resmi.
- Ikuti prosedur organisasi terkait pembaruan perangkat.

Pegawai juga perlu memahami bahwa **update bukan sekadar menambah fitur baru**. Pembaruan dapat memperbaiki kelemahan yang berpotensi dimanfaatkan oleh penyerang.

Tips Praktis

Gunakan prinsip sederhana:

Kenali aset → Ketahui versinya → Pantau pembaruan → Prioritaskan risiko → Terapkan patch → Verifikasi.

Untuk organisasi, pembaruan sebaiknya tidak dilakukan secara sporadis hanya ketika terjadi masalah. Pembaruan harus menjadi bagian dari **proses pengelolaan keamanan yang rutin dan terdokumentasi**.

Kesimpulan

Sistem yang tidak diperbarui dapat menjadi titik lemah dalam pertahanan keamanan organisasi. Kerentanan yang sebenarnya sudah diketahui dan telah memiliki patch tetap dapat dimanfaatkan apabila organisasi tidak menerapkan pembaruan secara tepat waktu.

Namun, patch management bukan berarti melakukan semua pembaruan secara sembarangan. Pembaruan perlu dikelola berdasarkan **risiko, kritikalitas sistem, kompatibilitas, dan kebutuhan operasional**.

Dengan inventaris aset yang baik, monitoring security advisory, prioritas berdasarkan risiko, pengujian, serta dokumentasi yang konsisten, organisasi dapat mengurangi kemungkinan sistem menjadi target eksploitasi akibat penggunaan perangkat lunak yang sudah rentan.

3.7 Hak Akses yang Berlebihan

Hak akses yang berlebihan (*excessive access privileges*) terjadi ketika pengguna, aplikasi, perangkat, atau pihak ketiga memperoleh hak akses yang lebih luas daripada yang sebenarnya diperlukan untuk menjalankan tugasnya.

Dalam keamanan informasi, akses seharusnya diberikan berdasarkan prinsip **Least Privilege**, yaitu setiap pengguna hanya memperoleh hak akses minimum yang diperlukan untuk melaksanakan pekerjaannya. Prinsip ini bertujuan membatasi dampak apabila akun pengguna berhasil dikompromikan atau digunakan secara tidak semestinya.

Hak akses yang berlebihan sering kali tidak langsung terlihat sebagai masalah keamanan. Pada awalnya akses tersebut mungkin diberikan untuk memudahkan pekerjaan. Namun, ketika akun tersebut diretas, hak akses yang terlalu luas dapat memberikan penyerang kesempatan untuk mengakses lebih banyak sistem dan data.

Prinsip Least Privilege

Prinsip **Least Privilege** berarti pengguna atau proses hanya diberikan hak yang diperlukan untuk melakukan tugas tertentu.

Sebagai contoh, seorang pegawai bagian administrasi mungkin hanya membutuhkan:

Membaca data administrasi

Membuat dokumen

Mengubah data sesuai kewenangan

Pegawai tersebut tidak seharusnya otomatis memperoleh:

Menghapus database

Mengubah konfigurasi server

Membuat akun administrator

Mengakses seluruh data organisasi

Dengan membatasi hak akses, organisasi dapat mengurangi dampak apabila akun tersebut berhasil disalahgunakan.

Contoh Hak Akses yang Berlebihan

Beberapa contoh yang sering ditemukan antara lain:

- Pegawai biasa memiliki hak administrator pada komputer.
- Pengguna dapat mengakses folder yang tidak berhubungan dengan pekerjaannya.
- Semua pegawai memiliki akses ke database produksi.
- Akun aplikasi memiliki hak akses database terlalu luas.
- Vendor memiliki akses penuh ke server meskipun hanya membutuhkan akses terbatas.

- Akun administrator digunakan untuk pekerjaan sehari-hari.
- Mantan pegawai masih memiliki akun yang aktif.
- Satu akun digunakan bersama oleh banyak orang.

Masalah bukan hanya terletak pada jumlah pengguna yang memiliki akses, tetapi juga pada **seberapa luas akses yang diberikan dan apakah akses tersebut masih diperlukan.**

Contoh Kasus

Seorang pegawai bagian administrasi diberikan akses ke folder bersama yang berisi berbagai dokumen organisasi. Karena pengaturan permission terlalu luas, pegawai tersebut tidak hanya dapat membaca dokumen administrasi, tetapi juga dapat mengakses dokumen keuangan dan dokumen yang berisi informasi sensitif.

Beberapa bulan kemudian, akun pegawai tersebut berhasil dicuri melalui phishing.

Pelaku kemudian menggunakan akun tersebut untuk mengakses berbagai dokumen yang sebenarnya tidak diperlukan oleh pegawai tersebut.

Dalam kasus ini, phishing merupakan **jalan masuk**, sedangkan hak akses yang berlebihan menyebabkan **dampak serangan menjadi lebih luas.**

Dampak

Hak akses yang berlebihan dapat meningkatkan risiko:

- Kebocoran data.
- Perubahan data tanpa izin.

- Penghapusan data.
- Penyalahgunaan sistem.
- Pengambilalihan sumber daya organisasi.
- Pergerakan penyerang ke sistem lain (*lateral movement*).
- Penyebaran malware atau ransomware.
- Penyalahgunaan akun administrator.
- Meningkatnya dampak ketika sebuah akun dikompromikan.

Semakin besar hak akses sebuah akun, semakin besar pula potensi dampak apabila akun tersebut jatuh ke tangan yang salah.

Penyebab Hak Akses Berlebihan

Beberapa penyebab yang umum antara lain:

- Hak akses diberikan berdasarkan kenyamanan, bukan kebutuhan pekerjaan.
- Tidak ada proses review akses secara berkala.
- Pegawai berpindah jabatan tetapi hak akses lama tidak dicabut.
- Akun mantan pegawai masih aktif.
- Vendor diberikan akses terlalu luas.
- Penggunaan akun administrator untuk aktivitas sehari-hari.
- Tidak adanya dokumentasi hak akses.
- Tidak adanya pemisahan tugas.

- Administrator lupa mencabut akses yang sudah tidak diperlukan.

Masalah ini sering berkembang secara bertahap. Pengguna awalnya memperoleh satu akses tambahan, kemudian beberapa akses lainnya ditambahkan tanpa pernah dilakukan evaluasi kembali.

Cara Pencegahan

Organisasi dapat mengurangi risiko hak akses berlebihan dengan menerapkan **Access Control** yang terstruktur.

Beberapa langkah yang dapat dilakukan:

- Terapkan prinsip **Least Privilege**.
- Berikan akses berdasarkan kebutuhan pekerjaan.
- Gunakan **Role-Based Access Control (RBAC)** apabila sesuai.
- Lakukan review hak akses secara berkala.
- Cabut akses yang sudah tidak diperlukan.
- Nonaktifkan akun pegawai yang sudah tidak bekerja.
- Perbarui hak akses ketika pegawai berpindah jabatan.
- Batasi akses vendor dan pihak ketiga.
- Pisahkan akun administrator dan akun pengguna biasa.
- Terapkan **Multi-Factor Authentication (MFA)** pada akun penting.
- Catat dan monitor aktivitas akun dengan hak istimewa.
- Terapkan *separation of duties* untuk proses yang kritis.

- **Joiner, Mover, dan Leaver**

Pengelolaan hak akses sebaiknya mengikuti perubahan status pengguna.

1. **Joiner**

Ketika pegawai baru bergabung, akses diberikan berdasarkan posisi, peran, dan kebutuhan pekerjaannya.

2. **Mover**

Ketika pegawai berpindah jabatan atau unit kerja, hak akses lama dievaluasi lalu disesuaikan dengan tanggung jawab baru.

3. **Leaver**

Ketika pegawai meninggalkan organisasi, seluruh akses yang tidak lagi diperlukan harus segera dicabut atau dinonaktifkan.

Pendekatan ini membantu mencegah **privilege accumulation**, yaitu kondisi ketika hak akses pengguna terus bertambah sepanjang masa kerja tetapi tidak pernah dikurangi.

Peran Administrator

Administrator perlu melakukan pemeriksaan secara berkala terhadap:

- Siapa yang memiliki akses.
- Sistem apa yang dapat diakses.
- Tingkat hak akses yang dimiliki.
- Alasan pengguna membutuhkan akses tersebut.
- Kapan akses terakhir digunakan.
- Apakah akses masih diperlukan.

Pertanyaan sederhana yang perlu digunakan adalah:

"Apakah pengguna ini masih membutuhkan akses tersebut untuk pekerjaannya?"

Jika jawabannya tidak, akses sebaiknya dicabut.

Tips Praktis untuk Pegawai

Pegawai juga perlu memahami bahwa memiliki akses bukan berarti boleh menggunakan seluruh data yang dapat dibuka.

Beberapa hal yang perlu diperhatikan:

- Gunakan akses hanya untuk pekerjaan.
- Jangan membuka data yang tidak berhubungan dengan tugas.
- Jangan menggunakan akun orang lain.
- Jangan meminta hak administrator hanya untuk kenyamanan.
- Jangan membagikan akun.
- Segera laporkan apabila menemukan akses yang seharusnya tidak dimiliki.
- Ketika berpindah jabatan, pastikan hak akses disesuaikan dengan tanggung jawab baru.

Akses yang diberikan kepada pengguna adalah amanah dan harus digunakan sesuai kewenangan.

Kesimpulan

Hak akses yang berlebihan dapat memperbesar dampak sebuah insiden keamanan. Apabila sebuah akun dengan hak

akses luas berhasil dikompromikan, penyerang dapat memperoleh akses terhadap lebih banyak sistem dan data.

Karena itu, organisasi perlu menerapkan prinsip **Least Privilege**, melakukan review akses secara berkala, mengelola perubahan hak akses berdasarkan siklus kerja pegawai, dan memantau akun dengan hak istimewa.

Keamanan yang baik bukan berarti memberikan akses sebanyak mungkin, tetapi **memberikan akses yang tepat kepada orang yang tepat untuk kebutuhan yang tepat**.

3.8 Salah Konfigurasi Sistem

Salah konfigurasi sistem (*security misconfiguration*) adalah kondisi ketika sistem, aplikasi, server, perangkat jaringan, layanan cloud, atau komponen teknologi lainnya dikonfigurasi dengan pengaturan yang tidak sesuai dengan kebutuhan keamanan. Kesalahan konfigurasi dapat terjadi karena fitur keamanan tidak diaktifkan, akses diberikan terlalu luas, layanan yang tidak diperlukan tetap aktif, atau konfigurasi bawaan (*default configuration*) tidak pernah diubah.

OWASP memasukkan **Security Misconfiguration** sebagai salah satu risiko utama pada aplikasi web. Kondisi tersebut dapat terjadi ketika fitur keamanan tidak diterapkan dengan benar, akun atau password bawaan masih digunakan, pesan error menampilkan informasi sensitif, atau sistem menggunakan konfigurasi yang tidak aman. (owasp.org)

Salah konfigurasi tidak selalu berarti administrator melakukan kesalahan secara langsung. Lingkungan teknologi yang semakin kompleks membuat konfigurasi keamanan perlu

diperiksa secara berkala karena perubahan aplikasi, jaringan, pengguna, dan kebutuhan organisasi dapat menyebabkan konfigurasi lama tidak lagi sesuai.

Contoh Salah Konfigurasi Sistem

Beberapa contoh salah konfigurasi yang umum antara lain:

- Menggunakan username dan password bawaan.
- Membiarkan akun administrator default tetap aktif.
- Membuka port atau layanan yang tidak diperlukan.
- Memberikan hak akses terlalu luas.
- Menampilkan directory listing pada web server.
- Menyimpan file konfigurasi sensitif di web root.
- Menampilkan pesan error yang mengungkap informasi teknis.
- Mengaktifkan layanan administrasi langsung dari internet tanpa perlindungan yang memadai.
- Tidak menerapkan HTTPS pada layanan yang membutuhkan perlindungan komunikasi.
- Menggunakan konfigurasi firewall yang terlalu longgar.
- Membiarkan perangkat menggunakan konfigurasi default.
- Tidak mengaktifkan logging dan monitoring.
- Membiarkan sistem menggunakan protokol atau algoritma keamanan yang sudah tidak direkomendasikan.

Mengapa Salah Konfigurasi Berbahaya?

Kerentanan aplikasi tidak selalu berasal dari kesalahan kode. Sistem yang sebenarnya memiliki perangkat lunak yang aman tetap dapat menjadi rentan apabila administrator mengonfigurasinya secara tidak tepat.

Sebagai contoh, sebuah server memiliki aplikasi web yang sudah diperbarui dan tidak memiliki kerentanan yang diketahui. Namun, administrator secara tidak sengaja membuka layanan administrasi server ke internet tanpa pembatasan akses yang memadai.

Dalam kondisi tersebut, **konfigurasi yang salah dapat menjadi jalan masuk bagi penyerang meskipun aplikasi utamanya sudah diperbarui.**

Contoh Kasus

Sebuah organisasi menggunakan server web untuk menyediakan layanan publik. Pada server tersebut terdapat direktori yang berisi file backup aplikasi.

Karena konfigurasi web server tidak membatasi akses terhadap direktori tersebut, isi direktori dapat ditampilkan kepada pengguna melalui browser.

Di dalam direktori tersebut terdapat file:

```
backup/  
├─ database-backup.sql  
├─ aplikasi-backup.zip  
└─ config.php.bak
```

Jika file-file tersebut dapat diunduh oleh pihak luar, penyerang berpotensi memperoleh informasi sensitif seperti

struktur database, konfigurasi aplikasi, atau kredensial yang tersimpan di dalam file.

Masalah tersebut bukan semata-mata karena aplikasi memiliki kerentanan, tetapi karena **konfigurasi server memungkinkan file yang seharusnya bersifat internal diakses dari luar.**

Dampak

Salah konfigurasi sistem dapat menyebabkan:

- Kebocoran data.
- Akses tidak sah.
- Pengungkapan informasi teknis.
- Pencurian kredensial.
- Pengambilalihan sistem.
- Penyebaran malware.
- Perubahan atau penghapusan data.
- Gangguan layanan.
- Peningkatan *attack surface*.
- Pelanggaran kebijakan keamanan.
- Kerugian finansial dan reputasi.

Dampaknya sangat bergantung pada sistem yang salah dikonfigurasi. Kesalahan kecil pada server biasa mungkin memiliki dampak terbatas, sedangkan kesalahan konfigurasi pada database, firewall, cloud storage, atau sistem administrator dapat menimbulkan risiko yang jauh lebih besar.

Security Misconfiguration pada Aplikasi Web

Pada aplikasi web, beberapa kesalahan konfigurasi yang perlu diperhatikan antara lain:

1. Default Configuration

Sistem masih menggunakan konfigurasi bawaan vendor.

2. Default Account

Akun administrator bawaan masih aktif dan menggunakan kredensial yang diketahui atau mudah ditebak.

3. Directory Listing

Web server menampilkan daftar file dan direktori kepada pengguna.

4. Informasi Error Berlebihan

Pesan error menampilkan informasi seperti:

Database server

Username database

Path aplikasi

Versi framework

Stack trace

Konfigurasi sistem

Informasi tersebut dapat membantu penyerang memahami lingkungan target.

5. Layanan Tidak Diperlukan

Service atau port yang tidak dibutuhkan tetap aktif sehingga menambah *attack surface*.

6. Hak Akses File Terlalu Longgar

File atau direktori diberikan permission yang memungkinkan pengguna atau proses yang tidak seharusnya melakukan perubahan.

OWASP merekomendasikan agar instalasi aplikasi tidak menyertakan fitur, framework, komponen, akun, maupun layanan yang tidak diperlukan dan agar konfigurasi keamanan diterapkan secara konsisten pada seluruh lingkungan aplikasi. (owasp.org)

Cara Pencegahan

Organisasi dapat mengurangi risiko salah konfigurasi dengan menerapkan **secure configuration management**.

Beberapa langkah yang dapat dilakukan:

- Ubah seluruh password default.
- Nonaktifkan akun default yang tidak diperlukan.
- Nonaktifkan service dan port yang tidak digunakan.
- Terapkan firewall sesuai kebutuhan.
- Batasi akses administrasi.
- Terapkan prinsip **Least Privilege**.
- Nonaktifkan directory listing.
- Jangan menyimpan file backup di lokasi yang dapat diakses publik.
- Jangan menampilkan informasi teknis pada halaman

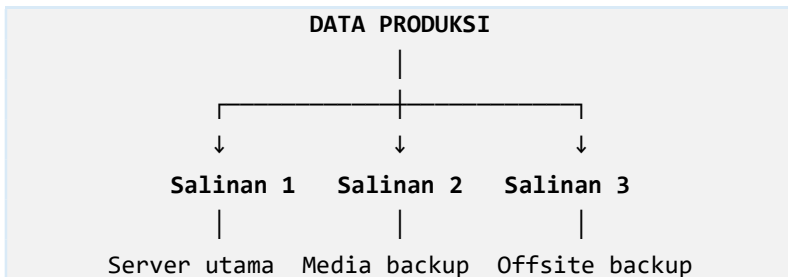
error produksi.

- Terapkan HTTPS.
- Aktifkan logging dan monitoring.
- Gunakan konfigurasi standar yang telah disetujui organisasi.
- Lakukan pemeriksaan konfigurasi secara berkala.
- Dokumentasikan perubahan konfigurasi.
- Lakukan *configuration review* setelah perubahan besar.
- Gunakan otomatisasi konfigurasi apabila sesuai dengan lingkungan organisasi.

Configuration Baseline

Organisasi sebaiknya memiliki **configuration baseline**, yaitu konfigurasi standar yang telah ditentukan dan disetujui untuk jenis sistem tertentu.

Contohnya:



Dengan adanya baseline, administrator tidak perlu menentukan konfigurasi keamanan dari awal untuk setiap server. Baseline juga dapat digunakan sebagai acuan ketika melakukan

audit atau pemeriksaan keamanan.

Pemeriksaan Konfigurasi

Pemeriksaan konfigurasi sebaiknya dilakukan secara berkala dan setelah terjadi perubahan besar pada sistem.

Hal-hal yang dapat diperiksa antara lain:

- Apakah terdapat akun default?
- Apakah terdapat port yang tidak diperlukan?
- Apakah layanan administrasi dapat diakses dari internet?
- Apakah file sensitif dapat diakses publik?
- Apakah permission file sudah sesuai?
- Apakah logging aktif?
- Apakah konfigurasi firewall sesuai kebijakan?
- Apakah sistem menggunakan konfigurasi keamanan terbaru?
- Apakah perubahan konfigurasi sudah terdokumentasi?

Tips Praktis untuk Pegawai

Kesalahan konfigurasi tidak hanya terjadi pada server. Pengguna biasa juga dapat melakukan konfigurasi yang meningkatkan risiko.

Beberapa kebiasaan yang perlu diterapkan:

- Jangan mengubah pengaturan keamanan perangkat tanpa izin.
- Jangan menonaktifkan antivirus atau firewall untuk mengatasi masalah aplikasi tanpa koordinasi dengan

administrator.

- Jangan menginstal service atau aplikasi yang tidak diperlukan.
- Jangan mengubah konfigurasi jaringan secara sembarangan.
- Laporkan apabila menemukan perangkat yang menggunakan password default.
- Laporkan layanan atau aplikasi yang dapat diakses tanpa autentikasi.
- Ikuti standar konfigurasi yang telah ditetapkan organisasi.

Kesimpulan

Salah konfigurasi merupakan salah satu penyebab insiden keamanan yang sering kali dapat dicegah melalui pengelolaan konfigurasi yang baik.

Keamanan sistem tidak cukup hanya dengan **menggunakan perangkat keamanan dan memperbarui software**. Konfigurasi setiap komponen juga harus diperiksa untuk memastikan bahwa fitur keamanan benar-benar diterapkan.

Prinsip sederhananya adalah:

Konfigurasi yang aman → attack surface lebih kecil → risiko lebih rendah.

Organisasi perlu memiliki standar konfigurasi, melakukan pemeriksaan secara berkala, mendokumentasikan perubahan, dan memastikan setiap sistem dikonfigurasi sesuai dengan kebutuhan keamanan.

3.9 Kurangnya Backup Data

Backup data adalah proses membuat salinan data yang dapat digunakan untuk memulihkan informasi ketika data asli hilang, rusak, terhapus, terenkripsi, atau tidak dapat diakses. Backup merupakan salah satu komponen penting dalam menjaga **ketersediaan (*availability*)** informasi dan mendukung proses pemulihan ketika terjadi insiden keamanan.

Kurangnya backup atau backup yang tidak dikelola dengan baik dapat memperbesar dampak insiden. Ketika ransomware mengenkripsi data produksi, misalnya, organisasi yang memiliki backup yang baik masih memiliki peluang untuk memulihkan data tanpa harus bergantung sepenuhnya pada sistem yang telah terkena serangan.

Namun, **memiliki backup tidak otomatis berarti organisasi aman**. Backup juga harus dilindungi dari penghapusan, manipulasi, ransomware, dan akses tidak sah.

Mengapa Backup Penting?

Data organisasi dapat hilang atau tidak dapat digunakan karena berbagai sebab, antara lain:

- Ransomware.
- Malware.
- Kesalahan manusia.
- Penghapusan data secara tidak sengaja.
- Kerusakan perangkat keras.
- Kegagalan sistem.

- Kesalahan konfigurasi.
- Gangguan infrastruktur.
- Bencana seperti kebakaran atau banjir.
- Serangan terhadap server atau database.

Tanpa backup yang dapat dipulihkan, organisasi mungkin harus membangun kembali data dari awal. Pada sistem yang menyimpan data penting selama bertahun-tahun, kondisi tersebut dapat menyebabkan gangguan operasional yang serius.

Contoh Kasus

Sebuah organisasi memiliki server yang menyimpan database aplikasi pelayanan. Data tersebut hanya disimpan pada server produksi dan tidak memiliki backup yang teruji.

Suatu hari server terkena ransomware. Database dan file aplikasi terenkripsi sehingga aplikasi tidak dapat digunakan.

Administrator memiliki beberapa pilihan untuk melakukan pemulihan, tetapi tidak memiliki salinan data yang dapat digunakan.

Akibatnya, organisasi tidak hanya menghadapi masalah keamanan, tetapi juga mengalami **kehilangan data dan gangguan layanan**.

Bandingkan dengan kondisi ketika organisasi memiliki backup yang terpisah dan dapat dipulihkan. Setelah sistem yang terinfeksi dibersihkan, organisasi dapat melakukan recovery dari backup yang masih aman.

Backup Bukan Sekadar Copy File

Kesalahan yang cukup umum adalah menganggap backup

hanya berarti menyalin file ke tempat lain.

Contohnya:

Server Produksi

↓

Backup Server

Jika backup server tersebut selalu terhubung dan memiliki kredensial yang sama dengan server produksi, ransomware yang berhasil menguasai server produksi dapat berpotensi mengakses dan mengenkripsi backup tersebut.

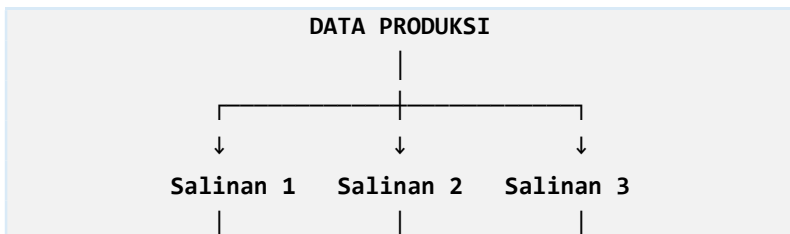
Karena itu, backup perlu dirancang dengan mempertimbangkan **keamanan, pemisahan, dan kemampuan pemulihan**.

Prinsip 3-2-1 Backup

Salah satu prinsip backup yang banyak digunakan adalah **3-2-1 backup strategy**:

- **3** salinan data.
- **2** jenis media penyimpanan yang berbeda.
- **1** salinan berada di lokasi yang berbeda (*offsite*).

Contoh:



Server utama Media backup Offsite backup

Strategi tersebut membantu mengurangi risiko apabila satu lokasi atau media mengalami kerusakan atau serangan.

Namun, kebutuhan organisasi dapat berbeda. Untuk sistem yang sangat kritis, organisasi dapat membutuhkan mekanisme tambahan seperti backup immutable, offline backup, atau replikasi ke lokasi pemulihan.

RPO dan RTO

Backup juga perlu dikaitkan dengan dua konsep penting:

Recovery Point Objective (RPO)

RPO menentukan seberapa banyak kehilangan data yang masih dapat diterima ketika terjadi pemulihan.

Misalnya:

RPO = 4 jam

Artinya organisasi menetapkan bahwa kehilangan data maksimal sekitar empat jam masih dapat diterima.

Recovery Time Objective (RTO)

RTO menentukan berapa lama waktu yang dapat ditoleransi sebelum layanan harus kembali tersedia.

Misalnya:

RTO = 4 jam

Artinya organisasi menargetkan layanan dapat dipulihkan dalam waktu maksimal sekitar empat jam.

RPO dan RTO membantu organisasi menentukan **seberapa**

sering backup harus dilakukan dan seberapa cepat proses recovery harus tersedia.

Backup yang Tidak Pernah Diuji

Salah satu kesalahan paling serius adalah memiliki backup tetapi **tidak pernah melakukan restore test.**

Backup dapat gagal dipulihkan karena:

- File backup rusak.
- Media penyimpanan mengalami kerusakan.
- Password atau encryption key hilang.
- Proses backup sebenarnya gagal.
- Backup tidak lengkap.
- Database backup tidak konsisten.
- Versi aplikasi tidak kompatibel.
- Tidak ada dokumentasi prosedur recovery.

Karena itu, organisasi perlu melakukan **uji pemulihan (restore test) secara berkala.**

Prinsipnya:

Backup belum dapat dianggap berhasil sampai proses restore berhasil dilakukan.

- **Backup dan Ransomware**

Ransomware merupakan salah satu alasan penting mengapa backup harus dirancang secara aman.

Jika backup selalu tersedia secara online dan dapat ditulis oleh sistem produksi, ransomware dapat mencoba menyerang

backup tersebut.

Untuk mengurangi risiko, organisasi dapat mempertimbangkan:

- **Offline backup.**
- **Immutable backup.**
- Backup dengan kredensial terpisah.
- Pembatasan akses terhadap sistem backup.
- MFA untuk administrasi backup.
- Backup ke lokasi berbeda.
- Monitoring aktivitas backup.
- Retensi beberapa versi backup.
- Pengujian restore secara berkala.

CISA juga merekomendasikan agar organisasi melakukan backup data secara rutin dan menyimpan backup secara terpisah sehingga tidak mudah terkena dampak ransomware.

Kesalahan Umum dalam Backup

Beberapa kesalahan yang sering terjadi antara lain:

1. Tidak melakukan backup

Data hanya berada pada sistem produksi.

2. Backup berada pada server yang sama

Jika server mengalami kerusakan atau serangan, backup ikut hilang.

3. Backup selalu terhubung ke jaringan

Backup dapat menjadi target ransomware.

4. Tidak ada monitoring

Backup gagal tetapi administrator tidak mengetahui kegagalan tersebut.

5. Tidak pernah melakukan restore test

Organisasi baru mengetahui backup bermasalah ketika sudah terjadi insiden.

6. Tidak memiliki retensi

Backup lama terus ditimpa sehingga tidak tersedia versi data dari periode sebelumnya.

7. Backup tidak dilindungi

Siapa pun yang memiliki akses ke sistem dapat menghapus atau memodifikasi backup.

Cara Pencegahan

Organisasi sebaiknya memiliki kebijakan backup yang mencakup:

- Data apa yang harus dibackup.
- Seberapa sering backup dilakukan.
- Berapa lama backup disimpan.
- Di mana backup disimpan.
- Siapa yang memiliki akses.
- Bagaimana backup dilindungi.
- Bagaimana proses restore dilakukan.

- Siapa yang bertanggung jawab ketika terjadi kegagalan.
- Kapan restore test dilakukan.

Backup juga perlu dimonitor sehingga kegagalan proses backup dapat segera diketahui.

Peran Pegawai

Pegawai juga memiliki peran dalam menjaga data agar dapat dipulihkan.

Beberapa kebiasaan yang perlu diterapkan:

- Simpan dokumen pekerjaan pada lokasi yang telah ditentukan organisasi.
- Jangan menyimpan satu-satunya salinan dokumen penting pada komputer pribadi.
- Jangan menghapus data organisasi tanpa prosedur.
- Jangan menonaktifkan software backup.
- Laporkan jika menemukan file penting yang tidak dapat diakses.
- Ikuti prosedur penyimpanan data organisasi.

Kesimpulan

Kurangnya backup dapat mengubah sebuah insiden keamanan menjadi **krisis operasional**. Ketika data rusak, terenkripsi, atau hilang, organisasi membutuhkan salinan yang dapat digunakan untuk melakukan pemulihan.

Backup yang baik bukan hanya tentang membuat salinan data, tetapi juga memastikan bahwa backup tersebut:

dibuat → dilindungi → dipantau → disimpan dengan aman → dan dapat dipulihkan.

Organisasi perlu menentukan kebutuhan RPO dan RTO, menerapkan strategi backup yang sesuai, melindungi backup dari ransomware, serta melakukan restore test secara berkala.

Dengan demikian, backup tidak hanya menjadi sarana penyimpanan cadangan, tetapi menjadi bagian penting dari **Business Continuity dan Incident Recovery**.

3.10 Kurangnya Kesadaran Keamanan Siber

Kesadaran keamanan siber (*cybersecurity awareness*) merupakan kemampuan individu untuk memahami risiko keamanan informasi, mengenali tindakan yang dapat membahayakan organisasi, serta mengambil keputusan yang sesuai ketika menghadapi ancaman siber.

Kurangnya kesadaran keamanan siber dapat menjadi salah satu penyebab terjadinya insiden karena pengguna sering menjadi pihak yang berinteraksi langsung dengan email, aplikasi, perangkat, data, dan sistem organisasi. Teknologi keamanan dapat membantu mengurangi risiko, tetapi keputusan pengguna tetap memiliki pengaruh besar terhadap keamanan organisasi.

NIST menekankan bahwa program pembelajaran keamanan siber tidak hanya bertujuan meningkatkan pengetahuan, tetapi juga mendorong perubahan perilaku dan membangun budaya keamanan dalam organisasi.

Mengapa Kesadaran Keamanan Siber Penting?

Seorang pengguna mungkin telah memiliki akses terhadap sistem dan aplikasi yang dilindungi oleh berbagai mekanisme

keamanan. Namun, pengguna tersebut tetap dapat melakukan tindakan yang meningkatkan risiko, misalnya:

- Membuka email phishing.
- Mengklik tautan mencurigakan.
- Membuka lampiran yang tidak dikenal.
- Menggunakan password yang sama pada beberapa layanan.
- Membagikan password.
- Mengabaikan pembaruan keamanan.
- Menggunakan perangkat USB yang tidak dikenal.
- Mengirim data sensitif kepada penerima yang salah.
- Menginstal aplikasi dari sumber yang tidak terpercaya.
- Mengabaikan peringatan keamanan.

Hal tersebut menunjukkan bahwa **keamanan siber bukan hanya masalah teknologi, tetapi juga masalah perilaku.**

Perbedaan Awareness dan Training

Keduanya sering dianggap sama, padahal memiliki tujuan yang berbeda.

Security Awareness berfokus pada membuat seseorang menyadari:

"Apa risikonya dan mengapa saya harus peduli?"

Sedangkan **Security Training** lebih berfokus pada:

"Bagaimana saya melakukan pekerjaan dengan cara yang aman?"

Sebagai contoh:

Awareness:

Pegawai memahami bahwa email phishing dapat digunakan untuk mencuri kredensial.

Training:

Pegawai mengetahui cara memeriksa alamat pengirim, URL, lampiran, dan bagaimana melaporkan email yang mencurigakan.

Keduanya perlu berjalan bersama agar pengetahuan dapat berubah menjadi perilaku yang aman.

Contoh Kurangnya Kesadaran

Seorang pegawai menerima email yang mengatasnamakan administrator sistem. Email tersebut meminta pegawai segera melakukan login karena akun akan dinonaktifkan.

Pegawai tidak memeriksa alamat pengirim dan langsung mengikuti instruksi tersebut.

Apabila pegawai memiliki kesadaran keamanan yang baik, ia seharusnya berhenti sejenak dan mempertanyakan:

- Apakah email tersebut benar-benar berasal dari administrator?
- Apakah saya memang sedang diminta melakukan tindakan tersebut?
- Apakah alamat website yang diberikan benar?
- Apakah permintaan tersebut sesuai prosedur?
- Apakah perlu melakukan konfirmasi melalui kanal lain?

Perbedaan antara kedua perilaku tersebut dapat menentukan apakah serangan berhasil atau dapat dihentikan.

Dampak Kurangnya Kesadaran

Kurangnya kesadaran keamanan siber dapat menyebabkan:

- Meningkatnya keberhasilan phishing.
- Kebocoran password.
- Infeksi malware.
- Penyebaran ransomware.
- Kebocoran data.
- Penggunaan perangkat secara tidak aman.
- Salah pengelolaan informasi.
- Kesalahan konfigurasi.
- Pelanggaran kebijakan keamanan.
- Meningkatnya dampak insiden.

Masalahnya bukan hanya ketika pengguna melakukan kesalahan, tetapi juga ketika pengguna **tidak mengetahui bahwa tindakannya berisiko**.

Faktor yang Menyebabkan Kurangnya Kesadaran

Beberapa faktor yang dapat menyebabkan rendahnya kesadaran keamanan antara lain:

- Tidak pernah mendapatkan edukasi keamanan.
- Pelatihan hanya dilakukan sekali.
- Materi terlalu teknis.

- Materi tidak sesuai dengan pekerjaan pengguna.
- Tidak ada simulasi atau praktik.
- Pengguna menganggap keamanan hanya tanggung jawab tim IT.
- Tidak ada budaya pelaporan insiden.
- Prosedur keamanan terlalu rumit.
- Tidak ada komunikasi mengenai ancaman terbaru.
- Organisasi tidak melakukan evaluasi efektivitas program awareness.

Karena ancaman siber terus berubah, kesadaran keamanan juga perlu **diperbarui secara berkala**.

Membangun Security Awareness

Program awareness yang baik sebaiknya tidak hanya berupa seminar satu kali. Organisasi dapat menggunakan berbagai pendekatan, seperti:

- Sosialisasi keamanan secara berkala.
- Poster dan materi pengingat.
- Simulasi phishing.
- Edukasi melalui email internal.
- Video pendek.
- Modul pembelajaran.
- Kuis keamanan.
- Studi kasus insiden.

- Simulasi pelaporan insiden.
- Peningkat keamanan pada aplikasi.
- Evaluasi perilaku pengguna.

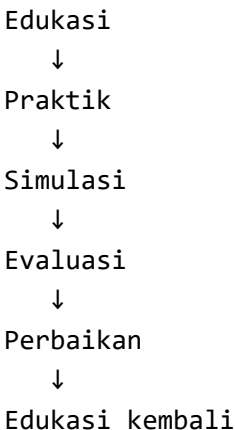
Materi juga sebaiknya disesuaikan dengan peran pengguna. Kebutuhan seorang pegawai administrasi tentu berbeda dengan administrator server atau pengelola sistem.

Security Awareness Harus Berkelanjutan

Kesadaran keamanan tidak dapat dibangun hanya melalui satu kali pelatihan.

Misalnya organisasi memberikan pelatihan phishing pada bulan Januari. Jika setelah itu tidak ada edukasi, simulasi, atau pengingat selama satu tahun, pengetahuan pengguna dapat menurun dan ancaman yang dihadapi organisasi juga mungkin sudah berubah.

Karena itu, pendekatan yang lebih baik adalah:



Pendekatan berkelanjutan tersebut membantu menjadikan keamanan sebagai **kebiasaan kerja**, bukan sekadar materi pelatihan.

Peran Pimpinan

Pimpinan organisasi memiliki peran penting dalam membangun budaya keamanan.

Pimpinan perlu menunjukkan bahwa keamanan merupakan bagian dari proses kerja, bukan hambatan pekerjaan.

Contohnya:

- Mendukung program security awareness.
- Menyediakan waktu bagi pegawai untuk mengikuti pelatihan.
- Tidak mendorong pegawai mengabaikan prosedur keamanan demi kecepatan.
- Mendukung pelaporan insiden.
- Tidak menyalahkan pegawai yang melaporkan kesalahan dengan itikad baik.
- Menjadikan keamanan sebagai bagian dari budaya organisasi.

Ketika pegawai takut melaporkan kesalahan, organisasi dapat kehilangan waktu penting untuk melakukan mitigasi.

Peran Pegawai

Setiap pegawai perlu memahami bahwa keamanan siber merupakan tanggung jawab bersama.

Kebiasaan sederhana yang perlu diterapkan antara lain:

- Berhenti sejenak sebelum mengklik tautan.
- Memeriksa email dan pengirim.
- Menjaga kerahasiaan password.
- Menggunakan MFA.
- Mengikuti prosedur keamanan.
- Tidak menginstal aplikasi sembarangan.
- Tidak membuka file mencurigakan.
- Memastikan penerima sebelum mengirim data sensitif.
- Melaporkan kejadian yang mencurigakan.
- Mengikuti pelatihan keamanan yang diberikan organisasi.

Mengukur Efektivitas Awareness

Organisasi sebaiknya tidak hanya mengukur keberhasilan program berdasarkan **jumlah pegawai yang mengikuti pelatihan**.

Ukuran yang lebih bermanfaat antara lain:

- Persentase pegawai yang dapat mengenali phishing.
- Hasil simulasi phishing.
- Jumlah laporan email mencurigakan.
- Waktu yang dibutuhkan untuk melaporkan insiden.
- Jumlah kesalahan terkait keamanan.
- Hasil evaluasi atau kuis.
- Perubahan perilaku pengguna dari waktu ke waktu.

Dengan demikian, organisasi dapat mengetahui apakah program awareness benar-benar menghasilkan perubahan perilaku.

Kesimpulan

Kurangnya kesadaran keamanan siber dapat menjadi faktor yang memperbesar kemungkinan terjadinya insiden. Pengguna yang tidak memahami risiko dapat melakukan tindakan yang memberikan kesempatan kepada penyerang untuk masuk atau memperluas serangan.

Namun, solusi terhadap masalah ini bukan sekadar **menyalahkan pengguna**. Organisasi perlu menyediakan edukasi, prosedur yang jelas, teknologi pendukung, mekanisme pelaporan, serta budaya yang mendorong perilaku aman.

Tujuan akhir dari **Cyber Security Awareness** adalah membuat keamanan menjadi bagian dari kebiasaan kerja sehari-hari.

Pegawai yang sadar keamanan bukan berarti pegawai yang tidak pernah melakukan kesalahan, tetapi pegawai yang mampu mengenali risiko, mengambil keputusan yang lebih aman, dan segera melaporkan ketika terjadi sesuatu yang mencurigakan.

3.11 Studi Kasus Sederhana

Untuk memahami bagaimana berbagai faktor penyebab insiden keamanan siber dapat saling berkaitan, berikut sebuah studi kasus sederhana yang menggambarkan kejadian di lingkungan organisasi.

Kasus: Akun Pegawai Diambil Alih melalui Phishing

Sebuah organisasi memiliki sistem email yang digunakan oleh seluruh pegawai. Salah seorang pegawai menerima email yang terlihat seperti pemberitahuan resmi dari administrator. Email tersebut menyatakan bahwa akun pegawai akan segera dinonaktifkan dan pengguna diminta melakukan verifikasi melalui sebuah tautan.

Pegawai tersebut sedang terburu-buru menyelesaikan pekerjaan. Tanpa memeriksa alamat pengirim dan alamat website tujuan, ia membuka tautan dan memasukkan username serta password.

Pada saat itu, akun pegawai **belum menggunakan Multi-Factor Authentication (MFA)**.

Beberapa saat kemudian, penyerang menggunakan username dan password yang diperoleh dari halaman phishing untuk masuk ke akun email tersebut.

Bagaimana Insiden Berkembang?

Setelah berhasil masuk, penyerang menemukan beberapa informasi penting di dalam email, termasuk dokumen internal dan komunikasi antara pegawai dengan bagian administrasi.

Penyerang kemudian menggunakan akun tersebut untuk mengirim email phishing kepada beberapa pegawai lain. Karena email dikirim menggunakan akun organisasi yang sah, pesan tersebut terlihat lebih meyakinkan.

Salah satu pegawai lain kemudian membuka tautan yang dikirimkan dan memasukkan kredensialnya.

Insiden akhirnya diketahui setelah administrator melihat aktivitas login yang tidak biasa dari akun pegawai.

Faktor Penyebab

Jika dianalisis, insiden tersebut tidak disebabkan oleh satu faktor saja.

1. Kurangnya Kesadaran Keamanan Siber

Pegawai tidak mengenali ciri-ciri phishing dan tidak melakukan verifikasi terhadap email.

2. Membuka Tautan Mencurigakan

Pegawai langsung membuka tautan dan memasukkan kredensial.

3. Tidak Menggunakan MFA

Password yang berhasil dicuri dapat langsung digunakan untuk mencoba mengambil alih akun.

4. Penggunaan Password yang Berisiko

Apabila password tersebut juga digunakan pada layanan lain, penyerang dapat mencoba melakukan *credential stuffing*.

5. Kurangnya Monitoring

Aktivitas login yang tidak biasa baru diketahui setelah akun digunakan untuk mengirim pesan kepada pengguna lain.

Dampak

Insiden tersebut dapat menyebabkan:

- Akun pegawai diambil alih.
- Email internal dapat dibaca oleh penyerang.
- Informasi organisasi berpotensi bocor.
- Pegawai lain menerima phishing dari akun yang telah

dikompromikan.

- Kredensial pengguna lain dapat ikut dicuri.
- Aktivitas operasional terganggu.
- Organisasi mengalami kerugian reputasi.

Jika akun tersebut memiliki akses yang berlebihan, dampaknya dapat menjadi lebih besar karena penyerang dapat mengakses lebih banyak sistem dan informasi.

Bagaimana Seharusnya Insiden Dicegah?

Insiden tersebut sebenarnya dapat dipersulit atau dihentikan melalui beberapa lapisan pengamanan.

Pada sisi pengguna:

- Memeriksa alamat pengirim.
- Tidak langsung membuka tautan.
- Memastikan alamat website tujuan.
- Melakukan konfirmasi apabila menerima permintaan yang tidak biasa.
- Segera melaporkan email mencurigakan.

Pada sisi sistem:

- Menerapkan MFA.
- Menggunakan perlindungan email terhadap phishing.
- Menerapkan monitoring aktivitas login.
- Menerapkan pembatasan akses berdasarkan kebutuhan.
- Menggunakan endpoint protection.

- Menyimpan log aktivitas untuk investigasi.

Pada sisi organisasi:

- Melakukan Cyber Security Awareness secara berkala.
- Melakukan simulasi phishing.
- Menetapkan prosedur pelaporan insiden.
- Melakukan review hak akses.
- Menyusun prosedur respons insiden.
- Melakukan evaluasi setelah insiden terjadi.

• Pelajaran yang Dapat Diambil

Studi kasus tersebut menunjukkan bahwa **insiden keamanan siber biasanya tidak hanya disebabkan oleh satu kesalahan.**

Dalam satu kejadian, beberapa kelemahan dapat saling berhubungan:

Kurang Awareness



Membuka Phishing



Password Dicuri



Tidak Ada MFA



Akun Diambil Alih



Email Disalahgunakan



Pegawai Lain Menjadi Target

Apabila salah satu lapisan pertahanan berhasil menghentikan serangan, dampaknya dapat dikurangi.

Misalnya, jika pegawai tidak memasukkan password ke halaman phishing, serangan dapat berhenti pada tahap awal. Jika password sudah terlanjur dicuri tetapi MFA diterapkan, pengambilalihan akun dapat menjadi lebih sulit. Jika akun berhasil diambil alih tetapi monitoring mendeteksi login mencurigakan dengan cepat, organisasi dapat segera melakukan pemblokiran dan pemulihan.

Kesimpulan

Studi kasus ini memperlihatkan pentingnya **pertahanan berlapis (*defense in depth*)**. Keamanan siber tidak boleh hanya mengandalkan satu teknologi atau satu prosedur.

Manusia, teknologi, kebijakan, monitoring, dan kemampuan respons harus saling melengkapi.

Satu kesalahan pengguna tidak selalu dapat dicegah, tetapi organisasi dapat membangun beberapa lapisan pertahanan agar satu kesalahan tidak berubah menjadi insiden besar.

BAB 4 MEMBANGUN PERTAHANAN SIBER

4.1 Konsep Defense in Depth

Keamanan siber tidak dapat dibangun hanya dengan mengandalkan satu teknologi atau satu mekanisme perlindungan. Firewall, antivirus, sistem autentikasi, maupun perangkat monitoring memiliki fungsi dan keterbatasan masing-masing. Oleh karena itu, organisasi membutuhkan beberapa lapisan perlindungan yang saling melengkapi.

Defense in Depth adalah pendekatan keamanan yang menerapkan beberapa lapisan pertahanan untuk melindungi aset, sistem, jaringan, aplikasi, dan data organisasi. Prinsip dasarnya adalah apabila salah satu lapisan pertahanan gagal, masih terdapat lapisan lain yang dapat mencegah, mendeteksi, membatasi, atau mengurangi dampak serangan.

Pendekatan ini penting karena serangan siber biasanya tidak hanya bergantung pada satu kelemahan. Sebagai contoh, serangan dapat dimulai ketika pengguna membuka tautan phishing, kemudian kredensial dicuri, akun diambil alih, dan penyerang menggunakan akun tersebut untuk mengakses sumber daya lain. Jika organisasi hanya mengandalkan satu mekanisme keamanan, kegagalan mekanisme tersebut dapat memberikan kesempatan lebih besar bagi penyerang untuk melanjutkan serangan.

Dalam pendekatan Defense in Depth, organisasi membangun beberapa lapisan pertahanan, antara lain:

- **Manusia dan awareness**, melalui edukasi serta kebiasaan kerja yang aman.
- **Autentikasi**, seperti penggunaan password yang kuat dan Multi-Factor Authentication (MFA).
- **Kontrol akses**, untuk memastikan pengguna hanya memperoleh akses sesuai kebutuhan.
- **Keamanan jaringan**, seperti firewall dan mekanisme penyaringan lalu lintas.
- **Perlindungan endpoint**, untuk mendeteksi aktivitas mencurigakan pada komputer dan server.
- **Perlindungan aplikasi**, seperti Web Application Firewall (WAF).
- **Monitoring dan logging**, untuk mengetahui aktivitas yang tidak normal.
- **Deteksi dan respons**, menggunakan mekanisme seperti IDS, IPS, EDR, dan SIEM.
- **Backup dan recovery**, untuk memastikan organisasi tetap memiliki kemampuan pemulihan ketika terjadi kerusakan atau kehilangan data.
- **Incident response**, untuk memastikan insiden ditangani secara terstruktur.

Dengan pendekatan tersebut, kegagalan satu lapisan tidak secara otomatis menyebabkan seluruh sistem pertahanan gagal. Lapisan berikutnya masih dapat memberikan perlindungan tambahan.

Contoh Penerapan Defense in Depth

Sebagai contoh, sebuah organisasi memiliki layanan email yang digunakan oleh pegawai. Seorang pegawai menerima email phishing dan tanpa sengaja membuka tautan yang diberikan.

Pada kondisi tersebut, lapisan **Cyber Security Awareness** gagal mencegah pengguna membuka tautan. Namun, serangan masih dapat dihentikan oleh lapisan berikutnya.

Apabila akun menggunakan **MFA**, password yang berhasil dicuri belum tentu cukup bagi penyerang untuk masuk ke akun. Jika penyerang tetap berhasil melakukan login, sistem **monitoring dan logging** dapat mendeteksi aktivitas login yang tidak biasa.

Apabila aktivitas tersebut terdeteksi sebagai ancaman, organisasi dapat menjalankan prosedur **Incident Response** untuk memblokir akun, mengakhiri sesi login, mengganti kredensial, dan melakukan investigasi.

Apabila serangan menyebabkan kehilangan atau kerusakan data, **backup** dapat digunakan sebagai salah satu mekanisme pemulihan.

Contoh tersebut menunjukkan bahwa setiap lapisan memiliki fungsi yang berbeda, tetapi semuanya bekerja untuk tujuan yang sama, yaitu mengurangi kemungkinan dan dampak insiden keamanan.

Defense in Depth Tidak Hanya Bergantung pada Teknologi

Defense in Depth bukan berarti organisasi harus memasang sebanyak mungkin perangkat keamanan. Pendekatan ini justru menekankan pentingnya kombinasi antara **manusia, proses, kebijakan, dan teknologi**.

Teknologi keamanan yang lengkap tidak akan memberikan perlindungan optimal apabila pengguna tidak memahami ancaman, hak akses tidak dikelola dengan baik, sistem tidak dipantau, atau organisasi tidak memiliki prosedur respons insiden.

Karena itu, penerapan Defense in Depth harus disesuaikan dengan risiko dan kebutuhan organisasi. Setiap lapisan harus memiliki tujuan yang jelas dan memberikan kontribusi terhadap perlindungan aset informasi.

Pada akhirnya, tujuan Defense in Depth bukan membuat organisasi menjadi **tidak mungkin diserang**, tetapi membuat serangan menjadi lebih sulit dilakukan, lebih cepat diketahui, lebih mudah dikendalikan, dan dampaknya dapat diminimalkan.



4.2 Firewall

Firewall merupakan salah satu komponen penting dalam

pertahanan keamanan jaringan. Firewall berfungsi mengendalikan lalu lintas komunikasi antara jaringan atau sistem berdasarkan aturan keamanan yang telah ditentukan.

Secara sederhana, firewall bertindak sebagai **pengendali lalu lintas** yang menentukan koneksi mana yang diperbolehkan dan koneksi mana yang harus ditolak. Dengan demikian, firewall dapat membantu membatasi akses yang tidak diperlukan dan mengurangi peluang sistem organisasi menjadi target serangan dari jaringan yang tidak terpercaya.

Firewall dapat diterapkan pada berbagai lingkungan, seperti jaringan organisasi, server, komputer, maupun layanan cloud. Bentuknya juga dapat berupa perangkat khusus (*appliance*), perangkat lunak, maupun fitur keamanan yang tersedia pada sistem operasi atau layanan cloud.

Fungsi Firewall

Beberapa fungsi utama firewall antara lain:

- Mengontrol lalu lintas jaringan.
- Membatasi koneksi dari jaringan yang tidak dipercaya.
- Mengizinkan komunikasi yang memang diperlukan.
- Menolak koneksi yang tidak sesuai dengan kebijakan keamanan.
- Membatasi akses terhadap port dan layanan tertentu.
- Membantu melakukan segmentasi jaringan.
- Mencatat aktivitas lalu lintas tertentu untuk kebutuhan monitoring.
- Menjadi salah satu lapisan pertahanan terhadap

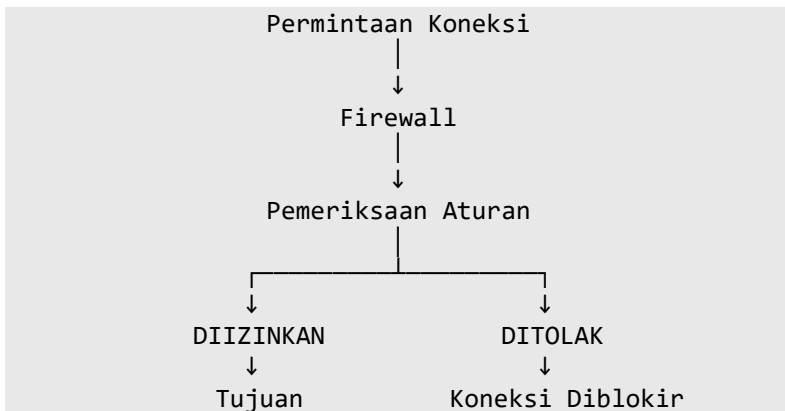
serangan jaringan.

Firewall tidak hanya digunakan untuk memblokir koneksi dari internet. Dalam organisasi yang memiliki beberapa segmen jaringan, firewall juga dapat digunakan untuk mengendalikan komunikasi **antarjaringan internal**.

Cara Kerja Firewall

Firewall menggunakan aturan atau kebijakan untuk menentukan apakah suatu komunikasi diperbolehkan atau ditolak.

Secara sederhana:



Aturan firewall dapat mempertimbangkan berbagai informasi, seperti:

- Alamat IP sumber.
- Alamat IP tujuan.
- Port.
- Protokol.

- Arah komunikasi.
- Zona jaringan.
- Status koneksi.
- Identitas atau aplikasi, tergantung jenis firewall.

Sebagai contoh, organisasi dapat membuat aturan yang mengizinkan akses HTTPS menuju web server, tetapi menolak akses langsung dari internet menuju port administrasi server.

Contoh Sederhana

Misalnya sebuah organisasi memiliki web server yang menyediakan layanan HTTPS.

Kebutuhan aksesnya:

Internet



Dengan konfigurasi tersebut, layanan publik dapat tetap diakses pengguna, sedangkan akses administrasi tidak perlu dibuka secara bebas dari internet.

Pembatasan tersebut dapat mengurangi *attack surface* karena tidak semua layanan server harus dapat diakses dari jaringan luar.

Firewall Bukan Antivirus

Firewall dan antivirus memiliki fungsi yang berbeda.

Firewall terutama berfokus pada pengendalian komunikasi

dan lalu lintas jaringan.

Antivirus atau endpoint protection berfokus pada pendeteksian dan perlindungan terhadap file, program, serta aktivitas berbahaya pada perangkat.

Contohnya, firewall dapat mencegah koneksi tertentu menuju server. Namun, apabila pengguna sudah menjalankan malware dari sebuah file yang diterima melalui media lain, firewall saja tidak cukup untuk menangani ancaman tersebut.

Karena itu, firewall merupakan **salah satu lapisan pertahanan**, bukan satu-satunya mekanisme keamanan.

Firewall dan Prinsip Default Deny

Salah satu prinsip penting dalam pengelolaan firewall adalah **Default Deny**.

Prinsip ini berarti lalu lintas yang tidak secara eksplisit diizinkan akan ditolak.

Contoh sederhana:

Default Policy



DENY



Hanya koneksi yang
diperlukan yang
dibuatkan aturan



ALLOW

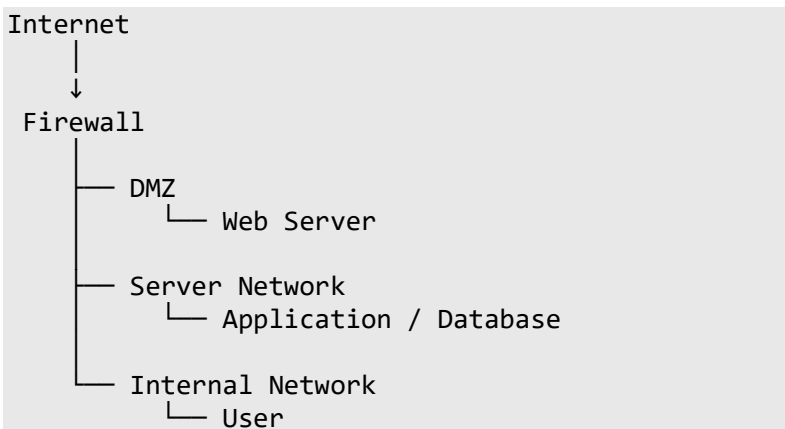
Pendekatan ini membantu mengurangi akses yang tidak diperlukan. Namun, aturan harus dirancang dengan hati-hati agar layanan yang memang dibutuhkan tetap dapat berjalan.

Pembahasan lebih khusus mengenai prinsip **Default Deny** akan dibahas pada **Subbab 4.11**.

Firewall dan Segmentasi Jaringan

Firewall juga dapat digunakan untuk membantu melakukan **segmentasi jaringan**.

Sebagai contoh, sebuah organisasi dapat memiliki:



Dengan segmentasi tersebut, tidak semua jaringan dapat berkomunikasi secara bebas.

Sebagai contoh, web server mungkin diperbolehkan berkomunikasi dengan application server pada port tertentu, sedangkan komputer pengguna tidak diperbolehkan mengakses database secara langsung.

Hal ini membantu membatasi **pergerakan penyerang**

(lateral movement) apabila salah satu sistem berhasil dikompromikan.

Firewall Tidak Menjamin Sistem Aman

Penggunaan firewall tidak berarti organisasi terbebas dari serangan.

Firewall dapat memiliki keterbatasan, misalnya:

- Serangan menggunakan koneksi yang memang diizinkan.
- Aplikasi memiliki kerentanan.
- Pengguna menjadi korban phishing.
- Kredensial berhasil dicuri.
- Konfigurasi firewall salah.
- Aturan firewall terlalu longgar.
- Sistem internal telah berhasil dikompromikan.
- Ancaman berasal dari jalur komunikasi yang dianggap terpercaya.

Sebagai contoh, firewall mungkin mengizinkan HTTPS karena layanan web memang harus dapat diakses dari internet. Jika penyerang menggunakan HTTPS untuk mengirim permintaan berbahaya ke aplikasi web, firewall jaringan biasa belum tentu dapat menentukan bahwa permintaan tersebut merupakan serangan terhadap aplikasi.

Pada kondisi tersebut diperlukan lapisan keamanan lain, seperti **Web Application Firewall (WAF)**.

Kesalahan Konfigurasi Firewall

Firewall yang dikonfigurasi dengan tidak tepat dapat justru meningkatkan risiko keamanan.

Beberapa contoh kesalahan:

- Membuka port yang tidak diperlukan.
- Mengizinkan akses dari seluruh internet padahal hanya diperlukan dari jaringan tertentu.
- Membuat aturan terlalu luas.
- Membiarkan aturan lama yang sudah tidak diperlukan.
- Tidak melakukan review terhadap rule.
- Tidak mencatat perubahan konfigurasi.
- Tidak melakukan monitoring terhadap log.
- Menggunakan konfigurasi yang tidak terdokumentasi.

Karena itu, firewall perlu dikelola secara berkala. Setiap aturan sebaiknya memiliki alasan yang jelas dan hanya memberikan akses sesuai kebutuhan.

Prinsip Pengelolaan Firewall

Beberapa prinsip yang dapat diterapkan antara lain:

1. Allow only what is necessary

Hanya izinkan komunikasi yang memang diperlukan.

2. Default Deny

Tolak lalu lintas yang tidak memiliki izin eksplisit sesuai kebijakan.

3. Least Privilege

Batasi akses berdasarkan kebutuhan.

4. Segmentasi

Pisahkan jaringan berdasarkan fungsi dan tingkat kepercayaan.

5. Review Rule

Periksa aturan firewall secara berkala.

6. Logging

Catat aktivitas penting untuk membantu monitoring dan investigasi.

7. Dokumentasi

Setiap aturan penting harus memiliki dokumentasi mengenai tujuan dan pemiliknya.

Contoh dalam Lingkungan Organisasi

Sebuah organisasi memiliki tiga kelompok sistem:



Dengan pendekatan tersebut, database tidak perlu dapat diakses langsung dari internet maupun dari seluruh komputer pengguna.

Jika web server berhasil dikompromikan, firewall dan segmentasi masih dapat membatasi komunikasi menuju sistem lainnya.

Ini adalah salah satu contoh penerapan **Defense in Depth** yang telah dibahas pada Subbab 4.1.

Peran Administrator

Administrator memiliki tanggung jawab penting dalam menjaga konfigurasi firewall.

Beberapa hal yang perlu dilakukan:

- Mengetahui seluruh rule yang aktif.
- Memastikan setiap rule memiliki tujuan yang jelas.
- Menghapus rule yang sudah tidak diperlukan.
- Membatasi sumber akses.
- Membatasi port dan protokol.
- Melakukan review konfigurasi secara berkala.
- Memonitor log firewall.
- Mendokumentasikan perubahan.
- Membatasi akses administratif terhadap firewall.
- Menggunakan MFA untuk akses administrasi apabila tersedia.

Kesimpulan

Firewall merupakan salah satu lapisan penting dalam pertahanan keamanan siber. Fungsi utamanya adalah mengendalikan lalu lintas komunikasi berdasarkan kebijakan keamanan sehingga akses yang tidak diperlukan dapat dibatasi.

Namun, firewall **bukan solusi tunggal**. Firewall harus dikombinasikan dengan kontrol keamanan lainnya seperti autentikasi, segmentasi jaringan, endpoint protection, IDS/IPS, WAF, monitoring, backup, dan prosedur respons insiden.

Prinsip yang perlu diingat adalah:

Firewall bukan sekadar membuka dan menutup port, tetapi merupakan mekanisme untuk menerapkan kebijakan keamanan terhadap komunikasi jaringan.

4.3 Intrusion Detection System (IDS)

Intrusion Detection System (IDS) adalah sistem keamanan yang digunakan untuk **mendeteksi aktivitas atau lalu lintas yang mencurigakan** pada jaringan maupun sistem. IDS bekerja dengan melakukan pemantauan dan analisis terhadap aktivitas yang terjadi, kemudian memberikan peringatan apabila ditemukan indikasi yang dianggap sebagai ancaman.

IDS memiliki peran penting dalam **Defense in Depth** karena memberikan lapisan deteksi tambahan setelah mekanisme pencegahan seperti firewall. Firewall dapat menentukan lalu lintas yang diizinkan atau ditolak, sedangkan IDS membantu mengidentifikasi aktivitas mencurigakan yang terjadi pada lalu lintas atau sistem yang sedang dipantau.

Fungsi IDS

Beberapa fungsi utama IDS antara lain:

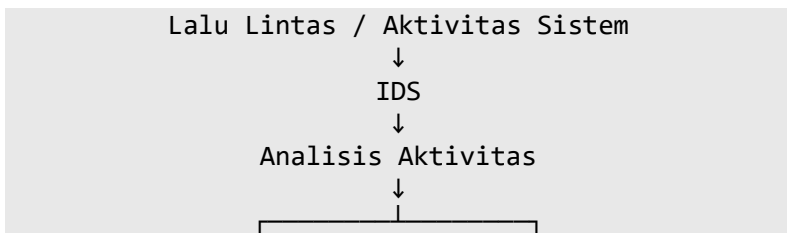
- Memantau aktivitas jaringan atau sistem.
- Mendeteksi pola aktivitas yang mencurigakan.
- Mengidentifikasi indikasi serangan.
- Memberikan peringatan kepada administrator.
- Membantu administrator melakukan investigasi.
- Menyediakan informasi untuk analisis insiden.
- Membantu mengetahui pola serangan yang terjadi.
- Menjadi salah satu sumber informasi dalam proses *incident response*.

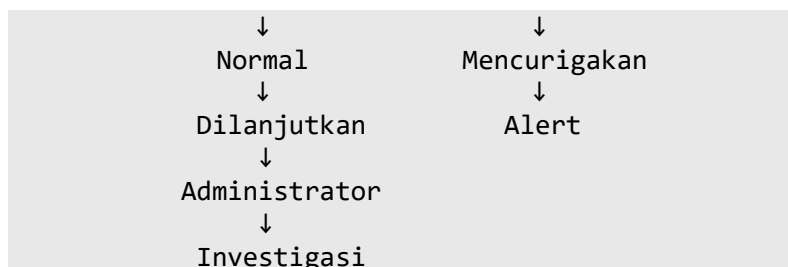
Dengan adanya IDS, organisasi memiliki kemampuan untuk mengetahui adanya aktivitas yang tidak normal tanpa harus menunggu sampai terjadi kerusakan atau kehilangan data.

Cara Kerja IDS

Secara sederhana, IDS bekerja dengan mengamati aktivitas yang terjadi kemudian membandingkannya dengan indikator atau pola yang digunakan untuk mendeteksi ancaman.

Gambaran sederhananya:





Ketika IDS menemukan aktivitas yang dianggap mencurigakan, sistem dapat menghasilkan **alert** yang kemudian dianalisis oleh administrator atau tim keamanan.

IDS Tidak Sama dengan Firewall

Firewall dan IDS memiliki fungsi yang berbeda.

Firewall berfokus pada pengendalian lalu lintas berdasarkan aturan keamanan.

IDS berfokus pada **mendeteksi dan memberikan peringatan** terhadap aktivitas yang dianggap mencurigakan.

Contohnya, firewall dapat mengizinkan koneksi HTTPS menuju sebuah web server karena layanan tersebut memang harus tersedia untuk pengguna.

IDS kemudian dapat menganalisis aktivitas pada koneksi tersebut dan menemukan pola permintaan yang menunjukkan indikasi serangan.

Dengan demikian:

Firewall



Mengendalikan akses



"Apakah koneksi ini boleh lewat?"

IDS



Menganalisis aktivitas



"Apakah aktivitas ini mencurigakan?"

Keduanya dapat digunakan secara bersamaan sebagai bagian dari pertahanan berlapis.

Jenis IDS

Secara umum, IDS dapat dibedakan berdasarkan lokasi atau objek yang dipantau.

1. Network Intrusion Detection System (NIDS)

NIDS memantau lalu lintas jaringan untuk mencari indikasi aktivitas yang mencurigakan.

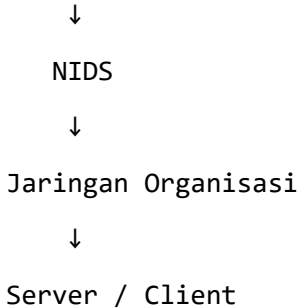
NIDS dapat ditempatkan pada titik tertentu dalam jaringan sehingga dapat mengamati lalu lintas yang melewati segmen jaringan tersebut.

Contohnya:

Internet



Firewall



NIDS dapat membantu mendeteksi aktivitas seperti pemindaian jaringan, pola serangan tertentu, maupun komunikasi yang menunjukkan indikasi malware.

2. Host Intrusion Detection System (HIDS)

HIDS dipasang pada host atau perangkat tertentu dan memantau aktivitas yang terjadi pada sistem tersebut.

HIDS dapat memantau berbagai aktivitas seperti:

- Perubahan file.
- Aktivitas proses.
- Log sistem.
- Perubahan konfigurasi.
- Aktivitas autentikasi.
- Aktivitas yang dianggap tidak normal.

Contohnya, HIDS pada server dapat memberikan peringatan ketika terdapat perubahan terhadap file penting yang seharusnya tidak berubah.

Signature-Based Detection

Salah satu pendekatan yang dapat digunakan IDS adalah **signature-based detection**.

Dalam pendekatan ini, IDS membandingkan aktivitas yang diamati dengan pola atau *signature* yang telah diketahui sebagai indikasi serangan.

Contohnya:

Aktivitas

↓

IDS

↓

Cocok dengan signature?

↓

YA

↓

Generate Alert

Pendekatan ini efektif untuk mendeteksi ancaman yang polanya sudah diketahui.

Namun, pendekatan ini memiliki keterbatasan ketika menghadapi serangan baru yang belum memiliki signature.

Anomaly-Based Detection

Pendekatan lainnya adalah **anomaly-based detection**.

IDS mencoba mengenali aktivitas yang berbeda secara signifikan dari pola aktivitas normal.

Sebagai contoh, sebuah server biasanya menerima jumlah

koneksi tertentu setiap hari. Kemudian tiba-tiba terjadi pola koneksi yang sangat berbeda dari kondisi normal.

Aktivitas tersebut dapat dianggap sebagai anomali dan menghasilkan peringatan untuk dilakukan pemeriksaan lebih lanjut.

Pendekatan ini dapat membantu mendeteksi aktivitas yang belum memiliki signature, tetapi dapat menghasilkan **false positive**, yaitu aktivitas yang sebenarnya normal tetapi dianggap mencurigakan.

Alert dan False Positive

Salah satu tantangan dalam penggunaan IDS adalah jumlah alert yang dihasilkan.

Tidak semua alert berarti serangan benar-benar terjadi.

Contohnya:

IDS

↓

100 Alert

↓

Administrator melakukan analisis

↓

70 aktivitas normal

20 aktivitas perlu pemeriksaan

10 indikasi serangan

Jika sistem menghasilkan terlalu banyak alert yang tidak

relevan, administrator dapat mengalami **alert fatigue**.

Karena itu, konfigurasi IDS dan proses analisis alert perlu dilakukan dengan baik agar tim keamanan dapat memprioritaskan aktivitas yang benar-benar penting.

Peran IDS dalam Incident Response

IDS dapat menjadi salah satu sumber informasi ketika terjadi insiden keamanan.

Contohnya, IDS mendeteksi aktivitas mencurigakan dari sebuah alamat IP menuju server organisasi.

Administrator kemudian dapat melakukan pemeriksaan terhadap:

- Log firewall.
- Log server.
- Log aplikasi.
- Aktivitas akun pengguna.
- EDR.
- SIEM.
- Sistem jaringan lainnya.

Informasi dari berbagai sumber tersebut dapat digunakan untuk menentukan apakah aktivitas tersebut merupakan serangan dan sejauh mana dampaknya.

Dengan demikian, IDS tidak hanya berguna untuk memberikan **peringatan**, tetapi juga dapat membantu proses investigasi.

Keterbatasan IDS

IDS bukan sistem yang dapat menjamin seluruh serangan akan terdeteksi.

Beberapa keterbatasannya antara lain:

- Tidak semua serangan memiliki pola yang mudah dikenali.
- Signature mungkin belum tersedia untuk serangan baru.
- Dapat menghasilkan false positive.
- Aktivitas terenkripsi dapat menyulitkan analisis tertentu.
- Memerlukan konfigurasi dan pemeliharaan.
- Alert membutuhkan analisis manusia.
- Tidak secara otomatis menghentikan seluruh serangan.

Karena itu, IDS sebaiknya digunakan bersama mekanisme keamanan lainnya.

IDS dalam Defense in Depth

Dalam konsep **Defense in Depth**, IDS berada pada lapisan **deteksi**.

Contoh sederhana:

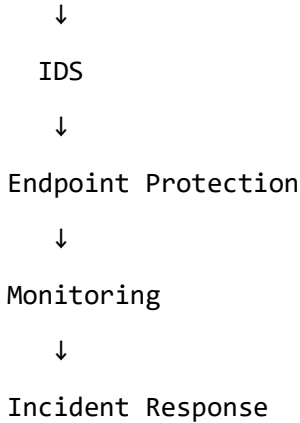
Pengguna



Autentikasi



Firewall



Firewall dapat membantu membatasi lalu lintas, sementara IDS membantu mendeteksi aktivitas yang mencurigakan. Apabila IDS menghasilkan alert, informasi tersebut dapat diteruskan ke proses monitoring dan incident response untuk dilakukan analisis dan tindakan lebih lanjut.

Kesimpulan

Intrusion Detection System (IDS) merupakan salah satu komponen penting dalam pertahanan siber karena membantu organisasi mengetahui adanya aktivitas yang mencurigakan.

IDS tidak menggantikan firewall dan tidak dapat bekerja sendirian. Firewall berfungsi mengendalikan akses, sedangkan IDS memberikan kemampuan tambahan untuk **mengamati, mendeteksi, dan memberikan peringatan** terhadap aktivitas yang berpotensi menjadi ancaman.

Dengan menggabungkan IDS dengan firewall, endpoint protection, logging, monitoring, SIEM, dan prosedur incident response, organisasi dapat membangun kemampuan deteksi yang lebih baik sebagai bagian dari **Defense in Depth**.

Firewall membantu mengendalikan lalu lintas, sedangkan IDS membantu mengetahui apakah aktivitas yang terjadi di dalam lalu lintas tersebut menunjukkan indikasi ancaman.

4.4 Intrusion Prevention System (IPS)

Intrusion Prevention System (IPS) adalah sistem keamanan yang digunakan untuk **mendeteksi sekaligus mencegah aktivitas jaringan yang dianggap berbahaya**. Berbeda dengan Intrusion Detection System (IDS) yang terutama memberikan peringatan ketika menemukan aktivitas mencurigakan, IPS dapat mengambil tindakan untuk menghentikan atau memblokir aktivitas tersebut sesuai dengan kebijakan keamanan yang diterapkan.

IPS merupakan salah satu lapisan penting dalam konsep **Defense in Depth** karena memberikan kemampuan pencegahan tambahan setelah mekanisme seperti firewall.

Fungsi IPS

Beberapa fungsi utama IPS antara lain:

- Memantau lalu lintas jaringan.
- Mendeteksi pola serangan.
- Mengidentifikasi aktivitas yang mencurigakan.
- Memblokir lalu lintas yang dianggap berbahaya.
- Menghentikan koneksi tertentu.
- Membantu mencegah eksploitasi terhadap sistem.
- Memberikan informasi dan log untuk kebutuhan investigasi.

- Membantu mengurangi dampak serangan yang terdeteksi.

Dengan kemampuan tersebut, IPS dapat membantu organisasi mencegah aktivitas berbahaya sebelum mencapai sistem yang menjadi target.

Perbedaan IDS dan IPS

Perbedaan paling sederhana antara IDS dan IPS terletak pada **tindakan setelah mendeteksi ancaman.**

IDS

Lalu Lintas



IDS



Analisis



Ancaman?



ALERT

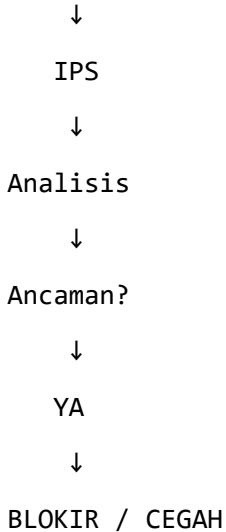


Administrator

Sedangkan:

IPS

Lalu Lintas



Dengan demikian:

Komponen Fungsi utama

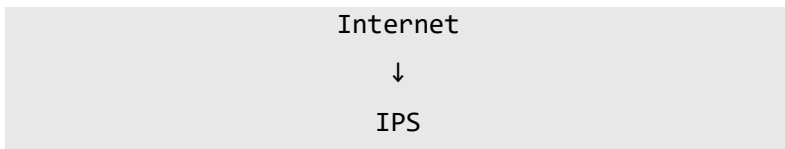
IDS Mendeteksi dan memberikan peringatan

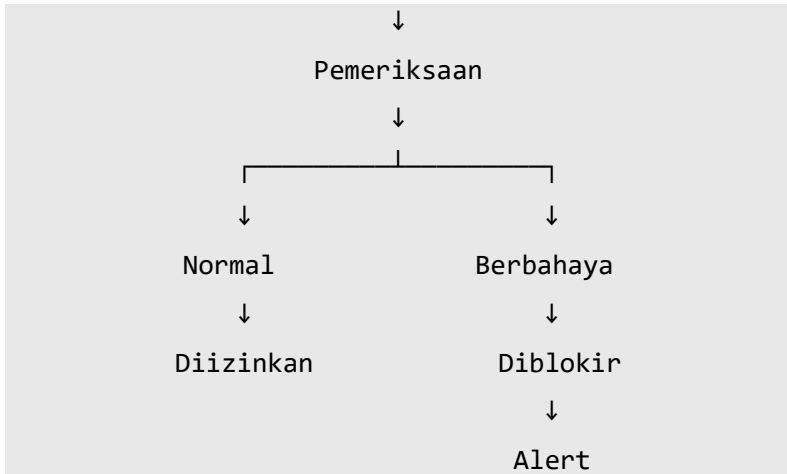
IPS Mendeteksi dan mengambil tindakan pencegahan

IDS lebih berorientasi pada **visibility dan detection**, sedangkan IPS menambahkan kemampuan **prevention**.

Cara Kerja IPS

Secara sederhana, IPS bekerja dengan memeriksa lalu lintas yang melewati sistem keamanan.





Ketika aktivitas dianggap normal dan sesuai kebijakan, lalu lintas dapat diteruskan.

Apabila ditemukan pola yang sesuai dengan indikasi serangan, IPS dapat mengambil tindakan seperti:

- Memblokir paket.
- Menghentikan koneksi.
- Memblokir sumber tertentu.
- Menolak permintaan.
- Menghasilkan alert.
- Mencatat kejadian untuk investigasi.

Tindakan yang dilakukan bergantung pada kemampuan produk dan kebijakan keamanan yang diterapkan.

Signature-Based Detection

Salah satu metode yang dapat digunakan IPS adalah

signature-based detection.

IPS menggunakan kumpulan *signature* yang menggambarkan pola serangan yang telah diketahui.

Misalnya:

Lalu lintas



IPS



Cocok dengan

signature serangan?



YA



BLOKIR



Generate Log

Pendekatan ini efektif untuk mendeteksi pola serangan yang sudah dikenal.

Namun, apabila sebuah serangan menggunakan pola baru yang belum dikenali oleh signature, kemampuan deteksi dapat menjadi lebih terbatas.

Anomaly-Based Detection

IPS juga dapat menggunakan pendekatan **anomaly-based**

detection, yaitu mendeteksi aktivitas yang menyimpang dari pola yang dianggap normal.

Misalnya, sebuah sistem biasanya menerima pola lalu lintas tertentu. Apabila tiba-tiba muncul aktivitas yang sangat berbeda, IPS dapat menganggapnya sebagai anomali dan mengambil tindakan sesuai kebijakan.

Pendekatan ini dapat membantu mendeteksi aktivitas yang belum memiliki signature tertentu, tetapi perlu dikonfigurasi dengan hati-hati karena aktivitas yang sebenarnya normal dapat dianggap sebagai ancaman.

IPS dan Firewall

IPS tidak menggantikan firewall.

Keduanya memiliki fungsi yang berbeda tetapi dapat bekerja bersama.

Firewall terutama digunakan untuk mengendalikan komunikasi berdasarkan aturan akses.

IPS berfokus pada pemeriksaan aktivitas dan mendeteksi pola yang menunjukkan adanya serangan.

Contohnya:

Internet



Firewall



IPS



Server

Firewall dapat menentukan bahwa koneksi HTTPS menuju web server diperbolehkan karena layanan tersebut memang harus tersedia.

IPS kemudian dapat melakukan pemeriksaan terhadap lalu lintas yang melewati jalur tersebut untuk mencari indikasi serangan.

Dengan demikian, keduanya memberikan lapisan perlindungan yang berbeda.

Contoh Kasus

Sebuah organisasi memiliki web server yang dapat diakses dari internet.

Penyerang mencoba mengirimkan serangkaian permintaan yang memiliki pola serangan yang telah dikenali oleh IPS.

IPS mendeteksi pola tersebut dan menentukan bahwa lalu lintas tersebut sesuai dengan signature serangan.

Kemudian IPS melakukan tindakan sesuai kebijakan, misalnya:

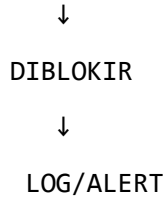
Permintaan Penyerang



IPS



Terdeteksi sebagai
aktivitas berbahaya

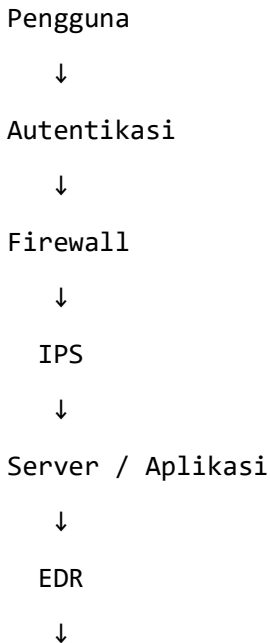


Dengan mekanisme tersebut, permintaan berbahaya dapat dihentikan sebelum diteruskan ke sistem tujuan.

IPS dalam Defense in Depth

IPS merupakan bagian dari lapisan **prevention dan detection** dalam Defense in Depth.

Contoh sederhana:



Monitoring / SIEM



Incident Response

Jika firewall tidak dapat mengidentifikasi sebuah aktivitas sebagai ancaman karena koneksi tersebut secara umum diperbolehkan, IPS dapat memberikan pemeriksaan tambahan terhadap pola aktivitas yang melewati jaringan.

Jika IPS mendeteksi aktivitas berbahaya, kejadian tersebut juga dapat menjadi sumber informasi bagi sistem monitoring atau SIEM.

Tantangan dalam Penggunaan IPS

IPS memberikan kemampuan pencegahan, tetapi penerapannya juga memiliki tantangan.

Beberapa di antaranya:

- **False positive**, yaitu aktivitas normal dianggap sebagai serangan.
- **False negative**, yaitu serangan tidak berhasil terdeteksi.
- Signature perlu diperbarui.
- Konfigurasi harus disesuaikan dengan lingkungan organisasi.
- Pemblokiran yang salah dapat mengganggu layanan.
- Lalu lintas terenkripsi dapat menyulitkan pemeriksaan tertentu.
- IPS membutuhkan monitoring dan pemeliharaan.

Karena IPS dapat mengambil tindakan langsung terhadap lalu lintas, konfigurasi yang tidak tepat dapat menyebabkan **layanan yang sebenarnya sah ikut terblokir**.

Oleh karena itu, penerapan IPS harus dilakukan dengan mempertimbangkan kebutuhan bisnis dan karakteristik sistem yang dilindungi.

Peran Administrator

Administrator perlu melakukan beberapa kegiatan untuk menjaga IPS tetap efektif:

- Memastikan signature dan mekanisme deteksi diperbarui.
- Melakukan review terhadap alert.
- Memeriksa aktivitas yang diblokir.
- Menyesuaikan kebijakan berdasarkan kebutuhan organisasi.
- Menangani false positive.
- Memastikan rule yang diterapkan tidak mengganggu layanan penting.
- Memonitor performa IPS.
- Meninjau log secara berkala.
- Mendokumentasikan perubahan konfigurasi.

IPS yang dibiarkan bekerja tanpa monitoring dapat menghasilkan banyak alert yang akhirnya tidak ditindaklanjuti.

IPS Bukan Pengganti Keamanan Lain

Walaupun IPS dapat melakukan pencegahan secara otomatis, IPS tidak dapat menggantikan seluruh mekanisme keamanan.

Serangan dapat terjadi melalui berbagai jalur, termasuk:

- Phishing.
- Kredensial yang dicuri.
- Malware.
- Kesalahan konfigurasi.
- Penyalahgunaan hak akses.
- Ancaman dari dalam organisasi.
- Kerentanan aplikasi.
- Serangan terhadap endpoint.

Karena itu, IPS harus menjadi bagian dari **arsitektur keamanan berlapis**, bukan satu-satunya mekanisme pertahanan.

Kesimpulan

Intrusion Prevention System (IPS) memberikan kemampuan untuk mendeteksi dan mengambil tindakan terhadap aktivitas jaringan yang dianggap berbahaya. Kemampuan tersebut membedakannya dari IDS yang terutama berfungsi memberikan peringatan.

IPS dapat membantu organisasi mencegah serangan sebelum mencapai sistem yang menjadi target. Namun, efektivitasnya sangat bergantung pada konfigurasi, kualitas deteksi, pembaruan signature, monitoring, serta kemampuan

administrator dalam menangani alert.

IDS membantu mengetahui adanya serangan, sedangkan IPS menambahkan kemampuan untuk mengambil tindakan pencegahan terhadap serangan yang terdeteksi.

Dalam konsep **Defense in Depth**, IPS sebaiknya dipadukan dengan firewall, endpoint protection, WAF, logging, SIEM, kontrol akses, dan incident response sehingga organisasi memiliki beberapa lapisan pertahanan.

4.5 Web Application Firewall (WAF)

Web Application Firewall (WAF) merupakan mekanisme keamanan yang dirancang untuk melindungi aplikasi web dari berbagai serangan yang dilakukan melalui lalu lintas HTTP atau HTTPS. WAF bekerja dengan memeriksa permintaan (*request*) dan respons aplikasi web berdasarkan aturan keamanan tertentu sebelum lalu lintas tersebut diteruskan ke aplikasi.

Berbeda dengan firewall jaringan yang terutama mengendalikan komunikasi berdasarkan alamat IP, port, protokol, atau aturan jaringan lainnya, WAF berfokus pada **lapisan aplikasi web**. WAF dapat membantu mendeteksi dan memblokir pola permintaan yang menunjukkan adanya upaya eksploitasi terhadap aplikasi.

Fungsi WAF

Beberapa fungsi utama WAF antara lain:

- Melindungi aplikasi web dari pola serangan yang umum.
- Memeriksa HTTP request dan response.
- Mendeteksi permintaan yang mencurigakan.

- Memblokir request yang memenuhi aturan serangan.
- Membantu melindungi aplikasi dari eksploitasi kerentanan tertentu.
- Mencatat aktivitas yang terindikasi sebagai serangan.
- Menjadi lapisan perlindungan tambahan bagi aplikasi yang dapat diakses melalui internet.

WAF sangat berguna terutama bagi organisasi yang menyediakan aplikasi web untuk publik, seperti portal layanan, sistem informasi, aplikasi administrasi, dan layanan digital lainnya.

Perbedaan Firewall dan WAF

Firewall jaringan dan WAF memiliki fungsi yang berbeda.

Firewall berfokus pada pengendalian lalu lintas jaringan.

WAF berfokus pada pemeriksaan lalu lintas menuju aplikasi web.

Gambaran sederhananya:

Firewall

Internet

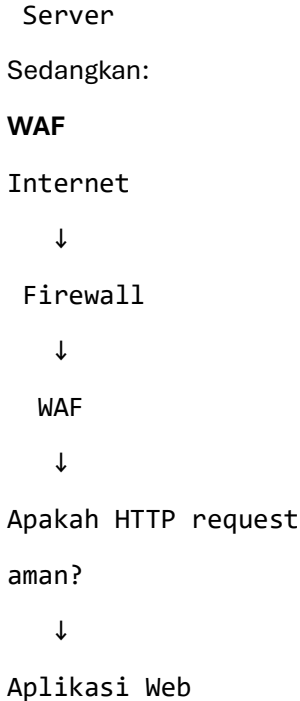


Firewall



Apakah koneksi
diperbolehkan?





Sebagai contoh, firewall dapat mengizinkan koneksi HTTPS menuju web server karena layanan tersebut memang harus tersedia untuk pengguna. WAF kemudian dapat melakukan pemeriksaan lebih lanjut terhadap isi request HTTP untuk mencari pola yang menunjukkan adanya serangan terhadap aplikasi.

Jenis Serangan yang Dapat Dibantu Dicegah

WAF dapat digunakan sebagai salah satu lapisan perlindungan terhadap berbagai jenis serangan aplikasi web, antara lain:

- SQL Injection.

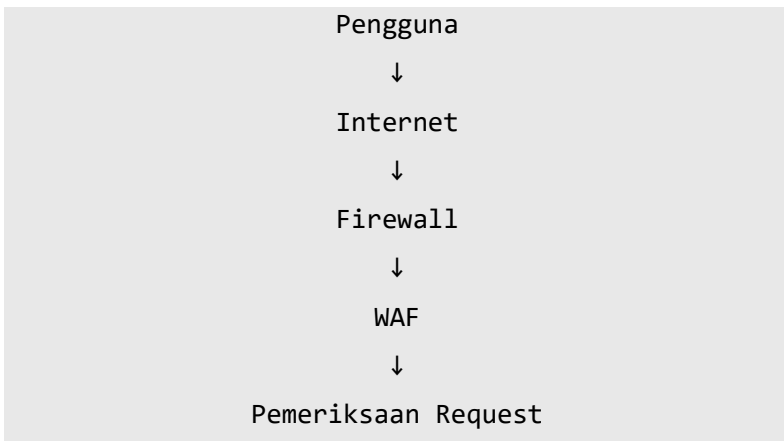
- Cross-Site Scripting (XSS).
- Local File Inclusion (LFI).
- Remote File Inclusion (RFI).
- Path Traversal.
- Command Injection.
- HTTP request yang tidak sesuai kebijakan.
- Eksploitasi pola serangan aplikasi web lainnya.

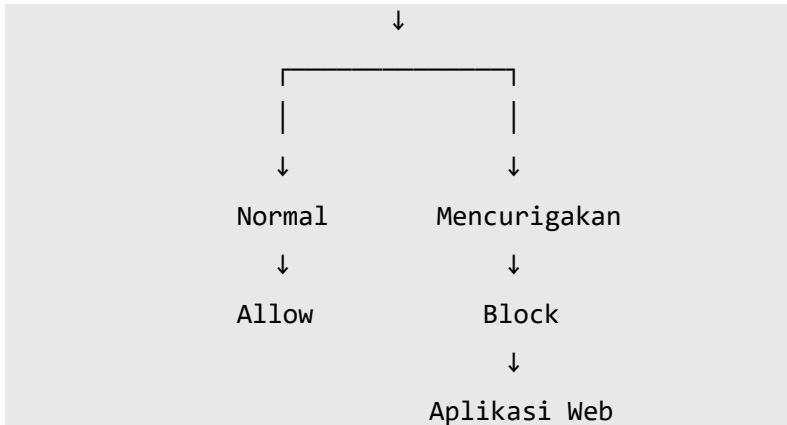
Kemampuan WAF bergantung pada konfigurasi, ruleset, mode deteksi, serta karakteristik aplikasi yang dilindungi.

WAF **bukan berarti aplikasi otomatis bebas dari kerentanan**. WAF merupakan lapisan perlindungan tambahan dan tidak menggantikan pengembangan aplikasi yang aman.

Cara Kerja WAF

Secara sederhana, WAF berada di antara pengguna dan aplikasi web.





Ketika pengguna mengakses aplikasi, request terlebih dahulu melewati WAF.

WAF kemudian melakukan pemeriksaan berdasarkan aturan keamanan yang telah ditentukan.

Jika request dianggap normal, request diteruskan ke aplikasi.

Jika request memenuhi pola serangan yang diblokir, WAF dapat menolak request tersebut dan mencatat aktivitasnya.

Contoh SQL Injection

Misalnya sebuah aplikasi memiliki fungsi pencarian data.

Pengguna normal mengirimkan request:

`/search?q=pegawai`

Request tersebut merupakan aktivitas yang umum.

Kemudian seseorang mencoba mengirimkan input yang memiliki pola SQL Injection.

`/search?q=' OR '1'='1`

Apabila pola tersebut sesuai dengan aturan deteksi WAF, WAF dapat memberikan peringatan atau memblokir request tersebut sebelum mencapai aplikasi.

Namun, perlu dipahami bahwa **WAF bukan pengganti penggunaan prepared statement atau parameterized query** pada aplikasi. Pencegahan utama SQL Injection tetap harus dilakukan pada kode aplikasi dan pengelolaan database yang aman.

Contoh Cross-Site Scripting (XSS)

Serangan XSS dapat terjadi ketika aplikasi tidak menangani input atau output pengguna dengan aman.

Sebagai contoh, penyerang mencoba memasukkan script melalui parameter aplikasi.

WAF dapat memiliki aturan yang mendeteksi pola tertentu yang menyerupai payload XSS dan memblokir request tersebut.

Namun, pengembang tetap harus menerapkan:

- Input validation.
- Output encoding.
- Content Security Policy bila sesuai.
- Praktik secure coding.

Dengan demikian, WAF berfungsi sebagai **lapisan tambahan**, bukan sebagai satu-satunya mekanisme keamanan aplikasi.

WAF dan Defense in Depth

Dalam konsep Defense in Depth, WAF memberikan

perlindungan khusus pada **lapisan aplikasi web**.

Contoh:

Internet



Firewall



WAF



Web Server



Application



Database

Setiap lapisan memiliki tanggung jawab berbeda.

- **Firewall** → mengendalikan lalu lintas jaringan.
- **WAF** → memeriksa lalu lintas aplikasi web.
- **Web server** → menjalankan layanan web.
- **Application** → menjalankan logika bisnis.
- **Database** → menyimpan data.

Apabila salah satu lapisan gagal mencegah serangan, lapisan lain masih dapat memberikan perlindungan tambahan.

WAF Tidak Hanya untuk Memblokir

Selain melakukan pemblokiran, WAF juga dapat memberikan **visibility** terhadap pola serangan yang ditujukan kepada aplikasi.

Log WAF dapat membantu administrator mengetahui:

- URL yang sering menjadi target.
- Jenis serangan yang dicoba.
- Alamat sumber serangan.
- Parameter yang menjadi target.
- Waktu serangan.
- Frekuensi serangan.
- Rule yang terpicu.

Informasi tersebut dapat digunakan sebagai bahan untuk melakukan analisis dan meningkatkan keamanan aplikasi.

Tantangan dalam Penggunaan WAF

WAF juga memiliki beberapa keterbatasan.

1. False Positive

Request yang sebenarnya sah dapat dianggap sebagai serangan.

Contohnya, aplikasi memiliki fitur yang memungkinkan pengguna memasukkan karakter tertentu yang secara kebetulan menyerupai pola serangan.

Jika rule terlalu ketat, request tersebut dapat diblokir dan mengganggu fungsi aplikasi.

2. False Negative

WAF juga dapat gagal mendeteksi serangan tertentu,

terutama jika serangan menggunakan teknik yang tidak dikenali oleh ruleset.

3. Konfigurasi

WAF membutuhkan konfigurasi dan penyesuaian terhadap karakteristik aplikasi.

Ruleset yang terlalu longgar dapat memberikan perlindungan yang kurang. Sebaliknya, ruleset yang terlalu ketat dapat menghasilkan banyak false positive.

4. Aplikasi yang Tidak Aman

WAF tidak dapat menggantikan secure coding.

Aplikasi tetap harus diperbaiki apabila memiliki kerentanan.

WAF dan Secure Coding

Penggunaan WAF sebaiknya ditempatkan sebagai **lapisan perlindungan tambahan**.

Keamanan aplikasi tetap harus dimulai dari proses pengembangan.

Contohnya:

Secure Coding



Input Validation



Authentication & Authorization



Secure Configuration



WAF



Monitoring

Pendekatan tersebut lebih kuat dibandingkan hanya mengandalkan WAF.

Jika aplikasi memiliki SQL Injection, misalnya, solusi utamanya adalah memperbaiki kode aplikasi. WAF dapat membantu mengurangi risiko eksploitasi sambil menunggu perbaikan atau menjadi lapisan tambahan setelah aplikasi diperbaiki.

Peran Administrator

Administrator atau pengelola WAF perlu:

- Memastikan WAF aktif dan berjalan.
- Memperbarui ruleset sesuai kebutuhan.
- Memantau log.
- Meninjau alert.
- Mengidentifikasi false positive.
- Menyesuaikan aturan dengan aplikasi.
- Mendokumentasikan perubahan konfigurasi.
- Melakukan pengujian setelah perubahan.
- Berkoordinasi dengan pengembang aplikasi apabila ditemukan serangan atau pola request yang

mencurigakan.

Peran Pengembang

Pengembang aplikasi juga memiliki tanggung jawab.

WAF tidak boleh digunakan sebagai alasan untuk mengabaikan keamanan aplikasi.

Pengembang tetap perlu menerapkan:

- Validasi input.
- Parameterized query.
- Authentication yang aman.
- Authorization.
- Output encoding.
- Manajemen session yang aman.
- Penanganan error yang tepat.
- Dependency yang diperbarui.
- Secure coding practice.

Dengan demikian, keamanan aplikasi dibangun sejak proses pengembangan dan kemudian diperkuat dengan lapisan keamanan tambahan seperti WAF.

Kesimpulan

Web Application Firewall (WAF) merupakan salah satu lapisan pertahanan yang penting untuk aplikasi web. WAF bekerja dengan memeriksa lalu lintas HTTP/HTTPS dan dapat mendeteksi serta memblokir request yang menunjukkan pola serangan tertentu.

WAF sangat berguna sebagai lapisan tambahan dalam **Defense in Depth**, tetapi tidak boleh dianggap sebagai pengganti keamanan aplikasi.

Prinsip yang perlu diingat adalah:

WAF melindungi aplikasi dari sisi lalu lintas, sedangkan secure coding melindungi aplikasi dari sisi pembuatannya.

Kombinasi keduanya memberikan perlindungan yang lebih baik dibandingkan hanya mengandalkan salah satunya.

4.6 Endpoint Detection and Response (EDR)

Endpoint Detection and Response (EDR) merupakan solusi keamanan yang digunakan untuk **memantau, mendeteksi, menganalisis, dan merespons aktivitas mencurigakan pada endpoint** seperti komputer pengguna, laptop, dan server.

Endpoint merupakan salah satu target penting dalam serangan siber karena menjadi tempat pengguna menjalankan aplikasi, membuka email, mengakses internet, dan mengolah data. Ketika endpoint berhasil dikompromikan, penyerang dapat menggunakan perangkat tersebut sebagai titik awal untuk melakukan aktivitas lebih lanjut di dalam jaringan organisasi.

EDR memberikan kemampuan monitoring yang lebih mendalam dibandingkan sekadar antivirus tradisional. EDR dapat mengumpulkan informasi mengenai proses, aktivitas file, koneksi jaringan, aktivitas pengguna, serta berbagai indikator lain yang dapat membantu mendeteksi dan menyelidiki ancaman.

Fungsi EDR

Beberapa fungsi utama EDR antara lain:

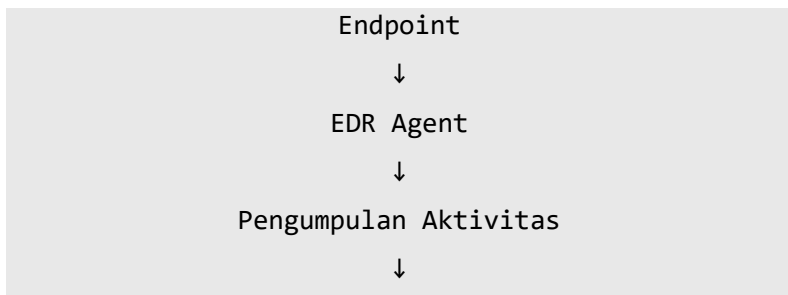
- Memantau aktivitas endpoint secara terus-menerus.
- Mendeteksi aktivitas yang mencurigakan.
- Mengumpulkan informasi mengenai proses dan aktivitas sistem.
- Mendeteksi indikasi malware.
- Membantu melakukan investigasi insiden.
- Memberikan peringatan kepada administrator atau tim keamanan.
- Membantu melakukan containment terhadap endpoint yang terindikasi terkompromikan.
- Menyediakan informasi untuk proses *incident response*.

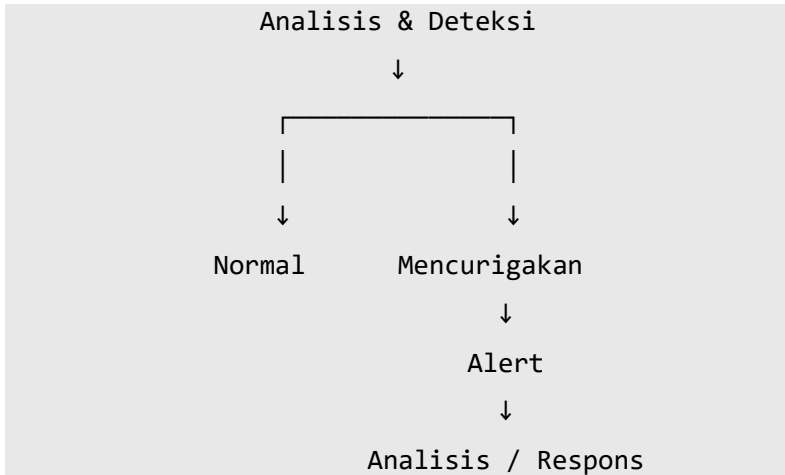
Dengan kemampuan tersebut, EDR membantu organisasi memperoleh **visibility** terhadap apa yang terjadi pada komputer pengguna dan server.

Cara Kerja EDR

EDR biasanya menggunakan komponen atau agent yang berjalan pada endpoint untuk mengumpulkan informasi aktivitas sistem.

Secara sederhana:





Informasi yang dikumpulkan dapat digunakan untuk mengetahui hubungan antara berbagai aktivitas.

Sebagai contoh:

Email



File Dibuka



Process Berjalan



PowerShell Berjalan



Koneksi ke Internet



Aktivitas Mencurigakan

Rangkaian aktivitas tersebut dapat memberikan gambaran yang lebih lengkap mengenai kemungkinan terjadinya serangan.

EDR dan Antivirus

EDR tidak berarti antivirus menjadi tidak diperlukan. Keduanya memiliki fungsi yang saling melengkapi.

Antivirus secara umum berfokus pada pencegahan dan deteksi malware berdasarkan berbagai mekanisme seperti signature, perilaku, dan reputasi file.

EDR memberikan kemampuan yang lebih luas dalam hal monitoring, analisis aktivitas endpoint, investigasi, dan respons terhadap insiden.

Perbandingan sederhananya:

Komponen	Fokus
----------	-------

Antivirus	Deteksi dan pencegahan malware
-----------	--------------------------------

EDR	Deteksi, investigasi, monitoring, dan respons endpoint
-----	--

EDR dapat memberikan konteks lebih luas mengenai **apa yang terjadi sebelum, selama, dan setelah aktivitas mencurigakan**.

Contoh Kasus

Seorang pegawai menerima email phishing yang berisi lampiran berbahaya. Pegawai tersebut membuka lampiran dan sebuah program mencurigakan mulai berjalan.

EDR pada komputer tersebut dapat mencatat rangkaian aktivitas:

Email Client



File Dibuka



Process Baru



Process Mencoba Mengubah File



Koneksi ke Server Eksternal



EDR Mendeteksi Aktivitas Mencurigakan



Alert

Administrator kemudian dapat melakukan pemeriksaan terhadap aktivitas tersebut.

Jika perangkat telah terindikasi terkompromikan, organisasi dapat melakukan tindakan seperti **isolasi endpoint dari jaringan**, menghentikan proses tertentu, atau melakukan investigasi lebih lanjut sesuai kemampuan produk dan prosedur organisasi.

Endpoint sebagai Titik Pertahanan

Endpoint perlu mendapatkan perhatian khusus karena

banyak aktivitas pengguna terjadi di perangkat tersebut.

Contohnya:

- Membuka email.
- Membuka dokumen.
- Mengakses website.
- Menggunakan aplikasi.
- Mengunduh file.
- Menggunakan USB.
- Mengakses server.
- Menggunakan VPN.

Karena itu, endpoint dapat menjadi titik masuk serangan sekaligus tempat penting untuk mendeteksi aktivitas penyerang.

EDR dalam Defense in Depth

Dalam konsep **Defense in Depth**, EDR memberikan lapisan perlindungan pada endpoint.

Contoh arsitektur sederhana:

Internet



Firewall



WAF



Application



Endpoint / Server



EDR



Monitoring / SIEM



Incident Response

Setiap lapisan memiliki fungsi yang berbeda.

- **Firewall** → mengendalikan lalu lintas jaringan.
- **WAF** → melindungi aplikasi web.
- **EDR** → memantau aktivitas endpoint.
- **SIEM** → membantu mengumpulkan dan menganalisis informasi keamanan.
- **Incident Response** → menangani kejadian yang telah teridentifikasi.

Dengan pendekatan tersebut, ketika serangan berhasil melewati satu lapisan, lapisan lainnya masih dapat memberikan kemampuan deteksi atau respons.

EDR dan Incident Response

Salah satu keunggulan EDR adalah kemampuannya membantu proses **investigasi insiden**.

Ketika sebuah endpoint menghasilkan alert, administrator dapat memeriksa:

- Process yang berjalan.
- File yang dibuat atau diubah.
- Koneksi jaringan.
- Aktivitas login.
- Perintah yang dijalankan.
- Waktu terjadinya aktivitas.
- Hubungan antara beberapa aktivitas.

Informasi tersebut dapat membantu menjawab pertanyaan:

Apa yang terjadi pada endpoint tersebut?

dan:

Sejauh mana endpoint tersebut telah terpengaruh?

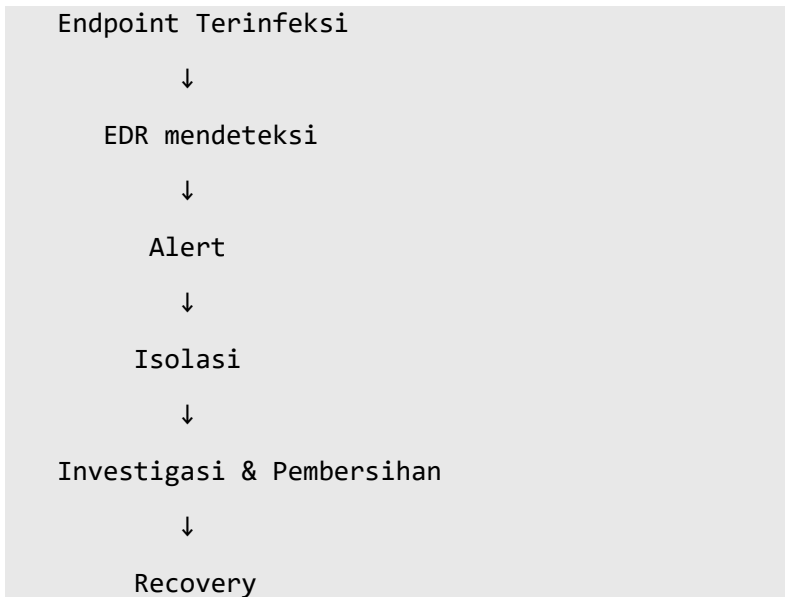
Informasi tersebut kemudian dapat digunakan untuk menentukan tindakan selanjutnya.

Containment

Dalam kondisi tertentu, EDR dapat membantu melakukan **containment**.

Contohnya, ketika sebuah komputer diduga terinfeksi malware, endpoint dapat diisolasi dari jaringan agar tidak mudah digunakan untuk menyebarkan serangan ke sistem lain.

Gambaran sederhananya:



Tujuan containment bukan langsung menyelesaikan seluruh insiden, tetapi **membatasi penyebaran dan memberikan waktu bagi tim keamanan untuk melakukan investigasi.**

Keterbatasan EDR

EDR juga memiliki keterbatasan.

Beberapa di antaranya:

- Tidak semua aktivitas berbahaya dapat dideteksi.
- Membutuhkan konfigurasi dan pemeliharaan.
- Alert tetap membutuhkan analisis.
- Dapat menghasilkan false positive.

- Endpoint yang tidak memiliki agent tidak mendapatkan perlindungan yang sama.
- Agent EDR sendiri perlu dilindungi agar tidak dinonaktifkan oleh penyerang.
- EDR tidak menggantikan firewall, WAF, backup, maupun kontrol keamanan lainnya.

Karena itu, EDR harus ditempatkan sebagai bagian dari **arsitektur keamanan berlapis**.

Peran Administrator

Administrator atau tim keamanan perlu:

- Memastikan endpoint penting telah terproteksi.
- Memastikan agent EDR berjalan dengan baik.
- Memantau alert.
- Melakukan investigasi terhadap aktivitas mencurigakan.
- Memastikan agent tetap diperbarui.
- Melakukan containment ketika diperlukan.
- Meninjau endpoint yang menunjukkan aktivitas tidak normal.
- Menghubungkan informasi EDR dengan sistem monitoring lainnya.
- Mendokumentasikan kejadian dan tindakan yang dilakukan.

Kesimpulan

Endpoint Detection and Response (EDR) memberikan

kemampuan untuk memantau, mendeteksi, menyelidiki, dan merespons aktivitas mencurigakan pada komputer pengguna maupun server.

EDR memiliki peran penting karena endpoint sering menjadi tempat pertama terjadinya aktivitas berbahaya setelah pengguna berinteraksi dengan email, file, website, atau aplikasi.

Namun, EDR bukan pengganti mekanisme keamanan lainnya. Perlindungan yang lebih baik diperoleh ketika EDR dikombinasikan dengan **firewall, WAF, kontrol akses, MFA, monitoring, SIEM, backup, dan incident response**.

Antivirus membantu melindungi endpoint dari malware, sedangkan EDR memberikan kemampuan yang lebih luas untuk melihat, mendeteksi, menyelidiki, dan merespons aktivitas mencurigakan pada endpoint.

4.7 Security Information and Event Management (SIEM)

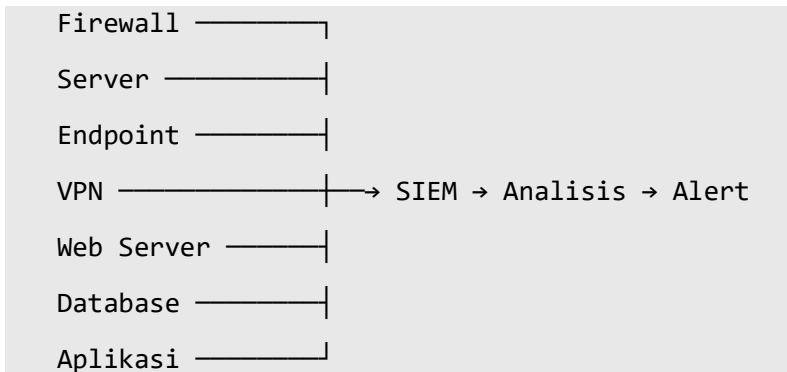
Security Information and Event Management (SIEM) merupakan solusi keamanan yang digunakan untuk **mengumpulkan, menggabungkan, menganalisis, dan memantau log serta informasi keamanan dari berbagai sumber dalam organisasi.**

Dalam lingkungan organisasi, informasi keamanan biasanya tersebar pada banyak perangkat dan aplikasi, seperti firewall, server, endpoint, aplikasi, database, VPN, dan perangkat jaringan. Jika setiap log diperiksa secara terpisah, administrator akan kesulitan melihat hubungan antara kejadian yang terjadi pada sistem yang berbeda.

SIEM membantu mengumpulkan informasi tersebut ke dalam satu lingkungan sehingga aktivitas keamanan dapat dianalisis secara lebih terpusat.

Mengapa SIEM Dibutuhkan?

Bayangkan sebuah organisasi memiliki beberapa sistem:



Tanpa SIEM, administrator mungkin harus memeriksa log masing-masing perangkat secara manual.

Dengan SIEM, berbagai sumber tersebut dapat dikumpulkan dan dianalisis dalam satu sistem.

Hal ini membantu organisasi memperoleh **centralized visibility** terhadap aktivitas keamanan.

Fungsi SIEM

Beberapa fungsi utama SIEM antara lain:

- Mengumpulkan log dari berbagai sumber.
- Menyimpan informasi keamanan secara terpusat.
- Menghubungkan kejadian dari berbagai sumber.

- Menganalisis pola aktivitas.
- Mendeteksi indikasi serangan.
- Menghasilkan alert.
- Membantu investigasi insiden.
- Menyediakan informasi untuk monitoring keamanan.
- Membantu menyediakan laporan dan audit keamanan.

SIEM tidak hanya melihat satu kejadian secara terpisah, tetapi dapat membantu melihat **hubungan antara beberapa kejadian**.

Contoh Sederhana

Misalnya terjadi aktivitas berikut:

10:00 Login gagal berkali-kali

10:02 Login berhasil

10:03 Akses dari lokasi yang tidak biasa

10:05 Banyak file diakses

10:07 Koneksi ke alamat eksternal mencurigakan

Jika setiap aktivitas tersebut berada pada sistem yang berbeda, administrator mungkin tidak langsung menyadari bahwa semuanya berkaitan.

SIEM dapat mengumpulkan informasi tersebut dan membantu membentuk gambaran:

Login Gagal



Login Berhasil



Aktivitas Tidak Biasa



Akses Data



Koneksi Mencurigakan



SIEM



ALERT

Dengan demikian, SIEM membantu tim keamanan melihat **rangkaian kejadian**, bukan hanya satu log secara terpisah.

Log sebagai Sumber Informasi

SIEM sangat bergantung pada data yang dikirimkan oleh sistem lain.

Sumber log dapat berasal dari:

- Firewall.
- Router.
- Switch.

- Server.
- Endpoint.
- VPN.
- Web server.
- Database.
- Aplikasi.
- Sistem autentikasi.
- IDS/IPS.
- EDR.
- Cloud service.

Contohnya, firewall dapat mengirimkan informasi mengenai koneksi jaringan, sedangkan server dapat mengirimkan informasi mengenai login pengguna.

Ketika kedua informasi tersebut dianalisis bersama, tim keamanan dapat memperoleh konteks yang lebih lengkap.

Security Event dan Security Information

SIEM pada dasarnya menggabungkan dua kemampuan utama.

Security Information Management

Berfokus pada pengumpulan dan pengelolaan informasi keamanan seperti log dan event.

Security Event Management

Berfokus pada pemantauan serta analisis kejadian keamanan secara lebih aktif untuk membantu mendeteksi

ancaman.

Dalam implementasinya, kemampuan tersebut digabungkan dalam satu platform SIEM.

Korelasi Event

Salah satu kemampuan penting SIEM adalah **event correlation**.

Korelasi berarti menghubungkan beberapa event yang secara terpisah mungkin terlihat biasa, tetapi jika dilihat bersama dapat menunjukkan adanya aktivitas mencurigakan.

Contoh:

Firewall

↓

Koneksi mencurigakan

+

VPN

↓

Login dari lokasi tidak biasa

+

Server

↓

Aktivitas login administrator

↓

SIEM



Korelasi



Aktivitas mencurigakan

Korelasi tersebut dapat membantu mengurangi waktu yang dibutuhkan administrator untuk menemukan hubungan antara kejadian yang terjadi pada berbagai sistem.

SIEM dan Alert

Ketika SIEM menemukan pola yang sesuai dengan aturan atau indikator tertentu, sistem dapat menghasilkan **alert**.

Contohnya:

Terjadi banyak percobaan login gagal kemudian diikuti login berhasil pada akun yang sama.

Alert tersebut dapat menjadi tanda bahwa akun sedang menjadi target serangan *brute force* atau terdapat aktivitas login yang tidak biasa.

Namun, alert tidak selalu berarti serangan benar-benar terjadi. Tim keamanan tetap perlu melakukan analisis untuk menentukan apakah alert tersebut merupakan:

- Aktivitas normal.
- False positive.
- Aktivitas mencurigakan.
- Insiden keamanan.
- **SIEM dan Incident Response**

SIEM memiliki hubungan erat dengan proses **Incident Response**.

Ketika terjadi insiden, tim keamanan membutuhkan informasi untuk menjawab pertanyaan seperti:

- Kapan aktivitas dimulai?
- Akun apa yang digunakan?
- Dari mana aktivitas berasal?
- Sistem apa yang terdampak?
- Apa yang dilakukan oleh penyerang?
- Apakah penyerang berpindah ke sistem lain?
- Data apa yang kemungkinan telah diakses?

Log yang dikumpulkan oleh SIEM dapat membantu proses investigasi tersebut.

Contohnya:

SIEM



Deteksi Alert



Analisis Event



Identifikasi Sistem Terdampak



Investigasi

↓

Containment

↓

Recovery

Dengan demikian, SIEM tidak hanya berguna untuk mendeteksi ancaman, tetapi juga membantu menyediakan **bukti dan konteks** selama proses investigasi.

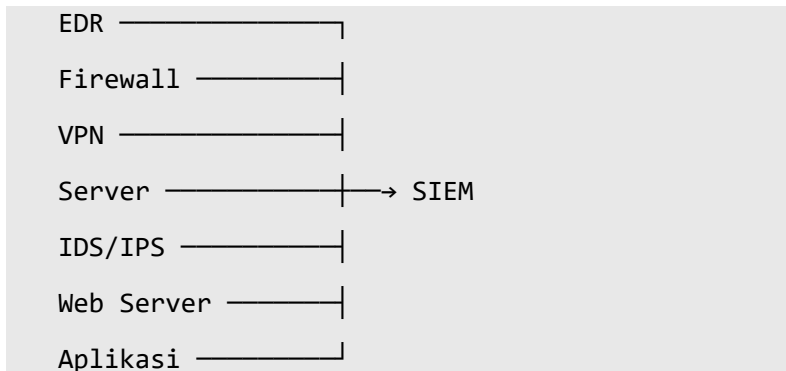
SIEM dan EDR

SIEM dan EDR memiliki fungsi yang berbeda tetapi dapat saling melengkapi.

EDR berfokus pada aktivitas endpoint.

SIEM mengumpulkan dan menganalisis informasi dari berbagai sumber.

Contohnya:



EDR dapat mendeteksi aktivitas mencurigakan pada sebuah komputer, sementara SIEM dapat menghubungkan aktivitas tersebut dengan event dari firewall, VPN, server, atau sistem

lainnya.

Dengan cara tersebut, organisasi dapat memperoleh konteks yang lebih luas.

Tantangan Implementasi SIEM

Penggunaan SIEM juga memiliki tantangan.

1. Banyaknya Log

Organisasi dapat menghasilkan log dalam jumlah sangat besar. Jika seluruh log dikumpulkan tanpa strategi yang jelas, volume data dapat menjadi sulit dikelola.

2. False Positive

Tidak semua alert menunjukkan serangan. Terlalu banyak false positive dapat menyebabkan **alert fatigue**.

3. Kualitas Log

SIEM hanya dapat menganalisis informasi yang tersedia. Jika sistem tidak menghasilkan log yang cukup atau log tidak dikirimkan dengan benar, kemampuan deteksi dapat berkurang.

4. Konfigurasi

Rule dan korelasi perlu disesuaikan dengan lingkungan organisasi. Konfigurasi yang tidak tepat dapat menghasilkan terlalu banyak atau terlalu sedikit alert.

5. Sumber Daya

SIEM membutuhkan sumber daya untuk pengelolaan, monitoring, penyimpanan, analisis, dan respons terhadap alert.

Peran Administrator dan Tim Keamanan

Pengelolaan SIEM tidak berhenti pada instalasi sistem.

Tim keamanan perlu:

- Menentukan sumber log yang penting.
- Memastikan log dikirim ke SIEM.
- Menentukan retensi log.
- Membuat dan menyesuaikan rule deteksi.
- Memantau alert.
- Melakukan investigasi.
- Menangani false positive.
- Melakukan review terhadap rule.
- Menjaga keamanan sistem SIEM.
- Mendokumentasikan kejadian penting.

SIEM yang hanya mengumpulkan log tanpa ada proses monitoring dan tindak lanjut tidak akan memberikan manfaat maksimal.

SIEM dalam Defense in Depth

Dalam konsep **Defense in Depth**, SIEM berperan terutama pada lapisan **visibility, detection, monitoring, dan investigation**.

Contoh sederhananya:

Firewall



IDS / IPS



WAF



EDR



SIEM



Analisis & Korelasi



Alert



Incident Response

SIEM dapat menjadi titik pengumpulan informasi dari berbagai lapisan keamanan tersebut.

Dengan demikian, organisasi tidak hanya memiliki perangkat keamanan yang bekerja secara terpisah, tetapi juga memiliki kemampuan untuk melihat kejadian keamanan secara lebih menyeluruh.

Kesimpulan

Security Information and Event Management (SIEM) merupakan salah satu komponen penting dalam keamanan siber karena membantu organisasi mengumpulkan dan menganalisis informasi keamanan dari berbagai sumber.

SIEM memberikan kemampuan untuk:

Mengumpulkan → Menghubungkan → Menganalisis → Mendeteksi → Memberikan Alert → Membantu Investigasi

SIEM bukan pengganti firewall, IDS, IPS, EDR, atau WAF. Sebaliknya, SIEM berfungsi **menghubungkan informasi dari berbagai lapisan keamanan tersebut** sehingga tim keamanan dapat memperoleh gambaran yang lebih lengkap mengenai kondisi lingkungan organisasi.

Dengan penerapan yang tepat, SIEM dapat membantu organisasi mendeteksi aktivitas mencurigakan lebih cepat, mempercepat investigasi, dan meningkatkan kemampuan dalam merespons insiden keamanan.

4.8 Access Control List (ACL)

Access Control List (ACL) adalah sekumpulan aturan yang digunakan untuk menentukan **siapa atau sumber mana yang diperbolehkan atau ditolak untuk mengakses suatu sumber daya**.

Dalam lingkungan jaringan, ACL umumnya digunakan pada firewall, router, switch, dan perangkat keamanan lainnya untuk mengendalikan lalu lintas berdasarkan kriteria tertentu. ACL membantu organisasi membatasi komunikasi hanya pada koneksi yang memang diperlukan.

ACL merupakan salah satu penerapan praktis dari prinsip **Access Control** dan **Least Privilege**. Dengan ACL, administrator dapat menentukan akses secara lebih spesifik daripada sekadar mengizinkan atau menolak seluruh lalu lintas.

Fungsi ACL

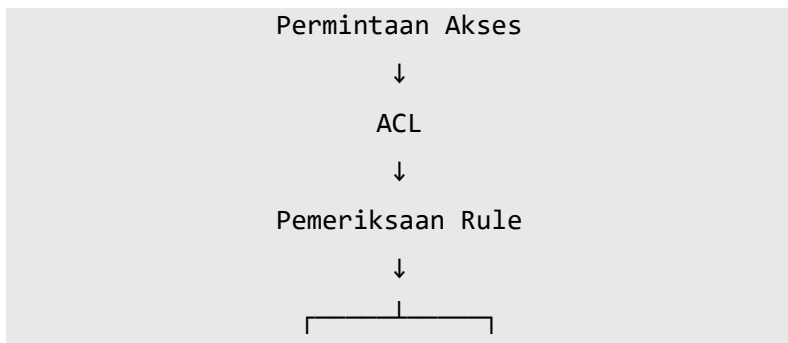
Beberapa fungsi ACL antara lain:

- Mengizinkan akses tertentu.
- Menolak akses tertentu.
- Membatasi sumber komunikasi.
- Membatasi tujuan komunikasi.
- Membatasi port dan protokol.
- Membatasi akses berdasarkan jaringan atau alamat IP.
- Membantu melakukan segmentasi jaringan.
- Mengurangi akses yang tidak diperlukan.
- Membantu menerapkan kebijakan keamanan jaringan.

Contohnya, administrator dapat membuat aturan agar hanya jaringan internal tertentu yang diperbolehkan mengakses server administrasi.

Cara Kerja ACL

Secara sederhana, ACL bekerja dengan mencocokkan lalu lintas atau permintaan akses terhadap aturan yang telah ditentukan.





Rule ACL dapat menggunakan beberapa parameter, misalnya:

- Source IP.
- Destination IP.
- Protocol.
- Source port.
- Destination port.
- Interface atau zona jaringan.
- Arah lalu lintas.

Kemampuan dan parameter yang tersedia dapat berbeda tergantung perangkat atau sistem yang digunakan.

Contoh Sederhana

Sebuah organisasi memiliki server aplikasi pada jaringan:

Server Aplikasi

10.10.20.10

Administrator hanya ingin mengizinkan jaringan administrator:

10.10.10.0/24

untuk mengakses layanan administrasi pada port tertentu.

Secara konseptual, aturan dapat dibuat seperti:

Source	Destination	Service	Action
10.10.10.0/24	10.10.20.10	Admin	ALLOW
Any	10.10.20.10	Admin	DENY

Dengan aturan tersebut, akses administrasi tidak tersedia secara bebas bagi seluruh jaringan.

ACL dan Prinsip Least Privilege

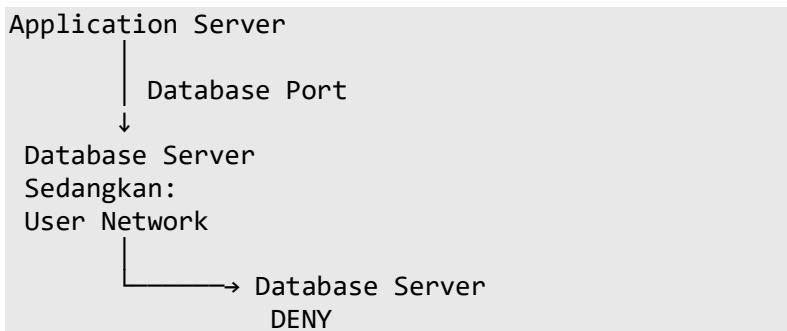
ACL sangat berkaitan dengan prinsip **Least Privilege**.

Prinsipnya:

Berikan akses hanya kepada pihak yang memang membutuhkan akses tersebut.

Misalnya, sebuah database digunakan oleh application server dan tidak perlu diakses langsung oleh seluruh komputer pegawai.

Maka akses dapat dibatasi:



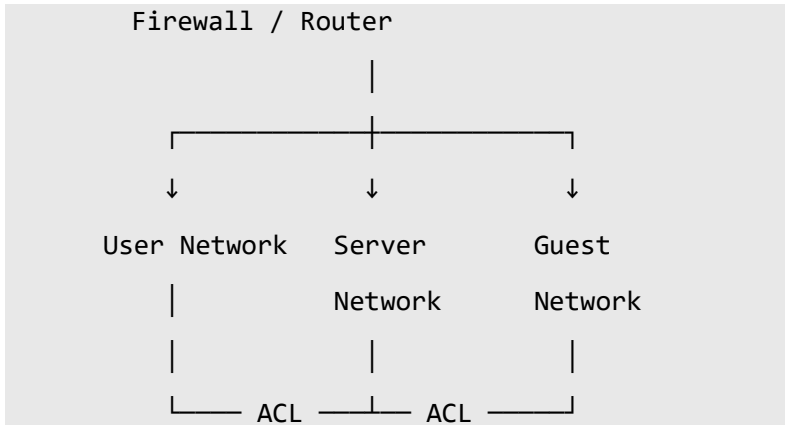
Dengan demikian, ACL membantu membatasi jalur

komunikasi yang tidak diperlukan.

ACL untuk Segmentasi Jaringan

ACL juga dapat digunakan untuk membantu menerapkan segmentasi jaringan.

Contohnya:



Tidak semua jaringan harus dapat berkomunikasi satu sama lain.

Sebagai contoh:

- User Network → Application Server: **ALLOW**
- Application Server → Database Server: **ALLOW**
- User Network → Database Server: **DENY**
- Guest Network → Internal Network: **DENY**

Pendekatan seperti ini dapat membatasi **lateral movement** apabila salah satu perangkat berhasil dikompromikan.

ACL dan Default Deny

ACL dapat diterapkan bersama prinsip **Default Deny**.

Artinya, akses yang tidak secara eksplisit diperbolehkan akan ditolak.

Contohnya:

ACL

↓

Rule 1 → Admin Network → Server → ALLOW

Rule 2 → App Server → Database → ALLOW

Rule 3 → Guest → Internal → DENY

Rule 4 → Other Traffic → DENY

Pendekatan ini dapat membantu mengurangi kemungkinan adanya akses yang tidak direncanakan.

Namun, administrator harus berhati-hati ketika menerapkan Default Deny karena aturan yang terlalu ketat dapat menyebabkan layanan yang sah ikut terblokir.

Urutan Rule Sangat Penting

Pada banyak implementasi ACL, **urutan rule dapat memengaruhi hasil pemeriksaan.**

Misalnya terdapat aturan:

Rule 1:

10.10.10.0/24 → Server → ALLOW

Rule 2:

Any → Server → DENY

Traffic dari 10.10.10.0/24 akan memenuhi Rule 1 dan diperbolehkan.

Jika aturan umum DENY ditempatkan sebelum aturan ALLOW, hasilnya dapat berbeda tergantung implementasi perangkat.

Karena itu, administrator perlu memahami mekanisme evaluasi rule pada perangkat yang digunakan.

Kesalahan dalam Pengelolaan ACL

ACL yang tidak dikelola dengan baik dapat menimbulkan masalah keamanan.

Beberapa kesalahan yang umum antara lain:

- Rule terlalu luas.
- Mengizinkan seluruh sumber (Any) tanpa alasan yang jelas.
- Membuka port yang tidak diperlukan.
- Rule lama tidak pernah dihapus.
- Rule yang saling bertentangan.
- Tidak mendokumentasikan tujuan rule.
- Tidak melakukan review secara berkala.
- Membuat pengecualian sementara tetapi lupa menghapusnya.

Contohnya, administrator sementara membuka akses:

Any → Server → Port tertentu → ALLOW

untuk kebutuhan troubleshooting.

Jika rule tersebut tidak dihapus setelah pekerjaan selesai, akses yang seharusnya sementara dapat menjadi akses permanen.

ACL dan Monitoring

ACL sebaiknya tidak hanya dibuat lalu dibiarkan tanpa pemeriksaan.

Administrator perlu mengetahui:

- Rule apa saja yang aktif.
- Rule mana yang sering digunakan.
- Rule mana yang sudah tidak diperlukan.
- Apakah terdapat traffic yang terus-menerus ditolak.
- Apakah terdapat percobaan akses yang mencurigakan.

Informasi tersebut dapat diperoleh dari log perangkat dan sistem monitoring.

ACL yang menghasilkan banyak koneksi yang ditolak dapat menjadi indikator bahwa terdapat kesalahan konfigurasi aplikasi atau bahkan aktivitas pemindaian dan serangan.

ACL Bukan Pengganti Firewall

ACL dan firewall memiliki hubungan yang erat, tetapi istilah ACL dapat digunakan dalam berbagai konteks.

ACL dapat ditemukan pada:

- Router.
- Switch.
- Firewall.

- Sistem operasi.
- File system.
- Aplikasi.

Dalam konteks jaringan, ACL merupakan salah satu mekanisme untuk menerapkan aturan akses.

Firewall biasanya menyediakan kemampuan yang lebih luas, seperti stateful inspection, NAT, VPN, application control, logging, dan fitur keamanan lainnya, tergantung jenis perangkat.

Peran Administrator

Administrator perlu:

- Membuat ACL berdasarkan kebutuhan yang jelas.
- Menggunakan prinsip Least Privilege.
- Membatasi source dan destination.
- Membatasi port dan protokol.
- Menghindari rule yang terlalu luas.
- Mendokumentasikan setiap rule.
- Melakukan review secara berkala.
- Menghapus rule yang sudah tidak diperlukan.
- Memonitor log.
- Menguji perubahan ACL sebelum diterapkan pada sistem kritis.

Setiap rule sebaiknya dapat menjawab pertanyaan:

Mengapa akses ini diperlukan?

Jika tidak ada alasan yang jelas, rule tersebut perlu dievaluasi kembali.

Kesimpulan

Access Control List (ACL) merupakan mekanisme penting untuk mengendalikan akses terhadap sumber daya dan komunikasi jaringan. Dengan ACL, organisasi dapat menentukan lalu lintas atau akses mana yang diperbolehkan dan mana yang harus ditolak.

ACL membantu menerapkan beberapa prinsip keamanan, terutama:

- **Least Privilege**
- **Default Deny**
- **Network Segmentation**
- **Access Control**

Namun, ACL harus dikelola secara hati-hati. Rule yang terlalu luas, tidak terdokumentasi, atau tidak pernah ditinjau dapat menjadi sumber risiko keamanan.

ACL yang baik bukan memberikan akses sebanyak mungkin, tetapi memberikan akses yang tepat sesuai kebutuhan.

4.9 Prinsip Least Privilege

Least Privilege adalah prinsip keamanan yang memberikan pengguna, aplikasi, perangkat, atau proses **hak akses minimum yang diperlukan untuk menjalankan tugasnya**.

Prinsip ini bertujuan mengurangi kemungkinan

penyalahgunaan akses dan membatasi dampak apabila akun atau sistem berhasil dikompromikan.

Dalam praktiknya, pengguna tidak seharusnya memperoleh akses hanya karena akses tersebut mudah diberikan. Akses harus disesuaikan dengan **tugas, tanggung jawab, dan kebutuhan pekerjaan**.

Mengapa Least Privilege Penting?

Setiap hak akses tambahan dapat menjadi potensi risiko apabila akun tersebut berhasil diambil alih.

Sebagai contoh, seorang pegawai hanya membutuhkan akses untuk membaca dan mengubah data administrasi. Namun, apabila akun tersebut juga diberikan hak untuk:

- Menghapus database.
- Membuat akun administrator.
- Mengubah konfigurasi server.
- Mengakses seluruh data organisasi.

maka dampak kompromi terhadap akun tersebut akan menjadi jauh lebih besar.

Dengan menerapkan Least Privilege, akses yang tidak diperlukan dapat dihilangkan.

Contoh Sederhana

Misalnya terdapat tiga kelompok pengguna:

Administrator



Mengelola sistem dan konfigurasi

Operator



Mengelola data operasional

Pegawai



Mengakses data sesuai kebutuhan pekerjaan

Setiap kelompok tidak harus memiliki hak akses yang sama.

Contohnya:

Pengguna	Akses yang Diperlukan
Administrator	Konfigurasi dan administrasi sistem
Operator	Input dan pengelolaan data operasional
Pegawai	Mengakses data sesuai tugas
Pengguna umum	Menggunakan layanan yang disediakan

Dengan pembagian tersebut, pengguna biasa tidak perlu mendapatkan hak administrator hanya untuk menjalankan pekerjaan sehari-hari.

Contoh pada Database

Misalnya sebuah aplikasi membutuhkan akses ke database.

Kesalahan yang berisiko adalah memberikan akun aplikasi hak penuh:

Application



Database



ALL PRIVILEGES

Padahal aplikasi mungkin hanya membutuhkan:

SELECT

INSERT

UPDATE

Maka hak yang tidak diperlukan seperti:

DROP

CREATE USER

GRANT

sebaiknya tidak diberikan kepada akun aplikasi apabila memang tidak diperlukan.

Dengan demikian, apabila kredensial aplikasi berhasil dicuri, ruang gerak penyerang menjadi lebih terbatas.

Contoh pada Server

Administrator juga sebaiknya membedakan antara **akun**

pengguna biasa dan akun administratif.

Penggunaan sehari-hari:

User Account



Aktivitas pekerjaan

Sedangkan pekerjaan administratif:

Admin Account



Administrasi sistem

Administrator tidak perlu menggunakan akun dengan hak tertinggi untuk aktivitas sehari-hari seperti membaca email atau mengakses website.

Pemisahan tersebut dapat mengurangi risiko apabila perangkat administrator terkena malware atau akun pengguna berhasil dikompromikan.

Least Privilege dan Hak Akses yang Berlebihan

Prinsip Least Privilege berkaitan langsung dengan pembahasan **Hak Akses yang Berlebihan** pada BAB 3.

Pada BAB 3 telah dijelaskan bahwa hak akses yang terlalu luas dapat memperbesar dampak ketika sebuah akun berhasil dikompromikan.

Di BAB 4, Least Privilege menjadi salah satu **mekanisme pertahanan** untuk mengurangi risiko tersebut.

Gambaran sederhananya:



Least Privilege pada Akun Administrator

Akun administrator memiliki hak yang sangat tinggi sehingga harus mendapatkan perlindungan lebih.

Beberapa praktik yang dapat diterapkan:

- Pisahkan akun administrator dari akun sehari-hari.
- Gunakan akun administrator hanya ketika diperlukan.
- Terapkan MFA.
- Batasi siapa yang memiliki hak administrator.
- Monitor aktivitas administrator.

- Hindari penggunaan satu akun administrator secara bersama-sama.
- Evaluasi hak administrator secara berkala.

Prinsipnya:

Hak istimewa hanya digunakan ketika benar-benar diperlukan.

Least Privilege pada Aplikasi

Least Privilege juga berlaku untuk aplikasi dan service, bukan hanya pengguna.

Sebuah aplikasi sebaiknya hanya memiliki akses terhadap:

- Database yang diperlukan.
- Folder yang diperlukan.
- API yang diperlukan.
- Port yang diperlukan.
- Resource yang diperlukan.

Sebagai contoh, aplikasi web yang hanya perlu membaca file tertentu tidak seharusnya diberikan akses tulis ke seluruh sistem file server.

Hal ini dapat membatasi dampak apabila aplikasi tersebut berhasil dieksploitasi.

Least Privilege pada Pihak Ketiga

Vendor atau pihak ketiga juga perlu mendapatkan akses berdasarkan kebutuhan.

Misalnya vendor hanya perlu melakukan pemeliharaan

terhadap satu server.

Tidak seharusnya vendor langsung diberikan:

Akses seluruh jaringan



Semua server



Semua database

Lebih baik:

Vendor



Akses terbatas



Server tertentu



Waktu tertentu

Jika memungkinkan, akses pihak ketiga juga dapat dibatasi berdasarkan sumber jaringan, waktu, metode autentikasi, dan kebutuhan pekerjaan.

Review Hak Akses

Least Privilege bukan berarti memberikan akses sekali kemudian tidak pernah memeriksanya lagi.

Hak akses perlu dievaluasi secara berkala.

Organisasi perlu memeriksa:

- Siapa yang memiliki akses?
- Sistem apa yang dapat diakses?
- Apa tingkat hak aksesnya?

- Apakah akses tersebut masih diperlukan?
- Apakah pengguna telah berpindah jabatan?
- Apakah terdapat akun yang sudah tidak digunakan?
- Apakah terdapat hak administrator yang tidak lagi diperlukan?

Hal ini penting untuk mencegah **privilege accumulation**, yaitu kondisi ketika hak akses pengguna terus bertambah tetapi tidak pernah dikurangi.

Least Privilege dan Siklus Pegawai

Prinsip ini juga berkaitan dengan siklus:

Joiner → Mover → Leaver

Ketika pegawai bergabung:

Berikan akses sesuai kebutuhan pekerjaan.

Ketika pegawai berpindah jabatan:

Evaluasi dan sesuaikan akses lama dengan tanggung jawab baru.

Ketika pegawai meninggalkan organisasi:

Cabut atau nonaktifkan seluruh akses yang tidak lagi diperlukan.

Dengan mekanisme tersebut, hak akses dapat tetap sesuai dengan kondisi aktual pengguna.

Tantangan Penerapan Least Privilege

Penerapan Least Privilege tidak selalu mudah.

Jika akses terlalu longgar, risiko keamanan meningkat.

Namun jika akses terlalu ketat, pekerjaan pengguna dapat terganggu.

Karena itu, organisasi perlu mencari keseimbangan antara:

Keamanan

dan

Kebutuhan operasional

Pemberian akses sebaiknya berdasarkan kebutuhan yang jelas dan dapat dipertanggungjawabkan, bukan sekadar berdasarkan permintaan pengguna.

Prinsip Praktis

Dalam menerapkan Least Privilege, organisasi dapat menggunakan pertanyaan sederhana:

"Apa akses minimum yang dibutuhkan untuk menyelesaikan pekerjaan ini?"

Bukan:

"Akses apa saja yang bisa kita berikan?"

Perbedaan cara berpikir tersebut sangat penting dalam membangun sistem keamanan yang baik.

Kesimpulan

Least Privilege merupakan prinsip dasar keamanan yang membatasi hak akses pengguna, aplikasi, perangkat, dan proses hanya pada kebutuhan yang diperlukan.

Prinsip ini dapat membantu:

- Mengurangi *attack surface*.

- Membatasi penyalahgunaan akun.
- Mengurangi dampak kompromi.
- Membatasi pergerakan penyerang.
- Mengurangi risiko kesalahan pengguna.
- Mencegah pemberian hak akses yang tidak diperlukan.

Least Privilege juga tidak berarti **"akses sesedikit mungkin tanpa mempertimbangkan pekerjaan"**, tetapi **"akses secukupnya sesuai kebutuhan pekerjaan"**.

Berikan hak akses yang diperlukan, bukan hak akses yang paling mudah diberikan.

4.10 Attack Surface

Attack Surface adalah seluruh titik, jalur, sistem, layanan, aplikasi, perangkat, dan komponen yang dapat menjadi tempat masuk atau dimanfaatkan oleh penyerang untuk menyerang organisasi.

Sederhananya, **attack surface menggambarkan seberapa banyak bagian dari lingkungan organisasi yang dapat menjadi target serangan.**

Semakin banyak sistem yang terhubung, layanan yang terbuka, aplikasi yang digunakan, akun yang memiliki akses, dan perangkat yang tidak dikelola dengan baik, semakin besar pula kemungkinan terdapat titik yang dapat dimanfaatkan oleh penyerang.

Contoh Attack Surface

Attack surface organisasi dapat mencakup berbagai

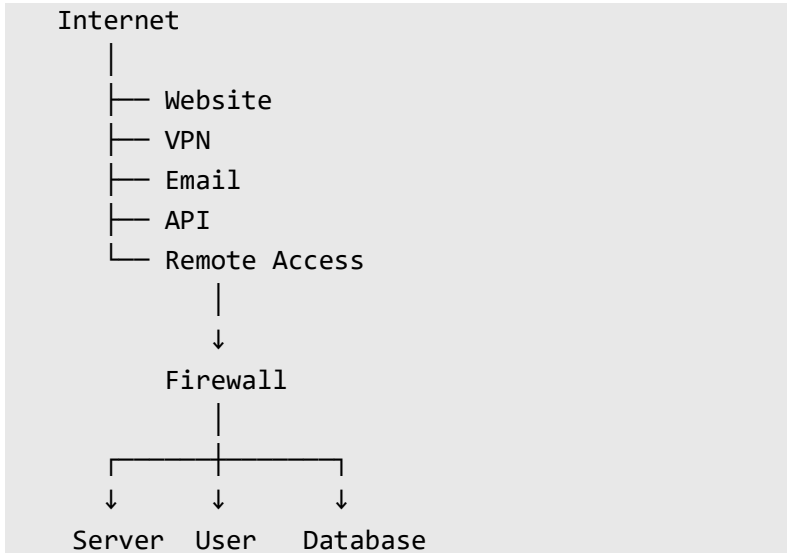
komponen, seperti:

- Website dan aplikasi web.
- Server.
- Database.
- Firewall dan perangkat jaringan.
- Komputer dan laptop pegawai.
- Smartphone.
- VPN.
- Email organisasi.
- Cloud service.
- API.
- Port dan service yang terbuka.
- Akun pengguna.
- Akun administrator.
- Perangkat IoT.
- Sistem pihak ketiga.
- Aplikasi dan library yang digunakan organisasi.

Tidak semua komponen tersebut secara otomatis merupakan kerentanan. Namun, setiap komponen yang dapat berinteraksi dengan pengguna, jaringan, atau sistem lainnya dapat menjadi bagian dari **attack surface**.

Contoh Sederhana

Bayangkan sebuah organisasi memiliki:

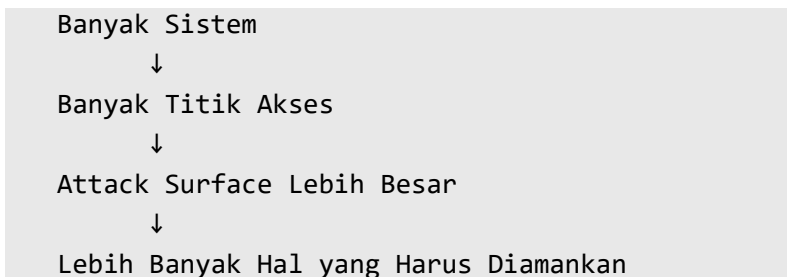


Semakin banyak layanan yang dapat diakses dari luar, semakin banyak pula titik yang perlu diamankan.

Misalnya organisasi tidak lagi membutuhkan sebuah layanan lama, tetapi layanan tersebut masih aktif dan dapat diakses dari internet. Layanan tersebut tetap menjadi bagian dari attack surface meskipun tidak lagi digunakan.

Attack Surface dan Risiko

Hubungan sederhananya dapat digambarkan sebagai:





Potensi Risiko Meningkat

Namun, **attack surface yang besar tidak selalu berarti organisasi pasti tidak aman**. Organisasi dengan banyak sistem dapat tetap memiliki keamanan yang baik apabila seluruh aset dikelola, dipantau, dan dilindungi dengan tepat.

Sebaliknya, organisasi dengan sistem yang relatif sedikit tetap dapat memiliki risiko tinggi apabila terdapat satu sistem penting yang sangat rentan.

Faktor yang Memperbesar Attack Surface

Beberapa kondisi yang dapat memperbesar attack surface antara lain:

- Terlalu banyak layanan yang terbuka.
- Sistem lama yang masih aktif.
- Aplikasi yang tidak diperbarui.
- Akun yang tidak lagi digunakan tetapi masih aktif.
- Hak akses yang berlebihan.
- Port yang tidak diperlukan.
- Perangkat yang tidak terinventarisasi.
- Aplikasi pihak ketiga yang tidak dipantau.
- Sistem cloud yang salah konfigurasi.
- API yang tidak diamankan dengan baik.
- Perangkat pegawai yang tidak dikelola.
- Layanan administrasi yang dapat diakses dari jaringan

yang tidak terpercaya.

Hal-hal tersebut menunjukkan bahwa **pengurangan attack surface tidak hanya berkaitan dengan firewall.**

Attack Surface pada Aplikasi Web

Aplikasi web dapat memiliki beberapa titik yang perlu diamankan, misalnya:

```
Aplikasi Web
|
├─ Login
├─ API
├─ Upload File
├─ Search
├─ Form
├─ URL Parameter
├─ Authentication
└─ Administrative Panel
```

Setiap fungsi tersebut perlu diperiksa dari sisi keamanan.

Contohnya, fitur upload file dapat menjadi risiko apabila aplikasi tidak melakukan validasi file dengan benar. Demikian juga API dapat menjadi risiko apabila autentikasi dan authorization tidak diterapkan dengan baik.

Karena itu, pengurangan attack surface pada aplikasi dapat dilakukan dengan menonaktifkan fungsi yang tidak diperlukan dan membatasi akses terhadap fungsi yang bersifat sensitif.

Attack Surface pada Akun Pengguna

Akun juga merupakan bagian dari attack surface.

Semakin banyak akun yang memiliki akses ke sistem, semakin banyak kredensial yang harus dilindungi.

Risiko dapat meningkat apabila terdapat:

- Akun yang tidak digunakan.
- Akun mantan pegawai.
- Akun bersama.
- Akun administrator terlalu banyak.
- Password yang lemah.
- Tidak menggunakan MFA.
- Hak akses terlalu luas.

Karena itu, **identity dan access management** merupakan bagian penting dalam mengurangi attack surface.

Attack Surface dan Least Privilege

Pada subbab sebelumnya telah dibahas prinsip **Least Privilege**.

Prinsip tersebut berhubungan erat dengan attack surface.

Jika pengguna hanya memiliki akses terhadap sistem yang diperlukan:

Akses Terbatas



Titik yang Dapat Diakses Penyerang Lebih Sedikit



Dampak Kompromi Dapat Dibatasi

Sebaliknya, apabila sebuah akun memiliki akses ke banyak sistem, kompromi terhadap akun tersebut dapat memberikan penyerang lebih banyak peluang untuk bergerak di dalam lingkungan organisasi.

Attack Surface Management

Organisasi perlu mengetahui apa saja yang menjadi bagian dari attack surface mereka.

Proses tersebut dapat dimulai dengan:

1. Identifikasi aset

Mengetahui server, aplikasi, perangkat, akun, layanan cloud, dan sistem lainnya.

2. Inventarisasi

Mencatat informasi seperti alamat IP, hostname, pemilik sistem, versi software, dan fungsi sistem.

3. Identifikasi layanan

Mengetahui layanan dan port yang tersedia.

4. Penilaian risiko

Menentukan sistem mana yang memiliki risiko paling tinggi.

5. Pengurangan

Menonaktifkan sistem, akun, layanan, atau port yang sudah tidak diperlukan.

6. Monitoring

Memantau perubahan sehingga aset baru atau layanan baru dapat segera diketahui.

Contoh Pengurangan Attack Surface

Misalnya sebuah server memiliki layanan:

HTTP → digunakan

HTTPS → digunakan

SSH → digunakan untuk administrasi

FTP → tidak digunakan

Telnet → tidak digunakan

Database → hanya digunakan internal

Jika FTP dan Telnet tidak diperlukan, layanan tersebut sebaiknya dinonaktifkan.

Hasilnya:

Sebelum

HTTP ———|

HTTPS ———|

SSH ———|

FTP ———|

Telnet ———|

Database ———|

Sesudah

HTTP ————|
HTTPS ————|
SSH ————|
Database ————|

Dengan menghilangkan layanan yang tidak diperlukan, jumlah titik yang perlu diamankan menjadi lebih sedikit.

Prinsip Mengurangi Attack Surface

Beberapa prinsip yang dapat diterapkan:

- **Hapus yang tidak diperlukan.**
- **Nonaktifkan layanan yang tidak digunakan.**
- **Batasi akses dari jaringan yang tidak terpercaya.**
- **Gunakan Least Privilege.**
- **Perbarui sistem dan aplikasi.**
- **Hapus akun yang sudah tidak diperlukan.**
- **Batasi akses administrasi.**
- **Gunakan segmentasi jaringan.**
- **Monitor aset dan layanan.**
- **Lakukan review secara berkala.**

Prinsipnya bukan sekadar:

"Amankan semua yang ada."

Tetapi juga:

"Jangan biarkan sesuatu tetap terbuka apabila memang

tidak diperlukan."

Attack Surface Bukan Hanya Sistem yang Terlihat

Organisasi juga perlu memperhatikan **third-party attack surface**.

Misalnya organisasi menggunakan:

- Cloud provider.
- Payment gateway.
- Vendor aplikasi.
- API eksternal.
- Managed service.
- Remote support.
- Software pihak ketiga.

Walaupun sistem tersebut tidak sepenuhnya dikelola oleh organisasi, koneksi dan integrasinya dapat menjadi bagian dari risiko organisasi.

Karena itu, pihak ketiga juga perlu dievaluasi berdasarkan tingkat akses dan kebutuhan bisnisnya.

Kesimpulan

Attack Surface merupakan gambaran mengenai seluruh titik yang dapat menjadi sasaran atau jalur masuk bagi penyerang ke lingkungan organisasi.

Semakin banyak sistem, layanan, akun, perangkat, dan koneksi yang tidak diperlukan atau tidak dikelola dengan baik, semakin besar pula area yang harus diamankan.

Pengurangan attack surface dapat dilakukan dengan:

Inventarisasi → Evaluasi → Batasi → Nonaktifkan yang Tidak Diperlukan → Monitor

Konsep ini sangat berkaitan dengan **Least Privilege, Default Deny, Security by Design, dan Defense in Depth** yang akan dibahas pada bagian berikutnya.

Keamanan bukan hanya tentang melindungi sistem yang ada, tetapi juga mengurangi sebanyak mungkin sistem dan akses yang sebenarnya tidak diperlukan.s

4.11 Filosofi Default Deny (Tutup Semua, Buka yang Dibutuhkan)

Default Deny adalah prinsip keamanan yang menetapkan bahwa **akses atau lalu lintas yang tidak secara eksplisit diizinkan akan ditolak.**

Prinsip ini sering diringkas sebagai:

Tutup semua, buka yang dibutuhkan.

Artinya, organisasi tidak memulai dari kondisi semua akses diperbolehkan kemudian mencoba mencari mana yang harus ditutup. Sebaliknya, akses pada awalnya dianggap **tidak diizinkan**, kemudian hanya akses yang memang diperlukan untuk pekerjaan atau layanan yang dibuka.

Pendekatan ini membantu mengurangi kemungkinan adanya akses yang tidak disengaja atau tidak diperlukan.

Contoh Sederhana

Misalnya sebuah server memiliki beberapa layanan:

HTTP → Dibutuhkan

HTTPS → Dibutuhkan

SSH → Dibutuhkan untuk administrasi

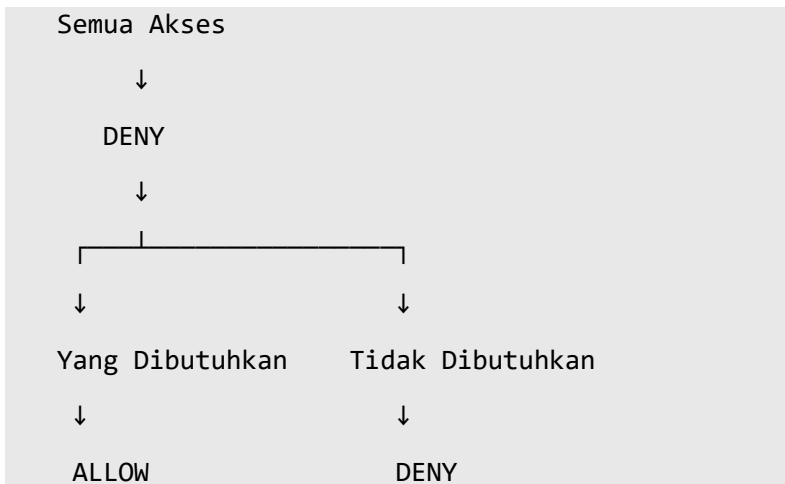
FTP → Tidak dibutuhkan

Telnet → Tidak dibutuhkan

Database → Hanya untuk jaringan internal

Dengan prinsip Default Deny, organisasi tidak perlu membuka seluruh layanan kemudian memblokir satu per satu.

Pendekatannya:



Hasilnya, hanya komunikasi yang memang diperlukan yang diberikan izin.

Default Deny pada Firewall

Dalam firewall, prinsip Default Deny dapat diterapkan melalui kebijakan akses.

Contohnya:

Source	Destination	Service	Action

Internet	Web Server	HTTPS	ALLOW
Admin Network	Server	SSH	ALLOW
App Server	Database	DB Port	ALLOW
Guest Network	Internal Network	Any	DENY
Any	Internal Network	Any	DENY

Pada contoh tersebut, akses HTTPS dari internet diperbolehkan karena web server memang harus tersedia untuk publik.

Sebaliknya, akses yang tidak memiliki kebutuhan bisnis atau teknis yang jelas tidak diberikan izin.

Mengapa Default Deny Penting?

Tanpa prinsip Default Deny, konfigurasi keamanan dapat berkembang menjadi terlalu permisif.

Misalnya:

ALLOW Internet → Server

ALLOW User → Server

ALLOW Vendor → Server

ALLOW Any → Port tertentu

Jika aturan seperti ini terus bertambah tanpa dilakukan review, organisasi dapat memiliki banyak jalur akses yang sebenarnya tidak diperlukan.

Default Deny memaksa administrator untuk menjawab pertanyaan:

"Mengapa akses ini harus dibuka?"

Jika tidak ada alasan yang jelas, akses tersebut seharusnya tidak diberikan.

Default Deny dan Least Privilege

Default Deny memiliki hubungan yang sangat erat dengan **Least Privilege**.

Least Privilege menjawab:

Siapa yang membutuhkan akses dan seberapa besar aksesnya?

Sedangkan **Default Deny** membantu menjawab:

Akses apa yang harus ditolak apabila tidak ada izin yang diberikan?

Contohnya:

Least Privilege



Admin → hanya akses administrasi

User → hanya akses pekerjaan

App → hanya akses database yang diperlukan



Default Deny



Akses lainnya → DENY

Keduanya dapat digunakan bersama untuk membatasi hak akses secara lebih ketat.

Default Deny dan Attack Surface

Pada subbab sebelumnya telah dibahas **Attack Surface**.

Default Deny membantu mengurangi attack surface dengan membatasi jalur komunikasi yang tersedia.

Contohnya:

Sebelum



Dengan demikian, layanan yang tidak diperlukan tidak perlu tersedia bagi pihak luar.

Contoh pada Aplikasi

Konsep Default Deny juga dapat diterapkan pada aplikasi.

Misalnya sebuah aplikasi memiliki beberapa fungsi:

Dashboard

Laporan

Data Pegawai

Administrasi

Manajemen User

Tidak semua pengguna harus dapat mengakses seluruh fungsi tersebut.

Contohnya:

Pegawai



Dashboard

Laporan

Administrator



Dashboard

Laporan

Data Pegawai

Administrasi

Manajemen User

Jika pengguna tidak memiliki hak terhadap fungsi tertentu, akses tersebut ditolak.

Dengan pendekatan ini, aplikasi tidak hanya mengandalkan tampilan menu untuk menyembunyikan fitur, tetapi juga

menerapkan **authorization** pada sisi sistem.

Default Deny Bukan Berarti Semua Harus Ditutup Selamanya

Prinsip Default Deny bukan berarti organisasi harus menutup seluruh akses sehingga sistem tidak dapat digunakan.

Maksudnya adalah:

Akses hanya dibuka ketika terdapat kebutuhan yang jelas dan dapat dipertanggungjawabkan.

Misalnya sebuah web server memang harus menyediakan HTTPS kepada pengguna internet. Maka akses tersebut dibuka.

Namun, akses administrasi server tidak harus ikut dibuka kepada seluruh internet apabila administrasi dapat dilakukan melalui jaringan internal, VPN, atau mekanisme akses khusus.

Kesalahan dalam Penerapan Default Deny

Penerapan Default Deny juga perlu dilakukan dengan hati-hati.

Beberapa kesalahan yang dapat terjadi:

- Memblokir layanan yang sebenarnya diperlukan.
- Tidak mendokumentasikan alasan rule.
- Membuat terlalu banyak pengecualian.
- Membuka akses terlalu luas untuk mengatasi masalah sementara.
- Lupa menghapus rule sementara.
- Tidak melakukan pengujian setelah perubahan.
- Tidak melakukan review terhadap rule.

Contohnya, administrator mengalami masalah aplikasi kemudian membuka:

ANY → SERVER → ANY

untuk melakukan troubleshooting.

Jika rule tersebut dibiarkan tanpa batas waktu, prinsip Default Deny menjadi tidak efektif.

Penerapan yang Baik

Untuk menerapkan Default Deny dengan baik, organisasi dapat melakukan beberapa langkah:

1. **Identifikasi kebutuhan akses.**
2. **Tentukan akses yang benar-benar diperlukan.**
3. **Tolak akses lainnya secara default.**
4. **Dokumentasikan setiap pengecualian.**
5. **Uji perubahan sebelum diterapkan pada sistem kritis.**
6. **Monitor aktivitas yang ditolak.**
7. **Review rule secara berkala.**
8. **Hapus pengecualian yang sudah tidak diperlukan.**

Dengan proses tersebut, Default Deny tidak hanya menjadi konfigurasi teknis, tetapi menjadi bagian dari kebijakan keamanan organisasi.

Contoh dalam Lingkungan Organisasi

Misalnya terdapat tiga jaringan:

User Network

10.10.10.0/24

Server Network

10.10.20.0/24

Guest Network

10.10.30.0/24

Kebutuhan komunikasi:

User → Application Server ALLOW

Application → Database ALLOW

Admin → Server ALLOW

Guest → Internal Network DENY

User → Database DENY

Internet → Database DENY

Dengan Default Deny, komunikasi yang tidak tercantum sebagai kebutuhan tidak diberikan akses.

Hal tersebut membantu membatasi kemungkinan penyerang menggunakan satu sistem yang berhasil dikompromikan untuk mengakses sistem lainnya.

Default Deny dalam Defense in Depth

Default Deny merupakan salah satu prinsip yang memperkuat **Defense in Depth**.

Contohnya:



Setiap mekanisme memiliki fungsi berbeda, tetapi semuanya bertujuan mengurangi kemungkinan akses yang tidak sah.

Kesimpulan

Default Deny merupakan prinsip keamanan yang sederhana tetapi sangat penting:

Tutup semua yang tidak diperlukan, kemudian buka hanya akses yang memang dibutuhkan.

Dengan pendekatan ini, organisasi dapat mengurangi akses yang tidak diperlukan, memperkecil attack surface, dan membatasi kemungkinan penyerang memanfaatkan jalur komunikasi yang terbuka.

Default Deny sebaiknya diterapkan bersama **Least Privilege, ACL, segmentasi jaringan, MFA, monitoring, dan Defense in Depth.**

Yang perlu diingat adalah bahwa keamanan bukan hanya tentang:

"Apa yang kita izinkan?"

tetapi juga:

"Apa yang seharusnya tidak pernah diizinkan?"

4.12 Security by Design

Security by Design adalah pendekatan yang menempatkan keamanan sebagai bagian dari proses perancangan dan pembangunan sistem sejak awal, bukan sebagai tambahan setelah sistem selesai dibuat.

Dalam pendekatan ini, aspek keamanan sudah dipertimbangkan ketika organisasi menentukan kebutuhan, merancang arsitektur, mengembangkan aplikasi, memilih teknologi, hingga melakukan pengujian dan pemeliharaan sistem.

Prinsip dasarnya adalah:

Keamanan harus dirancang sejak awal, bukan ditambahkan setelah terjadi masalah.

Mengapa Security by Design Penting?

Sistem yang sejak awal tidak mempertimbangkan keamanan dapat menghasilkan berbagai kelemahan yang sulit diperbaiki ketika sistem sudah digunakan.

Sebagai contoh, sebuah aplikasi dibangun tanpa mempertimbangkan:

- autentikasi;

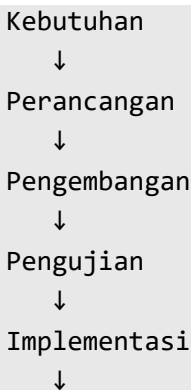
- authorization;
- validasi input;
- perlindungan data;
- logging;
- backup;
- pengelolaan session;
- pembaruan komponen.

Ketika aplikasi sudah digunakan, perbaikan terhadap kelemahan tersebut dapat membutuhkan perubahan arsitektur, kode, database, atau proses bisnis.

Sebaliknya, apabila keamanan sudah menjadi bagian dari desain sejak awal, risiko dapat dipertimbangkan sebelum sistem digunakan.

Security by Design dalam Siklus Pengembangan

Security by Design sebaiknya diterapkan sepanjang siklus hidup sistem.



Monitoring



Pemeliharaan

Pada setiap tahap, aspek keamanan perlu dipertimbangkan.

1. Tahap Perencanaan

Sebelum sistem dibangun, organisasi perlu memahami:

- Data apa yang akan diproses?
- Siapa yang menggunakan sistem?
- Siapa yang boleh mengakses data?
- Apa risiko terhadap data tersebut?
- Sistem apa yang akan terhubung?
- Apa konsekuensi apabila sistem mengalami gangguan?

Pertanyaan tersebut membantu menentukan kebutuhan keamanan sejak awal.

2. Tahap Perancangan

Pada tahap desain, organisasi dapat menentukan:

- Arsitektur jaringan.
- Segmentasi sistem.
- Mekanisme autentikasi.
- Authorization.
- Pengelolaan hak akses.
- Enkripsi.

- Logging.
- Backup.
- Mekanisme monitoring.
- Mekanisme pemulihan.

Dengan demikian, keamanan tidak bergantung pada keputusan yang dibuat secara terburu-buru setelah sistem berjalan.

3. Tahap Pengembangan

Pada tahap pengembangan aplikasi, keamanan perlu menjadi bagian dari proses pembuatan kode.

Contohnya:

- Validasi input.
- Parameterized query.
- Pengelolaan session.
- Password hashing.
- Authorization.
- Secure error handling.
- Pengelolaan secret.
- Dependency management.

Pengembang sebaiknya tidak menganggap keamanan sebagai pekerjaan yang hanya dilakukan setelah aplikasi selesai.

4. Tahap Pengujian

Sebelum sistem digunakan, fungsi keamanan perlu diuji.

Contohnya:

- Apakah pengguna tanpa hak dapat mengakses data?
- Apakah authorization berjalan dengan benar?
- Apakah input berbahaya ditangani?
- Apakah login memiliki perlindungan yang memadai?
- Apakah log tercatat?
- Apakah backup dapat dipulihkan?

Pengujian keamanan membantu menemukan kelemahan sebelum sistem masuk ke lingkungan produksi.

5. Tahap Operasional

Security by Design tidak berhenti ketika aplikasi sudah digunakan.

Selama sistem beroperasi, organisasi tetap perlu melakukan:

- Monitoring.
- Patch management.
- Review hak akses.
- Vulnerability assessment.
- Pengelolaan log.
- Backup.
- Incident response.
- Evaluasi konfigurasi.

Perubahan sistem juga perlu mempertimbangkan dampaknya terhadap keamanan.

Security by Design dan Least Privilege

Security by Design memiliki hubungan erat dengan **Least Privilege**.

Jika hak akses baru dipikirkan setelah sistem selesai dibuat, kemungkinan desain awal sudah terlanjur memberikan akses terlalu luas.

Dengan Security by Design, kebutuhan akses dapat ditentukan sejak tahap perancangan.

Contohnya:

Aplikasi



Mebutuhkan Database



Tentukan akses sejak desain



Hanya akses database yang diperlukan



Least Privilege

Dengan demikian, prinsip keamanan sudah menjadi bagian dari arsitektur sistem.

Security by Design dan Default Deny

Prinsip **Default Deny** juga dapat dipertimbangkan sejak

tahap desain.

Misalnya sebuah aplikasi memiliki beberapa fungsi:

User

└─ Dashboard	→ ALLOW
└─ Laporan	→ ALLOW
└─ Administrasi	→ DENY
└─ Manajemen User	→ DENY

Akses administrasi tidak diberikan kepada pengguna biasa hanya karena sistem memungkinkan akses tersebut.

Akses diberikan berdasarkan kebutuhan dan peran pengguna.

Security by Design dan Defense in Depth

Security by Design juga mendukung konsep **Defense in Depth**.

Ketika sistem dirancang, organisasi dapat menentukan beberapa lapisan keamanan sejak awal:

Authentication



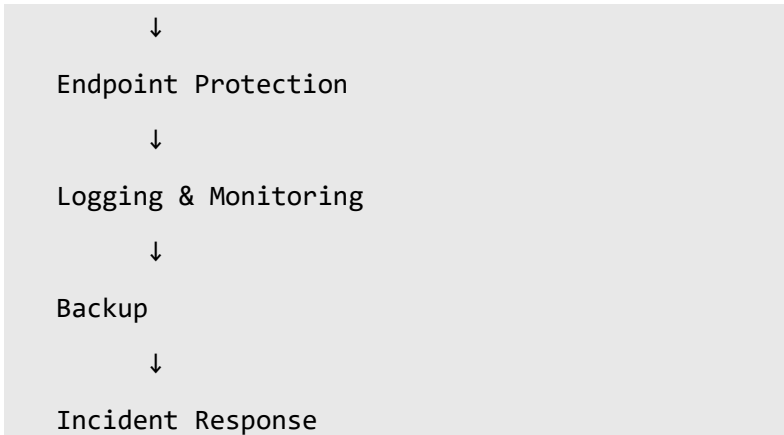
Authorization



Firewall



WAF



Dengan demikian, pertahanan tidak ditambahkan secara terpisah setelah sistem selesai, tetapi menjadi bagian dari arsitektur sistem.

Security Bukan Hanya Tanggung Jawab Tim IT

Security by Design membutuhkan keterlibatan berbagai pihak.

Contohnya:

Manajemen

Menentukan kebutuhan bisnis dan tingkat risiko yang dapat diterima.

Tim IT

Merancang infrastruktur dan kontrol keamanan.

Pengembang

Menerapkan keamanan pada aplikasi dan kode.

Administrator

Mengelola konfigurasi dan operasional sistem.

Pengguna

Menggunakan sistem sesuai prosedur keamanan.

Dengan pendekatan tersebut, keamanan menjadi tanggung jawab bersama.

Contoh Sederhana

Sebuah organisasi akan membangun aplikasi untuk menyimpan data pegawai.

Jika keamanan baru dipikirkan setelah aplikasi selesai, kemungkinan muncul masalah seperti:

Aplikasi selesai



Baru memikirkan keamanan



Ditemukan banyak kelemahan



Perbaikan mahal dan kompleks

Dengan Security by Design:

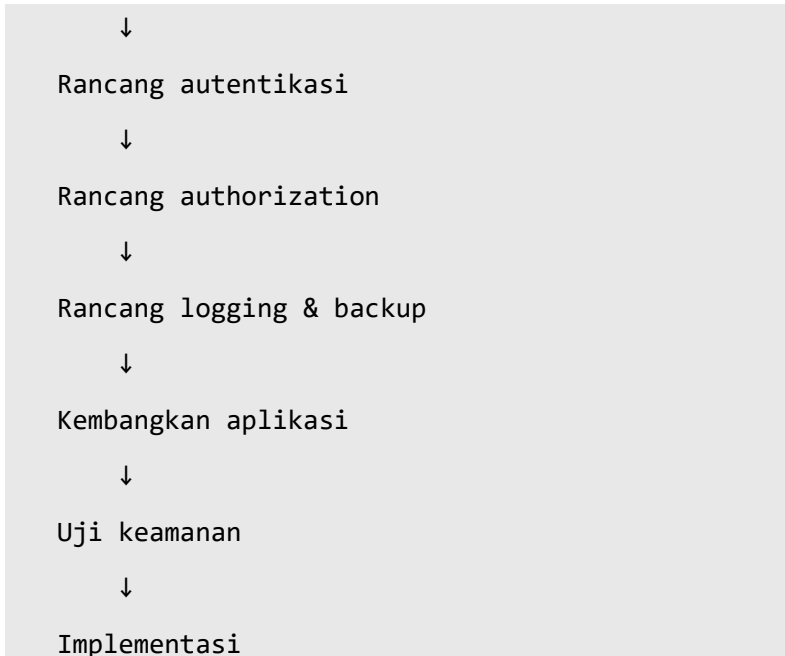
Kebutuhan



Identifikasi data sensitif



Tentukan hak akses



Keamanan menjadi bagian dari proses sejak awal.

Security by Design Bukan Berarti Sistem Tidak Bisa Diserang

Penerapan Security by Design tidak menjamin sistem menjadi bebas dari kerentanan.

Tujuannya adalah **mengurangi risiko dengan memasukkan pertimbangan keamanan ke dalam setiap tahap pembangunan dan pengelolaan sistem.**

Kerentanan baru tetap dapat ditemukan setelah sistem digunakan. Karena itu, monitoring, patching, vulnerability management, dan incident response tetap diperlukan.

Prinsip Praktis Security by Design

Beberapa pertanyaan sederhana dapat digunakan ketika merancang sistem:

- Data apa yang harus dilindungi?
- Siapa yang membutuhkan akses?
- Apa akses minimum yang diperlukan?
- Apa yang terjadi jika akun berhasil dikompromikan?
- Apa yang terjadi jika sistem mengalami gangguan?
- Bagaimana aktivitas pengguna dicatat?
- Bagaimana insiden akan dideteksi?
- Bagaimana data dipulihkan?
- Bagaimana sistem akan diperbarui?

Pertanyaan tersebut membantu memastikan keamanan tidak dilupakan ketika sistem dirancang.

Kesimpulan

Security by Design merupakan pendekatan yang menjadikan keamanan sebagai bagian dari proses perancangan, pengembangan, implementasi, dan pengelolaan sistem.

Pendekatan ini membantu organisasi mengurangi risiko karena aspek keamanan dipertimbangkan sebelum sistem digunakan, bukan hanya setelah terjadi insiden.

Security by Design juga memperkuat prinsip-prinsip yang telah dibahas sebelumnya, seperti:

- **Defense in Depth**
- **Least Privilege**

- **Default Deny**
- **Access Control**
- **Monitoring**
- **Backup dan Recovery**

Sistem yang aman bukan hanya sistem yang telah diperbaiki setelah diserang, tetapi sistem yang sejak awal dirancang dengan mempertimbangkan bagaimana sistem tersebut dapat disalahgunakan.

4.13 Zero Trust

Zero Trust adalah pendekatan keamanan yang tidak memberikan kepercayaan secara otomatis kepada pengguna, perangkat, aplikasi, maupun koneksi hanya berdasarkan lokasi atau jaringan tempat mereka berada.

Prinsip sederhananya adalah:

Never trust, always verify.

Artinya, setiap permintaan akses harus diverifikasi dan dinilai berdasarkan konteks sebelum akses diberikan.

Pendekatan ini berbeda dengan model keamanan tradisional yang sering membedakan antara jaringan **internal** yang dianggap terpercaya dan jaringan **eksternal** yang dianggap tidak terpercaya.

Dalam Zero Trust, berada di dalam jaringan organisasi **tidak otomatis berarti pengguna atau perangkat tersebut dapat dipercaya.**

Mengapa Zero Trust Dibutuhkan?

Lingkungan organisasi saat ini tidak lagi memiliki batas jaringan yang sederhana.

Pengguna dapat bekerja dari:

- Kantor.
- Rumah.
- Perangkat pribadi.
- Perangkat organisasi.
- Jaringan publik.
- Cloud.

Sementara aplikasi dan data dapat berada di:

- Data center.
- Cloud.
- Server internal.
- SaaS.
- Aplikasi web.
- Perangkat pengguna.

Kondisi tersebut membuat pendekatan yang hanya mengandalkan batas jaringan menjadi kurang memadai.

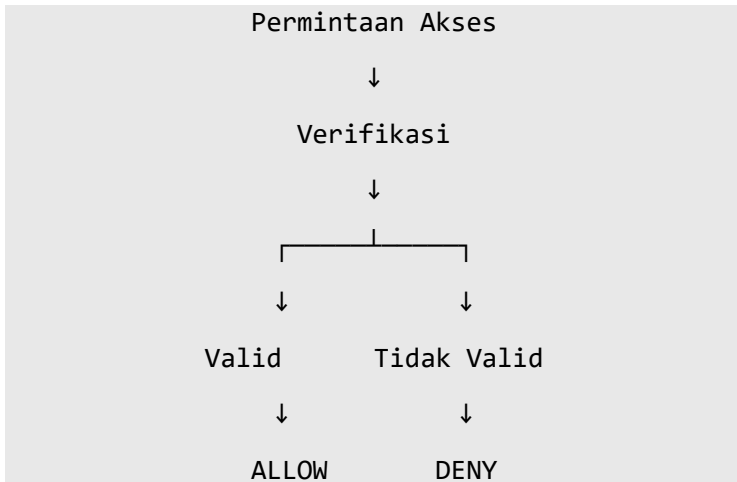
Sebagai contoh, apabila seorang penyerang berhasil mengambil alih satu akun pengguna, penyerang tidak seharusnya langsung mendapatkan akses ke seluruh sistem hanya karena akun tersebut berhasil masuk ke jaringan internal.

Prinsip Dasar Zero Trust

Zero Trust dapat dipahami melalui beberapa prinsip utama.

1. **Never Trust, Always Verify**

Setiap akses harus diverifikasi.



Verifikasi dapat mempertimbangkan identitas pengguna, perangkat, lokasi, aplikasi, dan kondisi lainnya sesuai implementasi organisasi.

2. **Least Privilege**

Pengguna hanya mendapatkan akses yang diperlukan.

Zero Trust sangat berkaitan dengan prinsip **Least Privilege** yang telah dibahas pada Subbab 4.9.

Jika seorang pengguna hanya membutuhkan akses ke satu aplikasi, tidak perlu memberikan akses ke seluruh jaringan.

3. **Assume Breach**

Organisasi perlu menganggap bahwa **pelanggaran keamanan dapat terjadi**.

Dengan asumsi tersebut, sistem dirancang agar kompromi terhadap satu akun atau perangkat tidak secara otomatis memberikan akses luas kepada penyerang.

4. Continuous Verification

Verifikasi tidak hanya dilakukan sekali ketika pengguna melakukan login.

Kondisi akses dapat dievaluasi kembali berdasarkan perubahan risiko atau aktivitas pengguna.

Identitas Menjadi Bagian Penting

Dalam Zero Trust, **identity** menjadi salah satu komponen utama.

Sebelum memberikan akses, organisasi perlu mengetahui:

- Siapa pengguna tersebut?
- Apakah identitasnya valid?
- Apakah pengguna memiliki hak akses?
- Perangkat apa yang digunakan?
- Apakah perangkat memenuhi persyaratan keamanan?
- Aplikasi atau data apa yang ingin diakses?

Contohnya:

Pengguna



Autentikasi



Verifikasi MFA



Pemeriksaan Perangkat



Pemeriksaan Hak Akses



Akses ke Resource

Dengan demikian, login berhasil tidak otomatis berarti seluruh akses diberikan.

Zero Trust dan MFA

Multi-Factor Authentication (MFA) merupakan salah satu mekanisme yang dapat mendukung Zero Trust.

Misalnya pengguna memiliki username dan password yang benar.

Sistem masih dapat meminta faktor tambahan:

Username + Password



MFA



Verifikasi



Akses Diberikan

Jika password berhasil dicuri tetapi faktor kedua tidak tersedia bagi penyerang, kemungkinan pengambilalihan akun dapat dikurangi.

Namun, MFA sendiri **bukan Zero Trust**. MFA hanya salah satu kontrol yang dapat digunakan dalam pendekatan Zero Trust.

Zero Trust dan Segmentasi

Zero Trust juga berkaitan dengan pembatasan akses antar sumber daya.

Misalnya:

User



Application



Database

Pengguna tidak harus diberikan akses langsung ke database.

Aplikasi dapat menjadi perantara, sedangkan komunikasi ke database dibatasi hanya untuk aplikasi yang memang membutuhkannya.

Pendekatan tersebut membantu mengurangi kemungkinan **lateral movement** apabila salah satu akun atau perangkat berhasil dikompromikan.

Contoh Sederhana

Sebuah organisasi memiliki aplikasi internal yang sebelumnya hanya dapat diakses dari jaringan kantor.

Model tradisional mungkin menerapkan:

Masuk Jaringan Internal



TRUST



Akses Aplikasi

Dalam pendekatan Zero Trust:

Permintaan Akses



Identitas Diverifikasi



MFA



Perangkat Diperiksa



Hak Akses Diperiksa



Akses ke Aplikasi

Dengan demikian, pengguna yang berada di jaringan internal tetap harus memenuhi persyaratan keamanan yang ditentukan.

Zero Trust dan Perangkat

Identitas pengguna saja tidak selalu cukup.

Perangkat yang digunakan juga dapat menjadi faktor penilaian.

Misalnya:

- Apakah perangkat terdaftar?
- Apakah sistem operasinya masih didukung?
- Apakah security software aktif?
- Apakah perangkat memenuhi kebijakan organisasi?
- Apakah perangkat terindikasi terkompromikan?

Contohnya:

Pengguna Valid

+

Perangkat Tidak Aman

↓

Akses Dibatasi / Ditolak

Dengan pendekatan tersebut, organisasi tidak hanya bertanya:

"Siapa yang meminta akses?"

tetapi juga:

"Dari perangkat apa dan dalam kondisi seperti apa akses tersebut diminta?"

Zero Trust dan Monitoring

Zero Trust membutuhkan kemampuan monitoring yang baik.

Aktivitas pengguna dan perangkat perlu dipantau untuk

mengetahui perubahan kondisi atau aktivitas yang mencurigakan.

Misalnya:

Login Normal



Akses Tidak Biasa



Perubahan Risiko



Verifikasi Ulang



Akses Dibatasi

Informasi dari sistem seperti **EDR, firewall, IAM, dan SIEM** dapat membantu organisasi mendapatkan konteks mengenai aktivitas tersebut.

Zero Trust Bukan Produk

Hal penting yang perlu dipahami adalah **Zero Trust bukan sebuah perangkat atau produk tertentu.**

Zero Trust merupakan **pendekatan atau model keamanan** yang dapat diterapkan menggunakan kombinasi berbagai mekanisme.

Contohnya:

- Identity and Access Management.
- MFA.

- Least Privilege.
- Network segmentation.
- Endpoint security.
- Device security.
- Encryption.
- Logging.
- Monitoring.
- SIEM.
- Policy enforcement.

Karena itu, membeli satu produk yang menggunakan istilah "Zero Trust" tidak otomatis membuat organisasi telah menerapkan Zero Trust.

Zero Trust dan Defense in Depth

Zero Trust dapat menjadi bagian dari strategi **Defense in Depth**.

Contohnya:

Identity



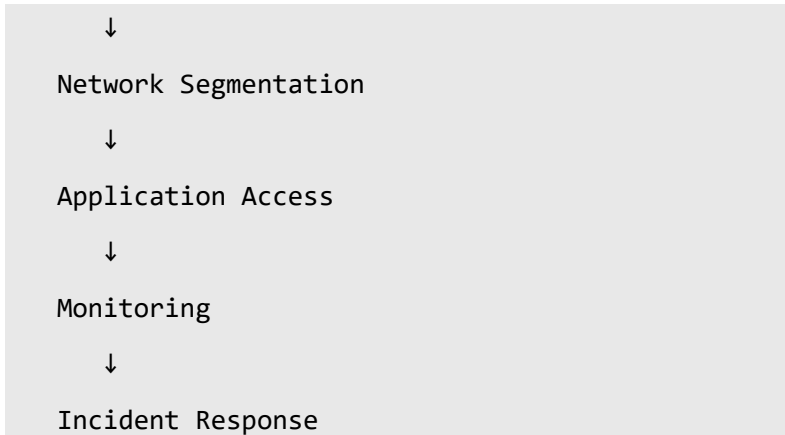
MFA



Least Privilege



Device Verification



Setiap lapisan memberikan kontrol tambahan terhadap akses.

Jika satu kredensial berhasil dicuri, kontrol lainnya masih dapat membatasi akses penyerang.

Tantangan Penerapan Zero Trust

Penerapan Zero Trust membutuhkan perubahan terhadap teknologi, proses, dan kebiasaan organisasi.

Beberapa tantangannya:

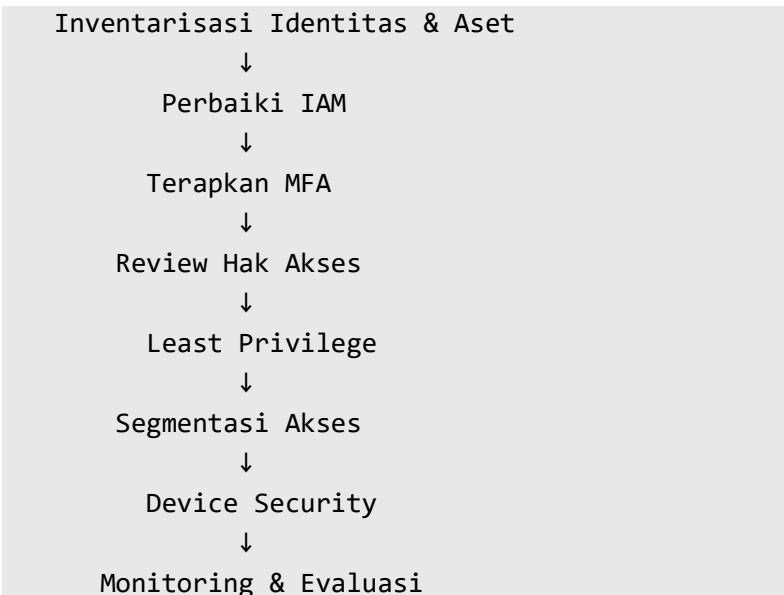
- Infrastruktur lama mungkin belum mendukung kontrol modern.
- Banyak aplikasi masih menggunakan model autentikasi tradisional.
- Inventarisasi aset belum lengkap.
- Identitas dan hak akses belum tertata.
- Segmentasi jaringan belum tersedia.

- Membutuhkan integrasi beberapa sistem keamanan.
- Pengguna perlu beradaptasi dengan mekanisme autentikasi tambahan.
- Membutuhkan monitoring dan pengelolaan yang berkelanjutan.

Karena itu, penerapan Zero Trust sebaiknya dilakukan secara bertahap berdasarkan prioritas risiko.

Contoh Tahapan Penerapan

Organisasi dapat memulai dari hal-hal dasar:



Pendekatan bertahap lebih realistis dibandingkan mencoba mengubah seluruh infrastruktur sekaligus.

Kesimpulan

Zero Trust merupakan pendekatan keamanan yang tidak memberikan kepercayaan otomatis berdasarkan lokasi jaringan atau keberadaan pengguna di dalam lingkungan organisasi.

Prinsip utamanya adalah:

Never Trust, Always Verify.

Zero Trust menekankan verifikasi identitas, pembatasan hak akses, pemeriksaan kondisi perangkat, segmentasi, monitoring, dan evaluasi akses secara berkelanjutan.

Zero Trust juga bukan pengganti firewall, MFA, EDR, SIEM, atau teknologi keamanan lainnya. Sebaliknya, berbagai teknologi tersebut dapat digunakan untuk mendukung penerapan Zero Trust.

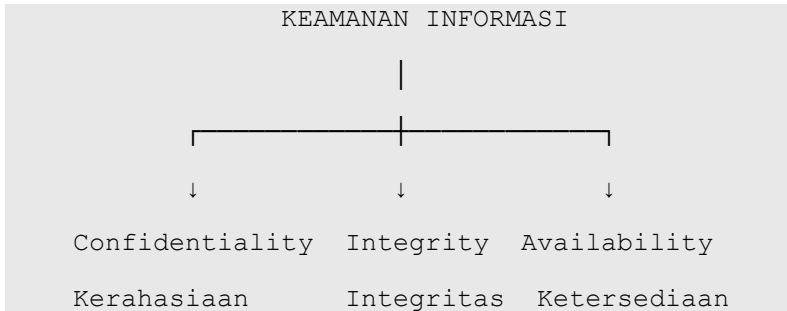
Berada di dalam jaringan organisasi tidak berarti otomatis dipercaya; setiap akses harus memiliki identitas, alasan, dan izin yang dapat diverifikasi.

4.14 CIA Triad (Confidentiality, Integrity, Availability)

CIA Triad merupakan salah satu konsep dasar dalam keamanan informasi yang digunakan untuk memahami tujuan utama perlindungan informasi dan sistem. CIA merupakan singkatan dari **Confidentiality, Integrity, dan Availability**.

Ketiga aspek tersebut menjadi dasar dalam menentukan bagaimana informasi harus dilindungi, siapa yang boleh mengaksesnya, bagaimana keakuratan informasi dijaga, serta bagaimana memastikan informasi dan layanan tetap tersedia ketika dibutuhkan.

Secara sederhana:



Ketiga aspek tersebut saling berkaitan. Sebuah sistem belum dapat dikatakan aman hanya karena data dirahasiakan. Data juga harus tetap benar dan tersedia bagi pihak yang memiliki hak untuk menggunakannya.

4.14.1 Confidentiality (Kerahasiaan)

Confidentiality adalah prinsip yang memastikan bahwa informasi hanya dapat diakses oleh pihak yang **memiliki hak atau kewenangan**.

Tujuan utamanya adalah mencegah informasi diakses, dibaca, atau diberikan kepada pihak yang tidak berwenang.

Contoh informasi yang membutuhkan kerahasiaan tinggi antara lain:

- Data pribadi.
- Data pasien.
- Password.
- Informasi keuangan.
- Dokumen internal.

- Data kepegawaian.
- Informasi strategis organisasi.

Beberapa mekanisme yang dapat membantu menjaga confidentiality antara lain:

- Authentication.
- Authorization.
- MFA.
- Encryption.
- Access Control.
- Least Privilege.
- Network segmentation.

Contoh sederhana:

Data Sensitif



Authentication



Authorization



Pengguna Berhak



Akses Diberikan

Sedangkan pengguna yang tidak memiliki hak akses harus

ditolak.

Contoh Pelanggaran Confidentiality

Seorang pegawai dapat mengakses data pegawai lain meskipun data tersebut tidak diperlukan untuk pekerjaannya.

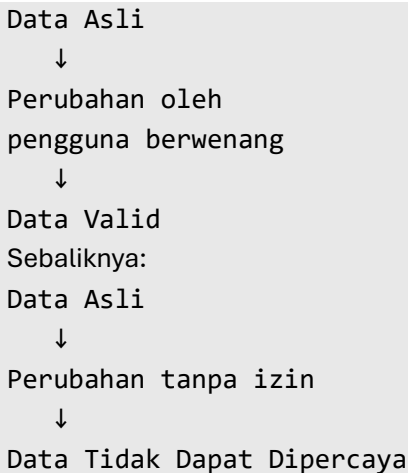
Kondisi tersebut menunjukkan adanya masalah pada **kontrol akses** dan dapat menyebabkan pelanggaran kerahasiaan.

4.14.2 Integrity (Integritas)

Integrity adalah prinsip yang memastikan bahwa informasi tetap **akurat, lengkap, dan tidak diubah secara tidak sah**.

Informasi yang dapat dipercaya bukan hanya informasi yang rahasia, tetapi juga informasi yang benar dan tidak mengalami perubahan tanpa kewenangan.

Contohnya:



Beberapa mekanisme yang dapat membantu menjaga integrity antara lain:

- Access control.
- Audit logging.
- Hashing.
- Digital signature.
- Version control.
- Database constraint.
- File integrity monitoring.
- Prosedur perubahan (*change management*).

Contoh Pelanggaran Integrity

Bayangkan sebuah sistem menyimpan nilai transaksi sebesar:

Rp10.000.000

Kemudian seseorang yang tidak memiliki kewenangan mengubahnya menjadi:

Rp100.000.000

Data tersebut masih tersedia dan mungkin masih tersimpan dengan baik, tetapi **integritasnya telah terganggu** karena informasi telah diubah tanpa kewenangan.

4.14.3 Availability (Ketersediaan)

Availability adalah prinsip yang memastikan informasi dan layanan dapat **diakses oleh pengguna yang berwenang ketika dibutuhkan**.

Informasi yang aman tetapi tidak dapat digunakan ketika dibutuhkan juga dapat menyebabkan masalah bagi organisasi.

Contohnya:

- Website layanan tidak dapat diakses.
- Database mengalami kerusakan.
- Server terkena ransomware.
- Jaringan mengalami gangguan.
- Data tidak dapat dipulihkan dari backup.

Beberapa mekanisme yang dapat mendukung availability antara lain:

- Backup.
- Disaster recovery.
- Redundancy.
- High availability.
- Monitoring.
- Load balancing.
- UPS.
- Failover.
- Capacity planning.
- **Contoh Pelanggaran Availability**

Sebuah aplikasi pelayanan publik harus tersedia selama jam kerja.

Jika server mengalami serangan DDoS dan aplikasi tidak dapat digunakan, maka aspek **availability** telah terganggu.

Demikian pula apabila ransomware mengenkripsi data

sehingga aplikasi tidak dapat beroperasi.

Hubungan Ketiga Aspek CIA

Ketiga aspek CIA tidak boleh dilihat sebagai bagian yang berdiri sendiri.

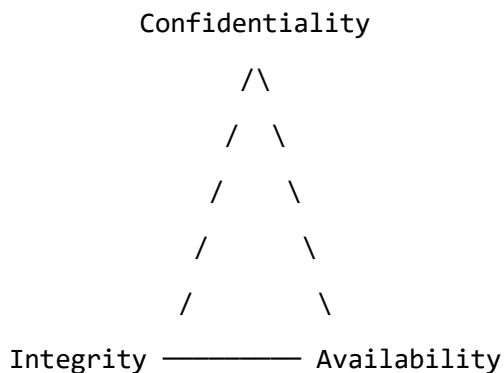
Contohnya, sebuah organisasi memiliki database yang sangat rahasia.

Organisasi kemudian membatasi akses secara ekstrem sehingga hanya satu administrator yang dapat mengakses database.

Confidentiality mungkin sangat baik, tetapi jika administrator tersebut tidak tersedia ketika sistem membutuhkan pemulihan, **availability** dapat menjadi masalah.

Sebaliknya, jika semua orang diberikan akses agar sistem mudah digunakan, availability mungkin baik tetapi confidentiality menjadi buruk.

Karena itu, organisasi perlu menemukan keseimbangan antara ketiganya.



Tujuan keamanan informasi adalah memastikan ketiga aspek tersebut mendapatkan perlindungan sesuai dengan kebutuhan dan tingkat risiko organisasi.

CIA Triad dan Serangan Siber

Berbagai jenis serangan dapat memengaruhi aspek CIA yang berbeda.

Serangan	Confidentiality	Integrity	Availability
Phishing	✓		
Data Breach	✓		
Malware	✓	✓	✓
Ransomware		✓	✓
DDoS			✓
Unauthorized Access	✓	✓	
Data Manipulation		✓	
Penghapusan Data		✓	✓

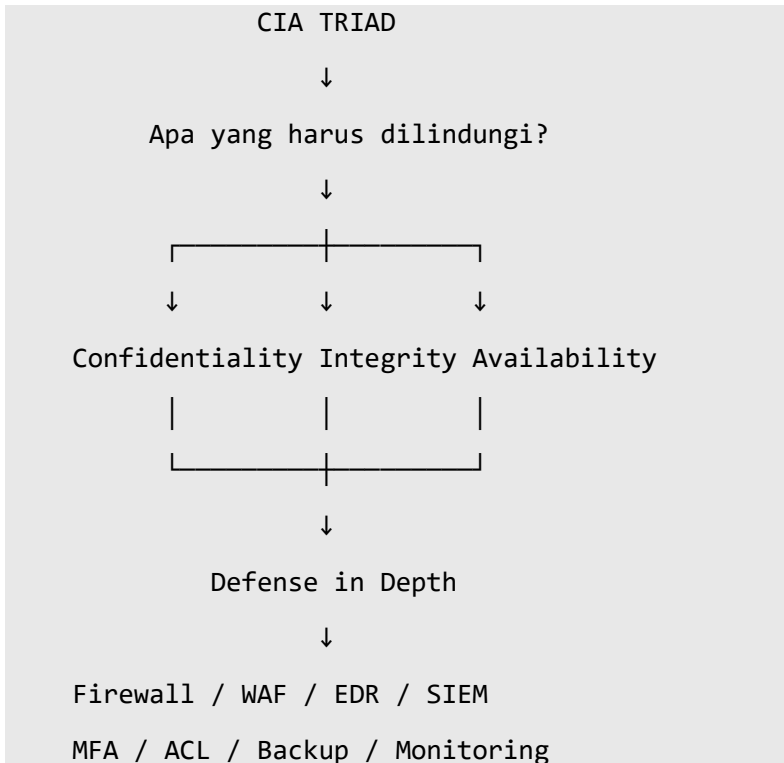
Satu serangan juga dapat memengaruhi lebih dari satu aspek.

Contohnya ransomware dapat menyebabkan data tidak dapat digunakan sehingga **availability** terganggu. Jika penyerang juga mengubah atau merusak data, **integrity** ikut terdampak. Apabila data kemudian dicuri sebelum dienkripsi, **confidentiality** juga dapat mengalami pelanggaran.

CIA Triad dalam Defense in Depth

CIA Triad membantu organisasi menentukan **apa yang ingin dilindungi**, sedangkan Defense in Depth membantu menentukan **bagaimana perlindungan tersebut dibangun dalam beberapa lapisan**.

Contohnya:



Dengan pendekatan tersebut, organisasi dapat menghubungkan tujuan keamanan dengan kontrol yang diterapkan.

Contoh Penerapan

Sebuah organisasi memiliki sistem informasi yang menyimpan data pegawai.

- **Confidentiality**

Hanya pegawai tertentu yang boleh mengakses data.

Kontrol yang digunakan:

- Authentication.
- MFA.
- Authorization.
- Least Privilege.

- **Integrity**

Data hanya dapat diubah oleh pengguna yang memiliki kewenangan.

Kontrol yang digunakan:

- Role-based access.
- Audit logging.
- Database control.
- Change management.

- **Availability**

Data dan aplikasi harus tetap tersedia ketika dibutuhkan.

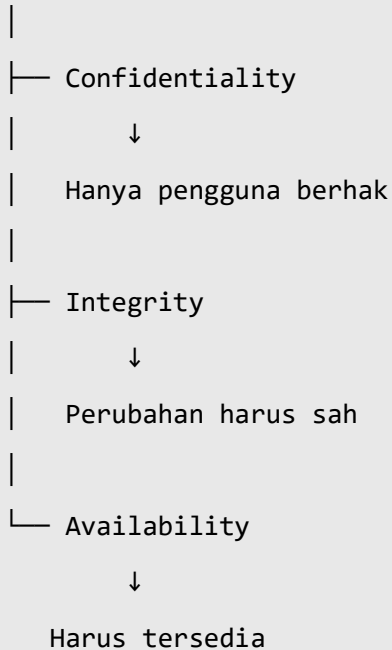
Kontrol yang digunakan:

- Backup.
- Monitoring.

- Redundancy.
- Disaster recovery.

Dengan demikian:

Data Pegawai



CIA Triad dan Pengelolaan Risiko

CIA Triad juga dapat membantu organisasi menentukan prioritas keamanan.

Tidak semua sistem memiliki kebutuhan yang sama.

Misalnya:

Sistem pelayanan publik

Availability mungkin menjadi prioritas tinggi karena layanan harus tetap dapat digunakan masyarakat.

Database data pribadi

Confidentiality mungkin menjadi prioritas sangat tinggi karena data harus dilindungi dari akses yang tidak sah.

Sistem keuangan

Integrity dapat menjadi prioritas tinggi karena perubahan data transaksi tanpa kewenangan dapat menimbulkan kerugian.

Namun, bukan berarti aspek lainnya dapat diabaikan. Ketiga aspek tetap perlu dipertimbangkan dalam penilaian risiko.

Kesimpulan

CIA Triad memberikan kerangka sederhana untuk memahami tiga tujuan utama keamanan informasi:

Confidentiality → informasi hanya dapat diakses oleh pihak yang berwenang.

Integrity → informasi tetap akurat dan tidak diubah secara tidak sah.

Availability → informasi dan layanan tersedia ketika dibutuhkan oleh pihak yang berwenang.

Ketiga aspek tersebut menjadi dasar dalam menentukan kontrol keamanan yang sesuai dengan kebutuhan organisasi.

BAB 4 yang dimulai dari **Defense in Depth**, kemudian membahas firewall, IDS, IPS, WAF, EDR, SIEM, ACL, Least Privilege, Attack Surface, Default Deny, Security by Design, dan Zero Trust, pada akhirnya ditutup dengan CIA Triad sebagai **kerangka untuk memahami tujuan perlindungan keamanan**

informasi.

Keamanan informasi bukan hanya tentang menjaga data agar tidak dicuri, tetapi juga memastikan data tetap benar dan tersedia ketika dibutuhkan.

BAB 5 MENJADI PENGGUNA YANG AMAN

5.1 Password yang Aman

Password merupakan salah satu mekanisme dasar untuk melindungi akun dan sistem informasi. Password digunakan untuk membuktikan bahwa seseorang memiliki kredensial yang sesuai untuk mengakses suatu layanan.

Namun, password yang digunakan dengan cara yang tidak aman dapat menjadi salah satu titik lemah keamanan. Password yang mudah ditebak, digunakan pada banyak layanan, atau dibagikan kepada orang lain dapat meningkatkan risiko pengambilalihan akun.

Dalam BAB 3 telah dibahas **Password yang Lemah** dan **Penggunaan Password yang Sama** sebagai salah satu penyebab insiden keamanan siber. Pada bab ini pembahasannya diarahkan pada **perilaku pengguna dalam membuat dan menggunakan password dengan aman**.

Ciri-Ciri Password yang Aman

Password yang baik sebaiknya:

- Memiliki panjang yang memadai.
- Tidak mudah ditebak.
- Tidak menggunakan informasi pribadi yang mudah diketahui.
- Tidak menggunakan pola sederhana seperti 123456 atau password.

- Tidak menggunakan satu password untuk banyak layanan.
- Tidak dibagikan kepada orang lain.
- Disimpan dengan cara yang aman.

Panjang password merupakan salah satu faktor penting. Password yang lebih panjang umumnya lebih sulit ditebak dibandingkan password yang pendek dan sederhana.

Hindari Informasi Pribadi

Pengguna sebaiknya tidak menggunakan informasi pribadi yang mudah diketahui sebagai password, misalnya:

Nama

Tanggal lahir

Nama pasangan

Nama anak

Nama instansi

Nomor telepon

Nama hewan peliharaan

Informasi tersebut sering kali dapat ditemukan atau ditebak dari media sosial maupun informasi publik lainnya.

Contoh password seperti:

Budi123

Brebes2026

Admin123

Password123

bukan pilihan yang baik karena menggunakan pola yang mudah ditebak.

Gunakan Password yang Berbeda

Salah satu kesalahan yang sering terjadi adalah menggunakan password yang sama untuk berbagai layanan.

Misalnya:

Email → Password A

Aplikasi → Password A

Media Sosial → Password A

VPN → Password A

Jika salah satu layanan mengalami kebocoran kredensial, penyerang dapat mencoba menggunakan kombinasi username dan password yang sama pada layanan lainnya.

Karena itu, setiap layanan penting sebaiknya menggunakan **password yang berbeda**.

Gunakan Passphrase

Salah satu pendekatan yang dapat digunakan adalah **passphrase**, yaitu rangkaian beberapa kata yang cukup panjang dan lebih mudah diingat oleh pengguna.

Contohnya, pengguna dapat membuat rangkaian kata yang tidak berkaitan dengan informasi pribadi dan tidak mudah ditebak.

Keuntungan passphrase adalah pengguna dapat memperoleh password yang panjang tanpa harus mengandalkan

kombinasi karakter pendek yang sulit diingat.

Namun, passphrase tetap harus unik dan tidak boleh menggunakan kutipan atau informasi yang mudah ditebak.

Jangan Membagikan Password

Password merupakan informasi autentikasi yang harus dijaga kerahasiaannya.

Pengguna sebaiknya tidak:

- Mengirim password melalui chat.
- Menulis password pada kertas yang ditempel di monitor.
- Menyimpan password dalam file teks tanpa perlindungan.
- Memberikan password kepada rekan kerja.
- Mengirim password melalui email tanpa mekanisme perlindungan.
- Menggunakan akun bersama jika sistem menyediakan akun individual.

Apabila seseorang membutuhkan akses ke sistem, sebaiknya diberikan **akun sendiri dengan hak akses sesuai kebutuhan**, bukan menggunakan password milik pengguna lain.

Gunakan Password Manager

Ketika seseorang memiliki banyak akun, menggunakan password yang berbeda untuk setiap layanan dapat menjadi sulit untuk diingat.

Password manager dapat digunakan untuk membantu menyimpan dan mengelola password secara aman.

Dengan password manager, pengguna tidak perlu mengingat seluruh password satu per satu. Pengguna cukup mengingat satu **master password** yang digunakan untuk membuka password manager.

Namun, master password harus mendapatkan perlindungan yang sangat baik karena menjadi kunci menuju kumpulan kredensial yang tersimpan.

Jangan Menyimpan Password di Tempat yang Tidak Aman

Password sebaiknya tidak disimpan dalam:

password.txt

password.docx

catatan tanpa perlindungan

spreadsheet tanpa perlindungan

pesan chat

email biasa

Jika password harus disimpan, gunakan mekanisme yang memang dirancang untuk pengelolaan kredensial.

Password dan MFA

Password sebaiknya tidak menjadi satu-satunya lapisan perlindungan untuk akun penting.

Multi-Factor Authentication (MFA) memberikan lapisan autentikasi tambahan.

Secara sederhana:

Username + Password



MFA



Akses Diberikan

Jika password berhasil dicuri, faktor autentikasi tambahan dapat membantu mencegah penyerang langsung mengambil alih akun.

Pembahasan MFA akan dijelaskan lebih lanjut pada **Subbab 5.2.**

Jangan Memasukkan Password pada Situs yang Tidak Terpercaya

Pengguna harus berhati-hati ketika diminta memasukkan password melalui tautan dari email, pesan, atau media sosial.

Sebelum memasukkan kredensial, periksa:

- Alamat website.
- Nama domain.
- Sertifikat/HTTPS.
- Konteks permintaan.
- Apakah halaman tersebut memang berasal dari layanan yang digunakan.

Penyerang dapat membuat halaman login palsu yang terlihat sangat mirip dengan halaman resmi.

Jika Password Diduga Bocor

Apabila pengguna menduga password telah diketahui orang

lain, password tersebut harus segera diganti.

Langkah yang dapat dilakukan:

1. Ganti password.
2. Gunakan password baru yang unik.
3. Jangan menggunakan kembali password lama.
4. Aktifkan MFA jika tersedia.
5. Periksa aktivitas login.
6. Laporkan kepada administrator apabila akun organisasi terlibat.
7. Periksa layanan lain apabila password yang sama pernah digunakan di sana.

Jika password yang sama digunakan pada beberapa layanan, seluruh layanan tersebut perlu diperiksa dan password-nya diganti dengan password yang berbeda.

Prinsip Sederhana Penggunaan Password

Pengguna dapat mengingat beberapa prinsip berikut:

Panjang, unik, rahasia, dan tidak digunakan ulang.

Secara sederhana:

Password Aman

- |
- └ Panjang
- └ Sulit ditebak
- └ Unik

- └─ Tidak dibagikan
- └─ Disimpan dengan aman
- └─ Dilindungi MFA

Kesimpulan

Password masih menjadi bagian penting dalam keamanan akun. Password yang kuat saja belum cukup apabila pengguna menggunakannya kembali pada banyak layanan, membagikannya kepada orang lain, atau memasukkannya ke halaman login palsu.

Kebiasaan yang perlu dibangun adalah:

- Gunakan password yang panjang dan sulit ditebak.
- Gunakan password yang berbeda untuk layanan yang berbeda.
- Gunakan password manager bila diperlukan.
- Jangan membagikan password.
- Jangan menyimpan password secara sembarangan.
- Aktifkan MFA.
- Segera ganti password apabila diduga telah bocor.

Password yang aman bukan hanya password yang sulit ditebak, tetapi juga password yang dikelola dengan cara yang aman.

5.2 Multi-Factor Authentication (MFA)

Multi-Factor Authentication (MFA) adalah mekanisme keamanan yang menggunakan **lebih dari satu faktor untuk**

memverifikasi identitas pengguna sebelum akses diberikan.

MFA memberikan lapisan perlindungan tambahan karena keamanan akun tidak hanya bergantung pada password.

Prinsip sederhananya:

Password benar belum tentu cukup untuk mendapatkan akses.

Jika password seseorang berhasil dicuri, penyerang masih harus melewati faktor autentikasi tambahan yang digunakan oleh akun tersebut.

Mengapa MFA Penting?

Password dapat dicuri melalui berbagai cara, misalnya:

- Phishing.
- Malware.
- Kebocoran data.
- Credential attack.
- Password reuse.
- Social engineering.

Tanpa MFA:

Username + Password



Akses Diberikan

Jika password diketahui penyerang, akun dapat langsung diambil alih.

Dengan MFA:

Username + Password



MFA



Verifikasi Berhasil



Akses Diberikan

Penyerang yang hanya memiliki password belum tentu dapat melewati faktor tambahan tersebut.

Faktor dalam MFA

Secara umum, autentikasi dapat menggunakan beberapa jenis faktor.

1. Something You Know

Sesuatu yang diketahui oleh pengguna.

Contohnya:

- Password.
- PIN.
- Passphrase.

2. Something You Have

Sesuatu yang dimiliki oleh pengguna.

Contohnya:

- Smartphone.
- Security key.
- Token autentikasi.
- Perangkat yang telah didaftarkan.

3. Something You Are

Sesuatu yang merupakan karakteristik pengguna.

Contohnya:

- Sidik jari.
- Pengenalan wajah.
- Karakteristik biometrik lainnya.

MFA menggabungkan faktor yang berbeda untuk meningkatkan keyakinan bahwa orang yang sedang melakukan login memang pengguna yang sah.

Contoh Penggunaan MFA

Misalnya seorang pegawai melakukan login ke aplikasi organisasi.

Tahap pertama:

Username

+

Password

Setelah password benar, sistem meminta faktor kedua:

Kode autentikasi

atau

Persetujuan pada aplikasi autentikator

atau

Security Key

Setelah faktor kedua berhasil diverifikasi, akses diberikan.

MFA Bukan Sekadar Password + Password

Hal penting yang perlu dipahami adalah bahwa menggunakan **dua password** bukanlah penerapan MFA yang sebenarnya.

Contohnya:

Password 1

+

Password 2

Keduanya masih termasuk faktor **something you know**.

MFA menggunakan faktor autentikasi yang berbeda, misalnya:

Password

+

Authenticator App

atau:

Password

+

Security Key

Contoh Metode MFA

Beberapa metode yang umum digunakan antara lain:

Authenticator App

Aplikasi autentikator menghasilkan kode atau memberikan permintaan persetujuan login.

Security Key

Perangkat fisik digunakan untuk melakukan autentikasi.

Biometric

Sistem menggunakan karakteristik biometrik seperti sidik jari atau pengenalan wajah.

One-Time Password (OTP)

Kode sekali pakai digunakan sebagai faktor tambahan.

Untuk lingkungan organisasi, pilihan metode MFA sebaiknya disesuaikan dengan kebutuhan keamanan, jenis sistem, kemampuan pengguna, serta risiko yang dihadapi.

Jangan Sembarangan Menyetujui Permintaan MFA

MFA dapat membantu melindungi akun, tetapi pengguna tetap harus berhati-hati.

Misalnya pengguna tiba-tiba menerima beberapa permintaan persetujuan login:

"Approve sign-in?"

↓

Pengguna tidak sedang login

↓

DENY



Laporkan jika diperlukan

Jangan menyetujui permintaan MFA yang tidak dilakukan oleh pengguna sendiri.

Penyerang dapat mencoba membuat pengguna menyetujui permintaan autentikasi yang sebenarnya berasal dari aktivitas login penyerang.

Jangan Memberikan Kode OTP

Kode OTP harus diperlakukan seperti password.

Jika seseorang meminta:

"Kirimkan kode OTP yang baru masuk ke HP Anda."

jangan berikan kode tersebut.

Kode tersebut dapat digunakan untuk menyelesaikan proses autentikasi.

Prinsip sederhananya:

Kode MFA adalah rahasia. Jangan diberikan kepada siapa pun.

MFA dan Perangkat Organisasi

Untuk akun organisasi, MFA sebaiknya diterapkan terutama pada akun yang memiliki akses penting, seperti:

- Administrator sistem.
- Administrator jaringan.
- Administrator aplikasi.
- Administrator cloud.

- Akun email organisasi.
- Akun VPN.
- Akun dengan akses ke data sensitif.

Semakin tinggi hak akses sebuah akun, semakin penting perlindungan tambahan terhadap akun tersebut.

MFA dan Password yang Bocor

MFA tidak membuat password menjadi tidak penting.

Password tetap harus:

- Unik.
- Sulit ditebak.
- Tidak digunakan ulang.
- Tidak dibagikan.
- Dijaga kerahasiaannya.

MFA berfungsi sebagai **lapisan tambahan**.

Contohnya:

Password Aman

+

MFA

+

Monitoring

↓

Perlindungan Akun Lebih Kuat

Pendekatan ini sejalan dengan konsep **Defense in Depth** yang telah dibahas pada BAB 4.

Jika Smartphone Hilang

Jika MFA menggunakan smartphone dan perangkat tersebut hilang, pengguna harus segera mengikuti prosedur pemulihan akun organisasi atau layanan yang digunakan.

Untuk akun organisasi, pengguna sebaiknya menghubungi administrator atau helpdesk sesuai prosedur.

Jangan mencoba membuat mekanisme bypass sendiri.

Organisasi sebaiknya memiliki prosedur pemulihan MFA yang jelas, termasuk:

- Penggantian perangkat.
- Verifikasi identitas.
- Pencabutan perangkat lama.
- Pendaftaran perangkat baru.
- Penggunaan recovery method yang aman.

MFA untuk Administrator

MFA sangat penting untuk akun administrator karena akun tersebut memiliki hak akses yang lebih besar.

Contohnya:

Akun Pengguna

↓

MFA

↓

Akses Aplikasi

Akun Administrator



MFA



Akses Administrasi

Jika akun administrator berhasil diambil alih, dampaknya dapat jauh lebih besar dibandingkan kompromi akun pengguna biasa.

Karena itu, akun dengan hak istimewa (*privileged account*) perlu mendapatkan perlindungan yang lebih kuat.

MFA Bukan Perlindungan yang Sempurna

MFA sangat membantu meningkatkan keamanan akun, tetapi bukan berarti akun menjadi kebal terhadap serangan.

Penyerang masih dapat mencoba berbagai teknik, misalnya:

- Phishing.
- Social engineering.
- Pencurian session.
- Malware.
- Serangan terhadap proses pemulihan akun.

Karena itu, MFA harus tetap dikombinasikan dengan:

- Password yang aman.

- Kesadaran pengguna.
- Endpoint security.
- Monitoring.
- Access control.
- Kebijakan keamanan.

Kebiasaan Aman Menggunakan MFA

Pengguna sebaiknya:

1. Mengaktifkan MFA pada akun yang mendukungnya.
2. Menggunakan metode MFA yang sesuai dengan kebijakan organisasi.
3. Tidak menyetujui permintaan login yang tidak dilakukan sendiri.
4. Tidak memberikan kode OTP kepada siapa pun.
5. Menjaga perangkat autentikasi.
6. Segera melaporkan kehilangan perangkat.
7. Mengikuti prosedur pemulihan MFA organisasi.
8. Tetap menggunakan password yang unik dan aman.

Kesimpulan

Multi-Factor Authentication (MFA) memberikan lapisan keamanan tambahan dengan meminta lebih dari satu faktor untuk membuktikan identitas pengguna.

MFA dapat mengurangi risiko pengambilalihan akun ketika password berhasil dicuri, tetapi pengguna tetap harus menjaga keamanan password dan berhati-hati terhadap permintaan

otentikasi yang mencurigakan.

Prinsip yang perlu diingat:

Gunakan password yang aman, aktifkan MFA, dan jangan pernah menyetujui atau membagikan faktor autentikasi yang tidak Anda lakukan sendiri.

5.3 Menggunakan Email Secara Aman

Email merupakan salah satu sarana komunikasi yang paling banyak digunakan dalam organisasi. Email digunakan untuk mengirim informasi, dokumen, pemberitahuan, maupun berbagai kebutuhan pekerjaan lainnya.

Namun, email juga menjadi salah satu media yang sering dimanfaatkan dalam serangan siber. Penyerang dapat menggunakan email untuk melakukan **phishing, penyebaran malware, pencurian kredensial, maupun social engineering.**

Karena itu, pengguna perlu memperlakukan email sebagai salah satu bagian penting dari keamanan informasi organisasi.

Waspada Email yang Tidak Biasa

Pengguna perlu berhati-hati ketika menerima email yang:

- Tidak dikenal pengirimnya.
- Meminta tindakan segera.
- Meminta password atau kode OTP.
- Meminta informasi pribadi.
- Meminta transfer atau pembayaran.
- Berisi tautan yang mencurigakan.

- Memiliki lampiran yang tidak diharapkan.
- Menggunakan bahasa yang mendesak atau mengancam.

Contohnya:

"Akun Anda akan dinonaktifkan dalam 30 menit. Klik tautan berikut untuk melakukan verifikasi."

Pesan seperti ini perlu diperiksa terlebih dahulu. Rasa takut atau urgensi sering digunakan penyerang agar pengguna bertindak tanpa melakukan pemeriksaan.

Periksa Identitas Pengirim

Jangan hanya melihat nama yang muncul pada email.

Periksa alamat email sebenarnya.

Contohnya:

Nama Pengirim:

Administrator Sistem

Alamat:

administrator@organisasi.go.id

berbeda dengan:

Nama Pengirim:

Administrator Sistem

Alamat:

administrator-organisasi@gmail.com

Nama pengirim dapat dibuat menyerupai nama orang atau unit yang dipercaya. Karena itu, alamat email perlu diperiksa dengan teliti.

Jangan Sembarangan Mengklik Tautan

Tautan dalam email dapat mengarah ke website yang berbahaya atau halaman login palsu.

Sebelum mengklik tautan, periksa alamat tujuan.

Contohnya, email mengaku berasal dari suatu layanan, tetapi tautannya justru menuju domain yang tidak berkaitan.

Prinsip sederhananya:

Jangan percaya sebuah tautan hanya karena nama atau tampilan email terlihat resmi.

Jika ragu, akses layanan melalui alamat website resmi yang biasa digunakan, bukan melalui tautan pada email.

Waspadai Lampiran

Lampiran email dapat digunakan untuk menyebarkan malware.

Jenis file tertentu perlu mendapatkan perhatian lebih, terutama file yang dapat menjalankan kode atau program.

Contohnya:

invoice.exe

dokumen.scr

update.bat

file.js

Namun, pengguna juga tidak boleh menganggap semua file dengan ekstensi dokumen otomatis aman.

File seperti:

dokumen.docx

laporan.xlsx

surat.pdf

tetap perlu diperhatikan apabila dikirim secara tidak terduga atau berasal dari sumber yang mencurigakan.

Jangan Mengaktifkan Macro Secara Sembarangan

Dokumen Microsoft Office tertentu dapat mengandung macro.

Apabila sebuah dokumen yang tidak diharapkan meminta pengguna untuk:

Enable Content

atau mengaktifkan macro agar dokumen dapat ditampilkan, pengguna perlu berhati-hati.

Jangan mengaktifkan macro hanya karena diminta oleh isi dokumen atau pengirim yang tidak dikenal.

Phishing Melalui Email

Phishing merupakan salah satu serangan yang sering memanfaatkan email.

Alur sederhananya:

Penyerang



Membuat Email Palsu



Mengirim kepada Korban



Korban Membuka Email



Klik Tautan / Lampiran



Data Dicuri / Malware Berjalan

Tujuan phishing dapat berupa:

- Mencuri username dan password.
- Mengambil alih akun.
- Mencuri data.
- Menyebarkan malware.
- Mengarahkan pengguna ke website palsu.

Karena itu, kemampuan mengenali phishing merupakan bagian penting dari keamanan penggunaan email.

Waspada! Permintaan yang Mendesak

Penyerang sering menggunakan rasa urgensi untuk membuat korban tidak sempat melakukan pemeriksaan.

Contohnya:

"Segera kirimkan dokumen tersebut."

"Akun Anda akan segera diblokir."

"Direktur membutuhkan transfer sekarang."

"Konfirmasi password Anda melalui tautan berikut."

Ketika email meminta tindakan yang sensitif atau tidak biasa, pengguna sebaiknya melakukan **verifikasi melalui jalur komunikasi lain**.

Misalnya, jika menerima permintaan transfer yang mengatasnamakan pimpinan, jangan langsung melakukan transfer. Konfirmasi kepada pihak yang bersangkutan menggunakan nomor atau kontak yang sudah diketahui sebelumnya.

Jangan Mengirim Password Melalui Email

Password tidak seharusnya dikirim melalui email.

Apabila seseorang meminta:

"Balas email ini dengan username dan password Anda."

permintaan tersebut harus dianggap mencurigakan.

Hal yang sama berlaku untuk:

- OTP.
- Recovery code.
- PIN.
- Security key information.
- Kredensial administrasi.

Informasi autentikasi harus tetap dirahasiakan.

Berhati-hati Saat Mengirim Email

Keamanan email tidak hanya berkaitan dengan email yang diterima.

Pengguna juga harus berhati-hati ketika mengirim informasi.

Sebelum menekan tombol **Send**, periksa:

- Alamat penerima.
- CC.
- BCC.
- Lampiran.
- Isi pesan.
- Informasi sensitif yang disertakan.

Kesalahan memilih alamat email dapat menyebabkan informasi organisasi terkirim kepada pihak yang tidak berhak.

Perlindungan Data Sensitif

Informasi sensitif tidak seharusnya dikirim melalui email tanpa mempertimbangkan mekanisme perlindungannya.

Contohnya:

- Data pribadi.
- Dokumen keuangan.
- Data pasien.
- Dokumen internal.
- Informasi autentikasi.
- Dokumen yang bersifat rahasia.

Jika organisasi memiliki prosedur khusus untuk mengirim

data sensitif, pengguna harus mengikuti prosedur tersebut.

Jangan Menggunakan Email Pribadi untuk Data Organisasi

Data organisasi sebaiknya dikirim menggunakan akun dan sistem yang telah disediakan organisasi.

Penggunaan email pribadi untuk mengirim dokumen organisasi dapat menimbulkan masalah seperti:

- Data berada di luar kendali organisasi.
- Tidak mengikuti kebijakan keamanan.
- Kesulitan melakukan audit.
- Risiko kebocoran data.
- Kesulitan ketika pegawai meninggalkan organisasi.

Karena itu, gunakan akun email organisasi sesuai dengan kebijakan yang berlaku.

Jika Menerima Email Mencurigakan

Jangan langsung menghapus email mencurigakan apabila organisasi memiliki prosedur pelaporan insiden.

Tindakan yang dapat dilakukan:

1. Jangan klik tautan.
2. Jangan membuka lampiran.
3. Jangan membalas email.
4. Jangan memberikan informasi.
5. Laporkan kepada administrator atau tim keamanan sesuai prosedur.

6. Ikuti instruksi organisasi mengenai penanganan email tersebut.

Pelaporan penting karena satu email phishing dapat dikirimkan kepada banyak pegawai. Jika dilaporkan lebih awal, organisasi dapat mengambil tindakan untuk melindungi pengguna lainnya.

Jika Terlanjur Mengklik Tautan

Apabila pengguna terlanjur mengklik tautan mencurigakan, jangan menyembunyikan kejadian tersebut.

Segera laporkan kepada administrator atau tim keamanan.

Jika pengguna juga memasukkan username dan password, segera lakukan tindakan sesuai prosedur organisasi, termasuk mengganti password dan memeriksa aktivitas akun.

Jika perangkat menunjukkan aktivitas yang tidak normal setelah membuka lampiran atau tautan, perangkat tersebut juga perlu segera dilaporkan untuk dilakukan pemeriksaan.

Checklist Aman Menggunakan Email

Sebelum melakukan tindakan terhadap sebuah email, gunakan pertanyaan sederhana:

Pemeriksaan	Pertanyaan
--------------------	-------------------

Pengirim	Apakah saya mengenal pengirimnya?
Alamat	Apakah alamat email benar?
Isi	Apakah permintaannya masuk akal?
Tautan	Apakah alamat tujuan dapat dipercaya?

Pemeriksaan	Pertanyaan
--------------------	-------------------

Lampiran	Apakah saya memang mengharapkan file tersebut?
Urgensi	Apakah pesan mencoba membuat saya panik?
Data	Apakah email meminta informasi sensitif?
Tindakan	Apakah saya perlu melakukan verifikasi terlebih dahulu?

Jika terdapat sesuatu yang tidak wajar, **berhenti dan lakukan verifikasi**.

Kesimpulan

Email merupakan bagian penting dari aktivitas organisasi, tetapi juga menjadi salah satu media yang sering digunakan untuk melakukan serangan siber.

Pengguna perlu membangun kebiasaan:

- Periksa identitas pengirim.
- Tidak sembarangan mengklik tautan.
- Berhati-hati terhadap lampiran.
- Tidak memberikan password atau OTP.
- Periksa penerima sebelum mengirim informasi.
- Tidak menggunakan email pribadi untuk data organisasi.
- Melaporkan email mencurigakan.
- Segera melaporkan apabila terlanjur melakukan tindakan yang berisiko.

Jangan menilai keamanan email hanya dari tampilannya. Periksa pengirim, tautan, lampiran, isi pesan, dan tindakan yang diminta.

5.4 Mengenali Email Phishing

Phishing adalah salah satu bentuk serangan siber yang memanfaatkan manipulasi pengguna untuk memperoleh informasi, kredensial, atau akses ke sistem. Email phishing biasanya dibuat seolah-olah berasal dari pihak yang dipercaya sehingga korban terdorong untuk melakukan tindakan tertentu, seperti membuka tautan, membuka lampiran, memasukkan password, atau memberikan informasi sensitif.

Kemampuan mengenali email phishing merupakan bagian penting dari **Security Awareness**. Pengguna tidak cukup hanya mengetahui bahwa phishing itu berbahaya, tetapi juga harus mampu mengenali tanda-tanda yang mencurigakan sebelum melakukan tindakan.

Ciri-Ciri Email Phishing

Tidak semua email phishing memiliki ciri yang sama. Namun, beberapa tanda berikut dapat digunakan sebagai indikator awal.

1. Pengirim Tidak Sesuai

Periksa alamat email sebenarnya, bukan hanya nama yang ditampilkan.

Contohnya:

Nama:

Administrator Sistem

Alamat:

admin@organisasi.go.id

terlihat berbeda dengan:

Nama:

Administrator Sistem

Alamat:

admin-organisasi@gmail.com

Penyerang dapat menggunakan nama yang menyerupai orang atau organisasi yang dipercaya.

2. Domain yang Menyerupai Domain Resmi

Penyerang dapat membuat domain yang terlihat mirip dengan domain resmi.

Contohnya:

Domain resmi:

organisasi.go.id

Domain mencurigakan:

organisasi-login.com

organisasi-go-id.com

organisasi.verify-account.com

Perbedaan kecil sering kali tidak diperhatikan apabila pengguna sedang terburu-buru.

Karena itu, periksa domain dengan teliti sebelum memasukkan kredensial.

3. Meminta Password atau Informasi Sensitif

Email yang meminta:

- Password.
- OTP.
- PIN.
- Nomor kartu.
- Data pribadi.
- Informasi rekening.
- Kode pemulihan akun.

perlu mendapatkan perhatian khusus.

Organisasi yang memiliki prosedur keamanan yang baik tidak seharusnya meminta pengguna mengirimkan password melalui email.

4. Menggunakan Bahasa Mendesak

Phishing sering menggunakan tekanan waktu agar korban tidak sempat melakukan pemeriksaan.

Contohnya:

"Akun Anda akan dinonaktifkan hari ini."

"Segera lakukan verifikasi untuk menghindari pemblokiran."

"Pembayaran harus dilakukan dalam waktu 30 menit."

Bahasa seperti ini tidak otomatis berarti phishing, tetapi merupakan **indikator yang perlu diperiksa lebih lanjut**.

5. Terdapat Tautan Mencurigakan

Jangan langsung mengklik tautan hanya karena tampilannya terlihat resmi.

Periksa alamat tujuan tautan terlebih dahulu.

Misalnya email mengaku berasal dari layanan organisasi, tetapi tautannya mengarah ke domain yang tidak berhubungan dengan organisasi.

Jika ragu, lebih aman membuka website melalui alamat resmi yang sudah diketahui daripada menggunakan tautan dari email.

6. Lampiran yang Tidak Diharapkan

Lampiran yang tidak pernah diminta atau tidak sedang ditunggu perlu dicurigai.

Terutama apabila email meminta pengguna:

"Segera buka lampiran ini."

atau:

"Aktifkan macro agar dokumen dapat ditampilkan."

Jangan membuka atau mengaktifkan konten aktif pada dokumen apabila sumbernya tidak dapat dipastikan.

7. Isi Email Tidak Sesuai Konteks

Perhatikan apakah isi email memang sesuai dengan pekerjaan dan aktivitas yang sedang dilakukan.

Misalnya seorang pegawai tiba-tiba menerima:

"Invoice pembelian yang harus segera dibayar"

padahal pegawai tersebut tidak pernah melakukan pembelian atau berhubungan dengan vendor tersebut.

Ketidaksesuaian konteks merupakan salah satu tanda yang perlu diperiksa.

8. Kesalahan Bahasa dan Format

Email phishing terkadang memiliki:

- Kesalahan ejaan.
- Tata bahasa yang tidak wajar.
- Format yang berantakan.
- Logo dengan kualitas buruk.
- Kalimat yang terasa seperti hasil terjemahan otomatis.

Namun, **email phishing tidak selalu memiliki kesalahan bahasa**. Penyerang saat ini dapat membuat email yang terlihat sangat profesional.

Karena itu, tidak adanya kesalahan bahasa juga **tidak berarti email tersebut aman**.

Jangan Hanya Mengandalkan Logo

Salah satu kesalahan pengguna adalah menganggap email aman karena memiliki logo organisasi.

Logo, warna, tanda tangan email, dan format dapat ditiru dengan mudah.

Yang lebih penting untuk diperiksa adalah:

Pengirim



Alamat Email



Domain



Isi Pesan



Tautan / Lampiran



Tindakan yang Diminta

Contoh Email Phishing

Misalnya pengguna menerima email:

Dari:

Administrator Sistem <admin@organisasi-security.com>

Subjek:

URGENT! Akun Anda Akan Dinonaktifkan

Isi:

Akun Anda akan segera dinonaktifkan.

Silakan klik tautan berikut untuk melakukan

verifikasi akun.

[VERIFIKASI SEKARANG]

Beberapa hal perlu diperiksa:

- Apakah domain pengirim merupakan domain resmi?
- Apakah pengguna memang menerima pemberitahuan tersebut?
- Apakah organisasi biasanya meminta verifikasi melalui email?
- Ke mana tautan tersebut mengarah?
- Apakah ada tekanan waktu?
- Apakah pengguna diminta memasukkan password?

Jika terdapat keraguan, **jangan klik tautan dan lakukan verifikasi melalui kanal resmi.**

Cara Memeriksa Email Phishing

Gunakan pendekatan sederhana:

1. Berhenti

Jangan langsung melakukan tindakan.

2. Periksa

Periksa pengirim, alamat email, domain, isi, tautan, dan lampiran.

3. Verifikasi

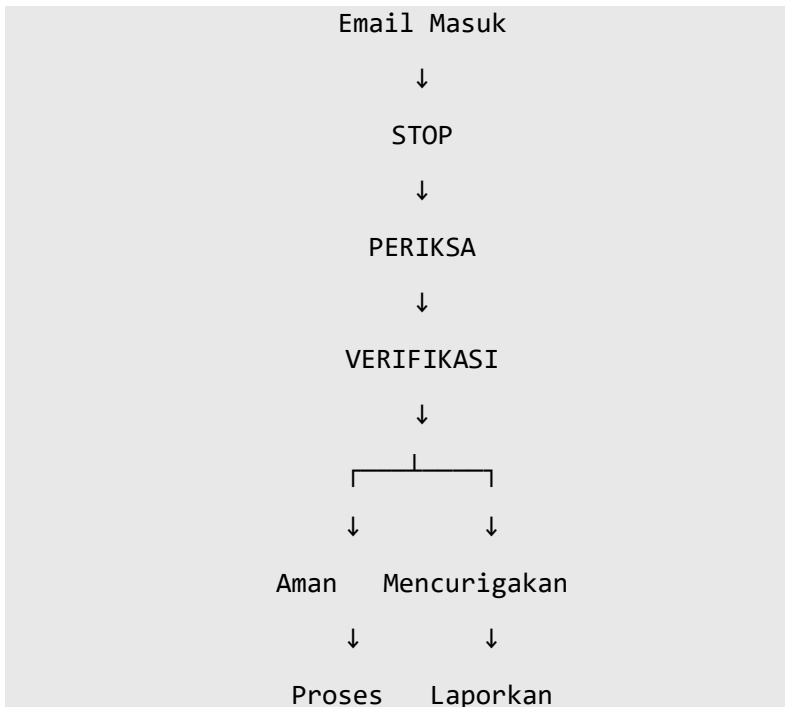
Jika email mengatasnamakan seseorang atau organisasi,

lakukan konfirmasi melalui jalur komunikasi yang sudah diketahui.

4. Laporkan

Jika dicurigai sebagai phishing, laporkan sesuai prosedur organisasi.

Gambaran sederhananya:



Jangan Takut Melaporkan Kesalahan

Kesalahan dapat terjadi. Pengguna mungkin saja terlanjur membuka tautan atau lampiran.

Hal yang paling penting adalah **segera melaporkan kejadian**

tersebut.

Jangan menunda pelaporan karena takut dianggap melakukan kesalahan.

Semakin cepat organisasi mengetahui adanya phishing, semakin cepat tindakan dapat dilakukan untuk:

- Memblokir domain atau alamat pengirim.
- Memeriksa akun yang terdampak.
- Mengganti kredensial.
- Memeriksa perangkat.
- Memberikan peringatan kepada pengguna lain.
- Mencegah korban berikutnya.
- **Checklist Mengenali Phishing**

Sebelum melakukan tindakan terhadap email yang mencurigakan, tanyakan:

Pemeriksaan Pertanyaan

Pengirim	Apakah saya mengenal pengirimnya?
Alamat	Apakah alamat email benar-benar sesuai?
Domain	Apakah domain merupakan domain resmi?
Konteks	Apakah saya memang mengharapkan email ini?
Tautan	Apakah tujuan tautan dapat dipercaya?
Lampiran	Apakah saya memang mengharapkan file tersebut?

Pemeriksaan Pertanyaan

Urgensi	Apakah email mencoba membuat saya panik?
Informasi	Apakah email meminta data sensitif?
Verifikasi	Apakah saya perlu mengonfirmasi melalui kanal lain?

Jika terdapat sesuatu yang tidak sesuai, **jangan lanjutkan sebelum melakukan verifikasi.**

Kesimpulan

Mengenali email phishing membutuhkan lebih dari sekadar melihat nama pengirim atau tampilan email. Pengguna perlu memeriksa **alamat email, domain, konteks pesan, tautan, lampiran, dan tindakan yang diminta.**

Prinsip yang mudah diingat:

Berhenti → Periksa → Verifikasi → Laporkan

Pengguna tidak harus mampu memastikan secara teknis apakah sebuah email benar-benar phishing. Ketika terdapat keraguan, tindakan yang paling aman adalah **tidak melakukan tindakan yang diminta dan melaporkannya kepada pihak yang berwenang.**

5.5 Browsing Internet Secara Aman

Internet merupakan salah satu sarana utama yang digunakan dalam aktivitas organisasi. Pegawai menggunakannya untuk mencari informasi, mengakses aplikasi, membaca berita, melakukan komunikasi, maupun menjalankan berbagai pekerjaan.

Namun, internet juga menjadi salah satu jalur yang sering dimanfaatkan penyerang untuk menyebarkan malware, melakukan phishing, mencuri informasi, atau mengarahkan pengguna ke website berbahaya.

Karena itu, pengguna perlu menerapkan kebiasaan **browsing internet secara aman** dan tidak menganggap bahwa website yang dapat dibuka otomatis aman untuk digunakan.

Periksa Alamat Website

Sebelum memasukkan informasi penting, perhatikan alamat website yang sedang diakses.

Periksa:

- Nama domain.
- Ejaan domain.
- Protokol HTTPS.
- Apakah domain sesuai dengan layanan yang ingin digunakan.

Contohnya, penyerang dapat membuat domain yang menyerupai layanan resmi:

Domain resmi:

example.com

Domain mencurigakan:

example-login.com

example-verification.com

example-support.net

Perbedaan kecil pada domain dapat sulit terlihat jika pengguna terburu-buru.

HTTPS Bukan Jaminan Website Aman

Website yang menggunakan HTTPS memiliki komunikasi yang terenkripsi antara browser dan server. Namun, **HTTPS tidak berarti website tersebut pasti aman atau resmi.**

Website phishing juga dapat menggunakan HTTPS.

Karena itu, jangan hanya melihat ikon gembok pada browser. Tetap periksa **domain dan konteks website.**

Prinsipnya:

HTTPS membantu melindungi komunikasi, tetapi tidak membuktikan bahwa pemilik website dapat dipercaya.

Hindari Website yang Mencurigakan

Berhati-hatilah ketika website:

- Menampilkan banyak pop-up.
- Mengarahkan ke banyak halaman secara otomatis.
- Meminta informasi yang tidak relevan.
- Meminta pengguna mengunduh file secara tiba-tiba.
- Meminta memasang ekstensi browser yang tidak diperlukan.
- Menampilkan peringatan keamanan yang tidak biasa.
- Mengaku perangkat terinfeksi dan meminta pengguna memasang aplikasi tertentu.

Jika sebuah website meminta tindakan yang tidak wajar, sebaiknya tutup halaman tersebut dan gunakan sumber resmi.

Jangan Sembarangan Mengunduh File

Internet menyediakan berbagai jenis file yang dapat diunduh, tetapi tidak semua file aman.

Hindari mengunduh software atau dokumen dari sumber yang tidak dikenal.

Lebih baik gunakan:

- Website resmi vendor.
- Repository resmi.
- Portal organisasi.
- Sumber yang telah disetujui organisasi.

Perhatikan juga ekstensi file sebelum menjalankannya.

Contohnya:

laporan.pdf

dokumen.docx

aplikasi.exe

update.bat

installer.scr

File yang dapat menjalankan program atau script membutuhkan perhatian lebih besar.

Jangan Mengikuti Pop-up yang Menyesatkan

Salah satu teknik yang sering digunakan website berbahaya

adalah menampilkan pesan seperti:

"Komputer Anda terkena virus!"

atau:

"Klik OK untuk membersihkan komputer."

Pesan tersebut belum tentu berasal dari sistem keamanan komputer.

Jangan langsung mengikuti instruksi tersebut, terutama jika pengguna diminta:

- Mengunduh aplikasi.
- Memasang extension.
- Menghubungi nomor tertentu.
- Memberikan akses remote.
- Memasukkan password.
- Memberikan informasi kartu atau pembayaran.

Jika muncul peringatan keamanan, gunakan aplikasi keamanan atau mekanisme resmi untuk melakukan pemeriksaan.

Hati-Hati dengan Ekstensi Browser

Browser dapat menggunakan extension untuk menambahkan fungsi tertentu.

Namun, extension memiliki kemampuan untuk mengakses data atau aktivitas tertentu pada browser, tergantung izin yang diberikan.

Karena itu:

- Instal extension hanya dari sumber terpercaya.
- Periksa siapa pengembangnya.
- Perhatikan izin yang diminta.
- Hapus extension yang tidak lagi digunakan.
- Jangan memasang extension hanya karena sebuah website memintanya.
- **Jangan Memasukkan Informasi Sensitif Sembarangan**

Ketika browsing, pengguna dapat menemukan berbagai formulir yang meminta informasi.

Sebelum mengisi formulir, tanyakan:

Apakah informasi ini memang diperlukan?

Hindari memasukkan informasi sensitif pada website yang tidak jelas.

Informasi yang perlu dijaga antara lain:

- Password.
- OTP.
- Nomor identitas.
- Data pribadi.
- Data keuangan.
- Informasi pekerjaan.
- Kredensial organisasi.
- **Waspadai Website yang Meniru Layanan Resmi**

Website palsu dapat dibuat menyerupai:

- Bank.
- Marketplace.
- Media sosial.
- Layanan pemerintah.
- Portal organisasi.
- Layanan email.
- Sistem internal.

Tampilan yang mirip bukan bukti bahwa website tersebut resmi.

Jika akan mengakses layanan penting, lebih aman mengetik alamat website sendiri atau menggunakan bookmark yang telah dibuat sebelumnya.

Gunakan Browser yang Diperbarui

Browser merupakan salah satu aplikasi yang berhubungan langsung dengan internet sehingga perlu diperbarui secara berkala.

Pembaruan dapat mencakup:

- Perbaikan keamanan.
- Perbaikan bug.
- Peningkatan kompatibilitas.
- Perlindungan terhadap kerentanan yang telah diketahui.

Karena itu, pengguna sebaiknya tidak menunda pembaruan browser tanpa alasan yang jelas.

Hindari Menggunakan Perangkat Umum untuk Aktivitas

Sensitif

Perangkat umum atau komputer yang bukan milik organisasi perlu mendapatkan perhatian khusus.

Hindari melakukan aktivitas sensitif seperti:

- Login ke akun administrasi.
- Mengakses data organisasi.
- Mengakses sistem keuangan.
- Mengakses akun dengan hak istimewa.

pada perangkat yang tidak dapat dipastikan keamanannya.

Jika terpaksa menggunakan perangkat umum, ikuti kebijakan organisasi dan hindari menyimpan password atau informasi sensitif pada browser.

Berhati-hati Menggunakan Wi-Fi Publik

Wi-Fi publik dapat digunakan untuk aktivitas sehari-hari, tetapi pengguna tetap perlu berhati-hati.

Jangan menganggap nama jaringan Wi-Fi otomatis membuktikan bahwa jaringan tersebut resmi.

Untuk aktivitas penting, gunakan koneksi yang dipercaya dan ikuti kebijakan organisasi, termasuk penggunaan VPN apabila diwajibkan.

Jangan Mengabaikan Peringatan Browser

Browser dapat menampilkan peringatan ketika menemukan masalah keamanan pada sebuah website.

Contohnya:

Website Berisiko



Browser Memberikan Peringatan



Jangan Langsung Melanjutkan



Periksa Alamat dan Tujuan

Jangan melewati peringatan keamanan hanya karena ingin segera membuka website.

Jika website tersebut memang diperlukan untuk pekerjaan, lakukan verifikasi melalui administrator atau pihak yang bertanggung jawab.

Browsing Aman untuk Aktivitas Organisasi

Dalam lingkungan kerja, pengguna sebaiknya menggunakan internet sesuai kebutuhan pekerjaan dan kebijakan organisasi.

Beberapa kebiasaan yang dapat diterapkan:

- Gunakan akun organisasi sesuai peruntukannya.
- Hindari mengunduh software ilegal atau tidak terpercaya.
- Jangan memasang software tanpa persetujuan jika organisasi memiliki kebijakan instalasi.
- Jangan mengakses website berisiko menggunakan perangkat organisasi.
- Jangan memasukkan data organisasi ke layanan online yang tidak disetujui.

- Laporkan website atau aktivitas internet yang mencurigakan.

Jika Terlanjur Mengakses Website Mencurigakan

Jika pengguna terlanjur membuka website yang mencurigakan, jangan langsung panik.

Jika hanya membuka halaman tanpa melakukan tindakan lebih lanjut, tutup halaman tersebut dan laporkan apabila diperlukan.

Jika pengguna:

- Mengunduh file.
- Menjalankan program.
- Memasukkan username dan password.
- Memberikan informasi sensitif.
- Mengizinkan extension.
- Mengizinkan akses remote.

segera laporkan kepada administrator atau tim keamanan organisasi.

Semakin cepat kejadian dilaporkan, semakin cepat pemeriksaan dapat dilakukan.

Checklist Browsing Aman

Sebelum melakukan aktivitas penting di internet, biasakan memeriksa:

Pemeriksaan	Pertanyaan
--------------------	-------------------

Domain	Apakah alamat website benar?
Sumber	Apakah website berasal dari sumber yang terpercaya?
HTTPS	Apakah koneksi menggunakan HTTPS?
Informasi	Apakah data yang diminta memang diperlukan?
Download	Apakah file berasal dari sumber resmi?
Pop-up	Apakah website meminta tindakan yang tidak wajar?
Extension	Apakah extension tersebut benar-benar diperlukan?
Perangkat	Apakah perangkat yang digunakan dapat dipercaya?

Jika sesuatu terlihat tidak wajar, **berhenti dan lakukan verifikasi terlebih dahulu.**

Kesimpulan

Browsing internet secara aman bukan berarti pengguna harus menghindari internet, tetapi harus mampu **mengenali risiko sebelum melakukan tindakan.**

Kebiasaan yang perlu dibangun antara lain:

- Periksa domain website.
- Tidak hanya mengandalkan HTTPS.

- Tidak sembarangan mengunduh file.
- Berhati-hati terhadap pop-up.
- Tidak memasukkan informasi sensitif ke website yang tidak terpercaya.
- Menggunakan browser yang diperbarui.
- Berhati-hati menggunakan Wi-Fi publik.
- Tidak mengabaikan peringatan keamanan browser.
- Segera melaporkan kejadian yang mencurigakan.

Jangan hanya bertanya "Apakah website ini bisa dibuka?", tetapi tanyakan juga "Apakah website ini memang seharusnya saya percaya?"

5.6 Menggunakan Media Sosial dengan Aman

Media sosial menjadi bagian dari aktivitas sehari-hari, baik untuk komunikasi pribadi maupun kegiatan organisasi. Platform seperti media sosial dapat digunakan untuk berbagi informasi, membangun komunikasi, dan memperoleh berita dengan cepat.

Namun, media sosial juga dapat menjadi sumber risiko keamanan. Informasi yang dibagikan secara berlebihan dapat dimanfaatkan untuk **social engineering, phishing, pencurian identitas, maupun penipuan**.

Karena itu, pengguna perlu memahami bahwa aktivitas di media sosial dapat berdampak terhadap **keamanan pribadi maupun keamanan organisasi**.

Jangan Membagikan Informasi Sensitif

Pengguna perlu berhati-hati ketika membagikan informasi di

media sosial.

Hindari membagikan informasi seperti:

- Password.
- OTP.
- Nomor identitas.
- Informasi rekening.
- Data pribadi yang tidak diperlukan.
- Informasi internal organisasi.
- Dokumen pekerjaan.
- Informasi mengenai sistem atau infrastruktur organisasi.
- Foto yang memperlihatkan informasi rahasia.

Informasi yang terlihat sederhana dapat menjadi bagian dari informasi yang digunakan penyerang untuk melakukan rekayasa sosial.

Berhati-hati dengan Informasi Pekerjaan

Pengguna sebaiknya tidak sembarangan membagikan informasi mengenai lingkungan kerja.

Contohnya:

Nama server

Alamat IP

Topologi jaringan

Nama aplikasi internal

Informasi konfigurasi

Struktur organisasi

Nomor internal

Dokumen pekerjaan

Informasi tersebut mungkin terlihat tidak berbahaya apabila berdiri sendiri. Namun, jika dikumpulkan bersama informasi lain, dapat membantu penyerang memahami lingkungan organisasi.

Periksa Pengaturan Privasi

Setiap platform media sosial memiliki pengaturan privasi yang berbeda.

Pengguna sebaiknya memeriksa:

- Siapa yang dapat melihat posting.
- Siapa yang dapat menghubungi.
- Siapa yang dapat melihat informasi profil.
- Siapa yang dapat menandai akun.
- Aplikasi apa saja yang memiliki akses ke akun.

Jangan menganggap pengaturan bawaan platform selalu sesuai dengan kebutuhan keamanan pengguna.

Waspadai Akun Palsu

Penyerang dapat membuat akun yang menggunakan nama, foto, atau identitas yang menyerupai orang yang dikenal.

Contohnya:

Akun asli



Nama dan foto ditiru



Akun palsu dibuat



Menghubungi korban



Meminta uang / informasi / tindakan

Jika seseorang yang dikenal tiba-tiba meminta sesuatu yang tidak biasa melalui media sosial, lakukan verifikasi melalui jalur komunikasi lain.

Jangan Mudah Percaya Pesan Pribadi

Pesan pribadi (*direct message*) dapat digunakan untuk melakukan phishing atau social engineering.

Contohnya:

"Akun Anda melanggar aturan. Klik tautan ini untuk menghindari pemblokiran."

atau:

"Anda memenangkan hadiah. Silakan isi data pada tautan berikut."

Jangan langsung mengikuti instruksi tersebut.

Periksa sumber pesan dan gunakan kanal resmi platform apabila perlu melakukan verifikasi.

Hati-Hati dengan Tautan

Tautan yang dibagikan melalui media sosial dapat mengarah

ke:

- Website phishing.
- Website malware.
- Website penipuan.
- Halaman login palsu.
- Layanan yang meminta informasi pribadi.

Jangan menganggap tautan aman hanya karena dikirim oleh teman atau akun yang dikenal. Akun teman tersebut mungkin saja sudah diambil alih.

- **Jangan Menggunakan Password yang Sama**

Akun media sosial sebaiknya menggunakan password yang berbeda dari akun penting lainnya.

Misalnya:

Email → Password A

Aplikasi → Password B

Media Sosial → Password C

VPN → Password D

Jika password media sosial bocor, penyerang tidak otomatis dapat menggunakan password tersebut untuk masuk ke layanan lain.

Gunakan MFA apabila platform menyediakan fitur tersebut.

Waspada Social Engineering

Media sosial menyediakan banyak informasi tentang seseorang. Informasi tersebut dapat dimanfaatkan penyerang

untuk membuat serangan yang lebih meyakinkan.

Misalnya penyerang mengetahui:

- Nama lengkap.
- Tempat bekerja.
- Jabatan.
- Nama rekan kerja.
- Kegiatan organisasi.
- Minat atau hobi.

Informasi tersebut dapat digunakan untuk membuat pesan yang terlihat lebih meyakinkan.

Karena itu, semakin banyak informasi pribadi yang tersedia secara publik, semakin banyak pula informasi yang dapat digunakan untuk melakukan rekayasa sosial.

Jangan Sembarangan Menerima Permintaan Pertemanan

Tidak semua akun yang mengirimkan permintaan pertemanan atau mengikuti akun dapat dipercaya.

Periksa:

- Apakah mengenal orang tersebut?
- Apakah profilnya masuk akal?
- Apakah akun baru dibuat?
- Apakah aktivitasnya mencurigakan?
- Apakah memiliki banyak kesamaan yang terasa tidak wajar?

Jangan menerima permintaan hanya karena akun tersebut menggunakan foto atau nama orang yang dikenal.

Berhati-hati Membagikan Lokasi

Informasi lokasi dapat memberikan gambaran mengenai keberadaan seseorang.

Hindari membagikan informasi lokasi secara berlebihan, terutama jika tidak diperlukan.

Contohnya, membagikan informasi bahwa rumah sedang kosong atau seseorang sedang berada jauh dari rumah dapat meningkatkan risiko keamanan di dunia nyata.

Pisahkan Akun Pribadi dan Organisasi

Apabila organisasi memiliki kebijakan mengenai penggunaan media sosial, pengguna harus mengikutinya.

Untuk aktivitas organisasi, sebaiknya gunakan akun atau kanal resmi yang telah disediakan.

Pengguna juga perlu berhati-hati agar pendapat atau aktivitas pribadi tidak secara tidak sengaja dianggap sebagai pernyataan resmi organisasi.

Waspada Penipuan dan Hadiah Palsu

Media sosial sering digunakan untuk menyebarkan penipuan seperti:

- Hadiah palsu.
- Undian palsu.
- Lowongan kerja palsu.
- Investasi palsu.

- Permintaan bantuan palsu.
- Akun customer service palsu.

Jika sebuah penawaran terlihat terlalu bagus untuk menjadi kenyataan, lakukan verifikasi melalui sumber resmi.

Jangan memberikan informasi sensitif atau melakukan pembayaran hanya berdasarkan pesan media sosial.

Jangan Menginstal Aplikasi dari Sumber Tidak Terpercaya

Beberapa penipuan media sosial mengarahkan pengguna untuk memasang aplikasi tertentu.

Jangan memasang aplikasi hanya karena diminta oleh akun atau pesan yang tidak dapat dipercaya.

Gunakan sumber aplikasi resmi dan periksa:

- Nama aplikasi.
- Pengembang.
- Jumlah pengguna.
- Izin aplikasi.
- Reputasi aplikasi.

Jika Akun Media Sosial Diretas

Jika pengguna menduga akun telah diambil alih:

1. Segera ganti password.
2. Aktifkan MFA jika belum digunakan.
3. Periksa aktivitas login.
4. Keluar dari sesi yang tidak dikenal.

5. Cabut akses aplikasi yang mencurigakan.
6. Periksa perubahan email atau nomor pemulihan.
7. Beri tahu kontak jika akun telah digunakan untuk mengirim pesan mencurigakan.
8. Gunakan prosedur pemulihan resmi platform.

Jika akun tersebut digunakan untuk aktivitas organisasi, segera laporkan kepada pihak yang bertanggung jawab.

Media Sosial dan Reputasi Organisasi

Aktivitas pengguna di media sosial dapat berdampak terhadap reputasi organisasi, terutama apabila pengguna mengidentifikasi dirinya sebagai bagian dari organisasi.

Karena itu, pengguna perlu berhati-hati ketika:

- Membagikan dokumen organisasi.
- Membicarakan informasi internal.
- Mengunggah foto lingkungan kerja.
- Menampilkan informasi sistem.
- Memberikan komentar atas nama organisasi.

Gunakan kanal resmi apabila informasi memang merupakan informasi yang harus disampaikan atas nama organisasi.

Checklist Aman Menggunakan Media Sosial

Pemeriksaan	Pertanyaan
--------------------	-------------------

Privasi	Siapa yang dapat melihat informasi saya?
---------	--

Profil	Apakah informasi pribadi yang dibagikan
--------	---

Pemeriksaan Pertanyaan

memang diperlukan?

Teman Apakah saya mengenal akun tersebut?

Pesan Apakah permintaan yang diberikan masuk akal?

Tautan Apakah tautan berasal dari sumber terpercaya?

Informasi kerja Apakah posting mengandung informasi internal?

Password Apakah password berbeda dari layanan lain?

MFA Apakah MFA sudah diaktifkan?

Aplikasi Apakah aplikasi yang terhubung memang diperlukan?

Lokasi Apakah informasi lokasi perlu dibagikan?

Prinsip Sederhana

Gunakan prinsip:

Think Before You Share.

Sebelum mengunggah atau membagikan sesuatu, tanyakan:

Apakah informasi ini memang perlu diketahui orang lain?

Apakah informasi ini dapat digunakan untuk menyerang saya atau organisasi?

Apakah saya tetap nyaman jika informasi ini tersebar di

luar kendali saya?

Jika jawabannya meragukan, lebih baik **jangan membagikannya**.

Kesimpulan

Media sosial memberikan banyak manfaat, tetapi juga dapat menjadi sumber informasi bagi penyerang. Informasi yang dibagikan pengguna dapat dimanfaatkan untuk membangun serangan yang lebih meyakinkan melalui phishing dan social engineering.

Kebiasaan yang perlu diterapkan antara lain:

- Batasi informasi pribadi yang dibagikan.
- Jangan membagikan informasi internal organisasi.
- Periksa pengaturan privasi.
- Waspadaai akun palsu.
- Jangan sembarangan mengklik tautan.
- Gunakan password unik dan MFA.
- Berhati-hati terhadap pesan dan penawaran mencurigakan.
- Jangan sembarangan memasang aplikasi.
- Segera laporkan apabila akun diduga diambil alih.

Apa yang kita bagikan di media sosial dapat menjadi informasi bagi orang lain. Karena itu, pikirkan keamanan sebelum membagikannya.

5.7 Mengamankan Laptop dan Komputer

Laptop dan komputer merupakan salah satu aset yang paling sering digunakan untuk mengakses sistem organisasi, mengolah data, menggunakan email, dan terhubung ke internet. Karena itu, perangkat tersebut juga menjadi salah satu target serangan siber.

Apabila sebuah laptop atau komputer berhasil dikompromikan, penyerang dapat memperoleh akses terhadap data, kredensial, aplikasi, maupun jaringan yang dapat dijangkau dari perangkat tersebut.

Keamanan perangkat tidak hanya menjadi tanggung jawab administrator. **Pengguna juga memiliki peran penting dalam menjaga keamanan perangkat yang digunakan untuk bekerja.**

Gunakan Akun Sesuai Kebutuhan

Pengguna sebaiknya menggunakan akun dengan hak akses yang sesuai.

Untuk aktivitas sehari-hari, pengguna tidak perlu selalu menggunakan akun administrator jika tidak diperlukan.

Prinsipnya:

Gunakan hak akses administrator hanya ketika memang diperlukan.

Hal ini sejalan dengan prinsip **Least Privilege** yang telah dibahas pada BAB 4.

Gunakan Password atau PIN

Laptop dan komputer harus dilindungi dengan mekanisme autentikasi.

Jangan meninggalkan perangkat tanpa perlindungan hanya karena perangkat digunakan di lingkungan kantor.

Gunakan:

- Password.
- PIN.
- Biometric authentication jika tersedia.
- Mekanisme autentikasi lain yang ditetapkan organisasi.

Password perangkat juga sebaiknya tidak sama dengan password akun penting lainnya.

Aktifkan Automatic Screen Lock

Perangkat yang ditinggalkan tanpa pengawasan dapat diakses oleh orang lain.

Aktifkan penguncian layar otomatis setelah perangkat tidak digunakan selama periode tertentu.

Contohnya:

Pengguna Meninggalkan Komputer



Screen Lock



Perlu Autentikasi



Akses Terlindungi

Kebiasaan sederhana ini dapat mencegah orang lain

menggunakan perangkat ketika pengguna sedang tidak berada di tempat.

Selalu Perbarui Sistem

Sistem operasi dan aplikasi yang tidak diperbarui dapat memiliki kerentanan yang telah diketahui.

Pengguna sebaiknya tidak menunda pembaruan tanpa alasan yang jelas.

Perbarui komponen seperti:

- Sistem operasi.
- Browser.
- Office suite.
- PDF reader.
- Aplikasi komunikasi.
- Software keamanan.
- Aplikasi lain yang digunakan untuk pekerjaan.

Pembaruan keamanan membantu mengurangi risiko eksploitasi terhadap kerentanan yang telah diketahui.

Gunakan Antivirus atau Endpoint Protection

Perangkat organisasi sebaiknya menggunakan solusi keamanan endpoint yang telah ditentukan oleh organisasi.

Perlindungan endpoint dapat membantu mendeteksi dan menangani berbagai aktivitas berbahaya, seperti:

- Malware.
- Trojan.

- Ransomware.
- File mencurigakan.
- Aktivitas aplikasi yang tidak wajar.

Pengguna tidak seharusnya menonaktifkan antivirus atau endpoint protection hanya karena dianggap mengganggu aktivitas pekerjaan.

Jika terdapat masalah, laporkan kepada administrator.

Jangan Menginstal Software Sembarangan

Software yang diinstal pada laptop atau komputer dapat menjadi sumber risiko.

Hindari menginstal:

- Software bajakan.
- Crack.
- Keygen.
- Aplikasi dari sumber tidak dikenal.
- Software yang tidak diperlukan.
- Aplikasi yang tidak mendapatkan persetujuan organisasi.

Software ilegal atau hasil modifikasi dapat mengandung malware atau komponen berbahaya.

Untuk perangkat organisasi, instalasi software sebaiknya mengikuti prosedur yang telah ditetapkan.

Berhati-hati dengan USB dan Media Penyimpanan

USB flash drive dan media penyimpanan eksternal dapat menjadi media penyebaran malware.

Jangan sembarangan menggunakan USB yang:

- Tidak diketahui pemiliknya.
- Ditemukan di tempat umum.
- Diberikan oleh pihak yang tidak dikenal.
- Tidak jelas sumber datanya.

Jika organisasi memiliki prosedur pemeriksaan media penyimpanan, ikuti prosedur tersebut.

Jangan Menyimpan Data Organisasi Secara Sembarangan

Laptop dapat menyimpan berbagai jenis informasi organisasi.

Pengguna perlu mengetahui data apa yang tersimpan pada perangkat.

Hindari menyimpan data sensitif di lokasi yang tidak sesuai dengan kebijakan organisasi.

Jika data memang harus disimpan secara lokal, gunakan mekanisme perlindungan yang telah ditetapkan, termasuk enkripsi apabila diwajibkan.

Enkripsi Perangkat

Enkripsi dapat membantu melindungi data apabila laptop hilang atau dicuri.

Contohnya:

Laptop Hilang



Hard Disk Diakses



Data Terenkripsi



Data Sulit Dibaca

Enkripsi tidak menggantikan password dan kontrol akses, tetapi memberikan lapisan perlindungan tambahan terhadap data yang tersimpan pada perangkat.

Berhati-hati Saat Menggunakan Wi-Fi

Laptop yang terhubung ke jaringan merupakan bagian dari lingkungan keamanan organisasi.

Pengguna harus berhati-hati ketika menggunakan Wi-Fi publik atau jaringan yang tidak dikenal.

Untuk aktivitas organisasi, ikuti kebijakan jaringan yang telah ditetapkan, termasuk penggunaan VPN jika diwajibkan.

Jangan menganggap jaringan Wi-Fi dengan nama yang terlihat resmi otomatis dapat dipercaya.

Jangan Memberikan Akses Remote kepada Orang Tidak Dikenal

Penipuan teknis (*technical support scam*) dapat meminta pengguna memasang aplikasi remote access agar seseorang dapat membantu memperbaiki komputer.

Jangan memberikan akses remote kepada pihak yang tidak dapat diverifikasi.

Jika membutuhkan bantuan teknis, gunakan administrator, helpdesk, atau vendor resmi sesuai prosedur organisasi.

Backup Data Penting

Data yang tersimpan pada laptop dapat hilang akibat:

- Kerusakan perangkat.
- Kesalahan pengguna.
- Malware.
- Ransomware.
- Kehilangan perangkat.
- Pencurian.

Karena itu, data penting perlu mengikuti mekanisme backup organisasi.

Pengguna sebaiknya tidak mengandalkan satu-satunya salinan yang berada di laptop.

Jangan Mengabaikan Peringatan Keamanan

Jika perangkat memberikan peringatan seperti:

- Antivirus mendeteksi malware.
- Sistem mendeteksi aplikasi mencurigakan.
- Login tidak biasa terdeteksi.
- Disk mengalami masalah.
- Sertifikat website bermasalah.

jangan langsung mengabaikannya.

Jika tidak memahami peringatan tersebut, konsultasikan dengan administrator atau tim IT.

Jika Laptop Hilang atau Dicuri

Kehilangan perangkat harus segera dilaporkan, terutama jika perangkat digunakan untuk mengakses sistem organisasi.

Tindakan yang dapat dilakukan sesuai prosedur organisasi antara lain:

1. Laporkan kehilangan kepada pihak yang bertanggung jawab.
2. Laporkan lokasi dan waktu kejadian jika diketahui.
3. Minta administrator mencabut atau membatasi akses perangkat.
4. Periksa akun yang digunakan pada perangkat.
5. Ganti kredensial apabila diperlukan.
6. Ikuti prosedur pengamanan atau penghapusan data jarak jauh jika tersedia.

Jangan menunggu sampai ditemukan adanya penyalahgunaan akun.

Kebiasaan Aman Menggunakan Laptop dan Komputer

Pengguna dapat membangun kebiasaan sederhana:

- Kunci layar ketika meninggalkan perangkat.
- Gunakan password atau PIN.
- Jangan membagikan akun.
- Jangan menggunakan akun administrator untuk aktivitas yang tidak membutuhkan hak administrator.
- Selalu perbarui sistem dan aplikasi.
- Jangan memasang software sembarangan.

- Jangan menonaktifkan antivirus tanpa alasan yang jelas.
- Hati-hati menggunakan USB.
- Hindari menyimpan data sensitif secara sembarangan.
- Gunakan backup sesuai kebijakan organisasi.
- Segera laporkan perangkat yang hilang atau dicurigai terinfeksi.

Checklist Keamanan Perangkat

Pemeriksaan	Kondisi Aman
Password/PIN	Sudah digunakan
Screen Lock	Aktif
Update	Sistem dan aplikasi diperbarui
Endpoint Protection	Aktif
Software	Hanya software yang diperlukan
USB	Digunakan dari sumber terpercaya
Data	Disimpan sesuai kebijakan
Enkripsi	Digunakan jika diperlukan
Backup	Data penting memiliki backup
Akses	Menggunakan hak minimum

Kesimpulan

Laptop dan komputer merupakan bagian penting dari

keamanan organisasi karena perangkat tersebut menjadi titik penghubung antara pengguna, data, aplikasi, dan jaringan.

Keamanan perangkat dapat diperkuat dengan:

**Autentikasi → Screen Lock → Update → Endpoint Protection
→ Software Terpercaya → Perlindungan Data → Backup**

Pengguna tidak harus menjadi administrator sistem untuk berkontribusi terhadap keamanan. Kebiasaan sederhana seperti mengunci layar, tidak memasang software sembarangan, memperbarui sistem, dan segera melaporkan kejadian mencurigakan dapat memberikan dampak yang besar.

Laptop yang aman bukan hanya perangkat yang memiliki antivirus, tetapi perangkat yang digunakan dan dikelola dengan kebiasaan yang aman.

5.8 Mengamankan Smartphone

Smartphone saat ini tidak hanya digunakan untuk komunikasi pribadi, tetapi juga sering digunakan untuk mengakses **email, aplikasi organisasi, layanan cloud, autentikasi MFA, dan berbagai sistem informasi.**

Karena menyimpan banyak informasi dan memiliki akses ke berbagai layanan, smartphone perlu diperlakukan sebagai **aset yang harus dilindungi**, sama seperti laptop dan komputer.

Jika smartphone hilang, dicuri, atau berhasil dikompromikan, penyerang berpotensi memperoleh akses terhadap data maupun akun yang tersimpan atau terhubung dengan perangkat tersebut.

Gunakan Kunci Layar

Smartphone harus dilindungi dengan mekanisme

penguncian layar.

Gunakan:

- PIN.
- Password.
- Pattern yang tidak mudah ditebak.
- Sidik jari.
- Pengenalan wajah jika tersedia.

Untuk aktivitas organisasi, gunakan metode yang sesuai dengan kebijakan keamanan organisasi.

Jangan membiarkan smartphone tanpa pengunci layar karena perangkat dapat langsung digunakan apabila hilang atau dipinjam oleh orang lain.

Gunakan PIN atau Password yang Tidak Mudah Ditebak

Hindari PIN sederhana seperti:

1234

0000

1111

123456

Jangan menggunakan informasi yang mudah diketahui seperti tanggal lahir atau angka yang berkaitan dengan identitas pribadi.

Jika perangkat mendukungnya, gunakan PIN atau password yang cukup kuat dan tidak digunakan sebagai password untuk layanan lain.

Selalu Perbarui Sistem

Sistem operasi smartphone perlu diperbarui secara berkala.

Pembaruan dapat berisi:

- Perbaikan kerentanan keamanan.
- Perbaikan bug.
- Peningkatan keamanan sistem.
- Perbaikan komponen yang digunakan oleh aplikasi.

Jangan menunda pembaruan keamanan tanpa alasan yang jelas.

Hal yang sama berlaku untuk aplikasi yang digunakan pada smartphone.

Instal Aplikasi dari Sumber Resmi

Aplikasi sebaiknya diunduh dari toko aplikasi resmi sesuai platform perangkat.

Hindari memasang aplikasi dari sumber yang tidak dikenal hanya karena aplikasi tersebut menawarkan fitur tertentu atau tersedia secara gratis.

Berhati-hatilah terhadap aplikasi yang:

- Tidak jelas pengembangnya.
- Meminta izin yang tidak relevan.
- Meminta akses terlalu luas.
- Dikirim melalui tautan atau chat.
- Mengklaim sebagai aplikasi resmi tetapi berasal dari sumber tidak resmi.

Periksa Izin Aplikasi

Aplikasi dapat meminta akses terhadap berbagai fungsi smartphone.

Contohnya:

- Kamera.
- Mikrofon.
- Lokasi.
- Kontak.
- File.
- SMS.
- Telepon.

Pengguna perlu mempertimbangkan apakah izin tersebut memang diperlukan.

Misalnya, aplikasi kalkulator sederhana seharusnya tidak membutuhkan akses ke kontak atau mikrofon tanpa alasan yang jelas.

Secara berkala, periksa kembali izin aplikasi dan cabut izin yang tidak diperlukan.

Gunakan MFA dengan Aman

Smartphone sering digunakan sebagai perangkat autentikasi MFA.

Misalnya:

Login

↓

Username + Password



Authenticator



Verifikasi MFA



Akses

Karena itu, smartphone yang digunakan untuk MFA harus mendapatkan perlindungan tambahan.

Jika perangkat hilang, segera laporkan dan ikuti prosedur organisasi untuk mengganti atau mencabut perangkat autentikasi tersebut.

Jangan Memberikan Kode OTP

OTP yang diterima melalui smartphone harus diperlakukan sebagai informasi rahasia.

Jangan memberikan kode OTP kepada orang lain, meskipun orang tersebut mengaku sebagai:

- Administrator.
- Customer service.
- Petugas bank.
- Teknisi.
- Pihak keamanan.

Jika pengguna tidak sedang melakukan proses login tetapi tiba-tiba menerima kode OTP atau permintaan autentikasi,

jangan memberikan atau menyetujui permintaan tersebut.

Hati-Hati dengan SMS dan Pesan Instan

Smartphone dapat menerima pesan melalui SMS, WhatsApp, Telegram, email, dan berbagai aplikasi komunikasi lainnya.

Pesan tersebut dapat digunakan untuk:

- Phishing.
- Penipuan.
- Penyebaran tautan berbahaya.
- Social engineering.
- Pencurian kredensial.

Jangan langsung percaya hanya karena pesan berasal dari nomor atau akun yang terlihat dikenal.

Jika pesan meminta tindakan penting, lakukan verifikasi melalui kanal lain.

Jangan Sembarangan Mengklik Tautan

Tautan pada SMS atau aplikasi pesan dapat mengarah ke website berbahaya.

Contohnya:

"Paket Anda tertahan. Klik tautan berikut untuk melakukan pembayaran."

atau:

"Akun Anda bermasalah. Klik untuk melakukan verifikasi."

Jangan langsung mengklik tautan tersebut.

Jika memang memiliki transaksi atau layanan yang sedang digunakan, buka aplikasi atau website resminya secara langsung.

Berhati-hati Menggunakan Wi-Fi Publik

Smartphone sering otomatis mencari jaringan Wi-Fi yang tersedia.

Berhati-hatilah ketika menggunakan Wi-Fi publik, terutama untuk aktivitas sensitif.

Hindari melakukan aktivitas administrasi penting melalui jaringan yang tidak dipercaya apabila tidak diperlukan.

Ikuti kebijakan organisasi jika smartphone digunakan untuk mengakses sistem internal.

Bluetooth dan Fitur Koneksi

Bluetooth dan fitur konektivitas lainnya sebaiknya tidak dibiarkan aktif tanpa kebutuhan.

Jika tidak diperlukan, pengguna dapat menonaktifkannya sesuai kebutuhan.

Hal yang sama berlaku untuk fitur koneksi atau berbagi perangkat yang memungkinkan perangkat lain berinteraksi dengan smartphone.

Jangan Melakukan Root atau Jailbreak Sembarangan

Rooting atau jailbreaking dapat mengubah mekanisme keamanan bawaan perangkat.

Untuk smartphone yang digunakan dalam aktivitas organisasi, jangan melakukan perubahan tersebut tanpa persetujuan dan pertimbangan keamanan dari pihak yang bertanggung jawab.

Perubahan sistem dapat:

- Mengurangi perlindungan bawaan.
- Meningkatkan risiko aplikasi berbahaya.
- Mengganggu mekanisme keamanan organisasi.
- Menyebabkan perangkat tidak memenuhi kebijakan keamanan.

Lindungi Data pada Smartphone

Smartphone dapat menyimpan:

- Email.
- Foto.
- Dokumen.
- Kontak.
- Pesan.
- Data aplikasi.
- Token atau informasi autentikasi.

Karena itu, pengguna perlu berhati-hati terhadap data yang disimpan di perangkat.

Data organisasi sebaiknya hanya disimpan sesuai kebutuhan dan kebijakan yang berlaku.

Gunakan Fitur Pelacakan dan Penghapusan Jarak Jauh

Smartphone modern umumnya menyediakan mekanisme untuk membantu menemukan perangkat yang hilang dan, pada kondisi tertentu, menghapus data dari jarak jauh.

Jika fitur tersebut tersedia dan diperbolehkan oleh kebijakan organisasi, sebaiknya diaktifkan.

Tujuannya adalah mengurangi risiko apabila perangkat hilang atau dicuri.

Gambaran sederhananya:

Smartphone Hilang



Deteksi Kehilangan



Kunci Perangkat



Pelacakan / Remote Wipe



Data Lebih Terlindungi

Jangan Membiarkan Smartphone Tidak Diawasi

Smartphone merupakan perangkat yang mudah dibawa dan mudah hilang.

Hindari meninggalkannya:

- Di tempat umum.
- Di kendaraan tanpa pengawasan.
- Di meja dalam kondisi tidak terkunci.
- Di lokasi yang mudah diakses orang lain.

Aktifkan screen lock sehingga kehilangan perangkat tidak

langsung berarti akses terhadap seluruh data terbuka.

Jika Smartphone Hilang

Jika smartphone yang digunakan untuk aktivitas organisasi hilang atau dicuri, segera laporkan.

Langkah yang dapat dilakukan sesuai prosedur organisasi:

1. Kunci perangkat.
2. Gunakan fitur pelacakan jika tersedia.
3. Laporkan kehilangan.
4. Cabut akses akun dari perangkat tersebut.
5. Ganti password akun penting jika diperlukan.
6. Cabut atau ganti perangkat MFA.
7. Lakukan remote wipe jika diperlukan dan tersedia.
8. Pantau aktivitas akun untuk mendeteksi penggunaan yang tidak sah.

Jangan menunggu sampai muncul indikasi penyalahgunaan.

Checklist Keamanan Smartphone

Pemeriksaan	Kondisi Aman
Screen Lock	Aktif
PIN/Password	Tidak mudah ditebak
Sistem Operasi	Diperbarui
Aplikasi	Dari sumber terpercaya

Pemeriksaan	Kondisi Aman
Izin Aplikasi	Sesuai kebutuhan
MFA	Dilindungi
OTP	Tidak dibagikan
Tautan	Diperiksa sebelum dibuka
Wi-Fi	Menggunakan jaringan terpercaya
Pelacakan	Diaktifkan jika tersedia
Remote Wipe	Tersedia jika diperlukan

Kesimpulan

Smartphone merupakan bagian penting dari keamanan karena perangkat tersebut dapat menyimpan data, menjalankan aplikasi, menerima pesan, dan digunakan sebagai faktor autentikasi.

Keamanan smartphone dapat diperkuat dengan:

Screen Lock → Update → Aplikasi Terpercaya → Kontrol Izin → MFA → Perlindungan Data → Pelacakan dan Remote Wipe

Pengguna juga perlu berhati-hati terhadap pesan, tautan, aplikasi, dan permintaan autentikasi yang mencurigakan.

Smartphone bukan sekadar alat komunikasi. Jika digunakan untuk mengakses sistem organisasi, smartphone merupakan bagian dari perimeter keamanan organisasi.

5.9 Menggunakan USB Flashdisk dengan Aman

USB flashdisk merupakan media penyimpanan yang praktis dan sering digunakan untuk memindahkan dokumen, aplikasi, maupun data antara satu komputer dengan komputer lainnya.

Namun, USB flashdisk juga dapat menjadi salah satu media penyebaran **malware**. Flashdisk yang telah terinfeksi dapat membawa file berbahaya ke komputer lain ketika digunakan.

Selain risiko malware, kehilangan flashdisk juga dapat menyebabkan **kebocoran data** apabila di dalamnya terdapat informasi organisasi yang tidak terlindungi.

Karena itu, penggunaan USB flashdisk perlu dilakukan dengan hati-hati.

Jangan Menggunakan Flashdisk yang Tidak Dikenal

Jangan sembarangan menggunakan flashdisk yang:

- Ditemukan di tempat umum.
- Tidak diketahui pemiliknya.
- Diberikan oleh orang yang tidak dikenal.
- Tidak jelas asal-usulnya.
- Tiba-tiba muncul di lingkungan kerja.

Flashdisk yang sengaja ditinggalkan dapat menjadi media untuk membuat pengguna penasaran dan kemudian memasukkannya ke komputer.

Prinsip sederhananya:

Jika tidak tahu dari mana flashdisk berasal, jangan menggunakannya.

Gunakan Flashdisk untuk Kebutuhan yang Jelas

Flashdisk sebaiknya digunakan hanya untuk kebutuhan yang memang diperlukan.

Hindari menjadikan flashdisk sebagai tempat penyimpanan berbagai macam file tanpa pengelolaan yang jelas.

Semakin banyak data yang disimpan, semakin besar pula risiko apabila flashdisk hilang atau dicuri.

Periksa Flashdisk Sebelum Membuka File

Jika flashdisk berasal dari sumber yang dapat dipercaya, tetap lakukan pemeriksaan sebelum membuka file.

Perhatikan:

- Nama file.
- Ekstensi file.
- Lokasi file.
- Apakah file memang diharapkan.
- Apakah antivirus atau endpoint protection memberikan peringatan.

Contohnya, pengguna mengharapkan sebuah dokumen:

Laporan.docx

tetapi menemukan file:

Laporan.docx.exe

File tersebut perlu dicurigai karena sebenarnya merupakan executable.

Jangan Sembarangan Menjalankan File

File yang berada di dalam flashdisk tidak otomatis aman.

Berhati-hatilah terhadap file yang dapat menjalankan program atau script, seperti:

.exe

.bat

.cmd

.scr

.js

.ps1

Jenis file dan tingkat risikonya dapat berbeda tergantung sistem operasi dan konfigurasi perangkat.

Jika file tidak diperlukan atau sumbernya tidak dapat dipastikan, jangan menjalankannya.

Gunakan Antivirus atau Endpoint Protection

Flashdisk yang digunakan pada komputer organisasi sebaiknya diperiksa menggunakan mekanisme keamanan endpoint yang telah ditetapkan organisasi.

Jika sistem keamanan mendeteksi file mencurigakan:

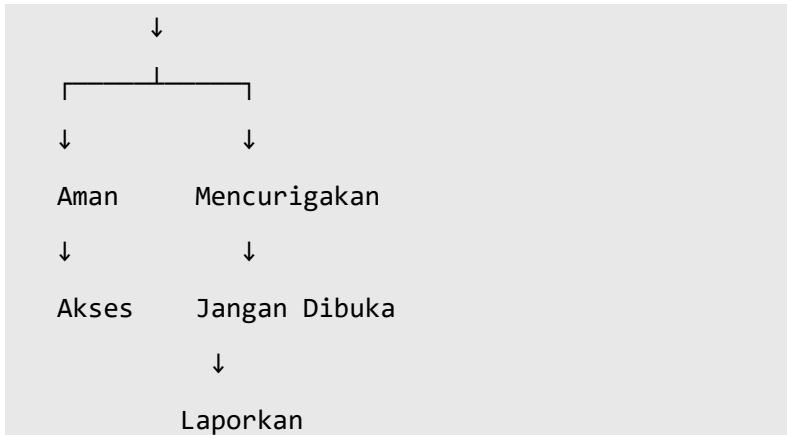
USB Flashdisk



Endpoint Protection



Pemeriksaan



Jangan menonaktifkan antivirus hanya agar file dari flashdisk dapat dibuka.

Jangan Menonaktifkan Fitur Keamanan

Pengguna terkadang menemukan masalah ketika membuka file dari USB kemudian mendapatkan peringatan keamanan.

Jangan mengatasi masalah tersebut dengan menonaktifkan antivirus atau mekanisme keamanan perangkat.

Jika file memang diperlukan untuk pekerjaan, konsultasikan dengan administrator atau tim IT.

Hindari Menyimpan Data Sensitif Tanpa Perlindungan

Flashdisk mudah hilang karena ukurannya kecil.

Karena itu, hindari menyimpan data sensitif secara sembarangan, terutama:

- Data pribadi.
- Data pasien.

- Data keuangan.
- Dokumen internal.
- Database.
- Kredensial.
- Dokumen rahasia organisasi.

Jika penyimpanan data pada USB memang diperlukan, gunakan media dan mekanisme perlindungan yang telah disetujui organisasi, termasuk **enkripsi** apabila tersedia atau diwajibkan.

Jangan Menyimpan Password di Flashdisk

Hindari menyimpan file seperti:

password.txt

akun.txt

credential.xlsx

terutama tanpa perlindungan.

Jika pengguna membutuhkan pengelolaan password, gunakan mekanisme pengelolaan kredensial yang sesuai, seperti password manager yang disetujui organisasi.

Gunakan Flashdisk Khusus untuk Organisasi

Jika organisasi memiliki kebijakan penggunaan media penyimpanan, ikuti kebijakan tersebut.

Untuk kebutuhan tertentu, organisasi dapat menetapkan flashdisk khusus yang:

- Terdaftar.
- Dikelola organisasi.

- Memiliki enkripsi.
- Dapat dipantau penggunaannya.
- Hanya digunakan untuk kebutuhan tertentu.

Hal ini lebih baik daripada menggunakan flashdisk pribadi secara bebas untuk memindahkan data organisasi.

Jangan Memindahkan File Organisasi Sembarangan

Pemindahan data menggunakan USB perlu mempertimbangkan **keamanan dan kebutuhan pekerjaan**.

Misalnya:

Server Organisasi



USB



Komputer Pribadi



Cloud Pribadi

Perpindahan seperti ini dapat menyebabkan data organisasi keluar dari lingkungan yang seharusnya.

Sebelum memindahkan data, pastikan tindakan tersebut diperbolehkan oleh kebijakan organisasi.

Hapus Data yang Tidak Lagi Diperlukan

Jika flashdisk digunakan untuk memindahkan file sementara, jangan membiarkan data tersebut tersimpan selamanya.

Setelah pekerjaan selesai, data yang tidak lagi diperlukan dapat dihapus sesuai prosedur organisasi.

Namun, apabila data merupakan bagian dari arsip atau bukti pekerjaan, jangan menghapusnya tanpa memastikan bahwa penghapusan tersebut diperbolehkan.

Eject Flashdisk dengan Benar

Setelah selesai menggunakan flashdisk, lakukan proses **eject/safely remove** sebelum mencabutnya apabila sistem operasi atau kebijakan perangkat mengharuskannya.

Hal ini membantu mengurangi risiko kerusakan data akibat proses penulisan yang belum selesai.

Jika Flashdisk Hilang

Kehilangan flashdisk perlu dilaporkan apabila media tersebut digunakan untuk menyimpan data organisasi.

Terutama jika flashdisk berisi:

- Data pribadi.
- Dokumen rahasia.
- Data keuangan.
- Data operasional.
- Informasi internal.

Jangan menunggu sampai diketahui adanya kebocoran data.

Jika flashdisk menggunakan enkripsi, risiko akses terhadap data dapat lebih rendah dibandingkan media tanpa perlindungan.

Checklist Penggunaan USB Flashdisk

Pemeriksaan

Kondisi Aman

Sumber USB	Diketahui dan terpercaya
File	Sesuai kebutuhan
Antivirus	Aktif
File mencurigakan	Tidak dijalankan
Data sensitif	Dilindungi
Enkripsi	Digunakan jika diperlukan
Password	Tidak disimpan sembarangan
Kebijakan organisasi	Dipatuhi
Setelah digunakan	Eject dengan benar
Kehilangan	Segera dilaporkan

Kebiasaan Sederhana

Sebelum menggunakan flashdisk, ingat prinsip:

Kenali sumbernya → Periksa isinya → Jangan jalankan file mencurigakan → Lindungi datanya → Lepaskan dengan aman.

Kesimpulan

USB flashdisk memang praktis, tetapi dapat menjadi media penyebaran malware dan sumber kebocoran data apabila digunakan tanpa pengamanan.

Pengguna sebaiknya:

- Tidak menggunakan flashdisk yang tidak diketahui

asalnya.

- Memeriksa file sebelum membukanya.
- Tidak menjalankan file mencurigakan.
- Memastikan endpoint protection aktif.
- Tidak menyimpan data sensitif tanpa perlindungan.
- Menggunakan enkripsi jika diperlukan.
- Mengikuti kebijakan organisasi.
- Segera melaporkan flashdisk yang hilang.

USB flashdisk adalah media penyimpanan, bukan media yang otomatis aman. Perlakukan setiap media penyimpanan sebagai bagian dari keamanan informasi.

5.10 Backup Data

Backup data adalah proses membuat salinan data yang dapat digunakan untuk memulihkan informasi ketika data asli hilang, rusak, terhapus, terenkripsi, atau tidak dapat diakses. Backup merupakan salah satu komponen penting dalam menjaga **availability** informasi dan mendukung proses pemulihan ketika terjadi insiden keamanan.

Bagi pengguna, backup bukan hanya persoalan teknis yang menjadi tanggung jawab administrator. Pengguna juga perlu memahami **data apa yang harus disimpan, bagaimana menyimpannya, dan apa yang harus dilakukan ketika data mengalami masalah.**

Mengapa Backup Penting?

Data dapat hilang atau tidak dapat digunakan karena

berbagai sebab, antara lain:

- Ransomware.
- Malware.
- Kesalahan manusia.
- Penghapusan data secara tidak sengaja.
- Kerusakan perangkat keras.
- Kegagalan sistem.
- Kesalahan konfigurasi.
- Gangguan infrastruktur.
- Bencana seperti kebakaran atau banjir.
- Serangan terhadap server atau database.

Tanpa backup yang dapat dipulihkan, organisasi mungkin harus membangun kembali data dari awal. Pada sistem yang menyimpan data penting selama bertahun-tahun, kondisi tersebut dapat menyebabkan gangguan operasional yang serius.

Contoh Kasus

Sebuah organisasi memiliki server yang menyimpan database aplikasi pelayanan. Data hanya disimpan pada server produksi dan tidak memiliki backup yang teruji.

Suatu hari server terkena ransomware. Database dan file aplikasi terenkripsi sehingga aplikasi tidak dapat digunakan.

Administrator memiliki beberapa pilihan untuk melakukan pemulihan, tetapi tidak memiliki salinan data yang dapat digunakan.

Akibatnya, organisasi tidak hanya menghadapi masalah keamanan, tetapi juga mengalami **kehilangan data dan gangguan layanan**.

Berbeda jika organisasi memiliki backup yang terpisah dan dapat dipulihkan. Setelah sistem yang terinfeksi ditangani, organisasi dapat melakukan recovery dari backup yang masih aman.

Backup Bukan Sekadar Copy File

Kesalahan yang cukup umum adalah menganggap backup hanya berarti menyalin file ke tempat lain.

Contohnya:

Server Produksi



Backup Server

Jika backup server selalu terhubung dan memiliki kredensial yang sama dengan server produksi, ransomware yang berhasil menguasai server produksi berpotensi mengakses dan mengenkripsi backup tersebut.

Karena itu, backup perlu dirancang dengan mempertimbangkan:

- **Keamanan**
- **Pemisahan**
- **Kemampuan pemulihan**
- **Backup Harus Dilindungi**

Memiliki backup tidak otomatis berarti organisasi aman.

Backup juga harus dilindungi dari:

- Penghapusan.
- Manipulasi.
- Ransomware.
- Akses tidak sah.

Artinya, sistem backup juga merupakan bagian dari aset yang harus diamankan.

Pengguna tidak boleh sembarangan memberikan akses terhadap lokasi penyimpanan backup, terutama jika backup berisi data sensitif organisasi.

Backup dan Ransomware

Backup memiliki peran penting ketika organisasi menghadapi ransomware.

Tanpa backup:

Ransomware



Data Dikripsi



Data Tidak Dapat Diakses



Pemulihan Sulit

Dengan backup yang terlindungi:

Ransomware



Data Produksi Terdampak



Insiden Ditangani



Backup Aman



Recovery

Dokumen buku juga menekankan bahwa strategi backup yang baik penting untuk mengurangi dampak ransomware, termasuk penggunaan **salinan offline atau immutable backup** pada lingkungan yang sesuai.

Peran Pengguna

Sebagai pengguna, beberapa hal sederhana yang perlu diperhatikan:

- Simpan data pekerjaan pada lokasi yang ditentukan organisasi.
- Jangan hanya menyimpan satu-satunya salinan data penting pada laptop.
- Jangan menyimpan data organisasi pada media pribadi tanpa izin.
- Ikuti kebijakan backup organisasi.
- Jangan menghapus data backup tanpa kewenangan.
- Segera laporkan kehilangan atau kerusakan data.

- Jika terkena ransomware, jangan mencoba melakukan pemulihan sendiri tanpa mengikuti prosedur organisasi.
- **Jika Data Terkena Ransomware**

Jika komputer menunjukkan tanda-tanda ransomware, pengguna sebaiknya **segera melaporkan kepada administrator atau tim keamanan**.

Jangan langsung mencoba mengambil backup dari perangkat yang terinfeksi dan menghubungkannya ke sistem tersebut, karena backup dapat ikut terkena dampak.

Pemulihan harus dilakukan menggunakan prosedur yang telah ditetapkan organisasi.

Backup Harus Bisa Dipulihkan

Hal penting yang perlu diperhatikan adalah **backup yang berhasil dibuat belum tentu backup yang dapat digunakan**.

Organisasi perlu memastikan proses pemulihan dapat dilakukan.

Secara sederhana:

Backup



Penyimpanan



Pengujian Restore



Data Dapat Dipulihkan



Backup Siap Digunakan

Jadi, keberhasilan proses backup saja tidak cukup. Kemampuan melakukan **restore** juga harus diperhatikan.

Checklist Backup Data

Pemeriksaan	Kondisi yang Baik
Data penting	Memiliki backup
Lokasi backup	Terpisah dari data utama
Perlindungan	Backup dilindungi
Akses	Dibatasi
Ransomware	Backup tidak mudah ikut terenkripsi
Restore	Dapat dipulihkan
Pengelolaan	Mengikuti kebijakan organisasi
Insiden	Segera dilaporkan

Kesimpulan

Backup merupakan salah satu mekanisme penting untuk menjaga **availability** dan membantu organisasi melakukan recovery setelah terjadi insiden.

Namun:

Backup bukan sekadar membuat salinan data. Backup harus aman, terpisah, dan dapat dipulihkan.

Bagi pengguna, hal terpenting adalah memahami bahwa data

pekerjaan tidak boleh hanya bergantung pada satu perangkat atau satu salinan. Pengguna juga harus mengikuti mekanisme backup yang telah ditetapkan organisasi dan segera melaporkan apabila terjadi kehilangan atau kerusakan data.

5.11 Melindungi Data Organisasi

Data merupakan salah satu aset penting dalam organisasi. Data digunakan untuk menjalankan pelayanan, administrasi, pengambilan keputusan, serta berbagai aktivitas operasional.

Data organisasi dapat berupa:

- Data pegawai.
- Data pelanggan atau masyarakat.
- Data pasien.
- Data keuangan.
- Dokumen administrasi.
- Dokumen pekerjaan.
- Database aplikasi.
- Informasi internal.
- Dokumen yang bersifat rahasia.

Apabila data tersebut bocor, diubah, hilang, atau digunakan oleh pihak yang tidak berwenang, organisasi dapat mengalami kerugian operasional, finansial, maupun reputasi.

Karena itu, **setiap pengguna memiliki tanggung jawab untuk menjaga data organisasi yang berada dalam aksesnya.**

Jangan Membagikan Data Sembarangan

Data organisasi tidak boleh diberikan kepada pihak lain hanya karena mereka meminta.

Sebelum membagikan data, pastikan:

- Siapa yang meminta data?
- Untuk keperluan apa?
- Apakah orang tersebut memiliki kewenangan?
- Apakah data tersebut memang boleh dibagikan?
- Apakah terdapat prosedur yang harus diikuti?

Jika tidak yakin, jangan langsung mengirimkan data. Lakukan verifikasi kepada pihak yang bertanggung jawab.

- **Kenali Tingkat Sensitivitas Data**

Tidak semua data memiliki tingkat kerahasiaan yang sama.

Secara sederhana, data dapat dibedakan berdasarkan tingkat sensitivitas dan kebutuhan perlindungannya.

Contohnya:

Jenis Data	Contoh
Publik	Informasi yang memang dipublikasikan organisasi
Internal	Dokumen dan informasi untuk kebutuhan internal
Sensitif	Data pribadi, keuangan, atau informasi operasional tertentu

Jenis Data	Contoh
-------------------	---------------

Rahasia	Informasi yang hanya boleh diakses oleh pihak tertentu
---------	--

Klasifikasi yang sebenarnya harus mengikuti kebijakan organisasi.

Semakin sensitif suatu data, semakin ketat pula kontrol akses dan perlindungannya.

Gunakan Data Sesuai Kebutuhan

Pengguna sebaiknya hanya mengakses data yang diperlukan untuk pekerjaannya.

Hal ini sejalan dengan prinsip **Least Privilege**.

Misalnya, seorang pegawai yang hanya membutuhkan data tertentu untuk menyelesaikan pekerjaannya tidak perlu memiliki akses ke seluruh database organisasi.

Prinsipnya:

Akses data hanya sesuai kebutuhan dan kewenangan.

Jangan Menyimpan Data Organisasi di Tempat Sembarangan

Data organisasi sebaiknya disimpan pada sistem penyimpanan yang telah ditentukan organisasi.

Hindari memindahkan data organisasi ke:

- Laptop pribadi tanpa izin.
- Flashdisk pribadi.
- Email pribadi.

- Cloud pribadi.
- Aplikasi berbagi file yang tidak disetujui.
- Media penyimpanan yang tidak terlindungi.

Pemindahan data ke tempat yang tidak dikelola organisasi dapat meningkatkan risiko kehilangan kendali terhadap data.

Hati-Hati Mengirim Data Melalui Email

Sebelum mengirim dokumen organisasi melalui email, periksa kembali penerimanya.

Pastikan:

- Alamat penerima benar.
- Lampiran yang dikirim memang diperlukan.
- Data boleh dikirim melalui email.
- Penerima memiliki kewenangan.
- Metode perlindungan sesuai dengan kebijakan organisasi.

Kesalahan sederhana dalam memilih alamat email dapat menyebabkan data terkirim kepada orang yang salah.

Jangan Membagikan Data melalui Aplikasi Pribadi

Pengguna terkadang menggunakan aplikasi komunikasi pribadi karena dianggap lebih praktis.

Namun, data organisasi yang dikirim melalui aplikasi pribadi dapat berada di luar kendali organisasi.

Sebelum menggunakan layanan atau aplikasi tertentu untuk mengirim data organisasi, pastikan penggunaannya memang

diperbolehkan.

Lindungi Data yang Disimpan

Data yang tersimpan pada laptop, smartphone, flashdisk, maupun media lainnya harus mendapatkan perlindungan yang sesuai.

Beberapa bentuk perlindungan antara lain:

- Password.
- Access control.
- Encryption.
- Backup.
- MFA untuk akun yang mengakses data.
- Endpoint protection.

Tidak semua data harus menggunakan mekanisme yang sama. Perlindungan perlu disesuaikan dengan tingkat sensitivitas dan risiko data.

Jangan Mengunggah Data Organisasi ke Layanan AI atau Online Sembarangan

Layanan online dapat memberikan manfaat dalam pekerjaan, tetapi pengguna harus berhati-hati ketika memasukkan data organisasi.

Jangan memasukkan informasi sensitif atau rahasia ke layanan online yang belum disetujui organisasi.

Contohnya:

Dokumen Internal



Upload ke Layanan Online



Data Berada di Sistem Pihak Ketiga

Sebelum menggunakan layanan tersebut, pastikan penggunaannya sesuai dengan kebijakan organisasi dan klasifikasi data yang akan diproses.

Hati-Hati Saat Menggunakan Screenshot

Screenshot terkadang terlihat tidak berbahaya, tetapi dapat memperlihatkan informasi sensitif.

Misalnya screenshot dapat menampilkan:

- Nama pengguna.
- Alamat email.
- Nomor identitas.
- Data pasien.
- Alamat IP.
- Informasi server.
- Nama database.
- Informasi sistem internal.

Sebelum membagikan screenshot, periksa kembali seluruh bagian gambar dan pastikan informasi sensitif tidak ikut terlihat.

Jangan Membagikan Password atau Kredensial

Password, API key, token, OTP, dan informasi autentikasi

merupakan informasi yang harus dilindungi.

Jangan memasukkan kredensial organisasi ke:

- Chat pribadi.
- Email yang tidak aman.
- Dokumen publik.
- Screenshot.
- Repository publik.
- Media sosial.

Jika kredensial diduga telah terekspos, segera laporkan dan lakukan tindakan sesuai prosedur organisasi.

Hapus Data dengan Benar

Menghapus file tidak selalu berarti data langsung tidak dapat dipulihkan.

Untuk data sensitif, penghapusan harus mengikuti prosedur organisasi dan mekanisme yang sesuai dengan jenis media penyimpanan.

Jangan membuang dokumen fisik yang berisi data sensitif ke tempat sampah biasa.

Gunakan prosedur pemusnahan dokumen yang telah ditetapkan organisasi.

Jangan Mengubah Data Tanpa Kewenangan

Melindungi data bukan hanya mencegah pencurian.

Integrity juga harus dijaga.

Pengguna tidak boleh mengubah, menghapus, atau

memanipulasi data organisasi jika tidak memiliki kewenangan.

Contohnya:

Data Organisasi



Pengguna Berwenang



Perubahan Sesuai Prosedur



Data Tetap Dapat Dipertanggungjawabkan

Perubahan penting sebaiknya dapat ditelusuri melalui mekanisme pencatatan atau audit yang diterapkan organisasi.

Backup Data Penting

Data organisasi yang penting harus mengikuti mekanisme backup yang telah ditetapkan.

Backup membantu ketika data mengalami:

- Penghapusan.
- Kerusakan.
- Ransomware.
- Kegagalan perangkat.
- Gangguan sistem.

Pembahasan mengenai backup telah dijelaskan pada

Subbab 5.10 Backup Data.

Pengguna tidak perlu membuat mekanisme backup sendiri

jika organisasi sudah memiliki sistem backup terpusat. Yang penting adalah mengikuti prosedur penyimpanan data yang telah ditetapkan.

Jika Data Salah Kirim

Kesalahan pengiriman data dapat terjadi, misalnya dokumen dikirim kepada alamat email yang salah.

Jika hal tersebut terjadi:

1. Jangan mencoba menyembunyikan kejadian.
2. Segera laporkan kepada pihak yang bertanggung jawab.
3. Jelaskan data yang terkirim dan penerimanya.
4. Ikuti prosedur penanganan insiden.
5. Jangan melakukan tindakan tambahan tanpa arahan jika data tersebut bersifat sensitif.

Pelaporan dengan cepat dapat membantu organisasi menentukan tindakan yang diperlukan.

Jika Menemukan Data yang Tidak Seharusnya Dapat Diakses

Pengguna mungkin menemukan data yang seharusnya tidak dapat diakses olehnya.

Misalnya:

Seorang pegawai dapat membuka dokumen yang seharusnya hanya tersedia untuk bagian tertentu.

Jangan memanfaatkan akses tersebut atau menyebarkan data yang ditemukan.

Sebaiknya:

1. Jangan membuka data lebih jauh dari yang diperlukan untuk mengetahui masalah.
2. Jangan menyalin atau menyebarkan data.
3. Laporkan kepada administrator atau pihak yang bertanggung jawab.
4. Ikuti prosedur organisasi.

- **Checklist Perlindungan Data**

Pemeriksaan	Pertanyaan
--------------------	-------------------

Akses	Apakah saya memang berhak mengakses data?
Penyimpanan	Apakah data disimpan di tempat yang ditentukan?
Pengiriman	Apakah penerima memiliki kewenangan?
Sharing	Apakah data boleh dibagikan?
Kredensial	Apakah password/token tetap rahasia?
Perangkat	Apakah perangkat terlindungi?
Cloud	Apakah layanan yang digunakan disetujui?
Backup	Apakah data mengikuti mekanisme backup?
Perubahan	Apakah saya berwenang mengubah data?
Insiden	Apakah kesalahan atau kebocoran segera dilaporkan?

Prinsip Sederhana

Sebelum menggunakan atau membagikan data organisasi, biasakan bertanya:

Apakah saya berwenang mengakses data ini?

Apakah data ini boleh dibagikan?

Apakah penerimanya memang berhak menerima?

Apakah media yang digunakan aman dan diperbolehkan?

Jika tidak yakin, **jangan membagikan data sebelum melakukan verifikasi.**

Kesimpulan

Melindungi data organisasi merupakan tanggung jawab seluruh pengguna, bukan hanya administrator atau tim keamanan.

Perlindungan data mencakup:

Akses yang tepat → Penyimpanan yang aman → Penggunaan yang sesuai → Pengiriman yang terkendali → Backup → Pelaporan insiden

Pengguna harus memahami bahwa kebocoran data dapat terjadi bukan hanya karena serangan teknis, tetapi juga karena kesalahan sederhana seperti salah mengirim email, membagikan screenshot, menggunakan cloud pribadi, atau memberikan akses kepada pihak yang tidak berwenang.

Data organisasi harus diperlakukan sebagai aset yang memiliki nilai dan harus dilindungi sesuai tingkat sensitivitasnya.

5.12 Bekerja dari Luar Kantor (Remote Working)

Remote Working adalah kondisi ketika pengguna menjalankan pekerjaan dan mengakses sumber daya organisasi dari luar lingkungan kantor. Remote working dapat dilakukan dari rumah, perjalanan dinas, lokasi mitra kerja, maupun lokasi lain yang tidak berada dalam jaringan kantor.

Bekerja dari luar kantor memberikan fleksibilitas, tetapi juga menimbulkan risiko keamanan tambahan karena perangkat dan koneksi yang digunakan berada di luar lingkungan yang sepenuhnya dikendalikan organisasi.

Dalam struktur buku, **5.12 Bekerja dari Luar Kantor (Remote Working)** memang merupakan bagian dari BAB 5 setelah *Melindungi Data Organisasi*.

Gunakan Perangkat yang Diizinkan

Jika organisasi menyediakan laptop atau perangkat khusus untuk bekerja dari luar kantor, gunakan perangkat tersebut sesuai kebijakan.

Hindari menggunakan komputer umum atau perangkat milik orang lain untuk mengakses sistem organisasi, terutama sistem yang mengandung data sensitif.

Jika penggunaan perangkat pribadi diperbolehkan, perangkat tersebut harus memenuhi persyaratan keamanan organisasi.

Gunakan Koneksi yang Aman

Koneksi internet yang digunakan ketika bekerja dari luar kantor perlu diperhatikan.

Jika organisasi menyediakan **VPN**, gunakan VPN sesuai

prosedur untuk mengakses sumber daya internal.

Contohnya:

Pengguna di Luar Kantor



Internet



VPN



Jaringan Organisasi



Sistem Internal

VPN bukan berarti semua aktivitas otomatis aman. Pengguna tetap harus menggunakan akun yang benar, MFA, perangkat yang aman, dan mengikuti kebijakan organisasi.

Hati-Hati Menggunakan Wi-Fi Publik

Wi-Fi di hotel, kafe, bandara, atau tempat umum dapat memberikan kemudahan ketika bekerja dari luar kantor.

Namun, pengguna tidak boleh menganggap jaringan tersebut sebagai jaringan yang sepenuhnya terpercaya.

Untuk pekerjaan yang sensitif:

- Gunakan koneksi yang dipercaya.
- Gunakan VPN jika diwajibkan.
- Hindari mengakses sistem penting melalui jaringan yang

tidak dikenal apabila tidak diperlukan.

- Jangan melakukan aktivitas sensitif hanya karena jaringan menggunakan nama yang terlihat resmi.
- **Lindungi Laptop Saat Bekerja di Tempat Umum**

Ketika bekerja di tempat umum, risiko tidak hanya berasal dari jaringan.

Orang lain dapat melihat layar atau dokumen yang sedang dibuka.

Hal ini dikenal sebagai **shoulder surfing**.

Contohnya:

Laptop



Data Organisasi



Dilihat Orang di Sekitar



Informasi Terungkap

Karena itu:

- Perhatikan posisi layar.
- Hindari membuka data sensitif di tempat yang ramai.
- Gunakan privacy screen jika diperlukan.
- Jangan meninggalkan laptop tanpa pengawasan.
- Selalu kunci layar ketika meninggalkan perangkat.

Jangan Meminjamkan Perangkat Kerja

Laptop organisasi sebaiknya tidak digunakan oleh anggota keluarga, teman, atau pihak lain tanpa izin.

Perangkat tersebut dapat memiliki akses ke:

- Email organisasi.
- Dokumen.
- VPN.
- Aplikasi internal.
- Data organisasi.

Penggunaan oleh pihak lain dapat menyebabkan data atau kredensial terekspos.

Jangan Menyimpan Data Organisasi di Perangkat Pribadi Tanpa Izin

Ketika bekerja dari rumah, pengguna mungkin tergoda memindahkan file organisasi ke komputer pribadi agar lebih mudah bekerja.

Hal tersebut tidak boleh dilakukan apabila bertentangan dengan kebijakan organisasi.

Hindari memindahkan data ke:

- Komputer pribadi.
- Flashdisk pribadi.
- Cloud pribadi.
- Email pribadi.
- Aplikasi berbagi file pribadi.

Gunakan media penyimpanan dan layanan yang telah ditentukan organisasi.

Gunakan MFA

Remote working membuat akun organisasi dapat diakses dari lokasi yang lebih beragam.

Karena itu, MFA menjadi lapisan perlindungan penting.

Login dari Luar Kantor



Username + Password



MFA



Verifikasi Berhasil



Akses Diberikan

Jika password berhasil dicuri, faktor tambahan dapat membantu mengurangi risiko pengambilalihan akun.

Jangan Memberikan Akses Remote kepada Orang Lain

Jangan memberikan username, password, kode MFA, atau akses remote kepada orang lain agar mereka dapat "membantu" mengerjakan sesuatu.

Jika membutuhkan bantuan teknis, gunakan helpdesk atau administrator yang ditunjuk organisasi.

Perbarui Perangkat Sebelum Digunakan

Laptop dan smartphone yang digunakan untuk remote working harus tetap diperbarui.

Pastikan:

- Sistem operasi mendapatkan pembaruan.
- Browser diperbarui.
- Aplikasi pekerjaan diperbarui.
- Endpoint protection aktif.
- Tidak terdapat aplikasi mencurigakan.

Remote working tidak boleh menjadi alasan untuk mengabaikan keamanan perangkat.

Waspadai Lingkungan Sekitar

Ketika bekerja dari luar kantor, lingkungan fisik juga perlu diperhatikan.

Hindari membahas informasi rahasia di tempat umum apabila percakapan dapat didengar orang lain.

Demikian pula, dokumen fisik tidak boleh dibiarkan terbuka atau ditinggalkan tanpa pengawasan.

Keamanan informasi tetap berlaku meskipun pekerjaan dilakukan di luar gedung kantor.

Jika Perangkat Hilang

Jika laptop atau smartphone yang digunakan untuk pekerjaan hilang atau dicuri:

1. Segera laporkan kepada organisasi.
2. Laporkan perangkat dan waktu kehilangan.

3. Minta administrator membatasi atau mencabut akses perangkat.
4. Ganti kredensial jika diperlukan.
5. Cabut atau ganti perangkat MFA apabila digunakan.
6. Ikuti prosedur remote lock atau remote wipe jika tersedia.

Jangan menunggu sampai ditemukan adanya aktivitas mencurigakan.

Jika Terjadi Insiden Saat Remote Working

Contoh kejadian yang perlu segera dilaporkan:

- Laptop hilang.
- Smartphone hilang.
- Password diduga dicuri.
- Terlanjur membuka phishing.
- Malware terdeteksi.
- Akun menunjukkan login yang tidak dikenal.
- Data salah dikirim.
- VPN tidak dapat digunakan sebagaimana mestinya.
- Perangkat menunjukkan aktivitas yang tidak normal.

Pengguna sebaiknya **segera melaporkan**, bukan mencoba menyembunyikan kejadian tersebut.

Checklist Remote Working

Pemeriksaan	Kondisi Aman
Perangkat	Menggunakan perangkat yang diizinkan
Sistem	Sudah diperbarui
Endpoint Protection	Aktif
Password	Aman dan unik
MFA	Aktif
VPN	Digunakan sesuai kebijakan
Wi-Fi	Menggunakan koneksi yang dipercaya
Data	Tidak disimpan sembarangan
Lingkungan	Tidak mudah dilihat/didengar orang lain
Perangkat	Tidak ditinggalkan tanpa pengawasan
Insiden	Segera dilaporkan

Prinsip Sederhana Remote Working

Sebelum bekerja dari luar kantor, ingat:

Perangkat aman → Koneksi aman → Akun aman → Data aman → Lingkungan aman

Remote working bukan berarti standar keamanan boleh diturunkan hanya karena pengguna tidak berada di kantor.

Kesimpulan

Bekerja dari luar kantor memberikan fleksibilitas, tetapi memperluas kondisi dan lingkungan tempat pengguna dapat mengakses sistem organisasi.

Karena itu, pengguna perlu:

- Menggunakan perangkat yang diizinkan.
- Menggunakan koneksi yang aman.
- Menggunakan VPN sesuai kebijakan.
- Mengaktifkan MFA.
- Menjaga keamanan perangkat.
- Melindungi data organisasi.
- Berhati-hati terhadap Wi-Fi dan lingkungan publik.
- Tidak membagikan akun atau akses.
- Segera melaporkan kehilangan perangkat maupun insiden keamanan.

Bekerja dari luar kantor bukan berarti bekerja tanpa perlindungan. Standar keamanan organisasi tetap berlaku di mana pun pekerjaan dilakukan.

5.13 Hal yang Harus Dilakukan (Do's)

Keamanan siber tidak hanya bergantung pada teknologi dan sistem keamanan yang digunakan organisasi. **Kebiasaan pengguna sehari-hari memiliki peran yang sangat penting** dalam mencegah terjadinya insiden keamanan.

Setelah memahami berbagai ancaman dan cara menggunakan perangkat secara aman, pengguna perlu

menerapkan beberapa kebiasaan dasar berikut dalam aktivitas sehari-hari.

1. Gunakan Password yang Kuat dan Unik

Gunakan password yang panjang, sulit ditebak, dan berbeda untuk setiap layanan penting.

Jangan menggunakan:

- Nama.
- Tanggal lahir.
- Nomor telepon.
- Password yang sederhana.
- Password yang sama pada banyak layanan.

Jika memungkinkan, gunakan password manager untuk membantu mengelola password yang berbeda.

2. Aktifkan Multi-Factor Authentication (MFA)

Aktifkan MFA pada akun yang mendukungnya, terutama untuk:

- Email.
- VPN.
- Sistem administrasi.
- Cloud.
- Aplikasi penting.
- Akun administrator.

MFA memberikan lapisan perlindungan tambahan apabila

password berhasil diketahui pihak lain.

3. Periksa Email Sebelum Bertindak

Sebelum membuka tautan, lampiran, atau mengikuti instruksi dalam email, periksa:

- Pengirim.
- Alamat email.
- Domain.
- Isi pesan.
- Tautan.
- Lampiran.
- Tindakan yang diminta.

Jika terdapat sesuatu yang mencurigakan, lakukan verifikasi terlebih dahulu.

4. Gunakan Perangkat yang Aman

Pastikan perangkat yang digunakan untuk bekerja:

- Memiliki screen lock.
- Menggunakan password atau PIN.
- Mendapatkan pembaruan.
- Memiliki endpoint protection.
- Tidak dipasang software sembarangan.

Jangan menonaktifkan fitur keamanan perangkat tanpa alasan dan tanpa kewenangan.

5. Simpan Data pada Lokasi yang Tepat

Simpan data organisasi pada sistem penyimpanan yang telah ditentukan.

Jangan memindahkan data organisasi ke:

- Email pribadi.
- Cloud pribadi.
- Flashdisk pribadi.
- Komputer pribadi.
- Aplikasi berbagi file yang tidak disetujui.

Gunakan media penyimpanan sesuai kebijakan organisasi.

6. Lakukan Backup Sesuai Kebijakan

Pastikan data penting mengikuti mekanisme backup organisasi.

Jika organisasi menggunakan penyimpanan terpusat, simpan data pada lokasi tersebut sehingga proses backup dapat dilakukan sesuai mekanisme yang telah ditentukan.

Jangan menganggap satu-satunya salinan pada laptop sebagai backup.

7. Kunci Perangkat Ketika Ditinggalkan

Biasakan mengunci laptop atau komputer ketika meninggalkan meja, meskipun hanya sebentar.

Contohnya:

Meninggalkan Komputer



Lock Screen



Perlu Autentikasi



Akses Tetap Terlindungi

Kebiasaan sederhana ini dapat mencegah orang lain menggunakan perangkat tanpa izin.

8. Periksa Sebelum Membagikan Informasi

Sebelum mengirim atau membagikan informasi, pastikan:

Siapa yang akan menerima informasi tersebut?

Apakah penerima memang berhak menerimanya?

Apakah informasi tersebut boleh dibagikan?

Hal ini berlaku untuk email, chat, cloud storage, media sosial, maupun media penyimpanan lainnya.

9. Gunakan Software dari Sumber Terpercaya

Gunakan software yang berasal dari sumber resmi atau yang telah disetujui organisasi.

Hindari:

- Software bajakan.
- Crack.
- Keygen.
- Installer dari sumber tidak dikenal.
- Aplikasi yang tidak diperlukan.

10. Perbarui Sistem dan Aplikasi

Lakukan pembaruan sistem operasi, browser, dan aplikasi yang digunakan untuk pekerjaan.

Pembaruan keamanan membantu mengurangi risiko eksploitasi terhadap kerentanan yang telah diketahui.

11. Berhati-Hati Saat Menggunakan Internet

Sebelum mengakses website, periksa alamat domain dan sumbernya.

Jangan langsung percaya pada:

- Pop-up.
- Tautan yang tidak dikenal.
- Peringatan palsu.
- Penawaran yang terlalu bagus.
- Website yang meminta informasi sensitif.

Jika ragu, gunakan website resmi atau lakukan verifikasi.

12. Gunakan USB Flashdisk dengan Hati-Hati

Gunakan flashdisk yang diketahui sumbernya.

Sebelum membuka file:

- Periksa nama file.
- Perhatikan ekstensi.
- Pastikan file memang diperlukan.
- Pastikan endpoint protection aktif.

Jangan menggunakan flashdisk yang ditemukan atau berasal dari sumber yang tidak diketahui.

13. Lindungi Smartphone

Pastikan smartphone yang digunakan untuk pekerjaan:

- Memiliki screen lock.
- Menggunakan PIN/password yang aman.
- Sistemnya diperbarui.
- Aplikasi berasal dari sumber terpercaya.
- Izin aplikasi diperiksa.
- MFA terlindungi.

Jika smartphone hilang, segera laporkan dan lakukan tindakan sesuai prosedur organisasi.

14. Gunakan VPN Saat Diperlukan

Ketika bekerja dari luar kantor, gunakan VPN apabila diwajibkan atau disediakan organisasi.

VPN membantu menyediakan koneksi yang sesuai untuk mengakses sumber daya internal dari jaringan luar.

Namun, VPN tetap harus digunakan bersama kontrol keamanan lainnya seperti password, MFA, dan perangkat yang aman.

15. Laporkan Kejadian yang Mencurigakan

Jangan menunggu sampai masalah menjadi besar.

Segera laporkan apabila:

- Menerima email phishing.
- Tidak sengaja membuka tautan mencurigakan.

- Menjalankan file yang mencurigakan.
- Password diduga diketahui orang lain.
- Mendapatkan permintaan MFA yang tidak dilakukan.
- Laptop atau smartphone hilang.
- Menemukan data yang tidak seharusnya dapat diakses.
- Perangkat menunjukkan gejala terinfeksi malware.

Pelaporan bukan berarti mengakui kesalahan. Pelaporan merupakan bagian dari pengamanan organisasi.

16. Ikuti Kebijakan Keamanan Organisasi

Setiap organisasi dapat memiliki aturan dan prosedur yang berbeda.

Pengguna harus mengikuti:

- Kebijakan penggunaan perangkat.
- Kebijakan password.
- Kebijakan akses sistem.
- Kebijakan penggunaan internet.
- Kebijakan penggunaan email.
- Kebijakan perlindungan data.
- Prosedur pelaporan insiden.

Jika terdapat keraguan, tanyakan kepada administrator, helpdesk, atau pihak yang bertanggung jawab.

Checklist Do's

No. Yang Harus Dilakukan

- 1 Gunakan password yang kuat dan unik
- 2 Aktifkan MFA
- 3 Periksa email sebelum bertindak
- 4 Gunakan perangkat yang aman
- 5 Simpan data pada lokasi yang ditentukan
- 6 Ikuti mekanisme backup
- 7 Kunci perangkat ketika ditinggalkan
- 8 Periksa sebelum membagikan informasi
- 9 Gunakan software dari sumber terpercaya
- 10 Perbarui sistem dan aplikasi
- 11 Browsing internet secara hati-hati
- 12 Gunakan USB dengan aman
- 13 Lindungi smartphone
- 14 Gunakan VPN sesuai kebutuhan
- 15 Segera laporkan kejadian mencurigakan
- 16 Patuhi kebijakan keamanan organisasi

Prinsip yang Perlu Diingat

Berhenti → Periksa → Lindungi → Laporkan

Jangan terburu-buru ketika menghadapi sesuatu yang tidak biasa. Berhenti sejenak, periksa kondisi, lindungi informasi dan perangkat, kemudian laporkan apabila terdapat indikasi masalah.

Kesimpulan

Keamanan siber merupakan bagian dari aktivitas sehari-hari. Pengguna dapat membantu melindungi organisasi dengan menerapkan kebiasaan sederhana secara konsisten.

Hal yang paling penting adalah:

Gunakan akses dengan benar, lindungi informasi, jaga perangkat, dan segera laporkan sesuatu yang mencurigakan.

Dengan kebiasaan tersebut, pengguna tidak hanya menjadi pengguna sistem, tetapi juga menjadi **bagian dari pertahanan keamanan organisasi**.

5.14 Hal yang Harus Dihindari (Don'ts)

Keamanan siber tidak hanya membutuhkan kebiasaan yang benar, tetapi juga menghindari tindakan yang dapat meningkatkan risiko terhadap akun, perangkat, dan data organisasi.

Bagian ini menjadi pasangan dari **5.13 Hal yang Harus Dilakukan (Do's)** dan menutup BAB 5 sebelum masuk ke BAB 6 tentang penanganan insiden keamanan siber. Struktur tersebut sesuai dengan dokumen buku saat ini.

1. Jangan Menggunakan Password yang Lemah

Hindari password yang mudah ditebak, seperti:

123456

password

admin123

tanggal lahir

nama pengguna

Jangan menggunakan informasi pribadi yang mudah ditemukan sebagai password.

2. Jangan Menggunakan Password yang Sama

Jangan menggunakan satu password untuk semua layanan.

Jika satu layanan mengalami kebocoran kredensial, password tersebut dapat dicoba pada layanan lainnya.

Gunakan password yang berbeda untuk akun yang berbeda, terutama untuk akun penting.

3. Jangan Membagikan Password

Jangan memberikan password kepada:

- Rekan kerja.
- Teman.
- Atasan.
- Administrator melalui jalur yang tidak resmi.
- Pihak yang mengaku sebagai technical support.

Password merupakan informasi autentikasi yang harus dijaga kerahasiaannya.

4. Jangan Membagikan OTP atau Persetujuan MFA

Jangan pernah memberikan kode OTP atau menyetujui

permintaan MFA yang tidak dilakukan sendiri.

Jika tiba-tiba muncul permintaan:

"Approve sign-in?"

sementara pengguna tidak sedang login, jangan menyetujuinya.

Laporkan apabila diperlukan.

5. Jangan Mengklik Tautan Mencurigakan

Jangan langsung mengklik tautan dari email, SMS, media sosial, atau aplikasi pesan yang:

- Tidak dikenal.
- Menggunakan domain mencurigakan.
- Meminta login.
- Meminta informasi pribadi.
- Menggunakan tekanan waktu.

Jika membutuhkan layanan tersebut, akses melalui website atau aplikasi resmi.

6. Jangan Membuka Lampiran yang Tidak Diharapkan

Jangan membuka lampiran hanya karena email terlihat resmi.

Terutama jika:

- Tidak sedang menunggu file tersebut.
- Pengirim tidak dikenal.
- File memiliki ekstensi mencurigakan.
- Dokumen meminta mengaktifkan macro atau konten

tertentu.

Jika ragu, lakukan verifikasi terlebih dahulu.

7. Jangan Menginstal Software Sembarangan

Hindari memasang:

- Software bajakan.
- Crack.
- Keygen.
- Installer dari sumber tidak dikenal.
- Aplikasi yang tidak diperlukan.
- Software yang tidak disetujui organisasi.

Software yang tidak terpercaya dapat menjadi sumber malware.

8. Jangan Menonaktifkan Antivirus atau Fitur Keamanan

Jangan mematikan antivirus, endpoint protection, firewall, atau mekanisme keamanan lainnya hanya karena dianggap mengganggu.

Jika aplikasi mengalami masalah karena mekanisme keamanan, hubungi administrator atau helpdesk.

9. Jangan Menggunakan USB yang Tidak Dikenal

Jangan memasukkan flashdisk yang:

- Ditemukan di tempat umum.
- Tidak diketahui pemiliknya.
- Tidak jelas asal-usulnya.

- Diberikan oleh pihak yang tidak dikenal.

USB dapat menjadi media penyebaran malware.

10. Jangan Menyimpan Data Organisasi Sembarangan

Hindari menyimpan data organisasi pada:

- Komputer pribadi tanpa izin.
- Flashdisk pribadi.
- Email pribadi.
- Cloud pribadi.
- Aplikasi berbagi file yang tidak disetujui.

Gunakan lokasi penyimpanan yang telah ditentukan organisasi.

11. Jangan Membagikan Data kepada Pihak yang Tidak Berwenang

Jangan memberikan dokumen atau informasi organisasi hanya karena seseorang memintanya.

Pastikan:

Penerima memang memiliki kewenangan dan kebutuhan untuk menerima data tersebut.

Jika tidak yakin, lakukan verifikasi terlebih dahulu.

12. Jangan Mengunggah Data Sensitif ke Layanan Online Sembarangan

Jangan memasukkan data organisasi yang sensitif atau rahasia ke layanan online yang belum disetujui organisasi.

Hal ini termasuk layanan:

- Cloud pribadi.
- File sharing.
- Aplikasi online.
- Platform AI.
- Layanan konversi dokumen online.

Sebelum menggunakan layanan pihak ketiga, pastikan penggunaannya sesuai dengan kebijakan organisasi.

13. Jangan Membiarkan Perangkat Tanpa Pengawasan

Jangan meninggalkan laptop, komputer, atau smartphone dalam kondisi tidak terkunci.

Biasakan:

Meninggalkan perangkat → Lock Screen

Hal ini berlaku di kantor maupun di luar kantor.

14. Jangan Menggunakan Wi-Fi Tidak Terpercaya untuk Aktivitas Sensitif

Jangan menganggap semua Wi-Fi publik aman.

Hindari mengakses sistem penting melalui jaringan yang tidak dipercaya apabila tidak diperlukan.

Gunakan mekanisme keamanan yang ditetapkan organisasi, seperti VPN, jika diperlukan.

15. Jangan Membagikan Akses Remote

Jangan memberikan akses remote kepada pihak yang tidak dapat diverifikasi.

Jangan memberikan:

- Username.
- Password.
- OTP.
- Persetujuan MFA.
- Kode akses.
- Akses remote desktop.

Jika membutuhkan bantuan, gunakan helpdesk atau administrator resmi.

16. Jangan Mengabaikan Peringatan Keamanan

Jangan mengabaikan peringatan dari:

- Browser.
- Antivirus.
- Sistem operasi.
- Endpoint protection.
- Aplikasi keamanan.

Peringatan tersebut dapat menjadi indikasi adanya masalah keamanan.

Jika tidak memahami peringatannya, konsultasikan kepada administrator.

17. Jangan Menghapus atau Menyembunyikan Bukti Insiden

Jika terjadi kejadian yang mencurigakan, jangan langsung menghapus email, file, log, atau informasi lain yang mungkin diperlukan untuk investigasi.

Segera laporkan kepada pihak yang bertanggung jawab dan ikuti instruksi penanganan insiden.

18. Jangan Menunda Pelaporan

Jangan berpikir:

"Nanti saja dilaporkan kalau memang benar-benar terjadi masalah."

Jika pengguna:

- Terlanjur mengklik phishing.
- Membuka file mencurigakan.
- Memasukkan password ke website palsu.
- Mendapatkan permintaan MFA yang tidak dikenal.
- Kehilangan perangkat.
- Salah mengirim data.

segera laporkan.

Kecepatan pelaporan dapat mengurangi dampak insiden.

Checklist Don'ts

No. Yang Harus Dihindari

- 1 Menggunakan password yang lemah
- 2 Menggunakan password yang sama
- 3 Membagikan password
- 4 Membagikan OTP atau MFA

No. Yang Harus Dihindari

- 5 Mengklik tautan mencurigakan
- 6 Membuka lampiran yang tidak diharapkan
- 7 Menginstal software sembarangan
- 8 Menonaktifkan fitur keamanan
- 9 Menggunakan USB yang tidak dikenal
- 10 Menyimpan data organisasi sembarangan
- 11 Membagikan data kepada pihak tidak berwenang
- 12 Mengunggah data sensitif ke layanan yang tidak disetujui
- 13 Meninggalkan perangkat tanpa pengawasan
- 14 Menggunakan jaringan tidak terpercaya untuk aktivitas sensitif
- 15 Memberikan akses remote kepada pihak yang tidak terverifikasi
- 16 Mengabaikan peringatan keamanan
- 17 Menghapus atau menyembunyikan bukti insiden
- 18 Menunda pelaporan insiden

Prinsip Sederhana

Ketika menghadapi sesuatu yang tidak biasa, **jangan terburu-buru bertindak.**

Gunakan prinsip:

Jangan klik → Jangan berikan → Jangan instal → Jangan bagikan → Laporkan

Prinsip ini sangat berguna ketika pengguna menghadapi email, pesan, tautan, file, permintaan akses, atau permintaan informasi yang mencurigakan.

Kesimpulan

Banyak insiden keamanan siber dapat diperburuk oleh tindakan pengguna yang sebenarnya terlihat sederhana.

Menghindari kebiasaan seperti menggunakan password yang sama, membuka tautan mencurigakan, memasang software sembarangan, membagikan data, atau menunda pelaporan dapat membantu mengurangi risiko terhadap organisasi.

Keamanan bukan hanya tentang mengetahui apa yang harus dilakukan, tetapi juga mengetahui apa yang tidak boleh dilakukan.

Dengan **Do's** dan **Don'ts**, pengguna memiliki panduan praktis untuk menerapkan kebiasaan keamanan dalam aktivitas sehari-hari.

BAB 6 PENANGANAN INSIDEN KEAMANAN SIBER

6.1 Apa itu Incident Response

Incident Response atau **penanganan insiden keamanan siber** adalah serangkaian proses yang dilakukan organisasi untuk **mempersiapkan diri, mendeteksi, menangani, mengendalikan, memulihkan, dan mengevaluasi insiden keamanan siber.**

Incident Response diperlukan karena tidak semua serangan dapat dicegah. Meskipun organisasi telah menerapkan firewall, WAF, antivirus, MFA, backup, dan berbagai kontrol keamanan lainnya, tetap terdapat kemungkinan terjadinya insiden.

Tujuan utama Incident Response bukan hanya menghentikan serangan, tetapi juga **mengurangi dampak, memulihkan layanan, melindungi data, dan mencegah kejadian serupa terulang kembali.**

BAB 6 dalam buku ini membahas Incident Response secara bertahap melalui **Preparation, Identification, Containment, Eradication, Recovery, dan Lessons Learned**, kemudian dilanjutkan dengan pelaporan insiden dan tindakan ketika serangan terjadi.

Mengapa Incident Response Penting?

Ketika terjadi insiden, organisasi tidak boleh hanya mengandalkan tindakan spontan.

Tanpa prosedur yang jelas, respons dapat menjadi tidak terkoordinasi.

Contohnya:

Insiden Terjadi



Tidak Ada Prosedur



Semua Orang Bertindak Sendiri



Respons Tidak Terkoordinasi



Dampak Semakin Besar

Sebaliknya, organisasi yang memiliki Incident Response dapat melakukan penanganan secara lebih terstruktur:

Insiden



Identifikasi



Containment



Eradication



Recovery



Evaluasi

Incident Response Bukan Hanya Tugas Tim IT

Penanganan insiden keamanan siber bukan hanya tanggung jawab administrator atau tim keamanan.

Pengguna juga memiliki peran penting.

Misalnya, ketika seorang pegawai menerima email phishing dan tidak sengaja mengklik tautan, tindakan yang paling penting adalah **segera melaporkan kejadian tersebut**.

Informasi dari pengguna dapat membantu tim keamanan melakukan identifikasi dan membatasi dampak insiden lebih cepat.

Karena itu, pengguna perlu mengetahui:

- Apa yang dianggap sebagai insiden.
- Kepada siapa insiden harus dilaporkan.
- Informasi apa yang perlu disampaikan.
- Apa yang boleh dan tidak boleh dilakukan ketika insiden terjadi.

Apa yang Termasuk Insiden Keamanan Siber?

Insiden dapat berupa berbagai kejadian yang mengancam kerahasiaan, integritas, atau ketersediaan informasi.

Contohnya:

- Akun diambil alih.
- Password dicuri.
- Malware terdeteksi.

- Ransomware mengenkripsi file.
- Data organisasi bocor.
- Website mengalami defacement.
- Server disusupi.
- Terjadi akses tidak sah.
- Laptop atau smartphone organisasi hilang.
- Pengguna tidak sengaja mengirim data sensitif kepada pihak yang salah.

Tidak semua kejadian memiliki tingkat dampak yang sama. Karena itu, organisasi perlu melakukan penilaian terhadap setiap kejadian untuk menentukan tindakan yang tepat.

Tahapan Incident Response

Dalam buku ini, Incident Response dibagi menjadi beberapa tahapan utama:

1. Preparation

Mempersiapkan organisasi sebelum insiden terjadi.

2. Identification

Mengidentifikasi apakah suatu kejadian merupakan insiden keamanan dan memahami apa yang sedang terjadi.

3. Containment

Mengendalikan atau membatasi insiden agar tidak semakin menyebar.

4. Eradication

Menghilangkan penyebab atau komponen berbahaya dari lingkungan yang terdampak.

5. Recovery

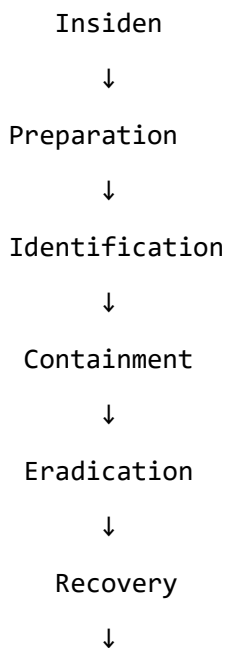
Memulihkan sistem dan layanan agar dapat kembali beroperasi secara normal.

6. Lessons Learned

Melakukan evaluasi terhadap insiden untuk mengetahui apa yang terjadi, apa yang berhasil, apa yang tidak, dan perbaikan apa yang diperlukan.

Secara sederhana:

INCIDENT RESPONSE



Lessons Learned

Incident Response dan Defense in Depth

Incident Response merupakan bagian dari pendekatan **Defense in Depth**.

Pertahanan berlapis tidak hanya bertujuan mencegah serangan, tetapi juga memastikan organisasi memiliki kemampuan untuk **mendeteksi dan merespons ketika salah satu lapisan pertahanan berhasil dilewati**.

Misalnya:

Penyerang

↓

Firewall ← Serangan tidak terblokir

↓

WAF ← Serangan tidak terdeteksi

↓

Endpoint Protection ← Malware masuk

↓

Monitoring ← Aktivitas terdeteksi

↓

Incident Response

↓

Containment & Recovery

Dengan demikian, kegagalan satu kontrol keamanan tidak

harus langsung berubah menjadi insiden besar.

Peran Pengguna Saat Terjadi Insiden

Pengguna memiliki peran yang sangat penting pada tahap awal.

Jika menemukan sesuatu yang mencurigakan:

Jangan panik.

Jangan mencoba menyembunyikannya.

Jangan menghapus bukti tanpa instruksi.

Segera laporkan kepada pihak yang bertanggung jawab.

Contohnya, jika pengguna tidak sengaja memasukkan password ke website phishing, tindakan yang benar bukan berpura-pura tidak terjadi apa-apa.

Segera laporkan agar organisasi dapat melakukan tindakan seperti:

- Mengamankan akun.
- Mengganti kredensial.
- Memeriksa aktivitas login.
- Memblokir akses mencurigakan.
- Memeriksa perangkat.
- Menentukan apakah pengguna lain ikut terdampak.

Incident Response Harus Memiliki Prosedur

Organisasi sebaiknya memiliki prosedur yang jelas mengenai:

- Siapa yang menerima laporan insiden.

- Siapa yang bertanggung jawab menangani insiden.
- Bagaimana insiden diklasifikasikan.
- Bagaimana komunikasi dilakukan.
- Bagaimana sistem diisolasi.
- Bagaimana bukti ditangani.
- Bagaimana layanan dipulihkan.
- Bagaimana insiden didokumentasikan.

Dengan prosedur tersebut, organisasi tidak perlu membuat keputusan dari awal setiap kali terjadi insiden.

Contoh Sederhana

Seorang pegawai menerima email phishing dan memasukkan username serta password ke website palsu.

Kemudian terjadi login mencurigakan pada akun tersebut.

Respons yang tepat dapat berupa:

Pegawai Menyadari Kesalahan



Melaporkan



Akun Diamankan



Aktivitas Diperiksa



Akses Mencurigakan Diblokir



Password Diganti



Recovery



Evaluasi

Dari kejadian tersebut, organisasi dapat menemukan bahwa pengguna membutuhkan edukasi tambahan atau perlu memperkuat kontrol keamanan seperti MFA dan monitoring.

Incident Response Bukan Berarti Menunggu Serangan

Incident Response sering dianggap hanya dilakukan setelah serangan terjadi.

Padahal, **persiapan sebelum insiden merupakan bagian penting dari Incident Response.**

Organisasi perlu menyiapkan:

- Prosedur.
- Tim atau pihak yang bertanggung jawab.
- Kontak darurat.
- Sistem monitoring.
- Backup.
- Mekanisme komunikasi.
- Dokumentasi.

- Prosedur recovery.

Dengan persiapan tersebut, organisasi dapat merespons lebih cepat ketika insiden benar-benar terjadi.

Kesimpulan

Incident Response adalah proses terstruktur untuk menangani insiden keamanan siber mulai dari **persiapan hingga evaluasi setelah insiden**.

Tahapan utamanya adalah:

**Preparation → Identification → Containment → Eradication
→ Recovery → Lessons Learned**

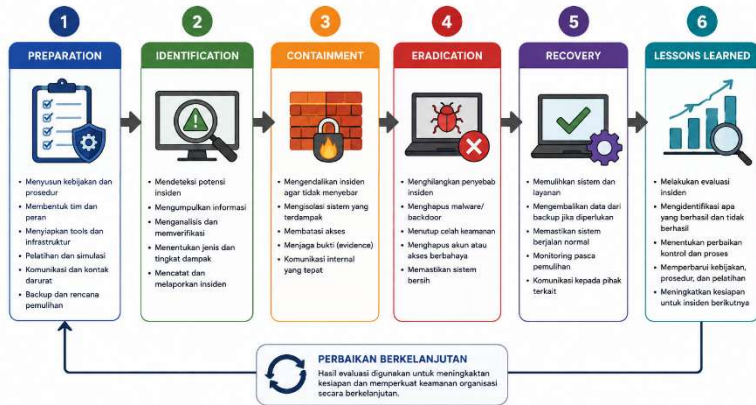
Tujuannya bukan hanya menghentikan serangan, tetapi juga **mengurangi dampak, memulihkan layanan, melindungi data, dan meningkatkan keamanan organisasi setelah insiden**.

Bagi pengguna, prinsip yang paling penting adalah:

Jika melihat atau mengalami sesuatu yang mencurigakan, segera laporkan. Jangan menunggu sampai dampaknya menjadi lebih besar.

ALUR INCIDENT RESPONSE

Preparation, Identification, Containment, Eradication, Recovery, dan Lessons Learned



Gambar 6.1 Alur Incident Response: Preparation, Identification, Containment, Eradication, Recovery, dan Lessons Learned

6.2 Preparation

Preparation merupakan tahap persiapan sebelum insiden keamanan siber terjadi. Tujuannya adalah memastikan organisasi memiliki **kebijakan, prosedur, sumber daya, teknologi, dan kemampuan** yang diperlukan agar dapat merespons insiden secara cepat, tepat, dan terkoordinasi.

Preparation sangat penting karena organisasi tidak seharusnya baru menentukan apa yang harus dilakukan setelah insiden terjadi. Ketika insiden muncul, pihak yang terlibat harus sudah mengetahui **peran, tanggung jawab, prosedur, dan jalur komunikasi** yang harus digunakan.

Tujuan Preparation

Tahap Preparation bertujuan untuk:

- Mempersiapkan organisasi menghadapi berbagai jenis

insiden keamanan.

- Mengurangi waktu yang diperlukan untuk merespons insiden.
- Menentukan peran dan tanggung jawab pihak yang terlibat.
- Memastikan ketersediaan sumber daya yang diperlukan.
- Menyiapkan mekanisme komunikasi ketika terjadi insiden.
- Memastikan data dan sistem penting dapat dipulihkan.
- Meningkatkan kesiapan melalui pelatihan dan simulasi.

Dengan persiapan yang baik, organisasi tidak perlu mengambil keputusan dari awal ketika insiden terjadi.

Kebijakan dan Prosedur

Organisasi perlu memiliki kebijakan dan prosedur yang menjadi dasar pelaksanaan Incident Response.

Dokumen tersebut setidaknya perlu menjelaskan:

- Definisi dan klasifikasi insiden.
- Prosedur pelaporan insiden.
- Pihak yang bertanggung jawab.
- Mekanisme eskalasi.
- Prosedur komunikasi.
- Prosedur isolasi sistem.
- Prosedur pemulihan.

- Mekanisme dokumentasi dan pelaporan.

Prosedur harus dibuat secara jelas agar dapat digunakan ketika kondisi sedang terjadi dan membutuhkan tindakan cepat.

Tim dan Peran

Organisasi perlu menentukan pihak yang akan terlibat dalam penanganan insiden.

Tim dapat melibatkan fungsi seperti:

- Administrator sistem.
- Administrator jaringan.
- Tim keamanan informasi.
- Helpdesk.
- Manajemen.
- Bagian hukum atau kepatuhan.
- Komunikasi atau humas.
- Pihak eksternal apabila diperlukan.

Setiap pihak harus memahami **peran dan tanggung jawabnya**.

Sebagai contoh, administrator teknis dapat bertanggung jawab melakukan isolasi sistem, sedangkan pihak manajemen bertanggung jawab mengambil keputusan yang membutuhkan kewenangan organisasi.

Tools dan Teknologi

Incident Response membutuhkan berbagai perangkat untuk membantu mendeteksi, menganalisis, dan menangani insiden.

Contohnya:

- Monitoring dan alerting.
- Log management.
- Endpoint protection.
- SIEM.
- Forensic tools.
- Sistem ticketing atau case management.
- Perangkat backup dan recovery.

Tools tersebut harus dipersiapkan sebelum insiden terjadi dan harus dapat digunakan ketika dibutuhkan.

Backup dan Pemulihan

Backup merupakan bagian penting dalam persiapan Incident Response, terutama untuk menghadapi insiden yang menyebabkan kehilangan atau kerusakan data.

Organisasi perlu memastikan bahwa:

- Backup berjalan sesuai jadwal.
- Backup berhasil dibuat.
- Backup dilindungi dari akses tidak sah.
- Backup tidak mudah terkena dampak serangan yang sama.
- Backup disimpan secara tepat.
- Proses restore pernah diuji.

Backup yang belum pernah diuji melalui proses restore tidak

dapat memberikan kepastian bahwa data benar-benar dapat dipulihkan ketika terjadi insiden.

Komunikasi dan Kontak Darurat

Ketika insiden terjadi, komunikasi harus dilakukan melalui jalur yang telah ditentukan.

Organisasi sebaiknya memiliki daftar:

- Kontak tim Incident Response.
- Administrator sistem.
- Administrator jaringan.
- Manajemen.
- Helpdesk.
- Pihak keamanan.
- Vendor atau penyedia layanan.
- Pihak eksternal yang relevan.

Selain daftar kontak, perlu ditentukan pula **siapa yang berwenang memberikan informasi kepada pihak internal maupun eksternal.**

Hal ini penting agar informasi mengenai insiden tidak disampaikan secara sembarangan.

Pelatihan dan Simulasi

Prosedur yang hanya tertulis di dokumen belum tentu dapat dilaksanakan dengan baik.

Karena itu, organisasi perlu melakukan:

- Pelatihan keamanan siber.

- Pelatihan teknis untuk tim respons.
- Simulasi insiden.
- Tabletop exercise.
- Evaluasi hasil simulasi.

Contohnya, organisasi dapat melakukan simulasi sederhana:

"Bagaimana jika server utama terkena ransomware?"

Kemudian setiap pihak diminta menjalankan perannya sesuai prosedur.

Dari simulasi tersebut dapat diketahui apakah terdapat masalah pada:

- Jalur komunikasi.
- Pembagian tugas.
- Prosedur eskalasi.
- Ketersediaan backup.
- Kemampuan teknis.
- Pengambilan keputusan.

Dokumentasi

Setiap organisasi perlu memiliki dokumentasi yang mendukung proses Incident Response.

Dokumentasi dapat mencakup:

- Daftar aset penting.
- Diagram jaringan.
- Daftar kontak.

- Prosedur Incident Response.
- Prosedur eskalasi.
- Informasi sistem.
- Lokasi backup.
- Prosedur recovery.

Dokumentasi harus diperbarui ketika terdapat perubahan pada sistem, infrastruktur, maupun personel yang terlibat.

Persiapan Pengguna

Preparation tidak hanya dilakukan oleh tim IT atau keamanan.

Pengguna juga perlu mengetahui:

1. Apa yang termasuk insiden.
2. Bagaimana cara melaporkan insiden.
3. Kepada siapa laporan diberikan.
4. Informasi apa yang perlu disampaikan.
5. Apa yang tidak boleh dilakukan ketika insiden terjadi.

Contohnya, jika pengguna tidak sengaja membuka email phishing, pengguna tidak perlu melakukan investigasi sendiri.

Tindakan yang lebih tepat adalah:

Menemukan Kejadian



Jangan Panik



Jangan Menghapus Bukti



Laporkan



Tim Berwenang Menangani

Persiapan Mengurangi Dampak Insiden

Preparation yang baik dapat mempercepat proses respons.

Tanpa persiapan:

Insiden



Bingung



Mencari Siapa yang Bertanggung Jawab



Mencari Prosedur



Respons Terlambat

Dengan persiapan:

Insiden



Identifikasi



Prosedur Sudah Tersedia



Pihak Bertanggung Jawab Sudah Ditentukan



Respons Dilakukan

Perbedaannya adalah organisasi telah memiliki **kesiapan sebelum insiden terjadi**.

Checklist Preparation

No.	Persiapan	Status
1	Kebijakan Incident Response tersedia	☐
2	Prosedur penanganan insiden tersedia	☐
3	Peran dan tanggung jawab ditentukan	☐
4	Daftar kontak darurat tersedia	☐
5	Sistem monitoring tersedia	☐
6	Log dapat dikumpulkan dan dianalisis	☐
7	Endpoint protection tersedia	☐
8	Backup berjalan	☐
9	Restore backup pernah diuji	☐
10	Prosedur komunikasi tersedia	☐
11	Pelatihan dilakukan	☐

No.	Persiapan	Status
12	Simulasi Incident Response dilakukan	☐
13	Dokumentasi sistem tersedia	☐
14	Prosedur dievaluasi secara berkala	☐

Kesimpulan

Preparation merupakan fondasi dari Incident Response. Organisasi yang telah mempersiapkan **prosedur, orang, teknologi, backup, komunikasi, dan pelatihan** akan memiliki kemampuan yang lebih baik ketika menghadapi insiden.

Prinsip yang perlu diingat:

Jangan menunggu insiden terjadi untuk mulai mempersiapkan respons.

Preparation memastikan bahwa ketika insiden benar-benar terjadi, organisasi sudah mengetahui **apa yang harus dilakukan, siapa yang harus bertindak, dan bagaimana proses pemulihan dilakukan.**

6.3 Identification

Identification (Identifikasi) merupakan tahap untuk **mendeteksi dan memastikan apakah suatu kejadian merupakan insiden keamanan siber.** Pada tahap ini, organisasi berusaha memahami apa yang terjadi, kapan kejadian terjadi, sistem apa yang terdampak, serta seberapa luas dampaknya.

Dalam materi buku, Identification mencakup **analisis log, laporan pengguna, identifikasi jenis serangan, penentuan**

ruang lingkup dampak, dan pengumpulan bukti awal.

Tujuan Identification

Tujuan utama tahap Identification adalah memperoleh gambaran awal mengenai insiden sehingga organisasi dapat menentukan tindakan berikutnya.

Pertanyaan yang perlu dijawab antara lain:

- **Apa yang terjadi?**
- **Kapan kejadian mulai terjadi?**
- **Sistem atau perangkat apa yang terdampak?**
- **Bagaimana insiden diketahui?**
- **Jenis serangan apa yang mungkin terjadi?**
- **Seberapa luas dampaknya?**
- **Apakah serangan masih berlangsung?**

Semakin cepat pertanyaan tersebut dapat dijawab, semakin cepat organisasi dapat masuk ke tahap **Containment**.

Sumber Informasi Insiden

Informasi mengenai insiden dapat berasal dari berbagai sumber.

1. Monitoring dan Alert

Sistem monitoring dapat memberikan indikasi adanya aktivitas yang tidak normal.

Contohnya:

- Peningkatan trafik jaringan secara tiba-tiba.

- Login dalam jumlah tidak biasa.
- Aktivitas akun dari lokasi yang tidak dikenal.
- Server menggunakan sumber daya secara berlebihan.
- Endpoint mendeteksi malware.

2. Log Server dan Firewall

Log merupakan salah satu sumber informasi penting dalam proses identifikasi.

Administrator dapat memeriksa:

- Waktu kejadian.
- Alamat IP sumber.
- Akun yang digunakan.
- Aktivitas login.
- Request yang masuk.
- Koneksi jaringan.
- Perubahan konfigurasi.

Materi sumber secara khusus mencantumkan **analisis log server dan firewall** sebagai salah satu kegiatan Identification.

3. Laporan Pengguna

Pengguna juga dapat menjadi sumber informasi awal.

Contohnya:

"Saya tiba-tiba menerima permintaan MFA padahal tidak

sedang login."

atau:

"File di komputer saya berubah menjadi tidak dapat dibuka."

Laporan seperti ini dapat menjadi indikasi awal bahwa telah terjadi insiden.

Materi buku juga menempatkan **laporan dari pengguna** sebagai salah satu sumber dalam proses Identification.

Contoh Indikasi Insiden

Beberapa contoh kejadian yang dapat menjadi indikator insiden antara lain:

Website tidak dapat diakses

Website Normal



Tiba-tiba Tidak Dapat Diakses



Periksa Server & Jaringan



Identifikasi Penyebab

Trafik jaringan meningkat secara tidak normal

Trafik Normal



Lonjakan Trafik

↓
Monitoring / Firewall Alert

↓
Analisis

File berubah menjadi terenkripsi

File Normal

↓
Tidak Dapat Dibuka

↓
Ekstensi Berubah

↓
Indikasi Ransomware

Akun digunakan tanpa izin

Login Tidak Dikenal

↓
Periksa Log

↓
Validasi dengan Pengguna

↓
Indikasi Account Compromise

Contoh-contoh tersebut juga tercantum dalam materi Incident Response yang menjadi dasar buku ini.

Mengumpulkan Bukti Awal

Ketika terdapat indikasi insiden, organisasi perlu mengumpulkan bukti awal yang relevan.

Contohnya:

- Log sistem.
- Log firewall.
- Alert dari sistem keamanan.
- Waktu kejadian.
- Alamat IP.
- Username atau akun yang terlibat.
- Nama perangkat.
- Screenshot jika diperlukan.
- Email atau pesan yang menjadi sumber insiden.

Bukti tersebut membantu tim memahami kronologi dan menentukan langkah selanjutnya.

Jangan Langsung Menghapus Bukti

Ketika menemukan perangkat atau akun yang diduga terkena serangan, jangan langsung menghapus file, log, atau bukti lainnya tanpa mengikuti prosedur.

Misalnya, pengguna menemukan file mencurigakan lalu langsung menghapusnya. Tindakan tersebut mungkin menghilangkan informasi yang sebenarnya diperlukan untuk mengetahui bagaimana serangan terjadi.

Prinsip sederhananya:

Amankan → Catat → Laporkan → Ikuti prosedur.

Tentukan Ruang Lingkup Dampak

Identification tidak berhenti pada menemukan satu perangkat yang bermasalah.

Tim perlu mengetahui apakah insiden hanya terjadi pada satu sistem atau telah menyebar ke sistem lain.

Contohnya:

Komputer A



Terindikasi Terinfeksi



Periksa Sistem Terkait



Komputer B?

Server?

Akun?

Jaringan?



Tentukan Scope

Materi sumber mencantumkan **menentukan ruang lingkup dampak** sebagai salah satu kegiatan utama Identification.

Bedakan Event dan Incident

Tidak setiap kejadian otomatis merupakan insiden

keamanan.

Event adalah kejadian yang terdeteksi oleh sistem atau dilaporkan pengguna.

Incident adalah kejadian yang setelah dianalisis menunjukkan adanya pelanggaran atau ancaman terhadap keamanan informasi.

Contohnya:

Banyak login gagal dapat menjadi sebuah **event**.

Setelah diperiksa dan ditemukan adanya percobaan brute-force terhadap akun, kejadian tersebut dapat dikategorikan sebagai **security incident** sesuai kriteria organisasi.

Karena itu, Identification memiliki peran penting untuk menentukan apakah sebuah kejadian memang perlu ditangani sebagai insiden.

Dokumentasikan Kronologi

Catat informasi penting sejak awal.

Minimal dokumentasikan:

Informasi	Contoh
Waktu	08 Agustus 2026, 10:15
Sumber laporan	Pengguna
Perangkat	Laptop-USER01
Gejala	File tidak dapat dibuka
Sistem terkait	File server

Informasi	Contoh
Indikasi	File berubah ekstensi
Tindakan awal	Dilaporkan ke administrator

Kronologi yang baik akan membantu tahap berikutnya dan juga berguna ketika dilakukan evaluasi setelah insiden.

Peran Pengguna dalam Identification

Pengguna sering menjadi pihak pertama yang mengetahui adanya sesuatu yang tidak normal.

Pengguna harus segera melaporkan:

- Email phishing.
- Login yang tidak dikenal.
- Permintaan MFA yang tidak dilakukan.
- File yang tiba-tiba berubah.
- Komputer menjadi sangat lambat tanpa sebab jelas.
- Antivirus memberikan peringatan.
- Website atau aplikasi berperilaku tidak normal.
- Data hilang atau berubah.

Pengguna **tidak perlu memastikan sendiri bahwa kejadian tersebut benar-benar merupakan serangan.**

Cukup laporkan indikasinya kepada pihak yang bertanggung jawab.

Contoh Kasus

Seorang pegawai melihat bahwa beberapa file pekerjaannya tiba-tiba berubah dan tidak dapat dibuka.

Tindakan awal:

File Tidak Dapat Dibuka



Pengguna Melapor



Administrator Memeriksa



Periksa Log



Identifikasi Jenis Kejadian



Tentukan Sistem Terdampak



Incident Dikonfirmasi



Containment

Pada tahap Identification, fokusnya **bukan membersihkan sistem**, tetapi memahami apa yang terjadi dan menentukan ruang lingkupnya.

Checklist Identification

No.	Pemeriksaan	Status
1	Kejadian telah dilaporkan	☐
2	Waktu kejadian diketahui	☐
3	Sumber informasi diketahui	☐
4	Log terkait diperiksa	☐
5	Jenis kejadian dianalisis	☐
6	Sistem/perangkat terdampak diidentifikasi	☐
7	Ruang lingkup dampak ditentukan	☐
8	Bukti awal dikumpulkan	☐
9	Kronologi mulai didokumentasikan	☐
10	Insiden dikategorikan sesuai prosedur	☐

Kesimpulan

Identification adalah tahap untuk mengetahui dan memastikan apa yang sedang terjadi sebelum organisasi melakukan pengendalian lebih lanjut.

Fokus utamanya adalah:

Deteksi → Analisis → Identifikasi → Tentukan Dampak → Kumpulkan Bukti

Tahap ini menjadi dasar untuk menentukan tindakan pada tahap berikutnya, yaitu **Containment**, yang bertujuan membatasi penyebaran dan dampak insiden. Materi sumber juga menempatkan Containment sebagai tahap setelah Identification.

6.4 Containment

Containment (Pengendalian) merupakan tahap dalam Incident Response yang bertujuan untuk **menghentikan atau membatasi penyebaran serangan agar dampaknya tidak semakin luas.**

Setelah tahap Identification memastikan apa yang terjadi dan sistem mana yang terdampak, organisasi perlu mengambil tindakan untuk mengendalikan insiden. Materi sumber menempatkan Containment setelah Identification dan menjelaskan kegiatan seperti mengisolasi server, memutus koneksi jaringan bila diperlukan, menonaktifkan akun yang disusupi, memblokir IP penyerang, serta menutup layanan atau port yang dieksploitasi.

Tujuan Containment

Tujuan utama Containment adalah:

- Membatasi penyebaran serangan.
- Mencegah sistem lain ikut terdampak.
- Mengurangi kerusakan yang ditimbulkan.
- Menghentikan akses penyerang.
- Memberikan waktu kepada tim untuk melakukan analisis dan pembersihan.

Prinsip sederhananya:

Hentikan penyebaran sebelum melakukan pemulihan.

Mengisolasi Sistem yang Terinfeksi

Salah satu tindakan Containment adalah mengisolasi sistem

yang terindikasi terkena serangan.

Contohnya:

Server Terinfeksi



Isolasi



Tidak dapat berkomunikasi
dengan sistem lain



Penyebaran dibatasi

Isolasi tidak selalu berarti langsung mematikan perangkat. Metode yang digunakan harus disesuaikan dengan kondisi dan prosedur organisasi.

Memutus Koneksi Jaringan

Jika sistem yang terinfeksi berpotensi menyebarkan malware atau berkomunikasi dengan penyerang, koneksi jaringan dapat diputus apabila diperlukan.

Contohnya:

Internet



Firewall



Server Terinfeksi

Tujuannya adalah membatasi komunikasi yang dapat digunakan untuk melanjutkan serangan.

Namun, tindakan pemutusan koneksi harus dilakukan secara terkontrol karena dapat memengaruhi layanan lain.

Menonaktifkan Akun yang Disusupi

Jika terdapat indikasi bahwa sebuah akun telah diambil alih, akun tersebut dapat dinonaktifkan sesuai prosedur organisasi.

Contohnya:

Login Mencurigakan



Akun Terindikasi Disusupi



Akun Dinonaktifkan



Akses Penyerang Terhenti

Setelah itu, tim dapat melakukan pemeriksaan terhadap aktivitas akun tersebut.

Memblokir IP Penyerang

Jika alamat IP penyerang telah diketahui dan pemblokiran sesuai dengan kondisi insiden, alamat tersebut dapat diblokir pada firewall atau kontrol jaringan yang tersedia.

Materi sumber mencantumkan **memblokir IP penyerang pada firewall** sebagai salah satu kegiatan Containment.

Namun, pemblokiran IP saja tidak selalu menghentikan

serangan. Penyerang dapat menggunakan alamat IP lain, sehingga tindakan ini harus menjadi bagian dari pengendalian yang lebih luas.

Menutup Layanan atau Port yang Dieksploitasi

Jika serangan memanfaatkan layanan atau port tertentu, layanan tersebut dapat ditutup atau aksesnya dibatasi.

Contohnya:

Port/Layanan Rentan



Serangan Masuk



Layanan Dinonaktifkan /

Akses Dibatasi



Serangan Dikendalikan

Tindakan ini perlu mempertimbangkan ketergantungan aplikasi agar tidak menyebabkan gangguan yang lebih besar.

Contoh Kasus: Web Server Diretas

Misalnya sebuah web server diketahui telah diretas dan terdapat indikasi bahwa server tersebut dapat digunakan untuk menyerang sistem lain.

Tindakan Containment dapat berupa:

Web Server Diretas



Identifikasi



Isolasi Server



Batasi Koneksi



Cegah Akses ke Server Lain



Analisis dan Pembersihan

Contoh ini sejalan dengan materi sumber, yaitu **server web yang diretas dipindahkan ke jaringan isolasi sehingga tidak dapat menyerang server lain.**

Containment Tidak Sama dengan Eradication

Kedua tahap ini memiliki tujuan yang berbeda.

Containment berfokus pada:

Membatasi dan menghentikan penyebaran.

Sedangkan **Eradication** berfokus pada:

Menghilangkan penyebab atau komponen berbahaya dari sistem.

Contohnya:

Server Terinfeksi



Containment



Server Diisolasi



Eradication



Malware / Backdoor Dihapus

Jadi, mengisolasi server belum berarti server sudah bersih.

Jangan Langsung Menghapus Bukti

Pada tahap Containment, tindakan pengendalian tetap perlu memperhatikan bukti yang mungkin diperlukan untuk investigasi.

Jangan melakukan tindakan yang tidak terkontrol hanya untuk membuat sistem terlihat normal kembali.

Jika organisasi memiliki prosedur forensik atau penanganan bukti, ikuti prosedur tersebut.

Pertimbangkan Dampak Bisnis

Containment harus mempertimbangkan dampak terhadap operasional.

Misalnya, memutus sebuah server dari jaringan dapat menghentikan serangan, tetapi juga dapat menyebabkan aplikasi pelayanan tidak tersedia.

Karena itu, keputusan Containment perlu mempertimbangkan:

- Tingkat keparahan insiden.
- Sistem yang terdampak.

- Risiko penyebaran.
- Ketergantungan layanan.
- Dampak terhadap operasional.
- Kewenangan pihak yang melakukan tindakan.

Peran Pengguna

Pada sebagian besar insiden, pengguna tidak perlu melakukan Containment teknis sendiri.

Jika pengguna mengetahui perangkatnya terindikasi terkena serangan, tindakan yang lebih tepat adalah:

1. Jangan panik.
2. Jangan menyebarkan informasi insiden.
3. Jangan menghapus bukti tanpa instruksi.
4. Ikuti instruksi administrator atau tim keamanan.
5. Segera laporkan kejadian.

Tim yang berwenang kemudian menentukan tindakan containment yang sesuai.

Checklist Containment

No.	Tindakan	Status
1	Sistem terdampak telah diidentifikasi	☐
2	Risiko penyebaran telah dinilai	☐
3	Sistem yang perlu diisolasi telah ditentukan	☐
4	Koneksi berbahaya telah dibatasi	☐

No.	Tindakan	Status
5	Akun yang disusupi telah diamankan	☐
6	IP atau sumber serangan telah diblokir bila diperlukan	☐
7	Layanan/port yang dieksploitasi telah dibatasi	☐
8	Dampak terhadap layanan telah dipertimbangkan	☐
9	Bukti tetap dipertahankan	☐
10	Tindakan containment telah didokumentasikan	☐

Kesimpulan

Containment merupakan tahap untuk **mengendalikan insiden agar tidak semakin menyebar**.

Beberapa tindakan yang dapat dilakukan meliputi:

**Isolasi sistem → Pembatasan jaringan → Pengamanan akun
→ Pemblokiran sumber serangan → Pembatasan layanan**

Containment belum berarti masalah telah selesai. Setelah ancaman berhasil dikendalikan, organisasi masuk ke tahap berikutnya, yaitu **Eradication**, untuk menghilangkan malware, backdoor, kerentanan, atau komponen lain yang menjadi penyebab insiden.

6.5 Eradication

Eradication (Pembersihan) merupakan tahap Incident Response yang bertujuan untuk **menghilangkan penyebab utama insiden dari sistem** setelah insiden berhasil dikendalikan melalui tahap Containment.

Pada tahap ini, organisasi tidak hanya menghentikan serangan, tetapi memastikan komponen yang digunakan penyerang benar-benar dihilangkan dari lingkungan yang terdampak. Materi sumber menjelaskan Eradication sebagai tahap untuk menghapus malware atau web shell, menutup celah keamanan, melakukan patching, menghapus akun ilegal, dan mengubah password yang terdampak.

Tujuan Eradication

Tujuan utama Eradication adalah:

- Menghilangkan malware.
- Menghapus web shell atau backdoor.
- Menghilangkan akun ilegal.
- Menutup celah keamanan yang digunakan penyerang.
- Memperbarui sistem yang rentan.
- Mengamankan kembali kredensial yang terdampak.
- Memastikan penyebab utama insiden telah ditangani.

Prinsip sederhananya:

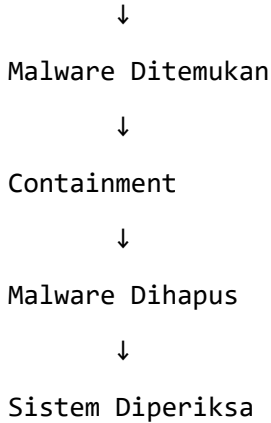
Jangan hanya menghentikan serangan. Hilangkan sumber serangannya.

Menghapus Malware

Jika insiden disebabkan oleh malware, komponen malware harus diidentifikasi dan dihapus sesuai prosedur.

Contohnya:

Sistem Terinfeksi

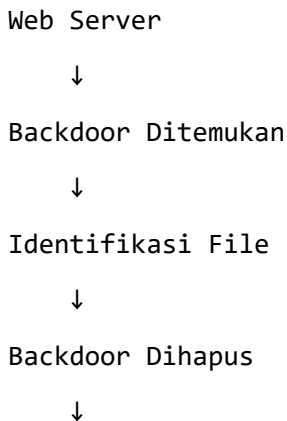


Penghapusan harus dilakukan secara hati-hati agar tidak menghilangkan bukti yang masih diperlukan untuk investigasi.

Menghapus Web Shell dan Backdoor

Pada web server, penyerang dapat menanam **web shell** atau **backdoor** untuk mempertahankan akses setelah serangan awal.

Contohnya:



Akses Penyerang Dihilangkan

Materi sumber memberikan contoh Eradication berupa **menghapus file backdoor yang ditanam penyerang pada web server.**

Menutup Celah Keamanan

Menghapus malware saja tidak cukup apabila kerentanan yang digunakan penyerang masih ada.

Misalnya:

Kerentanan



Dieksploitasi



Malware Masuk



Malware Dihapus



Kerentanan Masih Ada



Serangan Dapat Terulang

Karena itu, kerentanan yang menjadi penyebab insiden harus ditangani.

Tindakan dapat berupa:

- Memperbaiki konfigurasi.

- Menutup layanan yang tidak diperlukan.
- Membatasi akses.
- Memasang patch.
- Memperbarui aplikasi.

Melakukan Patching

Jika sistem terdampak menggunakan software yang memiliki kerentanan yang telah diperbaiki oleh vendor, lakukan **patching** sesuai prosedur organisasi.

Tujuannya adalah mencegah penyerang menggunakan kerentanan yang sama setelah sistem kembali beroperasi.

Materi sumber secara eksplisit mencantumkan **memperbarui sistem (patching)** sebagai kegiatan Eradication.

Menghapus Akun Ilegal

Penyerang dapat membuat akun baru untuk mempertahankan akses ke sistem.

Contohnya:

Akun Normal



Penyerang Mendapat Akses



Akun Ilegal Dibuat



Akun Ditemukan



Akun Dihapus

Seluruh akun yang ditemukan harus diperiksa berdasarkan kewenangan dan kebutuhan aksesnya.

Jangan langsung menghapus akun tanpa memastikan bahwa akun tersebut memang tidak sah atau tidak dibutuhkan oleh sistem.

Mengubah Password yang Terdampak

Jika terdapat indikasi bahwa password telah diketahui atau dicuri oleh penyerang, password yang terdampak harus diganti sesuai prosedur.

Perubahan dapat mencakup:

- Akun pengguna.
- Akun administrator.
- Akun layanan.
- Kredensial aplikasi.

Materi sumber mencantumkan **mengubah seluruh password yang terdampak** sebagai bagian dari Eradication.

Jika tersedia, MFA juga perlu dipastikan tetap aktif dan perangkat autentikasi yang terdampak ditangani sesuai prosedur.

Pastikan Penyebab Utama Sudah Ditangani

Eradication tidak boleh berhenti hanya karena malware sudah tidak terlihat.

Tim perlu memastikan:

Bagaimana penyerang masuk?

Apa yang digunakan penyerang?

Apakah akses penyerang masih tersedia?

Apakah kerentanan yang sama masih ada?

Apakah terdapat akun atau backdoor lain?

Tujuannya adalah memastikan sistem tidak kembali terkompromikan setelah dipulihkan.

Contoh Kasus Web Server

Misalnya sebuah web server diretas dan ditemukan web shell.

Pada tahap Containment, server telah diisolasi agar tidak digunakan untuk menyerang sistem lain.

Kemudian masuk ke Eradication:

Server Diisolasi



Analisis Penyebab



Web Shell Ditemukan



Web Shell Dihapus



Celah Keamanan Ditutup



Aplikasi / Sistem Di-patch



Kredensial Terdampak Diganti



Pemeriksaan Ulang



Siap Recovery

Setelah tahap ini selesai, sistem dapat masuk ke **Recovery** untuk dikembalikan ke kondisi operasional secara aman.

Eradication Bukan Recovery

Kedua tahap memiliki tujuan berbeda.

Eradication:

Menghilangkan penyebab dan komponen serangan.

Recovery:

Mengembalikan sistem agar dapat digunakan kembali secara normal dan aman.

Contohnya:

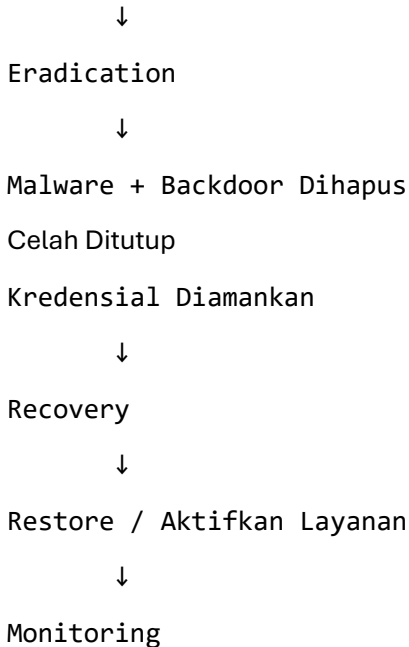
Server Terinfeksi



Containment



Isolasi



Materi sumber juga menempatkan **Recovery setelah Eradication**.

Dokumentasikan Tindakan

Setiap tindakan penting selama Eradication perlu didokumentasikan.

Contohnya:

Informasi	Keterangan
Sistem	Web Server
Ancaman	Web Shell

Informasi	Keterangan
Lokasi	Direktori aplikasi
Tindakan	Web Shell dihapus
Kerentanan	Aplikasi belum diperbarui
Perbaikan	Patching dilakukan
Kredensial	Password terdampak diganti
Status	Siap Recovery

Dokumentasi ini akan membantu proses Recovery dan evaluasi pada tahap **Lessons Learned**.

Checklist Eradication

No.	Pemeriksaan	Status
1	Malware telah diidentifikasi	☐
2	Malware telah dihapus	☐
3	Web shell/backdoor telah diperiksa	☐
4	Akun ilegal telah diperiksa	☐
5	Celah keamanan telah ditangani	☐
6	Patching telah dilakukan	☐
7	Password terdampak telah diganti	☐
8	Akses penyerang telah dihilangkan	☐

No.	Pemeriksaan	Status
9	Sistem diperiksa kembali	☐
10	Tindakan telah didokumentasikan	☐

Kesimpulan

Eradication merupakan tahap untuk **membersihkan sistem dari penyebab dan komponen serangan**.

Kegiatan utamanya meliputi:

Hapus malware/web shell → Tutup celah → Patching → Hapus akun ilegal → Ganti kredensial terdampak → Verifikasi

Tujuannya adalah memastikan bahwa ancaman **benar-benar telah dihilangkan** sebelum sistem masuk ke tahap Recovery.

6.6 Recovery

Recovery (Pemulihan) merupakan tahap Incident Response yang bertujuan untuk mengembalikan sistem, aplikasi, data, dan layanan yang terdampak insiden agar dapat kembali beroperasi secara normal dan aman. Tahap ini dilakukan setelah proses Containment dan Eradication selesai serta organisasi telah memastikan bahwa penyebab dan komponen serangan telah ditangani.

Recovery bukan sekadar menyalakan kembali server atau mengembalikan file dari backup. Organisasi perlu memastikan bahwa sistem yang dipulihkan tidak kembali berada dalam kondisi yang sama seperti sebelum insiden. Kerentanan yang telah dimanfaatkan penyerang harus diperbaiki, kredensial yang terdampak harus diamankan, dan sistem perlu diperiksa

sebelum layanan dikembalikan kepada pengguna.

Secara sederhana, alur Recovery dapat digambarkan sebagai berikut:



Tahap Recovery harus dilakukan secara terencana dan terdokumentasi agar organisasi dapat mengurangi risiko terjadinya serangan ulang serta memastikan layanan dapat kembali digunakan dengan aman.

Tujuan Recovery

Tujuan utama Recovery adalah:

- Mengembalikan sistem yang terdampak agar dapat beroperasi kembali.
- Memulihkan data yang hilang atau rusak apabila tersedia backup yang valid.
- Memastikan sistem telah berada dalam kondisi aman

sebelum digunakan.

- Memastikan fungsi aplikasi dan layanan berjalan sebagaimana mestinya.
- Mengurangi risiko terjadinya serangan ulang.
- Memastikan akses dan kredensial telah dikembalikan secara aman.
- Memantau sistem setelah layanan kembali aktif.
- Mendokumentasikan proses pemulihan.

Prinsip sederhananya:

**Jangan hanya mengembalikan sistem agar hidup kembali.
Pastikan sistem kembali dalam kondisi aman.**

Verifikasi Sebelum Recovery

Sebelum melakukan pemulihan, organisasi perlu memastikan bahwa tahap Eradication telah selesai.

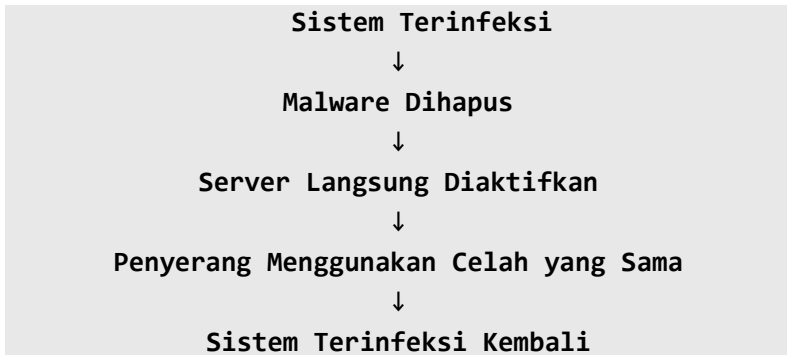
Beberapa hal yang perlu diperiksa antara lain:

- Malware telah dihapus.
- Web shell atau backdoor telah dihilangkan.
- Akun ilegal telah ditangani.
- Celah keamanan yang digunakan penyerang telah diperbaiki.
- Patching telah dilakukan apabila diperlukan.
- Password atau kredensial yang terdampak telah diganti.
- Akses penyerang telah dihilangkan.

- Sistem telah diperiksa kembali.

Hal tersebut penting karena Recovery yang dilakukan terlalu cepat dapat menyebabkan sistem kembali terkompromikan.

Contohnya:



Oleh karena itu, sebelum Recovery dilakukan, organisasi harus memastikan bahwa penyebab utama insiden telah ditangani. Bagian Eradication sebelumnya juga menekankan bahwa verifikasi bertujuan memastikan ancaman benar-benar telah dihilangkan sebelum sistem masuk ke tahap Recovery.

Memulihkan Sistem

Pemulihan sistem dilakukan berdasarkan kondisi dan tingkat kerusakan yang terjadi.

Beberapa metode pemulihan dapat berupa:

- Mengembalikan sistem dari backup.
- Mengembalikan database dari backup yang valid.
- Memulihkan konfigurasi sistem.
- Menginstal ulang sistem yang telah rusak.

- Memulihkan aplikasi.
- Mengembalikan data pengguna.
- Mengaktifkan kembali layanan yang sebelumnya dihentikan.

Pemilihan metode Recovery harus disesuaikan dengan hasil investigasi dan prosedur organisasi.

Apabila sistem diketahui telah mengalami kompromi yang serius, melakukan restore terhadap sistem yang sama tanpa memastikan sumber kompromi telah dihilangkan dapat menyebabkan masalah terulang kembali.

Sebagai contoh:



Pemulihan Data dari Backup

Backup merupakan salah satu komponen penting dalam proses Recovery. Dengan adanya backup yang baik, organisasi memiliki sumber data yang dapat digunakan ketika data utama mengalami kerusakan, kehilangan, atau terdampak serangan.

Namun, tidak semua backup dapat langsung digunakan.

Sebelum melakukan restore, organisasi perlu memastikan:

- Backup berasal dari sumber yang terpercaya.
- Backup tidak ikut terinfeksi.
- Backup dapat dibaca dan digunakan.
- Backup sesuai dengan sistem yang akan dipulihkan.
- Waktu backup sesuai dengan kebutuhan pemulihan.
- Kredensial atau encryption key yang diperlukan masih tersedia.
- Prosedur restore tersedia dan dapat dijalankan.

Buku ini sebelumnya telah menjelaskan bahwa backup harus diuji melalui **restore test**. Backup yang tidak pernah diuji belum dapat dianggap benar-benar dapat digunakan ketika terjadi insiden.

Dalam proses Recovery, organisasi juga perlu mempertimbangkan **Recovery Point Objective (RPO)** dan **Recovery Time Objective (RTO)**.

RPO menentukan seberapa banyak kehilangan data yang masih dapat diterima, sedangkan RTO menentukan berapa lama waktu yang dapat ditoleransi sebelum layanan harus kembali tersedia.

Pengujian Setelah Pemulihan

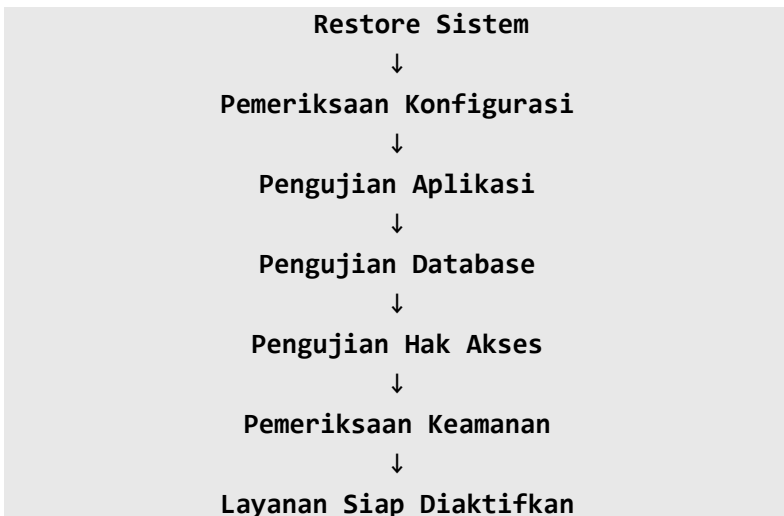
Setelah sistem berhasil dipulihkan, jangan langsung menganggap Recovery telah selesai.

Sistem harus diuji untuk memastikan bahwa:

- Sistem dapat diakses.
- Aplikasi berjalan normal.
- Database dapat digunakan.
- Data dapat dibaca dengan benar.
- Fungsi utama aplikasi berjalan.
- Hak akses pengguna sesuai.
- Integrasi dengan sistem lain berjalan.
- Tidak terdapat aktivitas mencurigakan.
- Mekanisme keamanan tetap berfungsi.

Pengujian dapat dilakukan terlebih dahulu pada lingkungan yang terkontrol sebelum layanan diberikan kembali kepada seluruh pengguna.

Contohnya:



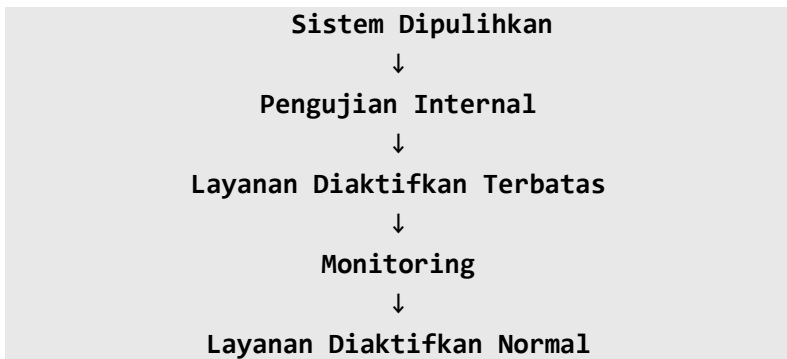
Pengujian ini penting untuk memastikan bahwa sistem tidak hanya berhasil dipulihkan secara teknis, tetapi juga dapat digunakan sesuai kebutuhan operasional organisasi.

Mengaktifkan Kembali Layanan

Setelah sistem dinyatakan aman dan hasil pengujian menunjukkan bahwa layanan telah berfungsi dengan baik, organisasi dapat mengaktifkan kembali layanan.

Aktivasi layanan sebaiknya dilakukan secara bertahap apabila sistem memiliki tingkat kepentingan yang tinggi.

Contohnya:



Pendekatan bertahap memberikan kesempatan kepada tim untuk mendeteksi masalah sebelum layanan digunakan secara penuh.

Apabila setelah aktivasi ditemukan aktivitas mencurigakan, gangguan, atau indikasi kompromi kembali, layanan dapat kembali dibatasi dan dilakukan investigasi lebih lanjut.

Monitoring Setelah Recovery

Recovery belum selesai hanya karena sistem telah kembali

online.

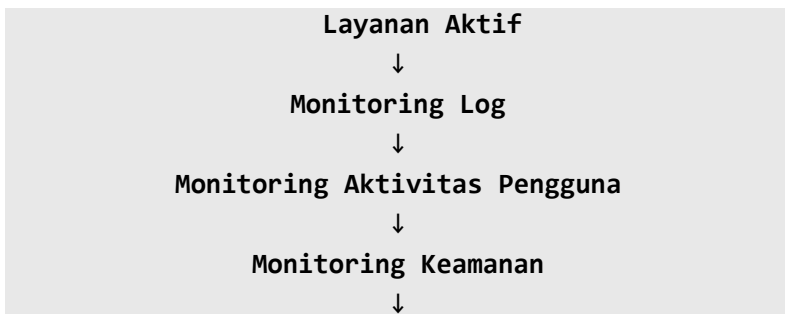
Setelah layanan diaktifkan, sistem perlu dipantau untuk memastikan tidak terdapat aktivitas yang menunjukkan bahwa serangan masih berlangsung atau terjadi kembali.

Monitoring dapat mencakup:

- Log sistem.
- Log aplikasi.
- Log autentikasi.
- Aktivitas akun administrator.
- Aktivitas jaringan.
- Penggunaan sumber daya sistem.
- Aktivitas file yang tidak normal.
- Alert dari perangkat keamanan.
- Aktivitas akses yang tidak biasa.

Periode monitoring perlu disesuaikan dengan tingkat risiko dan karakteristik insiden.

Contohnya:



Tidak Ada Indikasi Serangan**Recovery Dinyatakan Selesai**

Jika ditemukan aktivitas mencurigakan, organisasi tidak boleh mengabaikannya hanya karena sistem telah berhasil dipulihkan. Temuan tersebut perlu dianalisis dan, apabila diperlukan, proses Incident Response dapat kembali ke tahap sebelumnya.

Dokumentasi Recovery

Seluruh proses Recovery perlu didokumentasikan.

Dokumentasi dapat mencakup:

Informasi	Keterangan
Sistem	Web Server
Insiden	Web Shell
Kondisi	Sistem telah dibersihkan
Backup	Backup tanggal tertentu
Tindakan	Restore sistem
Pengujian	Aplikasi dan database diuji
Aktivasi	Layanan diaktifkan
Monitoring	Tidak ditemukan aktivitas mencurigakan
Status	Recovery selesai

Dokumentasi tersebut penting untuk memberikan catatan

mengenai tindakan yang telah dilakukan serta menjadi bahan evaluasi pada tahap **Lessons Learned**.

Bagian Eradication sebelumnya juga menggunakan dokumentasi tindakan sebagai dasar untuk membantu proses Recovery dan evaluasi pada tahap Lessons Learned.

Checklist Recovery

No.	Pemeriksaan	Status
1	Penyebab insiden telah ditangani	☐
2	Malware/web shell telah dihapus	☐
3	Celah keamanan telah diperbaiki	☐
4	Kredensial terdampak telah diamankan	☐
5	Backup yang digunakan telah diverifikasi	☐
6	Sistem telah dipulihkan	☐
7	Data telah diperiksa	☐
8	Aplikasi telah diuji	☐
9	Hak akses telah diperiksa	☐
10	Layanan telah diaktifkan	☐
11	Monitoring setelah Recovery dilakukan	☐
12	Tidak ditemukan indikasi serangan ulang	☐
13	Proses Recovery telah didokumentasikan	☐

Contoh Kasus Web Server

Misalnya sebuah web server mengalami serangan dan ditemukan web shell.

Pada tahap Containment, server telah diisolasi. Pada tahap Eradication, web shell telah dihapus, celah keamanan telah diperbaiki, aplikasi telah diperbarui, dan kredensial yang terdampak telah diganti.

Setelah dilakukan verifikasi, proses Recovery dapat dilakukan.

Alurnya:



Apabila selama monitoring ditemukan kembali web shell, akun mencurigakan, atau aktivitas penyerang, organisasi harus

menghentikan atau membatasi kembali layanan dan melakukan investigasi.

Hal ini menunjukkan bahwa **Recovery** bukan akhir dari pengamanan sistem. **Recovery** merupakan proses untuk mengembalikan layanan sekaligus memastikan bahwa sistem dapat beroperasi dalam kondisi yang aman.

Recovery Bukan Sekadar Restore

Perlu dipahami bahwa **restore** dan **recovery** bukanlah istilah yang sepenuhnya sama.

Restore merupakan proses mengembalikan data, sistem, atau konfigurasi dari sumber cadangan.

Sedangkan **Recovery** merupakan proses yang lebih luas untuk mengembalikan sistem dan layanan agar dapat digunakan kembali secara normal dan aman.

Contohnya:





Recovery

Dengan demikian, restore dapat menjadi bagian dari Recovery, tetapi Recovery tidak selalu hanya berupa restore.

Kesimpulan

Recovery merupakan tahap Incident Response yang bertujuan mengembalikan sistem, data, dan layanan agar dapat digunakan kembali secara normal dan aman.

Kegiatan utama Recovery meliputi:

Verifikasi → Restore → Pengujian → Aktivasi → Monitoring

Recovery harus dilakukan setelah organisasi memastikan bahwa penyebab dan komponen serangan telah ditangani. Sistem yang dipulihkan juga perlu diuji dan dipantau untuk memastikan tidak terjadi kompromi kembali.

Prinsip sederhananya:

Pulihkan layanan, pastikan aman, uji, kemudian pantau.

Recovery yang baik membantu organisasi mengurangi waktu gangguan layanan, memulihkan operasional, melindungi data, serta meningkatkan kemampuan organisasi dalam menghadapi insiden keamanan siber berikutnya.

6.7 Lessons Learned

Recovery (Pemulihan) merupakan tahap Incident Response yang bertujuan untuk mengembalikan sistem, aplikasi, data, dan layanan yang terdampak insiden agar dapat kembali beroperasi secara normal dan aman. Tahap ini dilakukan setelah proses

Containment dan Eradication selesai serta organisasi telah memastikan bahwa penyebab dan komponen serangan telah ditangani.

Recovery bukan sekadar menyalakan kembali server atau mengembalikan file dari backup. Organisasi perlu memastikan bahwa sistem yang dipulihkan tidak kembali berada dalam kondisi yang sama seperti sebelum insiden. Kerentanan yang telah dimanfaatkan penyerang harus diperbaiki, kredensial yang terdampak harus diamankan, dan sistem perlu diperiksa sebelum layanan dikembalikan kepada pengguna.

Secara sederhana, alur Recovery dapat digambarkan sebagai berikut:



Tahap Recovery harus dilakukan secara terencana dan terdokumentasi agar organisasi dapat mengurangi risiko terjadinya serangan ulang serta memastikan layanan dapat kembali digunakan dengan aman.

Tujuan Recovery

Tujuan utama Recovery adalah:

- Mengembalikan sistem yang terdampak agar dapat beroperasi kembali.
- Memulihkan data yang hilang atau rusak apabila tersedia backup yang valid.
- Memastikan sistem telah berada dalam kondisi aman sebelum digunakan.
- Memastikan fungsi aplikasi dan layanan berjalan sebagaimana mestinya.
- Mengurangi risiko terjadinya serangan ulang.
- Memastikan akses dan kredensial telah dikembalikan secara aman.
- Memantau sistem setelah layanan kembali aktif.
- Mendokumentasikan proses pemulihan.

Prinsip sederhananya:

Jangan hanya mengembalikan sistem agar hidup kembali.

Pastikan sistem kembali dalam kondisi aman.

Verifikasi Sebelum Recovery

Sebelum melakukan pemulihan, organisasi perlu memastikan bahwa tahap Eradication telah selesai.

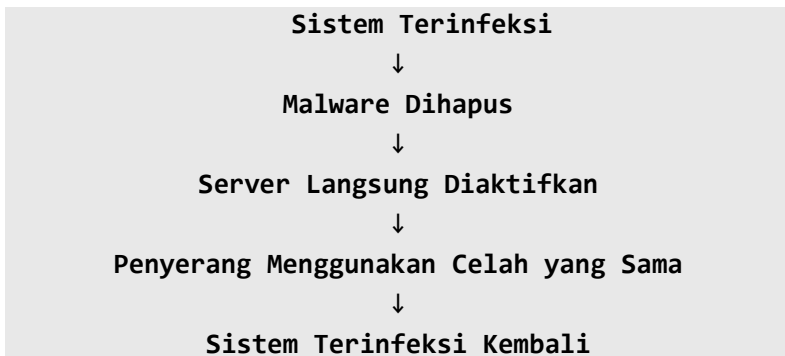
Beberapa hal yang perlu diperiksa antara lain:

- Malware telah dihapus.
- Web shell atau backdoor telah dihilangkan.

- Akun ilegal telah ditangani.
- Celah keamanan yang digunakan penyerang telah diperbaiki.
- Patching telah dilakukan apabila diperlukan.
- Password atau kredensial yang terdampak telah diganti.
- Akses penyerang telah dihilangkan.
- Sistem telah diperiksa kembali.

Hal tersebut penting karena Recovery yang dilakukan terlalu cepat dapat menyebabkan sistem kembali terkompromikan.

Contohnya:



Oleh karena itu, sebelum Recovery dilakukan, organisasi harus memastikan bahwa penyebab utama insiden telah ditangani. Bagian Eradication sebelumnya juga menekankan bahwa verifikasi bertujuan memastikan ancaman benar-benar telah dihilangkan sebelum sistem masuk ke tahap Recovery.

Memulihkan Sistem

Pemulihan sistem dilakukan berdasarkan kondisi dan tingkat

kerusakan yang terjadi.

Beberapa metode pemulihan dapat berupa:

- Mengembalikan sistem dari backup.
- Mengembalikan database dari backup yang valid.
- Memulihkan konfigurasi sistem.
- Menginstal ulang sistem yang telah rusak.
- Memulihkan aplikasi.
- Mengembalikan data pengguna.
- Mengaktifkan kembali layanan yang sebelumnya dihentikan.

Pemilihan metode Recovery harus disesuaikan dengan hasil investigasi dan prosedur organisasi.

Apabila sistem diketahui telah mengalami kompromi yang serius, melakukan restore terhadap sistem yang sama tanpa memastikan sumber kompromi telah dihilangkan dapat menyebabkan masalah terulang kembali.

Sebagai contoh:





Layanan Diaktifkan

Pemulihan Data dari Backup

Backup merupakan salah satu komponen penting dalam proses Recovery. Dengan adanya backup yang baik, organisasi memiliki sumber data yang dapat digunakan ketika data utama mengalami kerusakan, kehilangan, atau terdampak serangan.

Namun, tidak semua backup dapat langsung digunakan.

Sebelum melakukan restore, organisasi perlu memastikan:

- Backup berasal dari sumber yang terpercaya.
- Backup tidak ikut terinfeksi.
- Backup dapat dibaca dan digunakan.
- Backup sesuai dengan sistem yang akan dipulihkan.
- Waktu backup sesuai dengan kebutuhan pemulihan.
- Kredensial atau encryption key yang diperlukan masih tersedia.
- Prosedur restore tersedia dan dapat dijalankan.

Buku ini sebelumnya telah menjelaskan bahwa backup harus diuji melalui **restore test**. Backup yang tidak pernah diuji belum dapat dianggap benar-benar dapat digunakan ketika terjadi insiden.

Dalam proses Recovery, organisasi juga perlu mempertimbangkan **Recovery Point Objective (RPO)** dan **Recovery Time Objective (RTO)**.

RPO menentukan seberapa banyak kehilangan data yang

masih dapat diterima, sedangkan RTO menentukan berapa lama waktu yang dapat ditoleransi sebelum layanan harus kembali tersedia.

Pengujian Setelah Pemulihan

Setelah sistem berhasil dipulihkan, jangan langsung menganggap Recovery telah selesai.

Sistem harus diuji untuk memastikan bahwa:

- Sistem dapat diakses.
- Aplikasi berjalan normal.
- Database dapat digunakan.
- Data dapat dibaca dengan benar.
- Fungsi utama aplikasi berjalan.
- Hak akses pengguna sesuai.
- Integrasi dengan sistem lain berjalan.
- Tidak terdapat aktivitas mencurigakan.
- Mekanisme keamanan tetap berfungsi.

Pengujian dapat dilakukan terlebih dahulu pada lingkungan yang terkontrol sebelum layanan diberikan kembali kepada seluruh pengguna.

Contohnya:





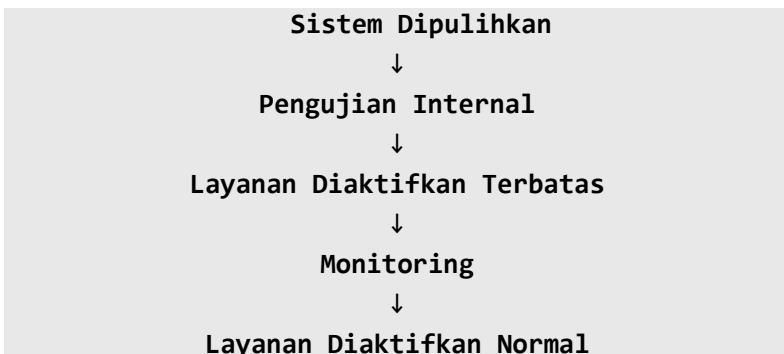
Pengujian ini penting untuk memastikan bahwa sistem tidak hanya berhasil dipulihkan secara teknis, tetapi juga dapat digunakan sesuai kebutuhan operasional organisasi.

Mengaktifkan Kembali Layanan

Setelah sistem dinyatakan aman dan hasil pengujian menunjukkan bahwa layanan telah berfungsi dengan baik, organisasi dapat mengaktifkan kembali layanan.

Aktivasi layanan sebaiknya dilakukan secara bertahap apabila sistem memiliki tingkat kepentingan yang tinggi.

Contohnya:



Pendekatan bertahap memberikan kesempatan kepada tim untuk mendeteksi masalah sebelum layanan digunakan secara penuh.

Apabila setelah aktivasi ditemukan aktivitas mencurigakan, gangguan, atau indikasi kompromi kembali, layanan dapat kembali dibatasi dan dilakukan investigasi lebih lanjut.

Monitoring Setelah Recovery

Recovery belum selesai hanya karena sistem telah kembali online.

Setelah layanan diaktifkan, sistem perlu dipantau untuk memastikan tidak terdapat aktivitas yang menunjukkan bahwa serangan masih berlangsung atau terjadi kembali.

Monitoring dapat mencakup:

- Log sistem.
- Log aplikasi.
- Log autentikasi.
- Aktivitas akun administrator.
- Aktivitas jaringan.
- Penggunaan sumber daya sistem.
- Aktivitas file yang tidak normal.
- Alert dari perangkat keamanan.
- Aktivitas akses yang tidak biasa.

Periode monitoring perlu disesuaikan dengan tingkat risiko dan karakteristik insiden.

Contohnya:



Jika ditemukan aktivitas mencurigakan, organisasi tidak boleh mengabaikannya hanya karena sistem telah berhasil dipulihkan. Temuan tersebut perlu dianalisis dan, apabila diperlukan, proses Incident Response dapat kembali ke tahap sebelumnya.

Dokumentasi Recovery

Seluruh proses Recovery perlu didokumentasikan.

Dokumentasi dapat mencakup:

Informasi	Keterangan
Sistem	Web Server
Insiden	Web Shell
Kondisi	Sistem telah dibersihkan
Backup	Backup tanggal tertentu

Informasi	Keterangan
Tindakan	Restore sistem
Pengujian	Aplikasi dan database diuji
Aktivasi	Layanan diaktifkan
Monitoring	Tidak ditemukan aktivitas mencurigakan
Status	Recovery selesai

Dokumentasi tersebut penting untuk memberikan catatan mengenai tindakan yang telah dilakukan serta menjadi bahan evaluasi pada tahap **Lessons Learned**.

Bagian Eradication sebelumnya juga menggunakan dokumentasi tindakan sebagai dasar untuk membantu proses Recovery dan evaluasi pada tahap Lessons Learned.

Checklist Recovery

No.	Pemeriksaan	Status
1	Penyebab insiden telah ditangani	☐
2	Malware/web shell telah dihapus	☐
3	Celah keamanan telah diperbaiki	☐
4	Kredensial terdampak telah diamankan	☐
5	Backup yang digunakan telah diverifikasi	☐
6	Sistem telah dipulihkan	☐
7	Data telah diperiksa	☐

No.	Pemeriksaan	Status
8	Aplikasi telah diuji	☐
9	Hak akses telah diperiksa	☐
10	Layanan telah diaktifkan	☐
11	Monitoring setelah Recovery dilakukan	☐
12	Tidak ditemukan indikasi serangan ulang	☐
13	Proses Recovery telah didokumentasikan	☐

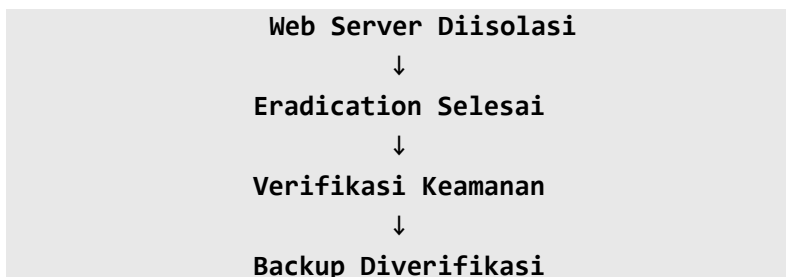
Contoh Kasus Web Server

Misalnya sebuah web server mengalami serangan dan ditemukan web shell.

Pada tahap Containment, server telah diisolasi. Pada tahap Eradication, web shell telah dihapus, celah keamanan telah diperbaiki, aplikasi telah diperbarui, dan kredensial yang terdampak telah diganti.

Setelah dilakukan verifikasi, proses Recovery dapat dilakukan.

Alurnya:





Apabila selama monitoring ditemukan kembali web shell, akun mencurigakan, atau aktivitas penyerang, organisasi harus menghentikan atau membatasi kembali layanan dan melakukan investigasi.

Hal ini menunjukkan bahwa Recovery bukan akhir dari pengamanan sistem. Recovery merupakan proses untuk mengembalikan layanan sekaligus memastikan bahwa sistem dapat beroperasi dalam kondisi yang aman.

Recovery Bukan Sekadar Restore

Perlu dipahami bahwa **restore** dan **recovery** bukanlah istilah yang sepenuhnya sama.

Restore merupakan proses mengembalikan data, sistem, atau konfigurasi dari sumber cadangan.

Sedangkan **Recovery** merupakan proses yang lebih luas untuk mengembalikan sistem dan layanan agar dapat digunakan kembali secara normal dan aman.

Contohnya:



Dengan demikian, restore dapat menjadi bagian dari Recovery, tetapi Recovery tidak selalu hanya berupa restore.

Kesimpulan

Recovery merupakan tahap Incident Response yang bertujuan mengembalikan sistem, data, dan layanan agar dapat digunakan kembali secara normal dan aman.

Kegiatan utama Recovery meliputi:

Verifikasi → Restore → Pengujian → Aktivasi → Monitoring

Recovery harus dilakukan setelah organisasi memastikan bahwa penyebab dan komponen serangan telah ditangani. Sistem yang dipulihkan juga perlu diuji dan dipantau untuk memastikan tidak terjadi kompromi kembali.

Prinsip sederhananya:

Pulihkan layanan, pastikan aman, uji, kemudian pantau.

Recovery yang baik membantu organisasi mengurangi waktu gangguan layanan, memulihkan operasional, melindungi data, serta meningkatkan kemampuan organisasi dalam menghadapi insiden keamanan siber berikutnya.

Catatan untuk dokumen: bagian ini sengaja saya buat sebagai lanjutan langsung dari 6.5. Di dokumen saat ini, 6.5 berakhir dengan verifikasi sebelum Recovery, kemudian judul **6.6 Recovery** masih kosong. Jadi alurnya sekarang sudah nyambung: **Containment → Eradication → Verification → Recovery → Lessons Learned.**

Lessons Learned

Worked for 5s

Baik. Setelah **6.6 Recovery**, kita lanjut ke **6.7 Lessons Learned**. Di buku ini, Lessons Learned memang didefinisikan sebagai evaluasi untuk mengetahui **apa yang terjadi, apa yang berhasil, apa yang tidak, dan perbaikan apa yang diperlukan.**

Saya buat dengan gaya yang konsisten dengan 6.5 dan 6.6.

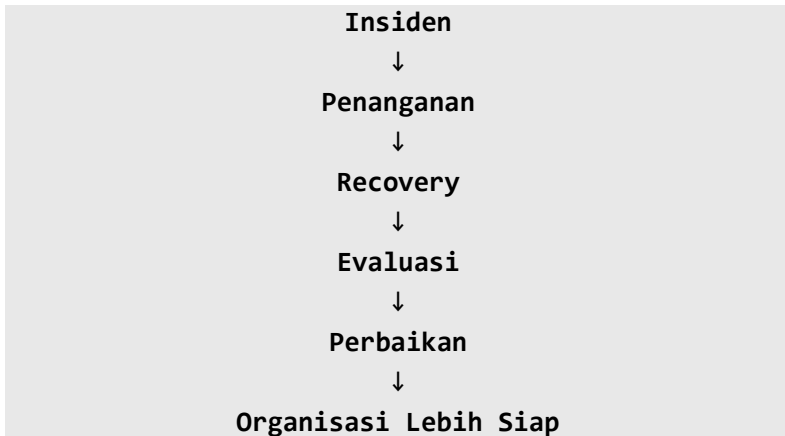
6.7 Lessons Learned

Lessons Learned (Pembelajaran dari Insiden) merupakan tahap evaluasi setelah proses penanganan dan pemulihan insiden selesai. Tujuan tahap ini adalah mempelajari pengalaman organisasi selama menghadapi insiden untuk mengetahui apa yang terjadi, apa yang telah berjalan dengan baik, apa yang mengalami kendala, serta perbaikan apa yang perlu dilakukan.

Incident Response tidak seharusnya berhenti setelah sistem kembali beroperasi. Setiap insiden memberikan informasi

penting mengenai kelemahan sistem, proses, kebijakan, maupun perilaku pengguna. Informasi tersebut dapat digunakan untuk meningkatkan kemampuan organisasi dalam mencegah dan menghadapi insiden berikutnya.

Secara sederhana:



Tahap Lessons Learned menjadi bagian penting karena Incident Response tidak hanya bertujuan menghentikan serangan dan memulihkan layanan, tetapi juga meningkatkan keamanan organisasi setelah insiden. Struktur Incident Response dalam buku ini memang menempatkan Lessons Learned sebagai tahap terakhir setelah Recovery.

Tujuan Lessons Learned

Tujuan utama Lessons Learned adalah:

- Memahami bagaimana insiden terjadi.
- Mengetahui penyebab utama insiden.
- Mengevaluasi efektivitas respons yang telah dilakukan.

- Mengidentifikasi tindakan yang berhasil.
- Mengidentifikasi tindakan yang mengalami kendala.
- Menemukan kelemahan yang masih ada.
- Menentukan tindakan perbaikan.
- Meningkatkan kesiapan menghadapi insiden berikutnya.
- Memperbaiki kebijakan dan prosedur keamanan.
- Meningkatkan kesadaran dan kemampuan pengguna.

Prinsip sederhananya:

Jangan hanya menyelesaikan insiden. Pelajari mengapa insiden terjadi dan bagaimana mencegahnya terulang.

Menyusun Kronologi Insiden

Langkah awal dalam Lessons Learned adalah menyusun kembali kronologi insiden berdasarkan informasi yang telah dikumpulkan selama proses Identification, Containment, Eradication, dan Recovery.

Kronologi dapat menjawab beberapa pertanyaan:

- Kapan aktivitas mencurigakan pertama kali ditemukan?
- Bagaimana insiden pertama kali diketahui?
- Bagaimana penyerang memperoleh akses?
- Sistem apa yang terdampak?
- Data atau layanan apa yang terdampak?
- Tindakan apa yang dilakukan?
- Kapan sistem berhasil dipulihkan?

- Apakah terdapat indikasi serangan ulang?

Contoh sederhana:

Waktu	Kejadian	Tindakan
08.00	Aktivitas login tidak normal ditemukan	Dilaporkan ke administrator
08.15	Akun mencurigakan ditemukan	Akun dinonaktifkan
08.30	Server diisolasi	Containment
09.30	Malware ditemukan	Investigasi
11.00	Malware dihapus	Eradication
13.00	Sistem dipulihkan	Recovery
14.00	Monitoring dimulai	Pemantauan
16.00	Tidak ditemukan aktivitas mencurigakan	Evaluasi

Kronologi yang baik membantu organisasi memahami rangkaian kejadian secara objektif dan menjadi dasar dalam melakukan evaluasi setelah insiden. Buku ini juga menekankan bahwa dokumentasi kronologi berguna dalam proses evaluasi setelah insiden.

Apa yang Berhasil?

Evaluasi perlu mengidentifikasi tindakan yang telah berjalan dengan baik.

Contohnya:

- Pengguna segera melaporkan email phishing.
- Administrator berhasil mengisolasi sistem dengan cepat.
- Backup tersedia dan dapat dipulihkan.
- Tim keamanan dapat menemukan sumber serangan.
- Prosedur Incident Response dapat dijalankan.
- Komunikasi antarbagian berjalan dengan baik.
- Layanan dapat dipulihkan sesuai target.

Identifikasi keberhasilan penting agar praktik yang efektif dapat dipertahankan dan diterapkan pada insiden berikutnya.

Apa yang Tidak Berjalan dengan Baik?

Selain keberhasilan, organisasi perlu secara terbuka mengidentifikasi bagian yang mengalami kendala.

Contohnya:

- Insiden terlambat dilaporkan.
- Tidak tersedia dokumentasi sistem yang lengkap.
- Backup tidak dapat langsung digunakan.
- Informasi kontak tim respons tidak diperbarui.
- Hak akses terlalu luas.
- Proses isolasi sistem membutuhkan waktu lama.
- Tidak tersedia prosedur pemulihan yang jelas.
- Log keamanan tidak lengkap.
- Komunikasi antarbagian tidak berjalan dengan baik.

Evaluasi sebaiknya tidak digunakan untuk mencari siapa yang harus disalahkan. Fokus utamanya adalah menemukan kelemahan proses dan menentukan cara memperbaikinya.

Mengidentifikasi Penyebab Utama

Lessons Learned juga perlu mengevaluasi mengapa insiden dapat terjadi.

Beberapa pertanyaan yang dapat digunakan:

Bagaimana penyerang masuk?

Mengapa mekanisme keamanan tidak mencegah serangan?

Mengapa aktivitas tersebut tidak segera terdeteksi?

Mengapa insiden tidak segera dilaporkan?

Apakah terdapat kelemahan pada sistem atau aplikasi?

Apakah terdapat kelemahan dalam pengelolaan hak akses?

Apakah pengguna telah mendapatkan edukasi keamanan yang memadai?

Sebagai contoh, apabila sebuah akun berhasil diambil alih karena password digunakan pada beberapa layanan, maka perbaikannya tidak cukup hanya mengganti password akun tersebut.

Organisasi juga perlu mempertimbangkan:

- Penggunaan password unik.
- Penerapan MFA.

- Review akun pengguna.
- Pemeriksaan aktivitas login.
- Edukasi pengguna.
- Penguatan kebijakan autentikasi.

Dengan demikian, Lessons Learned menghasilkan perbaikan yang lebih mendasar daripada sekadar menyelesaikan masalah yang terlihat.

Menentukan Tindakan Perbaikan

Hasil evaluasi harus diterjemahkan menjadi tindakan perbaikan yang jelas.

Contohnya:

Temuan	Perbaikan
Password pengguna lemah	Menerapkan kebijakan password yang lebih baik
MFA belum digunakan	Mengaktifkan MFA pada layanan yang mendukung
Backup tidak pernah diuji	Melakukan restore test berkala
Patch terlambat	Memperbaiki proses patch management
Hak akses terlalu luas	Melakukan review dan pembatasan hak akses
Insiden terlambat	Memperjelas prosedur pelaporan

Temuan	Perbaikan
dilaporkan	
Log tidak lengkap	Meningkatkan logging dan monitoring
Pengguna mudah tertipu phishing	Melakukan security awareness dan simulasi phishing

Tindakan perbaikan sebaiknya memiliki **penanggung jawab** dan **target penyelesaian** agar hasil Lessons Learned benar-benar diterapkan.

Contohnya:

Temuan	Tindakan	Penanggung Jawab	Target
Backup belum diuji	Restore test	Administrator	30 hari
MFA belum aktif	Aktivasi MFA	Administrator	14 hari
Pengguna kurang waspada phishing	Pelatihan	Tim TI/SDM	30 hari
Hak akses berlebihan	Review akses	Administrator	14 hari

Memperbarui Kebijakan dan Prosedur

Apabila hasil evaluasi menunjukkan bahwa kebijakan atau prosedur organisasi memiliki kelemahan, dokumen tersebut perlu diperbarui.

Contohnya:

- Kebijakan password.
- Kebijakan penggunaan email.
- Kebijakan penggunaan perangkat.
- Prosedur pelaporan insiden.
- Prosedur backup dan restore.
- Prosedur pengelolaan hak akses.
- Prosedur penanganan malware.
- Prosedur pemulihan layanan.

Tujuannya agar pengalaman dari sebuah insiden tidak hanya tersimpan dalam laporan, tetapi menjadi bagian dari perbaikan proses organisasi.

Meningkatkan Security Awareness

Tidak semua perbaikan harus berbentuk teknologi.

Apabila insiden terjadi karena kesalahan pengguna, organisasi perlu meningkatkan kesadaran keamanan.

Kegiatan dapat berupa:

- Sosialisasi keamanan siber.
- Pelatihan phishing awareness.
- Simulasi phishing.
- Edukasi penggunaan password.
- Edukasi MFA.
- Pelatihan pelaporan insiden.

- Simulasi Incident Response.

Buku ini sebelumnya juga telah menempatkan kegiatan seperti simulasi phishing, prosedur pelaporan insiden, review hak akses, penyusunan prosedur respons insiden, dan evaluasi setelah insiden sebagai bagian dari upaya peningkatan keamanan.

Dokumentasi Lessons Learned

Hasil evaluasi sebaiknya dituangkan dalam dokumen Lessons Learned.

Dokumen tersebut dapat berisi:

1. Ringkasan insiden.
2. Kronologi kejadian.
3. Sistem yang terdampak.
4. Penyebab insiden.
5. Dampak insiden.
6. Tindakan yang telah dilakukan.
7. Hal yang berjalan dengan baik.
8. Hal yang mengalami kendala.
9. Temuan kelemahan.
10. Rekomendasi perbaikan.
11. Penanggung jawab perbaikan.
12. Target penyelesaian.
13. Status tindak lanjut.

Dokumentasi ini dapat menjadi referensi apabila organisasi menghadapi insiden dengan karakteristik yang serupa di kemudian hari.

Contoh Kasus Web Server

Misalnya sebuah web server mengalami serangan dan ditemukan web shell.

Setelah sistem berhasil dipulihkan, organisasi melakukan evaluasi.

Hasil evaluasi menunjukkan:

Temuan:

- Aplikasi belum diperbarui.
- Celah keamanan digunakan penyerang.
- Monitoring belum optimal.
- Administrator baru mengetahui insiden setelah perubahan pada website terlihat.
- Backup tersedia dan berhasil digunakan.

Tindakan perbaikan:

- Memperbaiki proses patching.
- Melakukan pemeriksaan kerentanan secara berkala.
- Meningkatkan monitoring dan logging.
- Memperbaiki mekanisme deteksi perubahan file.
- Melakukan restore test secara berkala.
- Meningkatkan security awareness administrator.

Alurnya:



Dengan pendekatan tersebut, satu insiden dapat menjadi sumber pembelajaran untuk memperkuat keamanan organisasi.

Checklist Lessons Learned

No.	Pemeriksaan	Status
1	Kronologi insiden telah disusun	☐
2	Penyebab utama telah diidentifikasi	☐
3	Sistem dan layanan terdampak telah didokumentasikan	☐
4	Dampak insiden telah dievaluasi	☐

No.	Pemeriksaan	Status
5	Tindakan yang berhasil telah dicatat	☐
6	Kendala selama penanganan telah dicatat	☐
7	Kelemahan keamanan telah diidentifikasi	☐
8	Tindakan perbaikan telah ditentukan	☐
9	Penanggung jawab perbaikan telah ditentukan	☐
10	Target penyelesaian telah ditentukan	☐
11	Kebijakan/prosedur yang diperlukan telah diperbarui	☐
12	Hasil evaluasi telah didokumentasikan	☐
13	Tindak lanjut perbaikan telah dipantau	☐

Lessons Learned Bukan Mencari Kesalahan

Salah satu prinsip penting dalam Lessons Learned adalah menghindari budaya menyalahkan individu.

Tujuan evaluasi bukan sekadar mencari siapa yang melakukan kesalahan, tetapi memahami **mengapa kesalahan tersebut dapat terjadi dan mengapa sistem organisasi tidak mampu mencegah atau membatasi dampaknya**.

Sebagai contoh, apabila seorang pegawai membuka email phishing, evaluasi tidak cukup hanya menyatakan bahwa pegawai tersebut lalai.

Organisasi juga perlu bertanya:

- Apakah pegawai telah mendapatkan pelatihan?
- Apakah email tersebut memiliki karakteristik yang mudah dikenali?
- Apakah sistem email memiliki mekanisme filtering?
- Apakah terdapat MFA?
- Apakah prosedur pelaporan sudah diketahui?
- Apakah terdapat mekanisme untuk membatasi dampak apabila akun berhasil diambil alih?

Pendekatan tersebut membantu organisasi memperbaiki **manusia, proses, dan teknologi** secara bersamaan.

Kesimpulan

Lessons Learned merupakan tahap evaluasi setelah insiden yang bertujuan mengubah pengalaman menghadapi serangan menjadi pembelajaran dan tindakan perbaikan.

Kegiatan utamanya meliputi:

**Evaluasi → Identifikasi Penyebab → Identifikasi Kelemahan
→ Perbaikan → Dokumentasi → Tindak Lanjut**

Hasil Lessons Learned tidak boleh berhenti sebagai laporan. Setiap temuan penting perlu diterjemahkan menjadi tindakan perbaikan yang memiliki penanggung jawab dan target penyelesaian.

Prinsip sederhananya:

Insiden harus menghasilkan pembelajaran. Pembelajaran harus menghasilkan perbaikan.

Dengan melaksanakan Lessons Learned secara konsisten,

organisasi dapat meningkatkan kemampuan dalam mencegah, mendeteksi, merespons, dan memulihkan diri dari insiden keamanan siber berikutnya. Ini juga melengkapi siklus Incident Response yang dalam buku disusun sebagai **Preparation → Identification → Containment → Eradication → Recovery → Lessons Learned**.

6.8 Melaporkan Insiden Keamanan Siber

Pelaporan merupakan salah satu bagian penting dalam penanganan insiden keamanan siber. Insiden yang tidak segera dilaporkan dapat menyebabkan keterlambatan dalam melakukan tindakan, sehingga dampaknya dapat menjadi lebih besar.

Dalam praktiknya, pengguna sering menjadi pihak pertama yang mengetahui adanya aktivitas yang tidak normal. Pengguna dapat melihat email mencurigakan, menerima permintaan login yang tidak biasa, menemukan file yang berubah, melihat aplikasi tidak dapat digunakan, atau mengetahui adanya aktivitas akun yang tidak dilakukan oleh dirinya sendiri.

Karena itu, setiap pegawai perlu mengetahui **kapan harus melaporkan insiden, kepada siapa laporan diberikan, informasi apa yang perlu disampaikan, serta tindakan apa yang tidak boleh dilakukan**.

Prinsip sederhananya:

Jika mencurigakan, jangan abaikan. Laporkan.

Mengapa Insiden Harus Segera Dilaporkan?

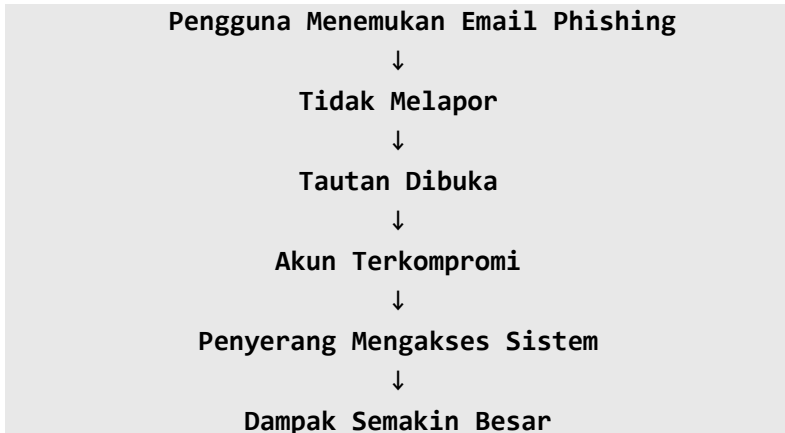
Kecepatan pelaporan sangat berpengaruh terhadap kemampuan organisasi dalam menangani insiden.

Semakin cepat insiden diketahui, semakin cepat organisasi dapat melakukan tindakan seperti:

- Melakukan pemeriksaan.
- Membatasi akses.
- Mengisolasi perangkat atau sistem.
- Mengamankan akun.
- Mengumpulkan informasi.
- Melindungi data.
- Mengurangi penyebaran insiden.

Sebaliknya, keterlambatan pelaporan dapat memberikan kesempatan kepada penyerang untuk melanjutkan aktivitasnya.

Contohnya:



Apabila pengguna segera melaporkan email tersebut, organisasi memiliki kesempatan untuk melakukan pemeriksaan dan mengambil tindakan sebelum dampaknya berkembang.

Apa yang Termasuk Insiden?

Pengguna tidak harus menunggu sampai memiliki kepastian bahwa suatu kejadian merupakan serangan.

Apabila terdapat aktivitas yang tidak biasa atau mencurigakan, pengguna dapat melaporkannya untuk diperiksa oleh pihak yang berwenang.

Contohnya:

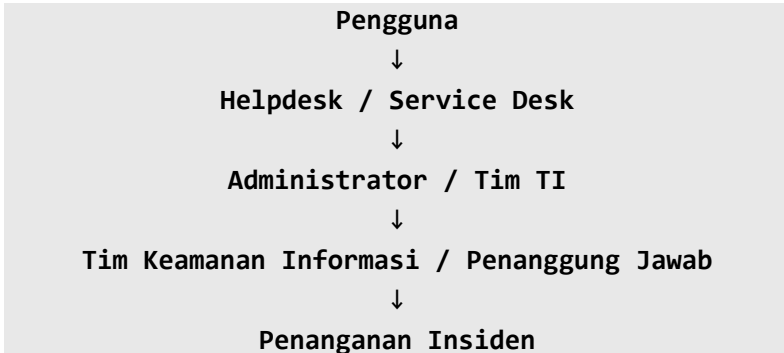
- Menerima email phishing.
- Mendapatkan pesan yang meminta password atau kode OTP.
- Menemukan login yang tidak dilakukan sendiri.
- Menemukan file yang tiba-tiba berubah atau tidak dapat dibuka.
- Menemukan aplikasi yang berjalan tidak normal.
- Mendapatkan notifikasi keamanan yang tidak dikenali.
- Menemukan perangkat kerja berperilaku tidak normal.
- Menemukan akun yang digunakan tanpa izin.
- Menemukan perubahan konfigurasi yang tidak diketahui.
- Mengetahui adanya kehilangan perangkat yang digunakan untuk mengakses sistem organisasi.

Pengguna tidak perlu melakukan investigasi teknis sendiri untuk menentukan apakah kejadian tersebut benar-benar merupakan insiden.

Kepada Siapa Insiden Dilaporkan?

Setiap organisasi harus memiliki mekanisme pelaporan yang jelas.

Pelaporan dapat diarahkan kepada pihak yang telah ditetapkan organisasi, misalnya:



Dalam kondisi tertentu, pengguna dapat langsung menghubungi administrator atau pihak yang ditunjuk apabila prosedur organisasi mengatur demikian.

Yang paling penting adalah **pengguna mengetahui jalur pelaporan yang berlaku di organisasinya**.

Buku ini juga menempatkan helpdesk sebagai salah satu pihak penting yang menerima laporan gangguan maupun insiden keamanan informasi.

Informasi yang Perlu Disampaikan

Ketika melaporkan insiden, pengguna sebaiknya memberikan informasi sebanyak mungkin tanpa melakukan tindakan yang dapat menghilangkan bukti.

Informasi yang dapat disampaikan antara lain:

- Nama pelapor.

- Unit kerja.
- Waktu kejadian.
- Perangkat yang digunakan.
- Aplikasi atau layanan yang terdampak.
- Apa yang terjadi.
- Pesan atau notifikasi yang muncul.
- Alamat email atau akun yang terkait.
- Tautan mencurigakan apabila tersedia.
- Nama file atau lampiran yang mencurigakan.
- Screenshot apabila diperlukan dan diperbolehkan.
- Tindakan yang sudah dilakukan pengguna.

Contoh laporan:

Waktu: 10.15

Pelapor: Pegawai Unit Administrasi

Perangkat: Laptop kantor

Kejadian: Menerima email yang meminta login melalui tautan.

Tindakan: Tautan belum dibuka dan email segera dilaporkan.

Laporan sederhana seperti ini sudah dapat memberikan informasi awal yang berguna bagi helpdesk atau tim keamanan.

Jangan Menunggu Sampai Memiliki Bukti Lengkap

Salah satu kesalahan yang sering terjadi adalah pengguna menunda pelaporan karena merasa belum memiliki cukup bukti.

Misalnya pengguna mengatakan:

"Saya belum yakin itu phishing, jadi belum saya laporkan."

Pendekatan tersebut berisiko.

Pengguna tidak harus memastikan sendiri bahwa kejadian tersebut benar-benar merupakan insiden. Pemeriksaan lebih lanjut dapat dilakukan oleh pihak yang memiliki kewenangan.

Prinsipnya:

Tugas pengguna adalah melaporkan indikasi. Tugas tim keamanan adalah melakukan verifikasi dan penanganan.

Hal ini juga sesuai dengan prinsip persiapan pengguna dalam buku, yaitu pengguna perlu mengetahui apa yang termasuk insiden, bagaimana melaporkannya, kepada siapa laporan diberikan, dan informasi yang perlu disampaikan.

Apa yang Tidak Boleh Dilakukan?

Ketika menemukan indikasi insiden, pengguna sebaiknya tidak melakukan tindakan yang dapat memperburuk keadaan atau menghilangkan informasi yang diperlukan untuk investigasi.

Beberapa tindakan yang perlu dihindari antara lain:

- Jangan mencoba menyerang balik.
- Jangan mencoba mencari identitas penyerang sendiri.
- Jangan menyebarkan informasi insiden ke pihak yang tidak berkepentingan.
- Jangan menghapus bukti tanpa mengikuti prosedur.
- Jangan mengubah konfigurasi sistem tanpa kewenangan.
- Jangan mencoba memperbaiki sistem sendiri apabila tidak memiliki kewenangan.
- Jangan membagikan password atau kode autentikasi

kepada pihak lain.

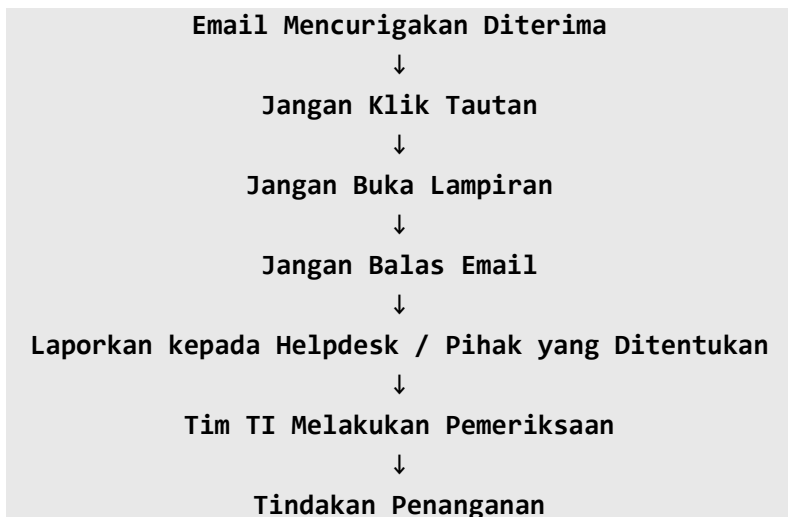
- Jangan menyebarkan email mencurigakan kepada pengguna lain tanpa mengikuti prosedur organisasi.

Untuk email mencurigakan, buku ini secara khusus menekankan agar pengguna tidak langsung menghapus email apabila organisasi memiliki prosedur pelaporan. Pengguna diarahkan untuk tidak mengklik tautan, membuka lampiran, membalas email, atau memberikan informasi.

Contoh Pelaporan Email Phishing

Misalnya seorang pegawai menerima email yang terlihat seperti berasal dari layanan organisasi dan meminta pengguna melakukan login melalui sebuah tautan.

Tindakan yang benar:

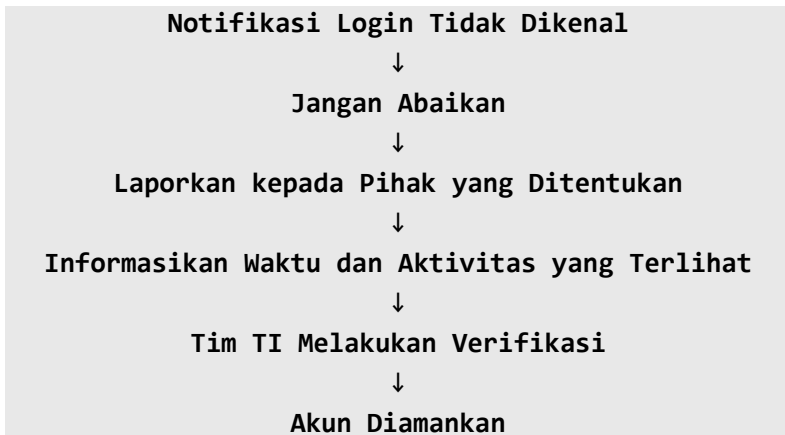


Pengguna tidak perlu mencoba membuka tautan tersebut untuk membuktikan bahwa email tersebut phishing.

- **Contoh Pelaporan Akun Terindikasi Diretas**

Misalnya seorang pegawai menerima notifikasi bahwa akun organisasinya digunakan untuk login dari lokasi atau perangkat yang tidak dikenali.

Tindakan yang dapat dilakukan sesuai prosedur organisasi:



Jika prosedur organisasi mengatur pengguna untuk segera mengganti password atau melakukan tindakan tertentu, pengguna mengikuti prosedur tersebut.

Contoh Pelaporan Malware

Misalnya komputer kantor menunjukkan gejala yang tidak biasa, seperti muncul peringatan keamanan, file berubah, atau aplikasi berjalan tidak normal.

Pengguna sebaiknya:

1. Tidak mencoba menghapus malware sendiri apabila tidak memiliki kewenangan.
2. Tidak menyebarkan file mencurigakan ke perangkat lain.

3. Melaporkan kejadian kepada pihak yang ditentukan.
4. Menyampaikan informasi mengenai gejala yang terlihat.
5. Mengikuti instruksi administrator atau tim keamanan.

Jika diperlukan isolasi perangkat, tindakan tersebut dilakukan sesuai prosedur organisasi.

Pelaporan Harus Mudah

Mekanisme pelaporan yang terlalu rumit dapat menyebabkan pengguna memilih untuk tidak melapor.

Karena itu, organisasi perlu menyediakan mekanisme yang mudah dipahami.

Contohnya:

- Helpdesk.
- Nomor internal.
- Email khusus.
- Sistem tiket.
- Aplikasi pelaporan.
- Kanal komunikasi internal yang telah ditetapkan.

Pengguna harus mengetahui:



Apa yang dilakukan setelah laporan diterima?

Organisasi juga perlu melakukan sosialisasi agar mekanisme tersebut benar-benar diketahui oleh pengguna.

Jangan Menyalahkan Pelapor

Budaya pelaporan harus dibangun dengan baik.

Pegawai yang melaporkan kesalahan dengan itikad baik seharusnya tidak takut untuk melapor.

Sebagai contoh, apabila seorang pegawai tidak sengaja membuka tautan phishing, hal yang paling penting adalah **segera melaporkan kejadian tersebut**.

Menunda laporan karena takut dimarahi justru dapat memperbesar dampak insiden.

Organisasi perlu membangun pemahaman bahwa:

Melaporkan kesalahan dengan cepat lebih baik daripada menyembunyikan kesalahan sampai masalah menjadi lebih besar.

Buku ini juga menekankan bahwa organisasi perlu mendukung pelaporan insiden dan tidak menyalahkan pegawai yang melaporkan kesalahan dengan itikad baik.

Mengukur Efektivitas Pelaporan

Organisasi dapat mengevaluasi apakah mekanisme pelaporan telah berjalan dengan baik.

Beberapa indikator yang dapat digunakan antara lain:

- Jumlah laporan insiden.
- Jumlah laporan email mencurigakan.

- Waktu rata-rata dari kejadian sampai laporan diterima.
- Persentase pegawai yang mengetahui mekanisme pelaporan.
- Hasil simulasi pelaporan.
- Jumlah insiden yang terlambat dilaporkan.

Buku ini secara khusus menyebut **jumlah laporan email mencurigakan** dan **waktu yang dibutuhkan untuk melaporkan insiden** sebagai ukuran yang dapat digunakan untuk melihat perkembangan kesadaran keamanan.

Checklist Pelaporan Insiden

No.	Pemeriksaan	Status
1	Pengguna mengetahui apa yang termasuk insiden	☐
2	Pengguna mengetahui jalur pelaporan	☐
3	Kontak pelaporan tersedia	☐
4	Insiden segera dilaporkan	☐
5	Waktu kejadian dicatat	☐
6	Sistem/perangkat terdampak disebutkan	☐
7	Kronologi singkat disampaikan	☐
8	Bukti yang relevan dipertahankan sesuai prosedur	☐
9	Pengguna tidak melakukan tindakan yang memperburuk insiden	☐

No.	Pemeriksaan	Status
10	Laporan diteruskan kepada pihak yang berwenang	☐

Kesimpulan

Pelaporan merupakan bagian penting dalam Incident Response karena menjadi pintu awal bagi organisasi untuk mengetahui dan menangani insiden.

Pengguna tidak harus memiliki kemampuan teknis untuk melakukan investigasi. Hal yang paling penting adalah mampu mengenali indikasi yang mencurigakan, segera melaporkannya melalui jalur yang telah ditentukan, memberikan informasi yang relevan, serta tidak melakukan tindakan yang dapat memperburuk keadaan.

Kegiatan utama dalam pelaporan insiden meliputi:

**Kenali → Jangan Panik → Jangan Memperburuk → Laporkan
→ Berikan Informasi → Ikuti Instruksi**

Prinsip sederhananya:

Lebih baik melaporkan sesuatu yang ternyata bukan insiden daripada tidak melaporkan insiden yang sebenarnya terjadi.

Organisasi yang memiliki budaya pelaporan yang baik dapat mengetahui insiden lebih cepat, mempercepat respons, mengurangi dampak, dan meningkatkan kemampuan keamanan secara keseluruhan.

6.9 Apa yang Harus Dilakukan Saat Terjadi Serangan

Ketika terjadi serangan keamanan siber, reaksi pertama pengguna sangat penting. Tindakan yang salah dapat memperbesar dampak insiden, menghilangkan bukti, atau memberikan kesempatan kepada penyerang untuk melanjutkan aktivitasnya.

Sebaliknya, tindakan yang cepat, tenang, dan sesuai prosedur dapat membantu organisasi membatasi dampak dan mempercepat proses penanganan.

Pengguna tidak harus memiliki kemampuan teknis untuk menangani seluruh serangan. Peran utama pengguna adalah **mengenali kejadian, tidak memperburuk keadaan, dan segera melaporkannya kepada pihak yang berwenang.**

Prinsip sederhananya:

Tetap tenang, jangan memperburuk keadaan, laporkan, dan ikuti instruksi.

1. Tetap Tenang

Ketika melihat sesuatu yang tidak normal, jangan langsung panik.

Contohnya:

- File tiba-tiba tidak dapat dibuka.
- Muncul pesan tebusan atau ransomware.
- Akun menunjukkan aktivitas login yang tidak dikenal.
- Komputer menjadi sangat lambat secara tiba-tiba.

- Muncul jendela atau aplikasi yang tidak dikenal.
- Website organisasi berubah tampilan.
- Menerima email atau pesan yang sangat mencurigakan.

Jangan langsung mengambil tindakan yang tidak diketahui dampaknya.

Pertama-tama, amati apa yang terjadi dan segera hubungi pihak yang telah ditentukan organisasi.

2. Jangan Melanjutkan Aktivitas yang Mencurigakan

Apabila serangan berkaitan dengan email, tautan, lampiran, atau aplikasi tertentu, jangan melanjutkan interaksi dengan sumber tersebut.

Contohnya:

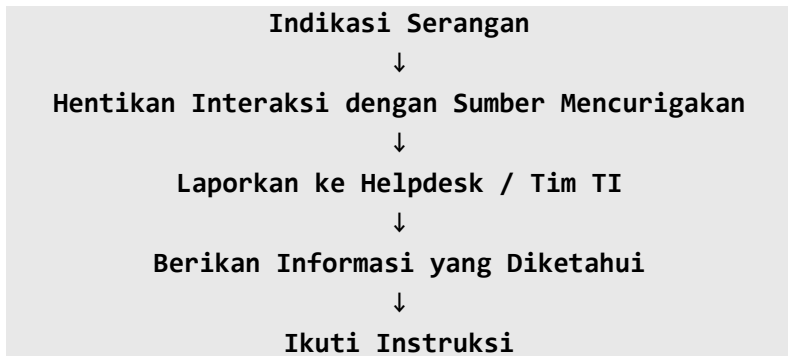
- Jangan klik tautan tambahan.
- Jangan membuka lampiran lainnya.
- Jangan membalas pesan penyerang.
- Jangan memasukkan username dan password.
- Jangan memberikan OTP.
- Jangan memberikan informasi rahasia.
- Jangan mengikuti instruksi mencurigakan.

Tujuannya adalah mencegah pengguna memberikan informasi tambahan atau memperbesar dampak serangan.

3. Segera Laporkan

Setelah menemukan indikasi serangan, segera gunakan mekanisme pelaporan yang telah ditetapkan organisasi.

Contohnya:



Pengguna tidak perlu menunggu sampai memiliki kepastian bahwa kejadian tersebut benar-benar merupakan serangan.

Seperti telah dibahas pada bagian pelaporan, tugas pengguna adalah menyampaikan indikasi, sedangkan pemeriksaan dan verifikasi dilakukan oleh pihak yang memiliki kewenangan.

4. Jangan Mencoba Menyerang Balik

Pengguna tidak boleh mencoba melakukan serangan balik terhadap pihak yang diduga sebagai penyerang.

Contohnya:

- Mencoba membobol akun penyerang.
- Melakukan serangan terhadap alamat IP tertentu.
- Mencoba mengambil alih sistem penyerang.
- Menyebarkan malware sebagai balasan.
- Melakukan tindakan lain di luar kewenangan.

Tindakan tersebut dapat memperburuk situasi dan tidak

termasuk dalam tanggung jawab pengguna ketika terjadi insiden.

Fokus pengguna adalah **melindungi diri, menjaga informasi, dan melaporkan kejadian.**

5. Jangan Menghapus Bukti

Apabila terdapat informasi yang berkaitan dengan kejadian, jangan langsung menghapusnya tanpa mengikuti prosedur organisasi.

Contohnya:

- Email mencurigakan.
- Pesan error.
- Notifikasi keamanan.
- Nama file yang mencurigakan.
- Screenshot.
- Informasi waktu kejadian.
- Informasi akun atau perangkat yang terdampak.

Informasi tersebut dapat membantu administrator atau tim keamanan melakukan investigasi.

Namun, pengguna juga tidak perlu melakukan investigasi teknis sendiri. Cukup pertahankan informasi yang tersedia dan ikuti instruksi pihak yang menangani insiden.

6. Jangan Menyebarkan Informasi Insiden

Ketika terjadi insiden, informasi mengenai kejadian tidak boleh disebarkan sembarangan.

Jangan langsung:

- Mengirim informasi insiden ke grup umum.
- Membagikan screenshot ke media sosial.
- Menyebarkan informasi kepada pihak eksternal.
- Memberikan informasi teknis kepada pihak yang tidak berkepentingan.
- Membuat kesimpulan mengenai penyebab serangan tanpa verifikasi.

Informasi insiden sebaiknya disampaikan melalui jalur komunikasi yang telah ditetapkan organisasi.

Hal ini penting karena insiden keamanan dapat berkaitan dengan informasi internal, data pengguna, konfigurasi sistem, atau informasi lain yang perlu dilindungi.

7. Ikuti Instruksi Administrator atau Tim Keamanan

Setelah laporan diterima, administrator atau tim keamanan dapat memberikan instruksi tertentu.

Misalnya:

- Menghentikan penggunaan perangkat.
- Memutus koneksi jaringan.
- Tidak melakukan restart.
- Mengganti password.
- Menggunakan perangkat lain.
- Menunggu pemeriksaan.
- Menyerahkan perangkat untuk diperiksa.

Pengguna harus mengikuti instruksi tersebut sesuai prosedur.

Jangan melakukan tindakan lain secara mandiri apabila tindakan tersebut dapat mengganggu proses investigasi atau pemulihan.

8. Jika Akun Diduga Terkompromi

Apabila terdapat indikasi bahwa akun telah diakses oleh pihak lain, segera laporkan kepada pihak yang berwenang.

Indikasinya dapat berupa:

- Login dari perangkat atau lokasi yang tidak dikenal.
- Password tiba-tiba tidak dapat digunakan.
- Email terkirim tanpa diketahui pengguna.
- Perubahan profil atau pengaturan akun.
- Notifikasi autentikasi yang tidak dilakukan sendiri.
- Aktivitas aplikasi yang tidak dikenal.

Tindakan berikutnya mengikuti prosedur organisasi.

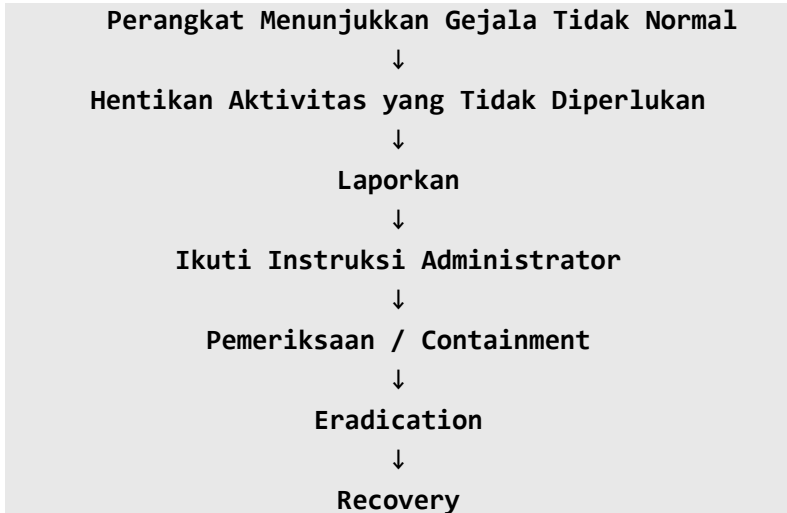
Apabila pengguna diperintahkan untuk mengganti password, gunakan password baru yang unik dan jangan menggunakan kembali password yang telah terdampak.

Apabila tersedia MFA, pastikan mekanisme tersebut tetap aktif sesuai kebijakan organisasi.

9. Jika Perangkat Diduga Terinfeksi

Apabila komputer atau perangkat kerja menunjukkan indikasi infeksi, jangan langsung mencoba melakukan pembersihan sendiri apabila pengguna tidak memiliki kewenangan.

Contohnya:



Tindakan teknis seperti isolasi, pemeriksaan malware, penghapusan malware, atau pemulihan sistem dilakukan oleh pihak yang memiliki kewenangan dan mengikuti prosedur organisasi.

10. Jika Terjadi Ransomware

Ransomware merupakan salah satu kondisi yang membutuhkan respons cepat.

Indikasinya dapat berupa:

- Banyak file tiba-tiba tidak dapat dibuka.
- Nama file berubah.
- Muncul file atau pesan tebusan.
- Sistem menunjukkan aktivitas yang tidak normal.
- Banyak perangkat mengalami masalah yang sama.

Apabila kondisi tersebut terjadi:

1. Jangan membayar atau berkomunikasi dengan penyerang tanpa arahan pihak yang berwenang.
2. Jangan mencoba menghapus pesan atau file yang berkaitan dengan insiden.
3. Segera laporkan kepada administrator atau tim keamanan.
4. Ikuti instruksi mengenai isolasi perangkat.
5. Jangan menghubungkan perangkat lain secara sembarangan.
6. Jangan mencoba melakukan pemulihan sendiri apabila tidak memiliki kewenangan.

Tujuan awal adalah **membatasi penyebaran dan memberikan kesempatan kepada tim keamanan untuk melakukan investigasi.**

11. Jika Website Organisasi Berubah Tampilan

Perubahan tampilan website secara tidak sah dapat menjadi indikasi kompromi.

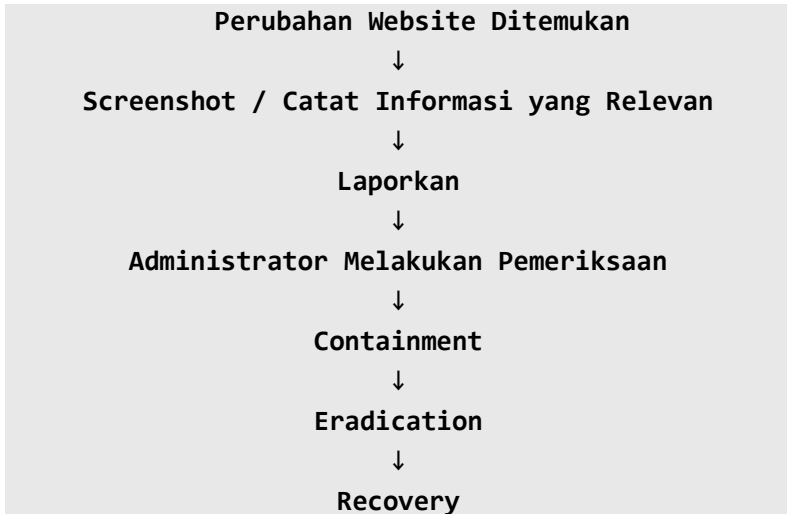
Contohnya:

- Halaman utama berubah.
- Muncul pesan yang tidak dikenal.
- Konten website berubah.
- Muncul iklan atau tautan yang tidak seharusnya.
- Website mengarahkan pengguna ke situs lain.

Apabila menemukan kondisi tersebut, pengguna tidak perlu mencoba memperbaiki website sendiri.

Segera laporkan kepada administrator atau pihak yang bertanggung jawab atas layanan tersebut.

Alurnya:



12. Jika Data Hilang atau Berubah

Apabila pengguna menemukan data yang hilang, berubah, atau tidak dapat dibuka, jangan langsung menganggap data tersebut sudah hilang permanen.

Segera laporkan:

- Nama aplikasi.
- Lokasi data.
- Waktu terakhir data masih normal.

- Jenis perubahan yang terjadi.
- Pesan error yang muncul.
- Perangkat yang digunakan.

Informasi tersebut dapat membantu tim TI menentukan tindakan selanjutnya, termasuk kemungkinan melakukan Recovery dari backup.

13. Catat Informasi Penting

Selama masih aman untuk dilakukan, pengguna dapat mencatat informasi sederhana mengenai kejadian.

Misalnya:

Informasi	Contoh
Waktu	10.15
Perangkat	Laptop kantor
Aplikasi	Email
Kejadian	Menerima email mencurigakan
Tindakan	Tidak membuka tautan
Pelaporan	Dilaporkan ke Helpdesk
Status	Menunggu pemeriksaan

Catatan sederhana dapat membantu administrator memahami apa yang terjadi dan kapan kejadian pertama kali diketahui.

14. Jangan Menyembunyikan Kesalahan

Kesalahan pengguna dapat terjadi.

Contohnya:

- Tidak sengaja membuka lampiran.
- Tidak sengaja mengklik tautan.
- Salah memasukkan password pada halaman phishing.
- Menghubungkan perangkat penyimpanan yang ternyata bermasalah.

Yang paling penting adalah **segera melaporkannya**.

Jangan mencoba menyembunyikan kejadian karena takut mendapatkan teguran.

Semakin cepat informasi diberikan, semakin cepat organisasi dapat mengambil tindakan untuk membatasi dampaknya.

Budaya keamanan yang baik harus mendukung pelaporan kesalahan dengan itikad baik, bukan membuat pegawai takut untuk melapor. Hal ini sejalan dengan prinsip yang telah dibahas sebelumnya dalam buku.

Alur Singkat Saat Terjadi Serangan

Secara sederhana, pengguna dapat mengingat alur berikut:





Atau dengan prinsip yang lebih mudah diingat:

STOP – REPORT – FOLLOW

STOP

Hentikan tindakan yang dapat memperburuk keadaan.

REPORT

Segera laporkan kepada pihak yang telah ditentukan.

FOLLOW

Ikuti instruksi administrator atau tim keamanan.

Checklist Saat Terjadi Serangan

No.	Tindakan	Status
1	Tetap tenang	☐
2	Hentikan interaksi dengan sumber mencurigakan	☐
3	Jangan memasukkan password/OTP	☐
4	Jangan menyebarkan informasi insiden	☐
5	Jangan menghapus bukti tanpa instruksi	☐
6	Catat waktu dan kejadian	☐

No.	Tindakan	Status
7	Segera laporkan	☐
8	Ikuti instruksi administrator	☐
9	Jangan mencoba menyerang balik	☐
10	Jangan mencoba memperbaiki sistem tanpa kewenangan	☐

Kesimpulan

Ketika terjadi serangan keamanan siber, pengguna tidak dituntut untuk menyelesaikan serangan secara teknis. Hal yang paling penting adalah **tidak memperburuk keadaan dan segera mengaktifkan mekanisme respons organisasi.**

Tindakan utama yang perlu diingat adalah:

Tetap Tenang → Hentikan Interaksi → Jangan Hapus Bukti → Laporkan → Ikuti Instruksi

Prinsip sederhananya:

Jangan panik. Jangan bertindak sembarangan. Jangan diam. Laporkan.

Respons pengguna yang cepat dan tepat dapat membantu organisasi melakukan Containment lebih awal, mengurangi dampak insiden, menjaga bukti, dan mempercepat proses pemulihan.

Dengan demikian, setiap pegawai bukan hanya pengguna sistem, tetapi juga menjadi bagian dari **rantai pertahanan keamanan siber organisasi.**

BAB 7 MEMBANGUN BUDAYA KEAMANAN SIBER

7.1 Cyber Security adalah Tanggung Jawab Bersama

Keamanan siber bukan hanya tanggung jawab administrator sistem, tim teknologi informasi, atau unit keamanan informasi. Keamanan siber merupakan **tanggung jawab bersama seluruh elemen organisasi**.

Setiap orang yang menggunakan komputer, jaringan, email, aplikasi, perangkat bergerak, maupun layanan digital organisasi memiliki peran dalam menjaga keamanan informasi.

Seorang pegawai mungkin tidak mengelola firewall atau server, tetapi keputusan sederhana seperti mengklik tautan, menggunakan password, membuka lampiran email, menyimpan data, atau melaporkan aktivitas mencurigakan dapat memengaruhi keamanan organisasi.

Karena itu, keamanan siber harus menjadi bagian dari aktivitas kerja sehari-hari.

Prinsip sederhananya:

Keamanan bukan hanya tugas orang TI. Keamanan adalah tanggung jawab semua orang.

Mengapa Keamanan Siber Menjadi Tanggung Jawab Bersama?

Organisasi modern menggunakan banyak sistem dan layanan digital.

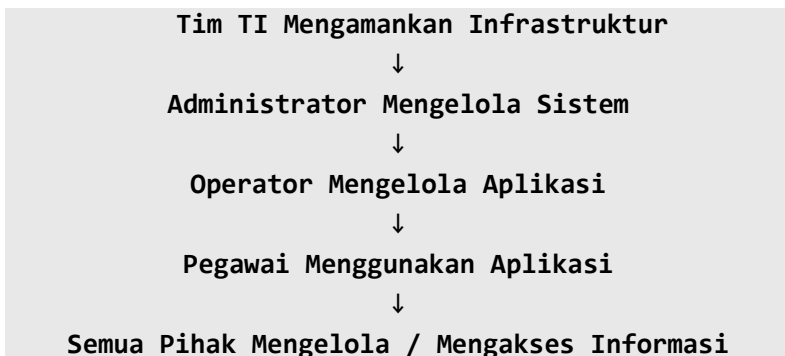
Data dapat disimpan pada:

- Komputer pengguna.
- Laptop.
- Server.
- Database.
- Aplikasi.
- Email.
- Cloud.
- Media penyimpanan.
- Perangkat bergerak.

Akses terhadap sistem tersebut juga dilakukan oleh banyak pihak.

Akibatnya, keamanan tidak dapat hanya bergantung pada satu unit.

Contohnya:



Apabila salah satu bagian mengabaikan keamanan, risiko dapat muncul meskipun teknologi keamanan yang digunakan

sudah baik.

Teknologi Saja Tidak Cukup

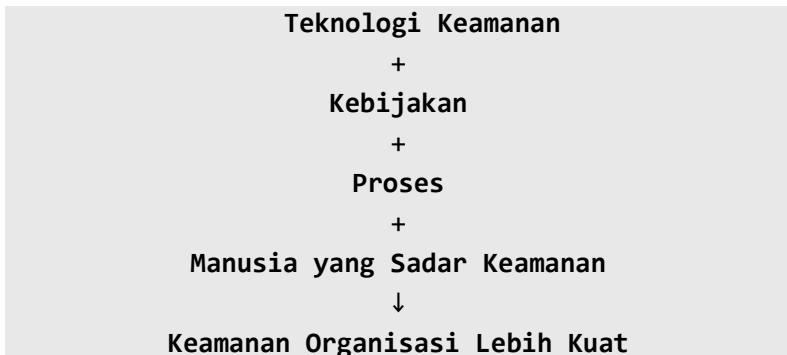
Organisasi dapat memiliki berbagai teknologi keamanan seperti firewall, IDS, IPS, WAF, endpoint protection, maupun EDR.

Namun, teknologi tersebut tidak dapat menggantikan perilaku manusia.

Misalnya organisasi telah memiliki sistem keamanan email, tetapi seorang pegawai tetap memberikan password dan OTP kepada penyerang.

Atau organisasi telah memiliki backup, tetapi backup tidak pernah diuji dan ternyata tidak dapat digunakan ketika terjadi insiden.

Contoh lainnya:



Buku ini juga menekankan bahwa budaya keamanan siber tidak dibangun melalui teknologi semata, tetapi melalui komitmen seluruh anggota organisasi untuk menjadikan keamanan informasi sebagai bagian dari aktivitas kerja sehari-hari.

Setiap Orang Memiliki Peran

Tanggung jawab keamanan memang berbeda berdasarkan tugas dan kewenangan masing-masing, tetapi setiap orang tetap memiliki kontribusi.

Secara sederhana:

Peran	Contoh Tanggung Jawab
Pimpinan	Menetapkan arah, kebijakan, dan dukungan keamanan
Pegawai	Menjaga akun, perangkat, dan informasi yang digunakan
Operator Aplikasi	Menggunakan dan mengelola aplikasi sesuai kewenangan
Helpdesk	Menerima dan meneruskan laporan
Administrator	Mengamankan sistem dan infrastruktur
Tim Keamanan	Melakukan pemantauan dan penanganan keamanan

Pembahasan mengenai peran masing-masing pihak akan dijelaskan lebih lanjut pada bagian berikutnya, mulai dari ASN, pegawai non-ASN, operator aplikasi, helpdesk, hingga administrator sistem. Struktur tersebut memang menjadi bagian dari BAB 7 buku ini.

Peran Pengguna Tidak Boleh Dianggap Kecil

Pengguna sering dianggap sebagai bagian yang paling sederhana dalam keamanan sistem. Padahal, pengguna dapat

menjadi salah satu titik penting dalam pertahanan organisasi.

Pengguna dapat menjadi:

Titik Masuk Serangan

atau

Lapisan Pertahanan

Perbedaannya ditentukan oleh perilaku.

Pengguna yang sembarangan membuka email dapat menjadi jalan masuk serangan.

Sebaliknya, pengguna yang:

- Memeriksa pengirim email.
- Berhenti sejenak sebelum mengklik tautan.
- Menjaga password.
- Menggunakan MFA.
- Tidak memberikan OTP.
- Melaporkan aktivitas mencurigakan.

dapat membantu mencegah insiden.

Buku ini secara khusus menekankan kebiasaan sederhana seperti berhenti sebelum mengklik tautan, memeriksa email dan pengirim, menjaga kerahasiaan password, dan menggunakan MFA.

Keamanan Dimulai dari Kebiasaan Kecil

Budaya keamanan tidak selalu dimulai dari teknologi yang mahal.

Keamanan dapat dimulai dari kebiasaan sederhana.

Contohnya:

Sebelum klik, periksa.

Sebelum membagikan informasi, pikirkan.

Sebelum menggunakan perangkat, pastikan aman.

Jika menemukan sesuatu yang mencurigakan, laporkan.

Kebiasaan sederhana yang dilakukan secara konsisten oleh banyak orang dapat memberikan dampak yang besar bagi keamanan organisasi.

Tanggung Jawab Pengguna

Setiap pengguna perlu memahami bahwa keamanan akun dan perangkat yang digunakan merupakan bagian dari tanggung jawabnya.

Kebiasaan yang perlu diterapkan antara lain:

- Menggunakan password yang kuat dan unik.
- Menjaga kerahasiaan password.
- Tidak memberikan password kepada orang lain.
- Tidak memberikan OTP atau kode autentikasi.
- Menggunakan MFA apabila tersedia.
- Mengunci komputer ketika meninggalkan meja.
- Tidak sembarangan memasang aplikasi.
- Tidak menggunakan media penyimpanan yang tidak dikenal.

- Berhati-hati terhadap email dan pesan mencurigakan.
- Tidak mengakses data yang tidak menjadi kewenangannya.
- Segera melaporkan kejadian mencurigakan.

Keamanan bukan berarti pengguna harus memahami seluruh aspek teknis. Yang penting adalah pengguna memahami **tanggung jawab dan batas kewenangannya**.

Tanggung Jawab Organisasi

Tanggung jawab bersama tidak berarti organisasi dapat menyerahkan seluruh tanggung jawab keamanan kepada pengguna.

Organisasi tetap memiliki kewajiban untuk menyediakan lingkungan yang mendukung perilaku aman.

Organisasi perlu:

- Menetapkan kebijakan keamanan.
- Menyediakan prosedur yang jelas.
- Memberikan pelatihan.
- Menyediakan mekanisme pelaporan.
- Menyediakan teknologi keamanan yang sesuai.
- Mengelola hak akses.
- Melakukan monitoring.
- Menangani insiden.
- Melakukan evaluasi secara berkala.

Dengan demikian, tanggung jawab bersama berarti

organisasi menyediakan sistem dan proses yang aman, sementara setiap orang menjalankan perannya sesuai kewenangan.

Peran Pimpinan Sangat Penting

Budaya keamanan tidak akan berjalan dengan baik tanpa dukungan pimpinan.

Pimpinan memiliki peran dalam:

- Menetapkan kebijakan.
- Menyediakan sumber daya.
- Mendukung pelatihan.
- Memastikan aturan keamanan diterapkan.
- Mendorong budaya pelaporan.
- Memberikan contoh perilaku yang aman.

Buku ini juga menekankan bahwa dukungan kebijakan, sumber daya, pelatihan berkala, dan penegakan aturan keamanan informasi merupakan faktor penting dalam keberhasilan penerapan keamanan siber.

Pimpinan tidak harus menjadi ahli teknis keamanan siber. Namun, pimpinan harus memahami bahwa keamanan siber merupakan bagian dari keberlangsungan organisasi dan tidak dapat diperlakukan hanya sebagai urusan teknis.

Jangan Menyalahkan Pengguna

Budaya keamanan yang baik bukan budaya yang membuat pegawai takut melapor.

Misalnya seorang pegawai tidak sengaja mengklik tautan

phishing.

Ada dua pendekatan:

Pendekatan Pertama

Pegawai takut dimarahi →
Tidak melapor →
Penyerang terus memiliki akses →
Dampak semakin besar.

Pendekatan Kedua

Pegawai segera melapor →
Tim TI melakukan pemeriksaan →
Akun diamankan →
Dampak dapat dibatasi.

Pendekatan kedua lebih mendukung keamanan organisasi.

Karena itu, organisasi perlu membangun budaya di mana pegawai **berani melaporkan kesalahan dengan itikad baik**.

Hal tersebut juga telah ditekankan pada pembahasan Incident Response: organisasi tidak seharusnya menyalahkan pegawai yang melaporkan kesalahan dengan itikad baik.

Security Awareness sebagai Budaya

Security awareness tidak seharusnya hanya berupa pelatihan satu kali.

Kesadaran keamanan perlu dibangun secara berkelanjutan.

Kegiatannya dapat berupa:

- Pelatihan berkala.
- Sosialisasi keamanan.

- Simulasi phishing.
- Peningkat keamanan.
- Kuis.
- Studi kasus.
- Simulasi pelaporan insiden.
- Evaluasi perilaku pengguna.

Tujuannya bukan sekadar membuat pegawai hafal aturan, tetapi membentuk kebiasaan.

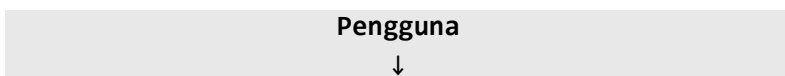


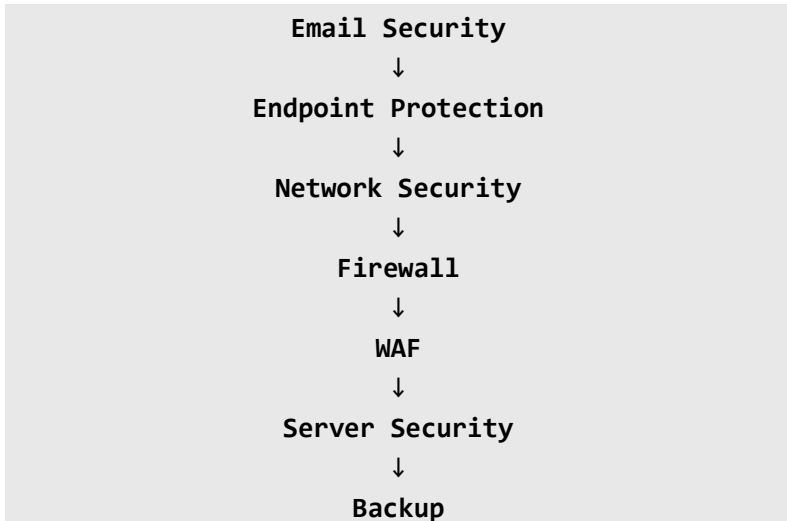
Buku ini menempatkan peningkatan pemahaman, kesadaran, dan partisipasi seluruh pengguna sebagai bagian dari tujuan membangun budaya keamanan siber yang berkelanjutan.

Defense in Depth Membutuhkan Manusia

Keamanan organisasi dapat dipandang sebagai pertahanan berlapis.

Misalnya:

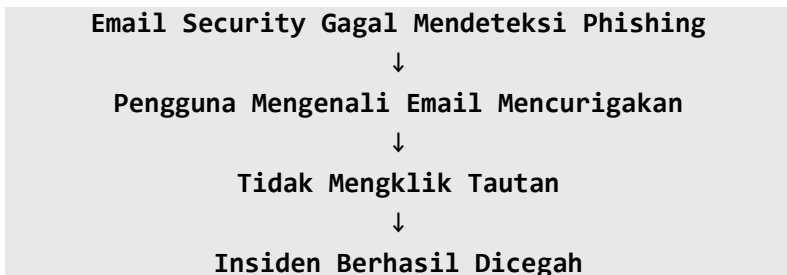




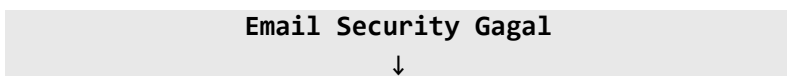
Apabila salah satu lapisan gagal, lapisan lainnya diharapkan dapat mengurangi dampaknya.

Namun, pengguna tetap menjadi bagian dari lapisan tersebut.

Contohnya:



Sebaliknya:



Pengguna Mengklik Tautan



Akun Terkompromi



Serangan Berlanjut

Karena itu, manusia bukan sekadar pengguna teknologi keamanan, tetapi juga merupakan bagian dari mekanisme pertahanan organisasi.

Keamanan sebagai Bagian dari Pekerjaan

Keamanan sebaiknya tidak dianggap sebagai pekerjaan tambahan yang hanya dilakukan ketika ada insiden.

Keamanan harus menjadi bagian dari aktivitas normal.

Contohnya:

Mengirim Email

→ Memeriksa penerima dan lampiran.

Mengakses Aplikasi

→ Menggunakan akun sendiri dan sesuai kewenangan.

Menerima File

→ Memastikan sumbernya dapat dipercaya.

Meninggalkan Komputer

→ Mengunci layar.

Menemukan Aktivitas Mencurigakan

→ Melaporkan.

Dengan cara tersebut, keamanan menjadi bagian dari proses kerja sehari-hari.

Contoh Sederhana

Bayangkan sebuah organisasi memiliki:

- Firewall.
- WAF.
- Antivirus/EDR.
- Backup.
- Monitoring.
- Administrator yang kompeten.

Namun seorang pegawai memberikan password dan OTP kepada seseorang yang mengaku sebagai administrator.

Teknologi keamanan yang tersedia belum tentu dapat mencegah seluruh dampak dari tindakan tersebut.

Sebaliknya, apabila pegawai:

- Memeriksa identitas peminta informasi.
- Tidak memberikan password.
- Tidak memberikan OTP.
- Melaporkan permintaan mencurigakan.

maka pegawai tersebut telah menjadi bagian dari pertahanan organisasi.

Contoh ini menunjukkan bahwa **teknologi, proses, dan manusia harus bekerja bersama.**

Checklist Tanggung Jawab Bersama

No.	Kebiasaan	Status
1	Menjaga kerahasiaan password	☐
2	Menggunakan MFA	☐
3	Berhati-hati terhadap phishing	☐
4	Mengunci perangkat ketika ditinggalkan	☐
5	Menggunakan sistem sesuai kewenangan	☐
6	Tidak memberikan OTP kepada orang lain	☐
7	Tidak memasang aplikasi sembarangan	☐
8	Menjaga informasi organisasi	☐
9	Melaporkan aktivitas mencurigakan	☐
10	Mengikuti kebijakan keamanan organisasi	☐

Kesimpulan

Keamanan siber merupakan tanggung jawab bersama seluruh elemen organisasi. Tidak ada satu unit atau satu teknologi yang mampu memberikan perlindungan secara sempurna tanpa dukungan manusia, proses, dan kebijakan yang tepat.

Tanggung jawab tersebut dapat diringkas menjadi:

Pimpinan → **Menetapkan** **Arah**
Organisasi → **Menyediakan Kebijakan dan Sumber Daya**
Tim TI → **Mengamankan** **Infrastruktur**
Operator → **Mengelola Aplikasi Sesuai Kewenangan**

Helpdesk → Menerima dan Meneruskan Laporan Pegawai → Menjalankan Perilaku Aman

Semua bagian tersebut saling melengkapi.

Prinsip sederhananya:

Keamanan siber bukan pekerjaan satu orang. Keamanan siber adalah budaya yang dibangun bersama.

Budaya keamanan yang kuat dibangun melalui **komitmen, kesadaran, kepatuhan, perilaku aman, dan kemauan untuk melaporkan aktivitas yang mencurigakan**. Dengan keterlibatan seluruh anggota organisasi, keamanan tidak lagi dipandang sebagai urusan teknis semata, tetapi menjadi bagian dari tanggung jawab dalam menjalankan pekerjaan sehari-hari.

7.2 Peran ASN

Aparatur Sipil Negara (ASN) merupakan bagian penting dalam penyelenggaraan pemerintahan dan pelayanan publik. Berdasarkan Undang-Undang Nomor 20 Tahun 2023 tentang Aparatur Sipil Negara, Pegawai ASN terdiri atas Pegawai Negeri Sipil (PNS) dan Pegawai Pemerintah dengan Perjanjian Kerja (PPPK). Pegawai ASN berperan sebagai perencana, pelaksana, dan pengawas penyelenggaraan tugas umum pemerintahan dan pembangunan nasional melalui pelaksanaan kebijakan dan pelayanan publik yang profesional. (Republik Indonesia, 2023).

Dalam lingkungan kerja yang semakin bergantung pada sistem informasi dan layanan digital, pelaksanaan tugas ASN juga semakin berkaitan dengan pengelolaan dan penggunaan informasi secara elektronik. Oleh karena itu, keamanan siber bukan hanya menjadi tanggung jawab pegawai yang bekerja pada

bidang teknologi informasi, tetapi juga menjadi bagian dari tanggung jawab ASN dalam menjalankan tugas sehari-hari.

ASN dapat menggunakan berbagai sistem digital seperti aplikasi pemerintahan, sistem administrasi, email kedinasan, sistem kepegawaian, sistem pelayanan publik, maupun sistem pengelolaan data. Setiap aktivitas tersebut memiliki risiko keamanan yang perlu diperhatikan.

Prinsip sederhananya:

ASN yang aman secara digital membantu menjaga keamanan organisasi dan pelayanan publik.

ASN sebagai Pengguna Sistem Informasi

Sebagian besar ASN merupakan pengguna sistem informasi dalam pelaksanaan pekerjaan.

Contohnya:

- Menggunakan komputer atau laptop kantor.
- Mengakses aplikasi pemerintahan.
- Menggunakan email kedinasan.
- Mengakses dokumen elektronik.
- Mengelola data masyarakat.
- Menggunakan sistem kepegawaian.
- Mengakses sistem administrasi.
- Menggunakan layanan berbasis cloud apabila disediakan organisasi.

Karena memiliki akses terhadap berbagai sumber informasi,

ASN perlu memahami bahwa setiap tindakan pada sistem digital dapat memiliki konsekuensi terhadap keamanan informasi.

Kesalahan sederhana seperti memberikan password kepada orang lain, membuka lampiran berbahaya, atau mengirim dokumen kepada penerima yang salah dapat menyebabkan kebocoran informasi.

Menjaga Kerahasiaan Informasi

ASN dapat memperoleh akses terhadap berbagai informasi yang digunakan dalam pelaksanaan tugas pemerintahan.

Informasi tersebut dapat berupa:

- Data pegawai.
- Data masyarakat.
- Dokumen administrasi.
- Informasi internal organisasi.
- Dokumen perencanaan.
- Informasi keuangan.
- Data pelayanan publik.
- Informasi lain yang penggunaannya dibatasi.

ASN harus menjaga informasi tersebut sesuai dengan klasifikasi, kewenangan, dan kebijakan organisasi.

Khusus untuk data pribadi, organisasi juga harus memperhatikan ketentuan Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi yang mengatur pemrosesan data pribadi serta kewajiban pengendali dan prosesor data pribadi. (Republik Indonesia, 2022).

Karena itu, ASN tidak boleh mengganggu informasi yang dapat diakses melalui sistem sebagai informasi yang bebas digunakan atau dibagikan.

Menggunakan Akun Sesuai Kewenangan

ASN harus menggunakan akun sesuai dengan identitas dan kewenangan yang diberikan.

Beberapa prinsip yang perlu diterapkan:

- Gunakan akun sendiri.
- Jangan meminjamkan akun kepada orang lain.
- Jangan menggunakan akun milik orang lain.
- Jangan membagikan password.
- Jangan memberikan kode OTP.
- Jangan menyimpan password secara sembarangan.
- Gunakan MFA apabila tersedia.
- Segera laporkan jika terdapat aktivitas login yang tidak dikenal.

Akun merupakan bagian dari identitas digital pengguna. Penyalahgunaan akun dapat menyebabkan aktivitas pihak lain tercatat seolah-olah dilakukan oleh pemilik akun.

Berhati-hati terhadap Phishing

ASN perlu meningkatkan kewaspadaan terhadap phishing karena email dan pesan elektronik sering digunakan sebagai sarana serangan.

Contoh pesan yang perlu dicurigai:

- Permintaan password.
- Permintaan OTP.
- Permintaan login melalui tautan.
- Pemberitahuan hadiah atau penghargaan yang tidak jelas.
- Permintaan pembayaran yang tidak biasa.
- Permintaan dokumen secara mendesak.
- Pesan yang mengatasnamakan pimpinan.
- Pesan yang meminta tindakan segera tanpa prosedur yang jelas.

Apabila menerima pesan mencurigakan:

Berhenti → Periksa → Jangan Klik → Laporkan

Program awareness yang baik seharusnya membantu seluruh personel memahami peran mereka dalam melindungi informasi dan aset organisasi. NIST SP 800-50 Rev. 1 menekankan pendekatan pembelajaran keamanan dan privasi yang berorientasi pada perubahan perilaku serta pembentukan budaya keamanan dalam organisasi (Merritt et al., 2024).

Menjaga Perangkat Kerja

Perangkat yang digunakan ASN merupakan bagian dari aset organisasi.

ASN perlu:

- Mengunci komputer ketika meninggalkan meja.
- Tidak memberikan perangkat kepada orang yang tidak

berwenang.

- Tidak memasang aplikasi tanpa izin.
- Tidak menghubungkan media penyimpanan yang tidak dikenal.
- Tidak menonaktifkan mekanisme keamanan.
- Melaporkan kehilangan perangkat.
- Melaporkan perilaku perangkat yang tidak normal.

Perangkat yang hilang atau dicuri dapat menjadi risiko keamanan apabila di dalamnya terdapat data organisasi atau sesi login yang masih aktif.

Menggunakan Data Sesuai Kebutuhan Tugas

Akses terhadap data bukan berarti pengguna memiliki kebebasan untuk menggunakan data tersebut untuk kepentingan apa pun.

ASN perlu menerapkan prinsip:

Akses karena tugas, gunakan sesuai kebutuhan, dan jangan sebar tanpa kewenangan.

Contohnya, seorang pegawai yang memperoleh akses terhadap data masyarakat untuk menyelesaikan pekerjaan tidak berarti dapat menyalin data tersebut ke perangkat pribadi atau membagikannya melalui aplikasi komunikasi pribadi.

Untuk data pribadi, penggunaan dan pemrosesannya perlu memperhatikan ketentuan yang berlaku. UU Nomor 27 Tahun 2022 mengatur kewajiban pengendali dan prosesor dalam pemrosesan data pribadi.

Melaporkan Aktivitas Mencurigakan

ASN merupakan salah satu pihak yang dapat pertama kali mengetahui adanya kejadian keamanan.

Contohnya:

- Password tiba-tiba tidak dapat digunakan.
- Mendapatkan notifikasi login yang tidak dilakukan.
- Menemukan email mencurigakan.
- Menemukan file berubah.
- Menemukan aplikasi berjalan tidak normal.
- Menemukan data yang tidak seharusnya dapat diakses.
- Kehilangan perangkat kerja.

ASN tidak perlu melakukan investigasi sendiri.

Yang perlu dilakukan adalah:

Kenali → Catat Informasi → Laporkan → Ikuti Instruksi

Budaya pelaporan yang baik membantu organisasi mengetahui insiden lebih cepat dan melakukan tindakan sebelum dampaknya menjadi lebih besar.

Mengikuti Kebijakan Keamanan Organisasi

ASN perlu memahami dan mengikuti kebijakan keamanan informasi yang berlaku di instansinya.

Kebijakan dapat mencakup:

- Penggunaan akun.
- Password.

- MFA.
- Email.
- Internet.
- Perangkat kerja.
- Media penyimpanan.
- Aplikasi.
- Penggunaan perangkat pribadi.
- Akses data.
- Pelaporan insiden.

Kepatuhan terhadap kebijakan merupakan bagian dari perilaku keamanan sehari-hari.

Namun, kebijakan juga harus dibuat dengan jelas dan dapat diterapkan. Prosedur yang terlalu rumit dapat menyebabkan pengguna mencari cara sendiri yang justru meningkatkan risiko.

ASN sebagai Bagian dari Budaya Keamanan

Keamanan siber tidak cukup hanya dengan memberikan pelatihan sekali.

ASN perlu membangun kebiasaan keamanan secara berkelanjutan.

NIST SP 800-50 Rev. 1 menggunakan pendekatan siklus hidup untuk program pembelajaran keamanan dan privasi serta mendorong perubahan perilaku sebagai bagian dari manajemen risiko. Program tersebut ditujukan untuk berbagai kelompok personel dengan kebutuhan yang berbeda. (Merritt et al., 2024).

Dalam konteks organisasi pemerintahan, pendekatan tersebut dapat diterapkan melalui:

- Pelatihan keamanan berkala.
- Sosialisasi phishing.
- Simulasi phishing.
- Simulasi pelaporan insiden.
- Peningkat keamanan.
- Kuis keamanan.
- Evaluasi perilaku pengguna.
- Pembaruan materi berdasarkan ancaman terbaru.

Dengan demikian, security awareness tidak berhenti pada pengetahuan, tetapi berkembang menjadi kebiasaan.

Contoh Perilaku ASN yang Aman

Situasi	Perilaku yang Benar
Menerima email mencurigakan	Tidak klik dan melaporkan
Diminta password	Tidak memberikan
Diminta OTP	Tidak memberikan
Meninggalkan komputer	Mengunci layar
Menemukan USB tidak dikenal	Tidak langsung memasang
Mendapat notifikasi login asing	Melaporkan
Memerlukan data pribadi	Menggunakan sesuai

	kewenangan
Kehilangan laptop kantor	Segera melaporkan
Menemukan aplikasi tidak normal	Melaporkan kepada pihak terkait
Mendapat permintaan data dari pihak luar	Memastikan kewenangan dan prosedurnya

ASN sebagai Bagian dari Pertahanan Organisasi

Keamanan organisasi dapat digambarkan sebagai pertahanan berlapis.

ASN



Aplikasi Keamanan Email



Endpoint Protection



Network Security



Firewall / WAF



Server Security



Monitoring dan Incident Response

Setiap lapisan memiliki fungsi yang berbeda.

Namun, apabila ASN mampu mengenali dan melaporkan serangan sejak awal, organisasi memiliki kesempatan lebih besar untuk menghentikan serangan sebelum mencapai sistem kritis.

Dengan demikian, ASN bukan hanya pengguna sistem, tetapi juga merupakan bagian dari **human layer of defense** organisasi.

Checklist Peran ASN

No.	Tanggung Jawab	Status
1	Menjaga kerahasiaan password	☐
2	Menggunakan akun sesuai kewenangan	☐
3	Menggunakan MFA apabila tersedia	☐
4	Waspada terhadap phishing	☐
5	Menjaga perangkat kerja	☐
6	Menggunakan data sesuai kebutuhan tugas	☐
7	Tidak membagikan informasi tanpa kewenangan	☐
8	Mengikuti kebijakan keamanan organisasi	☐
9	Melaporkan aktivitas mencurigakan	☐
10	Mengikuti pelatihan keamanan	☐

Kesimpulan

ASN memiliki peran penting dalam menjaga keamanan siber organisasi karena ASN merupakan bagian dari proses penyelenggaraan pemerintahan dan pelayanan publik.

Peran tersebut tidak berarti setiap ASN harus menjadi ahli keamanan siber. Yang lebih penting adalah setiap ASN memahami tanggung jawabnya ketika menggunakan sistem, perangkat, akun, dan informasi organisasi.

Peran ASN dapat diringkas menjadi:

Gunakan dengan Aman → Lindungi Informasi → Patuhi Kebijakan → Waspada → Laporkan

Prinsip sederhananya:

ASN yang sadar keamanan bukan hanya melindungi akunnya sendiri, tetapi turut melindungi organisasi dan pelayanan publik.

Keamanan siber yang kuat membutuhkan perubahan perilaku secara berkelanjutan. Karena itu, peningkatan awareness dan pembelajaran keamanan perlu menjadi bagian dari budaya organisasi, bukan sekadar kegiatan pelatihan satu kali. Pendekatan ini sejalan dengan NIST SP 800-50 Rev. 1 yang menempatkan awareness, training, education, perubahan perilaku, dan budaya keamanan sebagai bagian dari program pembelajaran keamanan dan privasi organisasi. (Merritt et al., 2024).

7.3 Peran Pegawai Non ASN

Pegawai non-ASN merupakan bagian dari lingkungan kerja organisasi yang dapat terlibat dalam pelaksanaan tugas administrasi, pelayanan, operasional, maupun fungsi pendukung lainnya. Walaupun tidak berstatus sebagai Pegawai ASN, pegawai non-ASN tetap dapat menggunakan perangkat, aplikasi, jaringan, akun, dan mengakses informasi milik organisasi.

Dalam konteks keamanan siber, status kepegawaian tidak menghilangkan kebutuhan untuk menerapkan perilaku keamanan. Setiap orang yang diberikan akses terhadap sistem atau informasi organisasi perlu memahami tanggung jawab

keamanan sesuai dengan tugas dan kewenangannya.

Perlu dibedakan bahwa berdasarkan Undang-Undang Nomor 20 Tahun 2023 tentang Aparatur Sipil Negara, Pegawai ASN terdiri atas PNS dan PPPK. Oleh karena itu, istilah pegawai non-ASN dalam buku ini digunakan untuk merujuk pada personel yang bekerja atau menjalankan fungsi di lingkungan organisasi tetapi bukan Pegawai ASN. (Republik Indonesia, 2023).

Prinsip sederhananya:

Bukan status kepegawaiannya yang menentukan tanggung jawab keamanan, tetapi akses dan peran seseorang terhadap sistem serta informasi organisasi.

Mengapa Pegawai Non ASN Perlu Memahami Keamanan Siber?

Dalam aktivitas sehari-hari, pegawai non-ASN dapat diberikan akses terhadap berbagai fasilitas organisasi.

Contohnya:

- Komputer atau laptop kerja.
- Email organisasi.
- Aplikasi administrasi.
- Sistem pelayanan.
- Dokumen elektronik.
- Database tertentu.
- Jaringan organisasi.
- Sistem komunikasi internal.

- Perangkat pendukung pekerjaan.

Setiap akses tersebut dapat menjadi bagian dari permukaan serangan (*attack surface*) organisasi.

Apabila akun atau perangkat seorang pegawai berhasil disalahgunakan, penyerang dapat menggunakannya sebagai titik awal untuk memperoleh akses yang lebih luas.

Karena itu:

Akses Sistem

↓

Tanggung Jawab

↓

Perilaku Aman

↓

Perlindungan Organisasi

Menggunakan Akses Sesuai Kewenangan

Pegawai non-ASN harus menggunakan akses yang diberikan sesuai dengan tugasnya.

Beberapa prinsip yang perlu diterapkan:

- Gunakan akun sendiri.
- Jangan menggunakan akun orang lain.
- Jangan meminjamkan akun.
- Jangan membagikan password.
- Jangan memberikan OTP.
- Jangan mencoba mengakses sistem yang tidak menjadi kewenangan.

- Jangan menggunakan akses untuk kepentingan pribadi.
- Jangan menyalin data organisasi tanpa kewenangan.

Akses yang diberikan kepada seseorang harus digunakan hanya untuk kebutuhan pekerjaan.

Contohnya, pegawai yang diberikan akses untuk memasukkan data ke dalam sebuah aplikasi tidak otomatis memiliki hak untuk mengakses seluruh database aplikasi tersebut.

Menjaga Kerahasiaan Informasi

Pegawai non-ASN dapat berinteraksi dengan informasi organisasi dalam menjalankan pekerjaannya.

Informasi tersebut dapat berupa:

- Data pegawai.
- Data masyarakat.
- Dokumen administrasi.
- Data pelayanan.
- Informasi internal.
- Dokumen keuangan.
- Dokumen pekerjaan.
- Informasi lain yang dibatasi penggunaannya.

Informasi yang diperoleh selama bekerja tidak boleh dibagikan kepada pihak yang tidak berwenang.

Khusus apabila pekerjaan melibatkan data pribadi, pemrosesan data perlu dilakukan sesuai ketentuan yang berlaku.

Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mengatur hak subjek data pribadi serta kewajiban pihak yang melakukan pemrosesan data pribadi. (Republik Indonesia, 2022).

Prinsip sederhananya:

Data yang dapat diakses karena pekerjaan bukan berarti data tersebut bebas untuk disalin, disimpan, atau dibagikan.

Waspada terhadap Phishing

Pegawai non-ASN memiliki risiko yang sama dalam menghadapi phishing, social engineering, malware, dan bentuk serangan lainnya.

Contoh pesan yang perlu dicurigai:

- Permintaan password.
- Permintaan OTP.
- Permintaan login melalui tautan.
- Permintaan dokumen secara mendesak.
- Pesan yang mengatasnamakan pimpinan.
- Pesan yang meminta pembayaran.
- Pesan yang menawarkan hadiah atau keuntungan.
- Lampiran yang tidak diharapkan.
- Tautan dengan alamat yang mencurigakan.

Ketika menerima pesan seperti itu:

Berhenti



Periksa

↓

Jangan Klik

↓

Jangan Berikan Informasi

↓

Laporkan

NIST mendefinisikan *awareness training* sebagai pelatihan dasar keamanan dan privasi bagi seluruh personel untuk membantu mereka memahami peran dalam melindungi informasi, aset keamanan siber, dan privasi organisasi.

Artinya, program awareness seharusnya tidak hanya ditujukan kepada pegawai dengan status tertentu, tetapi kepada personel yang memiliki kebutuhan dan akses terhadap lingkungan organisasi.

Menjaga Perangkat Kerja

Perangkat yang digunakan untuk bekerja harus diperlakukan sebagai aset organisasi.

Pegawai non-ASN perlu:

- Mengunci komputer ketika meninggalkan meja.
- Menjaga perangkat agar tidak digunakan pihak lain.
- Tidak memasang aplikasi sembarangan.
- Tidak menonaktifkan antivirus atau mekanisme keamanan.
- Tidak menggunakan media penyimpanan yang tidak dikenal.

- Tidak menghubungkan perangkat ke jaringan yang berisiko tanpa mengikuti kebijakan organisasi.
- Segera melaporkan kehilangan perangkat.
- Melaporkan apabila perangkat menunjukkan perilaku tidak normal.

Kebiasaan sederhana tersebut membantu mengurangi risiko penyalahgunaan perangkat dan akun.

Tidak Menggunakan Perangkat Pribadi Secara Sembarangan

Dalam beberapa lingkungan kerja, pegawai dapat menggunakan perangkat pribadi untuk mendukung pekerjaan.

Apabila organisasi mengizinkan penggunaan perangkat pribadi, pengguna harus mengikuti kebijakan yang berlaku.

Hal yang perlu diperhatikan antara lain:

- Apakah penggunaan perangkat pribadi diperbolehkan?
- Apakah data organisasi boleh disimpan pada perangkat pribadi?
- Apakah aplikasi komunikasi pribadi boleh digunakan untuk mengirim dokumen?
- Apakah perangkat harus menggunakan pengamanan tertentu?
- Bagaimana data organisasi dihapus ketika perangkat tidak lagi digunakan?

Pegawai tidak boleh menganggap bahwa karena perangkat tersebut milik pribadi, maka seluruh data organisasi yang tersimpan di dalamnya juga menjadi bebas digunakan.

Tidak Membagikan Akun

Salah satu kebiasaan yang perlu dihindari adalah berbagi akun.

Contohnya:

"Gunakan akun saya saja, nanti password-nya saya berikan."

Praktik tersebut dapat menyebabkan masalah:

- Identitas pengguna menjadi tidak jelas.
- Aktivitas tidak dapat ditelusuri dengan baik.
- Akun dapat disalahgunakan.
- Tanggung jawab menjadi tidak jelas.
- Investigasi insiden menjadi lebih sulit.

Jika seseorang membutuhkan akses, akses tersebut seharusnya diberikan melalui mekanisme resmi organisasi.

Mengikuti Prosedur Organisasi

Pegawai non-ASN perlu mengikuti prosedur keamanan yang berlaku di lingkungan tempatnya bekerja.

Prosedur tersebut dapat mencakup:

- Penggunaan perangkat.
- Penggunaan email.
- Penggunaan internet.
- Pengelolaan password.
- Akses aplikasi.
- Pengelolaan dokumen.

- Penggunaan media penyimpanan.
- Pelaporan insiden.
- Penggunaan perangkat pribadi.
- Pengelolaan data.

Prosedur yang baik harus dibuat sederhana, jelas, dan sesuai dengan pekerjaan pengguna.

NIST SP 800-50 Rev. 1 menekankan bahwa program pembelajaran keamanan dan privasi perlu disesuaikan dengan kebutuhan organisasi serta kelompok personel yang beragam, dan diarahkan pada perubahan perilaku serta pembentukan budaya keamanan. (Merritt et al., 2024).

Segera Melaporkan Insiden

Pegawai non-ASN juga dapat menjadi orang pertama yang menemukan indikasi insiden.

Contohnya:

- Menerima email phishing.
- Menemukan login yang tidak dikenal.
- Menemukan file berubah.
- Mendapatkan pesan error yang tidak biasa.
- Menemukan perangkat berjalan tidak normal.
- Kehilangan perangkat kerja.
- Menemukan data yang tidak dapat diakses.
- Menemukan aktivitas akun yang tidak dilakukan sendiri.

Yang harus dilakukan:

Temukan → Jangan Panik → Jangan Perburuk → Laporkan

Pegawai tidak perlu melakukan investigasi teknis sendiri.

Tugas utamanya adalah memberikan informasi kepada pihak yang telah ditentukan organisasi.

Jangan Takut Melaporkan Kesalahan

Kesalahan dapat terjadi pada siapa saja.

Misalnya seorang pegawai tidak sengaja mengklik tautan phishing.

Hal yang paling berbahaya bukan hanya kesalahan tersebut, tetapi apabila pegawai kemudian memilih untuk menyembunyikannya.

Contohnya:

Klik Tautan Phishing

↓

Takut Melapor

↓

Akun Tidak Diamankan

↓

Penyerang Melanjutkan Aktivitas

Sebaliknya:

Klik Tautan Phishing

↓

Segera Melapor

↓

Akun Diamankan

↓

Investigasi



Dampak Dibatasi

Karena itu, organisasi perlu membangun lingkungan yang mendorong pelaporan dengan itikad baik.

Mengikuti Security Awareness

Pegawai non-ASN perlu mengikuti kegiatan security awareness yang diwajibkan organisasi.

Kegiatan dapat berupa:

- Pelatihan keamanan.
- Sosialisasi phishing.
- Simulasi phishing.
- Kuis keamanan.
- Simulasi pelaporan insiden.
- Edukasi penggunaan password.
- Edukasi MFA.
- Peningkat keamanan secara berkala.

NIST SP 800-50 Rev. 1 mendorong organisasi menjalankan program pembelajaran keamanan dan privasi secara berkelanjutan, dengan evaluasi dan perbaikan berdasarkan kebutuhan serta hasil pengukuran (Merritt et al., 2024).

Dengan demikian, security awareness bukan kegiatan satu kali pada saat seseorang mulai bekerja.

Perbedaan Peran dengan Administrator

Pegawai non-ASN tidak selalu memiliki tanggung jawab teknis seperti administrator sistem.

Perbedaannya dapat digambarkan sebagai berikut:

Pegawai Non ASN	Administrator Sistem
Menggunakan sistem	Mengelola sistem
Menjaga akun sendiri	Mengelola akun pengguna
Menjaga data yang digunakan	Mengamankan infrastruktur
Mengenali aktivitas mencurigakan	Melakukan investigasi teknis
Melaporkan insiden	Menangani insiden
Mengikuti prosedur	Menetapkan/menerapkan konfigurasi
Menjaga perangkat yang digunakan	Mengelola keamanan sistem

Namun, perbedaan kewenangan tidak berarti salah satu pihak tidak memiliki tanggung jawab keamanan.

Pengguna menjaga dari sisi penggunaan. Administrator menjaga dari sisi teknis.

Contoh Kasus

Seorang pegawai non-ASN bekerja pada bagian administrasi dan mendapatkan akses ke aplikasi internal.

Suatu hari, pegawai tersebut menerima email yang

mengatasnamakan administrator sistem dan meminta password serta OTP untuk "verifikasi akun".

Pegawai tersebut:

1. Tidak memberikan password.
2. Tidak memberikan OTP.
3. Tidak mengklik tautan.
4. Menyimpan informasi email.
5. Melaporkan email tersebut kepada helpdesk.
6. Mengikuti instruksi dari administrator.

Dalam kasus tersebut, pegawai non-ASN telah menjalankan peran keamanan dengan baik meskipun tidak memiliki kemampuan teknis untuk melakukan analisis phishing.

Contoh Perilaku yang Tidak Aman

Beberapa contoh perilaku yang perlu dihindari:

Perilaku	Risiko
Meminjamkan akun	Aktivitas sulit ditelusuri
Membagikan password	Akun dapat disalahgunakan
Memberikan OTP	Akun dapat diambil alih
Menyimpan data organisasi di perangkat pribadi tanpa izin	Kebocoran data
Menggunakan USB tidak dikenal	Malware

Membuka lampiran mencurigakan	Infeksi
Mengirim dokumen melalui kanal tidak resmi	Kebocoran informasi
Tidak melaporkan insiden	Dampak dapat semakin besar
Menonaktifkan mekanisme keamanan	Perlindungan berkurang

Checklist Peran Pegawai Non ASN

No.	Tanggung Jawab	Status
1	Menggunakan akun sendiri	☐
2	Menjaga password	☐
3	Tidak membagikan OTP	☐
4	Menggunakan akses sesuai kewenangan	☐
5	Menjaga informasi organisasi	☐
6	Waspada terhadap phishing	☐
7	Menjaga perangkat kerja	☐
8	Mengikuti kebijakan keamanan	☐
9	Mengikuti security awareness	☐
10	Melaporkan aktivitas mencurigakan	☐

Kesimpulan

Pegawai non-ASN merupakan bagian dari lingkungan kerja organisasi dan dapat memiliki akses terhadap sistem, perangkat, aplikasi, maupun informasi organisasi. Karena itu, mereka juga merupakan bagian dari **human layer of defense** organisasi.

Peran tersebut dapat diringkas menjadi:

Gunakan Sesuai Kewenangan → Lindungi Akun → Lindungi Informasi → Waspada → Laporkan

Pegawai non-ASN tidak harus menjadi ahli keamanan siber. Namun, mereka perlu memahami bahwa setiap akses terhadap sistem membawa tanggung jawab untuk menjaga keamanan.

Prinsip sederhananya:

Siapa pun yang memiliki akses terhadap sistem dan informasi organisasi memiliki peran dalam menjaga keamanannya.

Dengan menerapkan perilaku yang aman, mengikuti kebijakan, mengikuti program awareness, dan segera melaporkan kejadian mencurigakan, pegawai non-ASN dapat membantu organisasi mengurangi risiko serangan dan memperkuat budaya keamanan siber.

Program awareness yang melibatkan seluruh kelompok personel juga sejalan dengan NIST SP 800-50 Rev. 1 yang menempatkan pembelajaran keamanan dan privasi sebagai program organisasi yang mencakup beragam kelompok personel serta bertujuan membangun perubahan perilaku dan budaya keamanan. (Merritt et al., 2024).

7.4 Peran Operator Aplikasi

Operator aplikasi merupakan personel yang diberikan kewenangan untuk menjalankan fungsi operasional tertentu dalam sebuah aplikasi organisasi. Operator dapat bertugas memasukkan, memperbarui, memverifikasi, memproses, atau menyajikan data sesuai dengan tugas yang diberikan.

Berbeda dengan pengguna biasa, operator aplikasi umumnya memiliki akses yang lebih luas terhadap fungsi dan data aplikasi. Karena itu, kesalahan atau penyalahgunaan akun operator dapat memberikan dampak yang lebih besar terhadap integritas data dan keberlangsungan layanan.

Operator aplikasi bukan administrator sistem. Operator berfokus pada penggunaan dan pengelolaan aplikasi sesuai kewenangan, sedangkan administrator bertanggung jawab terhadap infrastruktur, konfigurasi sistem, akun teknis, dan aspek keamanan teknis yang berada dalam kewenangannya.

Prinsip sederhananya:

Operator bertanggung jawab menggunakan aplikasi dengan benar, menjaga data yang dikelola, dan tidak menggunakan kewenangan di luar tugasnya.

Menggunakan Akun Sesuai Identitas

Operator harus menggunakan akun yang diberikan secara resmi oleh organisasi.

Akun operator sebaiknya:

- Digunakan oleh pemilik akun.
- Tidak dipinjamkan kepada orang lain.

- Tidak digunakan bersama-sama.
- Dilindungi dengan password yang kuat.
- Menggunakan MFA apabila tersedia.
- Tidak disimpan pada tempat yang mudah diketahui orang lain.
- Segera dilaporkan apabila diduga telah disalahgunakan.

Penggunaan akun bersama dapat menyulitkan penelusuran aktivitas.

Misalnya terdapat perubahan data yang tidak sah. Apabila beberapa orang menggunakan satu akun operator, administrator akan kesulitan menentukan siapa yang melakukan perubahan tersebut.

Karena itu:

Satu orang, satu identitas, satu akun.

Memahami Batas Kewenangan

Operator harus memahami fungsi apa saja yang boleh digunakan.

Tidak semua menu atau data yang secara teknis dapat diakses berarti boleh digunakan.

Contohnya, seorang operator diberikan akses untuk:

- Memasukkan data.
- Memperbarui data tertentu.
- Membuat laporan.
- Melakukan verifikasi.

Hal tersebut tidak otomatis memberikan hak untuk:

- Mengubah konfigurasi aplikasi.
- Menghapus seluruh data.
- Membuat akun administrator.
- Mengubah hak akses pengguna lain.
- Mengubah database secara langsung.
- Menonaktifkan mekanisme keamanan.

Prinsip yang harus diterapkan adalah:

Gunakan akses sesuai kebutuhan pekerjaan dan kewenangan yang diberikan.

Pengendalian akses merupakan salah satu komponen penting keamanan informasi karena bertujuan memastikan bahwa akses diberikan kepada pihak yang berwenang untuk melakukan tindakan yang sesuai. ISO/IEC 27002:2022 memasukkan access control sebagai salah satu area pengendalian keamanan informasi.

Menjaga Kerahasiaan Data

Operator sering berinteraksi langsung dengan data organisasi.

Data tersebut dapat berupa:

- Data masyarakat.
- Data pegawai.
- Data pelayanan.
- Data transaksi.

- Data administrasi.
- Dokumen organisasi.
- Informasi internal.
- Data lain yang dibatasi penggunaannya.

Operator harus menjaga data tersebut dan hanya menggunakannya untuk kepentingan pekerjaan.

Operator tidak boleh:

- Menyalin data untuk kepentingan pribadi.
- Mengirim data ke akun pribadi tanpa kewenangan.
- Menyimpan data pada media yang tidak disetujui.
- Membagikan data kepada pihak lain tanpa otorisasi.
- Mengambil screenshot data sensitif tanpa kebutuhan pekerjaan.
- Menggunakan data organisasi untuk kepentingan di luar tugas.

Apabila aplikasi memproses data pribadi, operator juga harus mengikuti kebijakan organisasi dan ketentuan perlindungan data pribadi yang berlaku.

Memastikan Data yang Dimasukkan Benar

Keamanan informasi bukan hanya mengenai kerahasiaan.

Operator juga memiliki tanggung jawab terhadap **integritas data**.

Kesalahan input dapat menyebabkan:

- Informasi menjadi tidak akurat.

- Laporan menjadi salah.
- Pelayanan terganggu.
- Keputusan organisasi menggunakan data yang tidak benar.
- Proses administrasi menjadi bermasalah.

Karena itu, sebelum menyimpan data, operator perlu melakukan pemeriksaan.

Contohnya:

Data Diterima

↓

Periksa Sumber

↓

Periksa Kelengkapan

↓

Periksa Kebenaran

↓

Input ke Aplikasi

↓

Verifikasi

↓

Simpan

Operator tidak boleh mengubah data secara sembarangan hanya untuk membuat proses terlihat selesai.

Tidak Melakukan Manipulasi Data

Operator memiliki akses yang dapat digunakan untuk mengubah data. Karena itu, akses tersebut harus digunakan secara bertanggung jawab.

Operator tidak boleh mengubah data:

- Tanpa dasar yang jelas.
- Untuk kepentingan pribadi.
- Untuk menguntungkan pihak tertentu.
- Untuk menyembunyikan kesalahan.
- Untuk melewati prosedur.
- Atas permintaan pihak yang tidak memiliki kewenangan.

Apabila terdapat permintaan perubahan data yang tidak biasa, operator perlu melakukan verifikasi melalui prosedur yang berlaku.

Contohnya:

"Tolong ubah data ini sekarang. Ini permintaan pimpinan."

Operator tidak seharusnya langsung melakukan perubahan hanya berdasarkan klaim tersebut.

Jika diperlukan persetujuan atau dokumentasi, ikuti prosedur organisasi.

Waspada terhadap Social Engineering

Operator dapat menjadi target social engineering karena memiliki akses terhadap aplikasi dan data.

Penyerang dapat berpura-pura menjadi:

- Pimpinan.
- Administrator.
- Rekan kerja.

- Petugas TI.
- Vendor.
- Instansi lain.
- Pengguna layanan.

Penyerang dapat meminta operator:

- Memberikan password.
- Memberikan OTP.
- Membuat akun baru.
- Mengubah data.
- Menghapus data.
- Mengubah hak akses.
- Memberikan informasi pengguna.
- Mengirimkan dokumen.

Operator harus memverifikasi permintaan yang tidak biasa melalui jalur resmi.

Prinsip sederhananya:

Permintaan yang terlihat mendesak tetap harus diverifikasi.

Tidak Memberikan Password dan OTP

Operator tidak boleh memberikan password atau kode autentikasi kepada orang lain.

Administrator yang sah sekalipun seharusnya tidak meminta operator memberikan password melalui chat atau email.

Jika terdapat masalah akun, gunakan mekanisme resmi seperti:

- Reset password.
- Helpdesk.
- Service desk.
- Administrator aplikasi.
- Prosedur pemulihan akun.

OTP juga tidak boleh diberikan kepada pihak lain.

Berhati-hati terhadap Perubahan Data yang Tidak Biasa

Operator merupakan salah satu pihak yang dapat mengetahui perubahan data secara langsung.

Contohnya:

- Banyak data berubah secara tiba-tiba.
- Data hilang.
- Data muncul tanpa diketahui sumbernya.
- Nilai data berubah secara tidak wajar.
- Status transaksi berubah tanpa alasan.
- Banyak akun melakukan aktivitas yang tidak biasa.

Jika menemukan kondisi seperti itu, operator sebaiknya tidak mencoba memperbaikinya sendiri dengan melakukan perubahan tambahan.

Tindakan yang lebih tepat:

Temukan Kejanggalan

↓

Hentikan Perubahan yang Tidak Diperlukan

↓

Catat Informasi

↓

Laporkan

↓

Tunggu Pemeriksaan

Hal ini membantu mencegah operator secara tidak sengaja memperbesar kerusakan atau menghilangkan informasi yang diperlukan untuk investigasi.

Menjaga Kerahasiaan Akun Operator

Karena akun operator memiliki akses yang lebih tinggi, perlindungannya perlu mendapat perhatian khusus.

Operator perlu:

- Menggunakan password unik.
- Mengaktifkan MFA apabila tersedia.
- Tidak menyimpan password dalam file teks biasa.
- Tidak menempelkan password di dekat komputer.
- Tidak membagikan password.
- Mengunci perangkat ketika ditinggalkan.
- Segera melaporkan dugaan kompromi akun.

Jika akun operator berhasil diambil alih, penyerang dapat melakukan aktivitas menggunakan kewenangan operator.

Karena itu, akun operator harus diperlakukan sebagai **akun**

bernilai tinggi.

Tidak Menggunakan Hak Operator untuk Kepentingan Pribadi

Hak akses yang diberikan organisasi merupakan fasilitas untuk melaksanakan pekerjaan.

Operator tidak boleh menggunakan akses tersebut untuk:

- Melihat data yang tidak berkaitan dengan tugas.
- Mencari informasi pribadi orang lain.
- Mengubah data milik pihak lain tanpa kewenangan.
- Mengambil data untuk kepentingan pribadi.
- Membantu pihak luar memperoleh akses.
- Melakukan aktivitas yang tidak berkaitan dengan pekerjaan.

Prinsipnya:

Bisa mengakses bukan berarti boleh mengakses.

Memastikan Perangkat yang Digunakan Aman

Operator perlu menjaga perangkat yang digunakan untuk mengakses aplikasi.

Hal yang perlu dilakukan:

- Mengunci komputer ketika meninggalkan meja.
- Tidak memberikan perangkat kepada orang lain.
- Menggunakan sistem operasi dan aplikasi sesuai kebijakan.
- Tidak memasang aplikasi sembarangan.

- Tidak menonaktifkan antivirus atau mekanisme keamanan.
- Tidak menggunakan media penyimpanan yang tidak dikenal.
- Melaporkan gejala malware atau aktivitas tidak normal.

Perangkat operator dapat menjadi jalur menuju aplikasi dan data organisasi sehingga keamanan perangkat merupakan bagian dari keamanan aplikasi.

Melaporkan Aktivitas Mencurigakan

Operator harus segera melaporkan apabila menemukan indikasi masalah keamanan.

Contohnya:

- Login yang tidak dikenal.
- Perubahan data yang tidak dilakukan sendiri.
- Akun tiba-tiba terkunci.
- Muncul menu atau fungsi yang sebelumnya tidak tersedia.
- Aplikasi berjalan tidak normal.
- Muncul pesan error yang tidak biasa.
- Data hilang.
- Data berubah secara massal.
- Terdapat akun baru yang tidak dikenal.

Operator tidak perlu melakukan investigasi teknis sendiri.

Cukup:

Kenali → Catat → Laporkan → Ikuti Instruksi

Operator sebagai Sumber Informasi Awal

Operator sering berada sangat dekat dengan aktivitas aplikasi sehingga dapat menjadi pihak pertama yang mengetahui adanya kegagalan.

Contohnya:

Operator menemukan bahwa banyak data berubah dalam waktu yang sangat singkat.

Operator tidak mengetahui apakah perubahan tersebut merupakan kesalahan aplikasi, kesalahan pengguna, atau aktivitas penyerang.

Namun, operator dapat mengenali bahwa aktivitas tersebut **tidak normal**.

Dengan segera melaporkan kondisi tersebut, tim TI atau keamanan dapat melakukan pemeriksaan lebih lanjut.

Dengan demikian, operator memiliki peran penting dalam **deteksi dini**.

Tidak Melakukan Perbaikan Teknis Tanpa Kewenangan

Ketika terjadi masalah aplikasi, operator mungkin tergoda untuk mencoba memperbaikinya sendiri.

Misalnya:

- Mengubah database secara langsung.
- Menghapus file aplikasi.
- Mengubah konfigurasi server.

- Menghapus log.
- Menonaktifkan fitur keamanan.
- Menggunakan akun administrator milik orang lain.

Tindakan tersebut dapat memperburuk masalah.

Operator sebaiknya melakukan tindakan teknis hanya apabila tindakan tersebut memang termasuk dalam prosedur dan kewenangannya.

Untuk masalah yang berada di luar kewenangan:

Laporkan, jangan mencoba-coba.

Dokumentasi Aktivitas

Apabila organisasi memiliki prosedur pencatatan aktivitas operator, operator harus menjalankannya secara konsisten.

Dokumentasi dapat mencakup:

- Perubahan data penting.
- Persetujuan.
- Aktivitas khusus.
- Permintaan perubahan.
- Gangguan aplikasi.
- Pelaporan insiden.

Dokumentasi membantu organisasi melakukan audit dan investigasi apabila terjadi masalah.

Contoh Kasus

Seorang operator aplikasi menerima pesan melalui aplikasi

komunikasi yang mengaku berasal dari administrator.

Pesan tersebut berbunyi:

"Ada masalah pada akun Anda. Kirimkan username, password, dan OTP agar kami dapat melakukan pengecekan."

Operator tidak memberikan informasi tersebut.

Operator kemudian:

1. Tidak memberikan password.
2. Tidak memberikan OTP.
3. Tidak mengikuti tautan yang diberikan.
4. Melakukan verifikasi melalui kanal resmi.
5. Melaporkan pesan tersebut kepada helpdesk.
6. Menunggu instruksi.

Tindakan tersebut benar karena operator tidak hanya melindungi akunnya sendiri, tetapi juga mencegah kemungkinan penyerang memperoleh akses terhadap aplikasi.

Contoh Kasus Perubahan Data Massal

Operator menemukan bahwa ratusan data dalam aplikasi berubah dalam waktu beberapa menit.

Operator tidak mengetahui penyebabnya.

Tindakan yang tepat:

Perubahan Data Massal Ditemukan

↓

Jangan Melakukan Perubahan Tambahan

↓

Catat Waktu dan Kondisi

↓

Laporkan kepada Administrator / Tim TI

↓

Investigasi

↓

Containment Jika Diperlukan

↓

Recovery Jika Diperlukan

Operator tidak seharusnya mencoba mengembalikan seluruh data secara manual sebelum mengetahui penyebab perubahan.

Perbedaan Operator dan Administrator

Pembagian tanggung jawab perlu dipahami dengan jelas.

Operator Aplikasi	Administrator Sistem
Menggunakan aplikasi	Mengelola sistem
Mengelola data sesuai tugas	Mengelola infrastruktur
Menggunakan fungsi sesuai kewenangan	Mengelola konfigurasi
Mengenali kejanggalan aplikasi	Melakukan investigasi teknis
Melaporkan insiden	Menangani insiden
Menjaga akun operator	Mengelola akun dan kontrol teknis
Tidak mengubah	Bertanggung jawab atas

konfigurasi sistem

konfigurasi sesuai kewenangan

Pembagian tersebut dapat berbeda antarorganisasi. Karena itu, batas kewenangan harus ditentukan melalui kebijakan dan prosedur organisasi.

Checklist Peran Operator Aplikasi

No.	Tanggung Jawab	Status
1	Menggunakan akun sendiri	☐
2	Menjaga password dan OTP	☐
3	Menggunakan akses sesuai kewenangan	☐
4	Menjaga kerahasiaan data	☐
5	Memastikan data yang dimasukkan benar	☐
6	Tidak memanipulasi data tanpa kewenangan	☐
7	Waspada terhadap social engineering	☐
8	Menjaga perangkat kerja	☐
9	Melaporkan aktivitas mencurigakan	☐
10	Tidak melakukan perubahan teknis di luar kewenangan	☐
11	Mengikuti prosedur aplikasi	☐
12	Mengikuti security awareness	☐

Kesimpulan

Operator aplikasi memiliki peran penting dalam menjaga keamanan karena mereka berinteraksi langsung dengan aplikasi dan data organisasi. Akses operator yang lebih luas dibandingkan pengguna biasa membuat perlindungan akun, pengendalian kewenangan, dan ketelitian dalam mengelola data menjadi sangat penting.

Peran operator dapat diringkas menjadi:

**Gunakan Sesuai Kewenangan → Lindungi Akun → Jaga Data
→ Verifikasi Permintaan → Laporkan Kejanggalan**

Prinsip sederhananya:

Operator bukan administrator sistem, tetapi operator tetap merupakan bagian penting dari pertahanan keamanan aplikasi.

Operator yang memahami batas kewenangan, menjaga akun, melindungi data, waspada terhadap social engineering, dan cepat melaporkan aktivitas mencurigakan dapat membantu organisasi mencegah kesalahan, mendeteksi anomali lebih awal, dan mengurangi dampak insiden.

Pendekatan pembelajaran berdasarkan peran juga sejalan dengan NIST SP 800-50 Rev. 1 yang mendorong organisasi membangun program pembelajaran keamanan dan privasi yang disesuaikan dengan kelompok personel dan kebutuhan peran masing-masing. Program tersebut diarahkan pada perubahan perilaku dan pembentukan budaya keamanan organisasi. (Merritt et al., 2024).

7.5 Peran Helpdesk

Helpdesk merupakan salah satu fungsi penting dalam

mendukung keamanan siber organisasi karena sering menjadi titik pertama yang menerima laporan dari pengguna ketika terjadi gangguan atau indikasi insiden keamanan.

Dalam konteks keamanan siber, helpdesk tidak hanya berfungsi sebagai penerima keluhan teknis. Helpdesk juga memiliki peran dalam mengenali laporan yang berpotensi berkaitan dengan keamanan, mencatat informasi awal, melakukan eskalasi kepada pihak yang berwenang, serta membantu memastikan bahwa laporan tidak berhenti tanpa tindak lanjut.

Helpdesk tidak selalu bertanggung jawab melakukan investigasi teknis secara mendalam. Peran tersebut dapat dilakukan oleh administrator, tim keamanan, atau personel lain sesuai struktur organisasi.

Prinsip sederhananya:

Helpdesk menerima laporan, mengenali indikasi, mencatat, meneruskan, dan memastikan laporan ditindaklanjuti.

Helpdesk sebagai Pintu Masuk Pelaporan

Pengguna sering tidak mengetahui harus menghubungi siapa ketika mengalami masalah keamanan.

Contohnya:

- Menerima email phishing.
- Tidak dapat login ke akun.
- Mendapatkan notifikasi login yang tidak dikenal.
- Komputer menunjukkan perilaku tidak normal.

- Menemukan file yang berubah.
- Kehilangan perangkat kerja.
- Menemukan aplikasi tidak dapat digunakan.
- Menemukan aktivitas yang mencurigakan.

Helpdesk dapat menjadi titik awal untuk menerima laporan tersebut.

Alurnya:

Pengguna

↓

Helpdesk

↓

Klasifikasi Awal

↓

Penerusan / Eskalasi

↓

Administrator / Tim Keamanan

↓

Penanganan

Dengan mekanisme tersebut, pengguna tidak perlu mencari sendiri pihak yang tepat untuk setiap jenis masalah.

Membedakan Gangguan dan Indikasi Insiden

Tidak semua laporan yang diterima helpdesk merupakan insiden keamanan.

Contohnya:

"Printer tidak bisa mencetak."

Kemungkinan besar merupakan gangguan teknis biasa.

Namun:

"Akun saya mendapat notifikasi login dari perangkat yang tidak saya kenal."

Kejadian tersebut dapat memiliki aspek keamanan dan perlu mendapatkan perhatian lebih lanjut.

Contoh lainnya:

Laporan	Kemungkinan Kategori
Printer tidak mencetak	Gangguan teknis
Aplikasi lambat	Gangguan teknis / perlu pemeriksaan
Password lupa	Permintaan layanan
Email meminta OTP	Indikasi keamanan
Login tidak dikenal	Indikasi keamanan
File berubah tanpa diketahui	Indikasi keamanan
Laptop hilang	Insiden keamanan potensial
Website berubah tampilan	Insiden keamanan potensial

Helpdesk tidak harus langsung menentukan penyebab teknis. Yang penting adalah mengenali bahwa sebuah laporan **berpotensi memiliki dampak keamanan** dan meneruskannya sesuai prosedur.

Mengumpulkan Informasi Awal

Ketika menerima laporan, helpdesk perlu mengumpulkan informasi yang relevan.

Informasi tersebut dapat meliputi:

- Nama pelapor.
- Unit kerja.
- Nomor kontak.
- Waktu kejadian.
- Perangkat yang digunakan.
- Nama aplikasi atau layanan.
- Deskripsi kejadian.
- Pesan error.
- Aktivitas yang dilakukan sebelum kejadian.
- Screenshot jika diperlukan.
- Informasi lain yang relevan.

Contoh:

Pelapor: Pegawai Unit Administrasi

Waktu: 09.15

Perangkat: Laptop kantor

Layanan: Email organisasi

Kejadian: Mendapat notifikasi login dari perangkat yang tidak dikenal

Tindakan pengguna: Tidak melakukan login tersebut

Informasi awal seperti ini dapat membantu pihak berikutnya melakukan analisis.

Jangan Meminta Informasi Rahasia

Helpdesk harus berhati-hati ketika meminta informasi dari pengguna.

Helpdesk tidak boleh meminta pengguna memberikan:

- Password.
- OTP.
- PIN.
- Recovery code.
- Private key.
- Token autentikasi.

Apabila diperlukan tindakan terhadap akun, gunakan mekanisme resmi yang telah ditetapkan organisasi.

Contohnya:

Pengguna Lupa Password

↓

Helpdesk Memverifikasi Identitas

↓

Reset Password melalui Prosedur Resmi

↓

Pengguna Membuat Password Baru

Bukan:

Pengguna Lupa Password

↓

Pengguna Memberikan Password Lama kepada Helpdesk

Prinsipnya:

Helpdesk membutuhkan informasi untuk memproses layanan, bukan rahasia autentikasi pengguna.

Melakukan Verifikasi Identitas

Helpdesk perlu memastikan bahwa permintaan berasal dari pihak yang berhak.

Hal ini terutama penting untuk permintaan yang berkaitan dengan:

- Reset password.
- Pembukaan akun.
- Perubahan data.
- Perubahan hak akses.
- Penggantian nomor telepon.
- Perubahan email.
- Pemulihan akun.

Proses verifikasi harus mengikuti prosedur organisasi.

Jangan menggunakan metode verifikasi yang terlalu lemah hanya karena pengguna meminta proses dipercepat.

Contohnya, seseorang menelepon dan mengatakan:

"Saya pimpinan. Segera reset password akun saya."

Helpdesk tetap harus mengikuti mekanisme verifikasi yang berlaku.

Melakukan Klasifikasi Awal

Helpdesk dapat melakukan klasifikasi awal berdasarkan informasi yang diterima.

Contohnya:

Kategori 1 – Permintaan Layanan

- Lupa password.
- Permintaan instalasi aplikasi.
- Permintaan akses sesuai prosedur.

Kategori 2 – Gangguan Teknis

- Aplikasi tidak dapat digunakan.
- Komputer bermasalah.
- Gangguan koneksi.

Kategori 3 – Indikasi Keamanan

- Phishing.
- Malware.
- Login mencurigakan.
- Akun diduga diambil alih.
- Kehilangan perangkat.
- Perubahan data tidak sah.

Kategori 4 – Insiden Keamanan Prioritas Tinggi

- Ransomware.
- Kebocoran data.
- Kompromi akun administrator.
- Serangan terhadap layanan penting.
- Perubahan website secara tidak sah.

- Penyebaran malware ke banyak perangkat.

Klasifikasi sebenarnya harus disesuaikan dengan kebijakan organisasi.

Melakukan Eskalasi

Apabila laporan memiliki indikasi keamanan, helpdesk perlu meneruskannya kepada pihak yang berwenang.

Contohnya:

Laporan Phishing

→ Tim Keamanan / Administrator Email

Akun Diduga Diambil Alih

→ Administrator / Tim Keamanan

Malware

→ Administrator Endpoint / Tim Keamanan

Server Bermasalah

→ Administrator Server

Aplikasi Bermasalah

→ Administrator Aplikasi / Tim Pengembang

Kebocoran Data

→ Tim Keamanan / Penanggung Jawab yang Ditentukan Organisasi

Helpdesk tidak boleh membiarkan laporan berhenti hanya karena masalah tersebut berada di luar kemampuan teknisnya.

• • **Menentukan Prioritas**

Tidak semua laporan memiliki tingkat urgensi yang sama.

Helpdesk perlu mengikuti aturan prioritas yang telah

ditetapkan organisasi.

Contohnya:

Kondisi	Prioritas
Lupa password	Normal
Aplikasi tidak dapat digunakan satu pengguna	Normal
Email phishing diterima	Perlu pemeriksaan
Akun diduga diambil alih	Tinggi
Malware pada satu perangkat	Tinggi
Ransomware pada banyak perangkat	Sangat tinggi
Kebocoran data	Sangat tinggi
Sistem layanan publik tidak tersedia karena serangan	Sangat tinggi

Penentuan prioritas sebaiknya mempertimbangkan dampak, jumlah pengguna terdampak, sensitivitas data, dan kemungkinan penyebaran.

Jangan Menunda Eskalasi

Salah satu risiko dalam helpdesk adalah laporan keamanan diperlakukan seperti tiket teknis biasa.

Misalnya:

"Nanti saja diproses setelah tiket lain selesai."

Jika laporan ternyata merupakan kompromi akun atau

malware yang sedang aktif, keterlambatan dapat memperbesar dampak.

Karena itu, laporan dengan indikasi keamanan harus mengikuti **jalur eskalasi keamanan** yang telah ditetapkan.

NIST SP 800-61 Rev. 3 menekankan pentingnya mengintegrasikan aktivitas respons insiden ke dalam manajemen risiko organisasi agar kemampuan deteksi, respons, dan pemulihan dapat berjalan lebih efektif (Nelson et al., 2025).

Menjaga Kerahasiaan Laporan

Laporan insiden dapat berisi informasi sensitif.

Contohnya:

- Nama pengguna.
- Alamat email.
- Informasi sistem.
- Nama server.
- Screenshot aplikasi.
- Informasi akun.
- Informasi keamanan.
- Data yang terdampak.

Helpdesk harus menangani informasi tersebut sesuai kebijakan organisasi.

Jangan menyebarkan detail insiden ke:

- Grup umum.
- Media sosial.

- Pihak yang tidak berkepentingan.
- Rekan kerja yang tidak terlibat.

Informasi hanya diberikan kepada pihak yang membutuhkan untuk menjalankan tugasnya.

Menjaga Bukti Awal

Dalam kondisi tertentu, laporan pengguna dapat mengandung informasi yang berguna untuk investigasi.

Helpdesk perlu berhati-hati agar tidak menghilangkan informasi tersebut.

Misalnya pengguna melaporkan:

"Saya mendapatkan email yang meminta login."

Helpdesk tidak seharusnya langsung meminta pengguna menghapus email tersebut apabila email tersebut masih diperlukan untuk pemeriksaan.

Sebaliknya, ikuti prosedur organisasi untuk mempertahankan informasi yang relevan.

Helpdesk juga sebaiknya tidak melakukan perubahan teknis yang tidak diperlukan hanya untuk mencoba menyelesaikan masalah sebelum pihak yang berwenang melakukan pemeriksaan.

Memberikan Instruksi Awal yang Aman

Helpdesk dapat memberikan instruksi awal apabila sudah terdapat prosedur yang jelas.

Contohnya:

Email Phishing

- Jangan klik tautan.
- Jangan buka lampiran.
- Jangan membalas.
- Jangan memberikan password atau OTP.
- Ikuti prosedur pelaporan.

Akun Diduga Terkompromi

- Jangan mengabaikan notifikasi.
- Jangan memberikan kode autentikasi.
- Ikuti prosedur pengamanan akun.
- Eskalasikan kepada pihak terkait.

Perangkat Diduga Terinfeksi

- Jangan melakukan tindakan pembersihan di luar prosedur.
- Ikuti instruksi administrator.
- Eskalasikan laporan.

Instruksi helpdesk harus berdasarkan prosedur organisasi dan kewenangan yang dimilikinya.

Mendokumentasikan Tiket

Setiap laporan perlu dicatat secara memadai.

Dokumentasi dapat mencakup:

- Nomor tiket.
- Waktu laporan.

- Identitas pelapor.
- Unit kerja.
- Jenis kejadian.
- Sistem/perangkat terdampak.
- Deskripsi kejadian.
- Tindakan awal.
- Pihak yang menerima eskalasi.
- Waktu eskalasi.
- Status penanganan.

Contoh:

Informasi	Isi
Ticket	INC-2026-00125
Waktu	09.15
Pelapor	Pegawai Unit Administrasi
Jenis	Dugaan phishing
Sistem	Email organisasi
Tindakan	Tidak membuka tautan
Eskalasi	Tim Keamanan
Waktu eskalasi	09.20
Status	Investigasi

Dokumentasi membantu memastikan tidak ada laporan yang hilang dan dapat menjadi sumber informasi untuk evaluasi setelah insiden.

Helpdesk sebagai Penghubung

Helpdesk berada di antara pengguna dan tim teknis.

Perannya dapat digambarkan:

Pengguna



Helpdesk



Administrator / Tim Keamanan / Tim Aplikasi

Helpdesk membantu menerjemahkan masalah pengguna menjadi informasi yang dapat ditindaklanjuti oleh tim teknis.

Sebaliknya, helpdesk juga dapat membantu menyampaikan instruksi teknis kepada pengguna dengan bahasa yang mudah dipahami.

Karena itu, kemampuan komunikasi menjadi bagian penting dari pekerjaan helpdesk.

Tidak Menyalahkan Pengguna

Helpdesk harus menjaga cara berkomunikasi ketika menerima laporan.

Misalnya pengguna mengatakan:

"Saya tidak sengaja membuka link phishing."

Respons yang tidak tepat:

"Kenapa bisa diklik?"

Respons yang lebih baik:

"Baik, kami catat. Jangan lakukan tindakan lain pada email tersebut. Kami akan meneruskan laporan ini untuk pemeriksaan."

Tujuannya adalah memastikan pengguna tetap mau memberikan informasi dan tidak takut melaporkan kejadian.

Budaya pelaporan yang baik membantu organisasi memperoleh informasi lebih cepat.

Helpdesk sebagai Bagian dari Security Awareness

Helpdesk dapat menjadi salah satu saluran edukasi keamanan.

Ketika menerima laporan, helpdesk dapat memberikan pengingat sederhana.

Contohnya:

"Untuk ke depannya, jangan pernah memberikan OTP kepada siapa pun, termasuk pihak yang mengaku sebagai administrator."

Namun edukasi tersebut harus dilakukan tanpa menghambat proses penanganan insiden.

NIST SP 800-50 Rev. 1 menekankan bahwa program pembelajaran keamanan dan privasi perlu melibatkan kelompok personel yang beragam dan mendorong perubahan perilaku serta budaya keamanan organisasi.

Mengukur Kinerja Pelaporan

Organisasi dapat menggunakan data helpdesk untuk

mengukur efektivitas mekanisme pelaporan keamanan.

Contohnya:

- Jumlah laporan keamanan.
- Jumlah laporan phishing.
- Waktu rata-rata dari laporan sampai eskalasi.
- Jumlah laporan yang salah klasifikasi.
- Jumlah laporan yang terlambat ditindaklanjuti.
- Jumlah insiden yang ditemukan melalui helpdesk.
- Persentase tiket keamanan yang memiliki informasi lengkap.

Salah satu indikator penting adalah **waktu antara pengguna menemukan kejadian dan laporan diterima**, serta waktu yang diperlukan untuk melakukan eskalasi.

Semakin cepat laporan diterima dan diteruskan, semakin cepat tim terkait dapat melakukan tindakan.

Contoh Kasus: Email Phishing

Seorang pegawai melapor:

"Saya menerima email yang meminta login. Saya belum mengklik link."

Helpdesk melakukan:

1. Mencatat laporan.
2. Memastikan identitas pelapor.
3. Mencatat waktu dan informasi email.

4. Memastikan pengguna tidak melanjutkan interaksi.
5. Mengeskalasi email kepada pihak yang menangani keamanan email.
6. Menyimpan informasi sesuai prosedur.
7. Memperbarui tiket dengan hasil tindak lanjut.

Helpdesk tidak perlu mencoba membuka tautan phishing untuk memastikan apakah link tersebut berbahaya.

Contoh Kasus: Akun Diduga Diambil Alih

Pengguna melapor:

"Saya mendapatkan notifikasi login dari lokasi yang tidak saya kenal."

Helpdesk:

Menerima Laporan

↓

Verifikasi Identitas

↓

Catat Informasi

↓

Klasifikasi sebagai Indikasi Keamanan

↓

Eskalasi

↓

Administrator / Tim Keamanan Mengamankan Akun

↓

Tiket Diperbarui

Helpdesk tidak meminta pengguna memberikan password

atau OTP.

Contoh Kasus: Ransomware

Apabila beberapa pengguna melaporkan bahwa file mereka tiba-tiba tidak dapat dibuka dan muncul pesan tebusan, helpdesk harus memperlakukannya sebagai kondisi yang memiliki potensi dampak tinggi.

Alurnya:

Beberapa Laporan Serupa

↓

Identifikasi Pola

↓

Prioritas Tinggi

↓

Eskalasi Segera

↓

Administrator / Tim Keamanan

↓

Containment

↓

Investigasi

Helpdesk tidak seharusnya menunggu semua pengguna membuat tiket sebelum melakukan eskalasi jika sudah terdapat indikasi pola serangan.

Checklist Peran Helpdesk

No.	Tanggung Jawab	Status
1	Mengetahui mekanisme pelaporan insiden	☐

2	Menerima laporan pengguna	☐
3	Mengumpulkan informasi awal	☐
4	Tidak meminta password atau OTP	☐
5	Melakukan verifikasi identitas sesuai prosedur	☐
6	Mengenal indikasi insiden keamanan	☐
7	Menentukan prioritas sesuai prosedur	☐
8	Melakukan eskalasi	☐
9	Menjaga kerahasiaan laporan	☐
10	Mempertahankan informasi yang relevan	☐
11	Mendokumentasikan tiket	☐
12	Memastikan tindak lanjut tercatat	☐

Kesimpulan

Helpdesk memiliki posisi strategis dalam keamanan siber karena menjadi salah satu titik pertama interaksi ketika pengguna mengalami masalah atau menemukan indikasi insiden.

Peran helpdesk dapat diringkas menjadi:

Terima → Verifikasi → Catat → Klasifikasi → Eskalasi → Pantau

Helpdesk tidak harus menjadi investigator keamanan atau administrator sistem. Namun, helpdesk harus mampu mengenali laporan yang memiliki potensi keamanan, memberikan instruksi awal yang aman sesuai prosedur, menjaga informasi, dan memastikan laporan diteruskan kepada pihak yang tepat.

Prinsip sederhananya:

Helpdesk mungkin bukan pihak yang menyelesaikan semua insiden, tetapi helpdesk harus memastikan insiden tidak berhenti di meja helpdesk.

Helpdesk yang responsif dan memiliki pemahaman keamanan yang baik dapat mempercepat deteksi, pelaporan, dan eskalasi insiden. Hal tersebut mendukung kemampuan organisasi dalam melakukan respons dan pemulihan secara lebih efektif, sebagaimana ditekankan dalam NIST SP 800-61 Rev. 3 (Nelson et al., 2025).

7.6 Peran Administrator Sistem

Administrator sistem merupakan personel yang memiliki tanggung jawab teknis dalam mengelola, memelihara, dan mengamankan sistem informasi serta infrastruktur yang berada dalam kewenangannya.

Administrator dapat bertanggung jawab terhadap server, sistem operasi, layanan jaringan, penyimpanan, akun pengguna, konfigurasi keamanan, logging, backup, monitoring, dan berbagai komponen teknis lainnya sesuai dengan pembagian tugas organisasi.

Karena memiliki hak akses yang tinggi, akun administrator merupakan salah satu aset yang harus mendapatkan perlindungan khusus. Penyalahgunaan akun administrator dapat memberikan dampak yang jauh lebih besar dibandingkan kompromi akun pengguna biasa.

NIST SP 800-53 Rev. 5 menempatkan berbagai aspek yang relevan dengan pekerjaan administrator dalam kelompok kontrol

seperti Access Control, Audit and Accountability, Configuration Management, Identification and Authentication, Incident Response, Maintenance, serta System and Information Integrity. (Joint Task Force, 2020).

Prinsip sederhananya:

Administrator memiliki kewenangan tinggi, sehingga harus menerapkan pengamanan yang lebih tinggi pula.

Mengelola Sistem Sesuai Kewenangan

Administrator hanya boleh melakukan tindakan teknis sesuai dengan kewenangan yang diberikan organisasi.

Kewenangan tersebut dapat mencakup:

- Mengelola server.
- Mengelola sistem operasi.
- Mengelola layanan jaringan.
- Mengelola akun pengguna.
- Mengelola konfigurasi.
- Mengelola backup.
- Mengelola logging.
- Melakukan monitoring.
- Melakukan patching.
- Menangani gangguan teknis.
- Melakukan tindakan awal ketika terjadi insiden.

Batas kewenangan harus ditentukan dengan jelas agar administrator tidak memiliki akses yang tidak diperlukan.

Prinsip yang digunakan adalah **least privilege**:

Berikan hak akses secukupnya untuk menjalankan tugas, bukan sebanyak-banyaknya karena secara teknis memungkinkan.

Melindungi Akun Administrator

Akun administrator merupakan akun bernilai tinggi.

Jika akun tersebut berhasil diambil alih, penyerang dapat memperoleh kemampuan untuk:

- Mengubah konfigurasi.
- Membuat akun baru.
- Mengubah hak akses.
- Mengakses data.
- Memasang malware.
- Menghapus log.
- Menghentikan layanan.
- Mengubah sistem keamanan.
- Mengganggu operasional organisasi.

Karena itu, administrator harus memberikan perhatian khusus terhadap keamanan akun.

Praktik yang perlu diterapkan antara lain:

- Menggunakan password yang kuat dan unik.
- Menggunakan MFA apabila tersedia.
- Tidak membagikan password.

- Tidak memberikan OTP.
- Tidak menggunakan akun administrator untuk aktivitas sehari-hari yang tidak membutuhkan hak administrator.
- Tidak menggunakan akun administrator pada perangkat yang tidak terpercaya.
- Segera melaporkan dugaan kompromi akun.
- **Memisahkan Akun Administrator dan Akun Harian**

Administrator sebaiknya menggunakan akun dengan hak akses administratif hanya ketika memang diperlukan.

Contohnya:

Akun Administrator

- Instalasi
- Konfigurasi
- Maintenance
- Administrasi sistem

Sedangkan aktivitas sehari-hari seperti:

- Membaca email.
- Browsing.
- Membuka dokumen.
- Komunikasi.

sebaiknya dilakukan menggunakan akun dengan hak akses yang lebih rendah.

Tujuannya adalah mengurangi dampak apabila perangkat administrator terkena malware atau administrator tidak sengaja berinteraksi dengan konten berbahaya.

Mengelola Hak Akses Pengguna

Administrator bertanggung jawab terhadap pengelolaan akun dan hak akses apabila fungsi tersebut berada dalam kewenangannya.

Hal yang perlu diperhatikan:

- Akun dibuat berdasarkan kebutuhan.
- Hak akses sesuai tugas.
- Akun yang tidak lagi diperlukan dinonaktifkan.
- Hak akses ditinjau secara berkala.
- Akun istimewa dibatasi.
- Aktivitas administratif dicatat.

Prosesnya dapat digambarkan:

Permintaan Akses

↓

Verifikasi Kewenangan

↓

Penentuan Hak Akses

↓

Pemberian Akses

↓

Monitoring

↓

Review Berkala

↓

Pencabutan Jika Tidak Diperlukan

Administrator tidak boleh memberikan akses hanya karena

pengguna memintanya.

Melakukan Patching

Sistem yang tidak diperbarui dapat memiliki kerentanan yang diketahui dan dapat dimanfaatkan penyerang.

Administrator perlu menjalankan proses patch management sesuai kebijakan organisasi.

Patching dapat mencakup:

- Sistem operasi.
- Web server.
- Database.
- Aplikasi pendukung.
- Perangkat keamanan.
- Komponen sistem lainnya.

Namun, patching tidak boleh dilakukan secara sembarangan pada sistem produksi.

Sebelum melakukan perubahan, administrator perlu mempertimbangkan:

- Dampak terhadap layanan.
- Kompatibilitas.
- Backup.
- Jadwal maintenance.
- Prosedur rollback.
- Pengujian.

Prinsipnya:

Patch sistem secara terencana, bukan menunggu sampai sistem terkena serangan.

Bagian Eradication dalam buku juga menempatkan patching sebagai salah satu tindakan untuk menangani celah keamanan setelah insiden.

Mengelola Konfigurasi Sistem

Konfigurasi yang tidak aman dapat menjadi sumber risiko.

Administrator perlu memperhatikan:

- Service yang aktif.
- Port yang terbuka.
- Akun pengguna.
- Hak akses file.
- Konfigurasi autentikasi.
- Konfigurasi jaringan.
- Konfigurasi logging.
- Konfigurasi keamanan.
- Komponen yang tidak diperlukan.

Prinsipnya:

Jika sebuah layanan tidak diperlukan, pertimbangkan untuk menonaktifkannya sesuai prosedur.

Administrator juga perlu mendokumentasikan perubahan konfigurasi penting agar kondisi sistem dapat diketahui dan dipulihkan apabila terjadi masalah.

Menerapkan Secure Configuration

Sistem sebaiknya tidak hanya dibuat agar berfungsi, tetapi juga dikonfigurasi dengan mempertimbangkan keamanan.

Contohnya:

- Menonaktifkan layanan yang tidak diperlukan.
- Membatasi akses administratif.
- Menggunakan protokol yang aman.
- Membatasi akses jaringan.
- Mengatur permission secara tepat.
- Mengaktifkan logging.
- Mengaktifkan mekanisme autentikasi yang sesuai.
- Menghindari konfigurasi default yang tidak aman.

Konfigurasi keamanan harus mempertimbangkan fungsi bisnis agar pengamanan tidak menyebabkan layanan menjadi tidak dapat digunakan.

Mengelola Logging

Log merupakan sumber informasi penting untuk monitoring, troubleshooting, audit, dan investigasi insiden.

Administrator perlu memastikan log penting tersedia dan dapat digunakan.

Contohnya:

- Login.
- Logout.

- Login gagal.
- Perubahan konfigurasi.
- Aktivitas administrator.
- Perubahan akun.
- Aktivitas layanan.
- Error sistem.
- Aktivitas keamanan.

Administrator juga perlu memperhatikan:

- Retensi log.
- Akses terhadap log.
- Sinkronisasi waktu.
- Perlindungan log dari perubahan atau penghapusan tidak sah.

Log yang tersedia tetapi tidak pernah diperiksa belum tentu memberikan manfaat keamanan yang optimal.

Melakukan Monitoring

Administrator perlu memantau kondisi sistem secara berkala.

Monitoring dapat mencakup:

- CPU.
- Memory.
- Disk.
- Network.

- Service.
- Login.
- Error.
- Resource utilization.
- Aktivitas akun.
- Alert keamanan.

Selain memantau ketersediaan layanan, administrator juga perlu memperhatikan **perubahan perilaku yang tidak biasa**.

Contohnya:

- Login administrator pada waktu tidak biasa.
- Banyak login gagal.
- Penggunaan resource meningkat secara tiba-tiba.
- Banyak file berubah.
- Service berhenti tanpa alasan.
- Koneksi jaringan tidak biasa.
- Muncul proses yang tidak dikenal.

Aktivitas tersebut tidak selalu berarti serangan, tetapi dapat menjadi indikator yang perlu diperiksa.

Menjaga Backup

Administrator memiliki peran penting dalam memastikan backup berjalan sesuai kebijakan organisasi apabila pengelolaan backup berada dalam kewenangannya.

Hal yang perlu diperhatikan:

- Backup berjalan sesuai jadwal.
- Backup berhasil.
- Backup terlindungi.
- Backup tidak mudah dihapus oleh akun yang sama dengan sistem produksi.
- Backup memiliki retensi yang sesuai.
- Restore dapat dilakukan.
- Prosedur pemulihan tersedia.

Backup yang hanya "berhasil dibuat" belum cukup.

Administrator perlu memastikan bahwa backup **dapat digunakan ketika dibutuhkan**.

Bagian Incident Response dalam buku juga menekankan bahwa organisasi perlu memastikan backup berjalan, berhasil dibuat, dilindungi dari akses tidak sah, dan dapat dipulihkan.

Melakukan Restore Test

Administrator perlu melakukan pengujian restore sesuai jadwal dan prosedur organisasi.

Contohnya:

Backup

↓

Restore Test

↓

Verifikasi Data



Verifikasi Aplikasi



Dokumentasi Hasil

Restore test membantu menjawab pertanyaan penting:

Apakah backup yang kita miliki benar-benar dapat digunakan ketika sistem mengalami masalah?

Hasil pengujian perlu dicatat agar organisasi mengetahui apakah proses pemulihan berjalan sesuai kebutuhan.

Menjaga Sinkronisasi Waktu

Waktu yang tidak konsisten antarserver dapat menyulitkan analisis log.

Administrator perlu memastikan sistem yang membutuhkan sinkronisasi waktu menggunakan mekanisme yang sesuai dengan standar dan kebijakan organisasi.

Hal ini penting terutama ketika melakukan investigasi.

Contohnya:

Server A: 10.15.20

Server B: 10.12.05

Firewall: 10.17.30

Jika ketiganya mencatat kejadian yang sama dengan waktu berbeda, penyusunan kronologi insiden dapat menjadi lebih sulit.

Karena itu, sinkronisasi waktu merupakan bagian penting dari pengelolaan sistem dan logging.

Mengelola Perubahan Sistem

Administrator sering melakukan perubahan terhadap sistem.

Contohnya:

- Update.
- Instalasi aplikasi.
- Perubahan konfigurasi.
- Perubahan firewall.
- Perubahan hak akses.
- Penambahan service.
- Perubahan storage.
- Perubahan jaringan.

Perubahan penting sebaiknya:

1. Memiliki alasan.
2. Memiliki persetujuan sesuai prosedur.
3. Didokumentasikan.
4. Mempertimbangkan risiko.
5. Diuji jika diperlukan.
6. Memiliki rencana rollback apabila diperlukan.

Tujuannya agar perubahan tidak menjadi sumber masalah baru.

Tidak Menggunakan Akun Administrator untuk Berbagi

Administrator tidak boleh menggunakan akun administratif sebagai akun bersama hanya karena dianggap lebih praktis.

Contohnya:

administrator digunakan oleh lima orang.

Jika terjadi perubahan konfigurasi, organisasi akan kesulitan mengetahui siapa yang melakukan perubahan.

Lebih baik setiap administrator memiliki identitas masing-masing sesuai kebijakan organisasi.

Dengan demikian, aktivitas dapat ditelusuri.

Menjaga Audit Trail

Aktivitas administratif sebaiknya dapat ditelusuri.

Contohnya:

- Siapa yang login.
- Kapan login dilakukan.
- Sistem yang diakses.
- Perubahan apa yang dilakukan.
- Konfigurasi apa yang diubah.
- Akun apa yang dibuat.
- Hak akses apa yang diubah.

Audit trail membantu organisasi melakukan:

- Investigasi.
- Audit.
- Troubleshooting.
- Evaluasi.

- Penelusuran perubahan.

Tidak Menghapus Log Secara Sembarangan

Ketika terjadi masalah, administrator mungkin perlu membersihkan log berdasarkan kebijakan retensi.

Namun, penghapusan log secara sembarangan dapat menghilangkan informasi penting.

Lebih berbahaya lagi apabila log dihapus untuk menyembunyikan aktivitas.

Administrator harus mengikuti kebijakan retensi dan pengelolaan log organisasi.

Jika terjadi insiden, log yang relevan perlu dipertahankan sesuai prosedur.

Menangani Insiden Sesuai Prosedur

Administrator merupakan salah satu pihak penting dalam Incident Response.

Ketika menemukan indikasi serangan, administrator dapat menjalankan tindakan sesuai kewenangan, seperti:

- Memeriksa log.
- Mengidentifikasi sistem terdampak.
- Membatasi akses.
- Mengisolasi sistem.
- Mengamankan akun.
- Mengumpulkan informasi.
- Melakukan eradication sesuai prosedur.

- Membantu recovery.

Namun administrator tidak boleh melakukan tindakan secara sembarangan hanya karena memiliki akses teknis.

Tindakan Incident Response harus mengikuti prosedur organisasi.

NIST SP 800-61 Rev. 3 menempatkan Incident Response sebagai bagian dari pengelolaan risiko keamanan siber dan menekankan integrasi aktivitas respons ke dalam kegiatan organisasi (Nelson et al., 2025).

Containment Saat Terjadi Insiden

Jika administrator menemukan sistem yang diduga telah terkompromi, salah satu tindakan yang mungkin dilakukan adalah containment.

Contohnya:

Indikasi Serangan

↓

Verifikasi Awal

↓

Identifikasi Sistem Terdampak

↓

Containment

↓

Investigasi

↓

Eradication

↓

Recovery

Bentuk containment dapat berbeda berdasarkan jenis sistem dan prosedur organisasi.

Contohnya:

- Memutus koneksi jaringan.
- Membatasi akses.
- Menonaktifkan akun.
- Memblokir alamat atau koneksi tertentu.
- Mengisolasi endpoint.

Administrator harus mempertimbangkan dampak tindakan tersebut terhadap layanan.

Tidak Mengubah Bukti Secara Sembarangan

Ketika melakukan investigasi, administrator perlu berhati-hati agar tindakan yang dilakukan tidak menghilangkan informasi penting.

Contohnya:

- Jangan langsung menghapus file mencurigakan.
- Jangan langsung menghapus akun mencurigakan tanpa dokumentasi.
- Jangan menghapus log.
- Jangan melakukan reboot tanpa mempertimbangkan kebutuhan investigasi.
- Jangan mengubah sistem tanpa mencatat tindakan.

Jika organisasi memiliki prosedur forensik atau incident handling, ikuti prosedur tersebut.

Menjaga Keamanan Sistem Setelah Recovery

Setelah sistem dipulihkan, administrator tetap memiliki tanggung jawab untuk memastikan sistem berada dalam kondisi aman.

Pemeriksaan dapat mencakup:

- Patch.
- Konfigurasi.
- Akun.
- Hak akses.
- Malware.
- Logging.
- Monitoring.
- Backup.
- Integritas file.
- Service yang berjalan.

Recovery bukan berarti pekerjaan administrator selesai.

Sistem perlu dipantau setelah layanan kembali aktif untuk memastikan tidak terjadi kompromi ulang.

Mengikuti Security Awareness

Administrator juga membutuhkan security awareness.

Walaupun memiliki kemampuan teknis, administrator tetap dapat menjadi target:

- Phishing.
- Credential theft.
- Social engineering.
- Malware.
- Exploit.
- Serangan terhadap akun privileged.

Karena itu, administrator perlu mengikuti pelatihan yang sesuai dengan tingkat tanggung jawabnya.

Program pembelajaran keamanan yang baik seharusnya disesuaikan dengan peran dan kebutuhan personel, bukan memberikan materi yang sama kepada seluruh orang. Pendekatan ini sejalan dengan NIST SP 800-50 Rev. 1 yang menekankan program pembelajaran keamanan dan privasi yang berkelanjutan serta perubahan perilaku organisasi. (Merritt et al., 2024).

Administrator sebagai Lapisan Pertahanan

Administrator dapat menjadi salah satu lapisan pertahanan teknis organisasi.

Contohnya:

User

↓

Helpdesk

↓

Operator

↓

Administrator

↓

Monitoring

↓

Security Team

↓

Incident Response

Administrator dapat menerima informasi dari pengguna dan helpdesk, melakukan pemeriksaan teknis, kemudian meneruskan temuan kepada tim keamanan atau manajemen sesuai kebutuhan.

Karena itu, komunikasi antara administrator, helpdesk, operator, dan pengguna harus berjalan dengan baik.

Contoh Kasus: Akun Administrator Diduga Terkompromi

Administrator menerima notifikasi login yang tidak dikenali pada akun administratif.

Tindakan yang tepat bukan mengabaikannya.

Alurnya:

Login Tidak Dikenal

↓

Verifikasi Aktivitas

↓

Amankan Akun

↓

Periksa Log

↓

Identifikasi Aktivitas

↓

Periksa Sistem Terdampak

↓

Containment Jika Diperlukan

↓

Incident Response

Tindakan detail harus mengikuti prosedur organisasi.

Contoh Kasus: Server Menunjukkan Aktivitas Tidak Normal

Administrator menemukan:

- CPU meningkat tiba-tiba.
- Terdapat proses tidak dikenal.
- Banyak koneksi keluar.
- File aplikasi berubah.

Administrator tidak seharusnya langsung menghapus proses atau file tanpa mempertimbangkan kebutuhan investigasi.

Pendekatan yang lebih tepat:

Anomali Ditemukan

↓

Catat Kondisi

↓

Periksa Log

↓

Identifikasi Sistem Terdampak

↓

Containment

↓

Investigasi

↓

Eradication

↓

Recovery

Dengan pendekatan tersebut, tindakan teknis tetap terarah dan dapat dipertanggungjawabkan.

Contoh Kasus: Patch Keamanan

Administrator menerima informasi bahwa terdapat patch keamanan penting untuk sistem yang dikelolanya.

Administrator tidak seharusnya hanya mengabaikannya karena sistem masih berjalan normal.

Proses yang baik:

Patch Tersedia

↓

Evaluasi Risiko

↓

Backup

↓

Pengujian

↓

Maintenance

↓

Patching

↓

Verifikasi

↓

Monitoring

Pendekatan ini membantu mengurangi risiko bahwa proses patching justru mengganggu layanan.

Checklist Peran Administrator Sistem

No.	Tanggung Jawab	Status
1	Melindungi akun administrator	☐
2	Menggunakan MFA apabila tersedia	☐
3	Menerapkan least privilege	☐
4	Mengelola akun sesuai kewenangan	☐
5	Melakukan patch management	☐
6	Mengelola konfigurasi sistem	☐
7	Mengaktifkan dan menjaga logging	☐
8	Melakukan monitoring	☐
9	Memastikan backup berjalan	☐
10	Melakukan restore test	☐
11	Menjaga audit trail	☐
12	Mendokumentasikan perubahan sistem	☐
13	Menangani insiden sesuai prosedur	☐
14	Menjaga bukti yang relevan saat insiden	☐
15	Memantau sistem setelah recovery	☐
16	Mengikuti security awareness	☐

Kesimpulan

Administrator sistem memiliki tanggung jawab besar dalam menjaga keamanan teknis sistem informasi organisasi. Hak akses yang tinggi memberikan kemampuan untuk melakukan perubahan penting, tetapi pada saat yang sama juga meningkatkan risiko apabila akun atau kewenangan tersebut disalahgunakan.

Tanggung jawab administrator dapat diringkas menjadi:

**Lindungi Akun → Batasi Akses → Amankan Konfigurasi → Patch
→ Monitor → Backup → Dokumentasikan → Respons Insiden**

Prinsip sederhananya:

Semakin tinggi hak akses, semakin besar tanggung jawab untuk menjaga keamanan.

Administrator yang baik bukan hanya memastikan sistem dapat berjalan, tetapi juga memastikan sistem berjalan dalam kondisi yang aman, terpantau, terdokumentasi, dan dapat dipulihkan ketika terjadi masalah.

Administrator juga merupakan bagian dari rantai Incident Response. Ketika terjadi insiden, administrator harus mampu menjalankan tindakan teknis sesuai kewenangan dan prosedur organisasi, termasuk membantu proses containment, eradication, dan recovery. Pendekatan tersebut sejalan dengan NIST SP 800-61 Rev. 3 yang menempatkan kemampuan deteksi, respons, dan pemulihan sebagai bagian dari pengelolaan risiko keamanan siber organisasi. (Nelson et al., 2025).

7.7 Komitmen Membangun Budaya Cyber Security

Keamanan siber tidak cukup hanya dibangun melalui teknologi, kebijakan, atau prosedur. Organisasi juga membutuhkan **budaya keamanan** yang membuat setiap orang terbiasa mengambil keputusan dengan mempertimbangkan aspek keamanan.

Budaya keamanan siber terbentuk ketika perilaku aman menjadi bagian dari kebiasaan sehari-hari, bukan hanya dilakukan ketika ada pemeriksaan, pelatihan, atau ketika organisasi sedang mengalami serangan.

NIST SP 800-50 Rev. 1 menempatkan perubahan perilaku sebagai salah satu tujuan penting dari program pembelajaran keamanan dan privasi. Program tersebut diharapkan dapat mendukung terbentuknya budaya keamanan dan privasi di dalam organisasi serta dilakukan secara berkelanjutan melalui evaluasi dan perbaikan. (Merritt et al., 2024).

Prinsip sederhananya:

Budaya keamanan bukan sekadar mengetahui aturan, tetapi membiasakan diri menjalankan aturan tersebut.

Dari Awareness Menjadi Budaya

Security awareness biasanya dimulai dari pengetahuan.

Seseorang diberi tahu:

- Apa itu phishing.
- Mengapa password harus dijaga.
- Mengapa MFA penting.

- Mengapa data tidak boleh dibagikan sembarangan.
- Bagaimana melaporkan insiden.

Namun, pengetahuan saja belum cukup.

Prosesnya harus berkembang menjadi:

Pengetahuan

↓

Kesadaran

↓

Pemahaman Risiko

↓

Perubahan Perilaku

↓

Kebiasaan Aman

↓

Budaya Keamanan

Jika seseorang sudah mengetahui bahwa OTP tidak boleh diberikan tetapi tetap memberikan OTP ketika diminta oleh penyerang, maka pengetahuan tersebut belum berubah menjadi perilaku aman.

Karena itu, tujuan security awareness bukan hanya membuat orang **tahu**, tetapi membuat mereka **bertindak dengan benar**.

Komitmen Harus Dimulai dari Pimpinan

Budaya keamanan membutuhkan dukungan pimpinan.

Pimpinan perlu menunjukkan bahwa keamanan siber merupakan bagian dari tanggung jawab organisasi, bukan hanya urusan teknis.

Komitmen tersebut dapat diwujudkan melalui:

- Kebijakan keamanan yang jelas.
- Penyediaan sumber daya.
- Dukungan terhadap pelatihan.
- Penetapan tanggung jawab.
- Dukungan terhadap pelaporan insiden.
- Evaluasi keamanan secara berkala.
- Pemberian contoh perilaku yang aman.

NIST CSF 2.0 menempatkan **Govern** sebagai salah satu fungsi utama dalam pengelolaan risiko keamanan siber. Fungsi ini menempatkan strategi, kebijakan, peran, tanggung jawab, dan pengawasan sebagai bagian dari tata kelola risiko siber organisasi. (Pascoe et al., 2024).

Dengan demikian, budaya keamanan tidak dapat hanya dibebankan kepada pegawai di tingkat operasional.

Pimpinan Harus Memberikan Contoh

Perilaku pimpinan akan memengaruhi perilaku organisasi.

Jika pimpinan:

- Menggunakan akun secara aman.
- Tidak meminta password bawahannya.
- Tidak meminta OTP.
- Mengikuti prosedur keamanan.
- Menggunakan kanal resmi.

- Mendukung pelaporan insiden.

maka pesan keamanan menjadi lebih kuat.

Sebaliknya, apabila pimpinan sendiri sering meminta pegawai melewati prosedur keamanan dengan alasan "karena saya pimpinan", maka organisasi dapat membentuk budaya yang salah.

Prinsipnya:

Aturan keamanan berlaku untuk semua orang, termasuk pimpinan.

Kebijakan Harus Didukung Perilaku

Organisasi mungkin memiliki kebijakan keamanan yang lengkap.

Namun, kebijakan tidak akan efektif apabila hanya menjadi dokumen.

Contohnya:

Kebijakan:

Password tidak boleh dibagikan.

Budaya yang salah:

"Kalau sedang sibuk, pinjam saja akun teman."

Atau:

Kebijakan:

Insiden harus segera dilaporkan.

Budaya yang salah:

"Jangan dilaporkan dulu, nanti kita dimarahi."

Karena itu, organisasi perlu memastikan bahwa kebijakan

diterjemahkan menjadi prosedur dan kebiasaan yang dapat diterapkan dalam pekerjaan sehari-hari.

Membangun Budaya Tidak Menyalahkan

Salah satu bagian penting dari budaya keamanan adalah menciptakan lingkungan yang mendorong orang untuk melaporkan kejadian.

Kesalahan dapat terjadi.

Misalnya:

Seorang pegawai tidak sengaja mengklik tautan phishing.

Organisasi memiliki dua pilihan.

Pendekatan Pertama

Pegawai takut →

Tidak melapor →

Akun tidak segera diamankan →

Penyerang melanjutkan aktivitas.

Pendekatan Kedua

Pegawai segera melapor →

Akun diamankan →

Pemeriksaan dilakukan →

Dampak dapat dibatasi.

Pendekatan kedua lebih mendukung keamanan.

Ini bukan berarti organisasi mengabaikan kesalahan. Evaluasi tetap diperlukan. Namun, prioritas pertama ketika terjadi insiden adalah **membatasi dampak dan memperbaiki kondisi**, bukan membuat orang takut untuk melapor.

Pelaporan Harus Dihargai

Pegawai yang melaporkan kejadian mencurigakan telah memberikan informasi penting kepada organisasi.

Contohnya:

"Saya menerima email yang meminta OTP."

"Saya mendapatkan notifikasi login yang tidak saya lakukan."

"Saya tidak sengaja membuka link tersebut."

"Laptop saya hilang."

Laporan seperti itu seharusnya dipandang sebagai bagian dari mekanisme pertahanan organisasi.

Semakin cepat laporan diterima, semakin cepat organisasi dapat menentukan tindakan.

Karena itu, organisasi perlu menyediakan mekanisme pelaporan yang:

- Mudah ditemukan.
- Mudah digunakan.
- Cepat.
- Jelas.
- Memiliki jalur eskalasi.
- Dapat digunakan tanpa rasa takut.

Security Awareness Harus Berkelanjutan

Security awareness tidak seharusnya dilakukan hanya satu kali dalam setahun.

Ancaman berubah.

Teknologi berubah.

Aplikasi berubah.

Cara bekerja berubah.

Karena itu, materi awareness juga harus diperbarui.

NIST SP 800-50 Rev. 1 menggunakan pendekatan *life cycle* untuk program pembelajaran keamanan dan privasi sehingga program dapat dievaluasi dan diperbaiki secara berulang sesuai kebutuhan organisasi dan perubahan risiko. (Merritt et al., 2024).

Contoh kegiatan berkelanjutan:

- Pelatihan keamanan.
- Sosialisasi phishing.
- Simulasi phishing.
- Kuis keamanan.
- Poster atau pengingat keamanan.
- Simulasi pelaporan insiden.
- Edukasi MFA.
- Edukasi keamanan perangkat.
- Evaluasi hasil pelatihan.

Tujuannya bukan membuat pegawai mengikuti banyak pelatihan, tetapi membentuk kebiasaan aman.

Materi Harus Sesuai Peran

Tidak semua orang membutuhkan materi keamanan yang

sama.

Pengguna biasa membutuhkan pemahaman seperti:

- Phishing.
- Password.
- MFA.
- Email.
- Data pribadi.
- Pelaporan insiden.

Operator aplikasi membutuhkan tambahan pemahaman:

- Hak akses.
- Integritas data.
- Pengelolaan akun.
- Social engineering.
- Pelaporan perubahan data.

Helpdesk membutuhkan pemahaman:

- Klasifikasi laporan.
- Verifikasi identitas.
- Eskalasi.
- Dokumentasi.
- Penanganan informasi sensitif.

Administrator membutuhkan pemahaman lebih lanjut:

- Privileged account.

- Logging.
- Monitoring.
- Patch management.
- Backup.
- Incident Response.
- Secure configuration.

Pendekatan ini sejalan dengan NIST SP 800-50 Rev. 1 yang menekankan program pembelajaran untuk berbagai kelompok personel dan kebutuhan yang berbeda.

Keamanan Harus Menjadi Bagian dari Pekerjaan

Budaya keamanan akan lebih kuat apabila keamanan dimasukkan ke dalam proses kerja.

Contohnya:

Mengirim Email

→ Periksa penerima dan lampiran.

Mengakses Sistem

→ Gunakan akun sendiri.

Mengelola Data

→ Gunakan sesuai kewenangan.

Mengubah Sistem

→ Ikuti prosedur perubahan.

Menerima Pesan Mencurigakan

→ Jangan klik dan laporkan.

Menemukan Insiden

→ Segera laporkan.

Dengan demikian, keamanan tidak dianggap sebagai pekerjaan tambahan.

Keamanan menjadi bagian dari cara organisasi bekerja.

Jangan Mengandalkan Teknologi Saja

Organisasi dapat memiliki:

- Firewall.
- WAF.
- EDR.
- Antivirus.
- SIEM.
- IDS/IPS.
- Backup.
- MFA.

Namun, tidak ada teknologi yang dapat sepenuhnya menggantikan manusia.

Contohnya:

Email Security gagal mendeteksi phishing

↓

Pengguna mengenali phishing

↓

Tidak mengklik

↓

Melaporkan



Serangan dihentikan

Dalam contoh tersebut, manusia menjadi bagian dari pertahanan.

Sebaliknya:

Email Security gagal mendeteksi phishing



Pengguna mengklik



Kredensial dicuri



Akun dikompromikan

Karena itu, keamanan organisasi membutuhkan kombinasi:

People + Process + Technology

Membangun Kebiasaan Aman

Budaya keamanan dapat dibangun dari kebiasaan sederhana.

Contohnya:

- Berhenti sebelum mengklik.
- Periksa pengirim.
- Periksa alamat website.
- Jangan memberikan OTP.
- Gunakan MFA.
- Kunci komputer.

- Gunakan akun sendiri.
- Jangan menyimpan data secara sembarangan.
- Laporkan kejadian mencurigakan.

Kebiasaan tersebut terlihat sederhana.

Namun apabila dilakukan oleh seluruh anggota organisasi secara konsisten, dampaknya dapat menjadi besar.

Mengukur Efektivitas Budaya Keamanan

Organisasi perlu mengetahui apakah program awareness benar-benar memberikan hasil.

Pengukuran tidak harus hanya berupa jumlah peserta pelatihan.

Beberapa indikator yang dapat digunakan:

Indikator	Contoh Pengukuran
Partisipasi	Persentase pegawai mengikuti pelatihan
Pengetahuan	Nilai evaluasi setelah pelatihan
Perilaku	Hasil simulasi phishing
Pelaporan	Jumlah laporan kejadian mencurigakan
Respons	Waktu dari kejadian sampai laporan
Kepatuhan	Persentase kepatuhan terhadap kebijakan
Perbaikan	Perubahan hasil dari waktu ke waktu

NIST SP 800-50 Rev. 1 juga memasukkan **metrics dan evaluation methods** sebagai bagian dari pengelolaan program

pembelajaran agar program dapat diperbaiki berdasarkan hasil pengukuran.

Jangan Mengukur dengan Jumlah Pelatihan Saja

Contohnya:

"100% pegawai sudah mengikuti pelatihan keamanan."

Angka tersebut belum membuktikan bahwa budaya keamanan sudah terbentuk.

Pertanyaan yang lebih penting:

- Apakah pegawai mampu mengenali phishing?
- Apakah pegawai tahu cara melapor?
- Apakah pegawai tidak memberikan OTP?
- Apakah pegawai menggunakan MFA?
- Apakah waktu pelaporan semakin cepat?
- Apakah jumlah kesalahan berulang menurun?

Dengan demikian, organisasi perlu mengukur **perubahan perilaku**, bukan hanya jumlah kegiatan.

Evaluasi dan Perbaikan

Program awareness harus dievaluasi secara berkala.

Contohnya:

Pelatihan

↓

Evaluasi

↓

Pengukuran

↓

Identifikasi Kelemahan

↓

Perbaiki Materi

↓

Pelatihan Berikutnya

Jika simulasi phishing menunjukkan banyak pegawai masih tertipu, organisasi tidak seharusnya hanya menyimpulkan bahwa pegawai "tidak paham".

Organisasi perlu mengevaluasi:

- Apakah materi terlalu sulit?
- Apakah contoh terlalu berbeda dari kondisi nyata?
- Apakah pelaporan mudah dilakukan?
- Apakah pegawai memahami indikator phishing?
- Apakah pelatihan terlalu jarang?

Pendekatan seperti ini menjadikan security awareness sebagai proses peningkatan berkelanjutan.

Budaya Keamanan dalam Kondisi Insiden

Budaya keamanan paling terlihat ketika terjadi masalah.

Organisasi dengan budaya yang baik akan cenderung:

Menemukan → Melaporkan → Merespons → Memulihkan →

Belajar

Bukan:

Menemukan → Menyembunyikan → Menunggu → Dampak Membesar

Karena itu, keberhasilan budaya keamanan tidak hanya terlihat ketika semuanya berjalan normal.

Budaya keamanan terlihat dari bagaimana organisasi bereaksi ketika terjadi kesalahan atau insiden.

Semua Peran Saling Terhubung

Pembahasan BAB 7 telah menunjukkan bahwa keamanan bukan tanggung jawab satu kelompok.

Hubungannya dapat digambarkan:

Pimpinan

↓

ASN & Pegawai Non ASN

↓

Operator Aplikasi

↓

Helpdesk

↓

Administrator Sistem

↓

Tim Keamanan / Manajemen

↓

Organisasi

Masing-masing memiliki tanggung jawab berbeda.

Namun semuanya memiliki tujuan yang sama:

Melindungi informasi, sistem, layanan, dan organisasi.

Komitmen Bersama

Komitmen membangun budaya keamanan dapat diwujudkan melalui beberapa prinsip:

1. **Keamanan menjadi bagian dari pekerjaan.**
2. **Setiap orang memahami perannya.**
3. **Hak akses digunakan sesuai kewenangan.**
4. **Kesalahan dilaporkan dengan cepat.**
5. **Informasi dilindungi sesuai kebutuhan.**
6. **Pelatihan dilakukan secara berkelanjutan.**
7. **Perilaku keamanan dievaluasi.**
8. **Kebijakan diperbaiki ketika diperlukan.**
9. **Pimpinan memberikan contoh.**
10. **Organisasi belajar dari setiap insiden.**

Checklist Komitmen Budaya Cyber Security

No.	Komitmen	Status
1	Pimpinan mendukung keamanan siber	☐
2	Kebijakan keamanan tersedia	☐
3	Peran dan tanggung jawab ditetapkan	☐
4	Mekanisme pelaporan tersedia	☐

5	Security awareness dilakukan berkala	☐
6	Materi disesuaikan dengan peran	☐
7	Simulasi atau latihan dilakukan	☐
8	Perilaku keamanan dievaluasi	☐
9	Insiden digunakan sebagai bahan pembelajaran	☐
10	Program awareness diperbaiki secara berkala	☐

Kesimpulan

Membangun budaya cyber security membutuhkan komitmen jangka panjang dari seluruh organisasi.

Budaya keamanan tidak terbentuk hanya karena organisasi memiliki kebijakan, membeli perangkat keamanan, atau menyelenggarakan pelatihan.

Budaya terbentuk ketika setiap orang:

Tahu → Peduli → Terbiasa → Bertindak Aman

Pimpinan memberikan arah.

Pegawai menjalankan perilaku aman.

Operator menjaga aplikasi dan data.

Helpdesk menerima dan meneruskan laporan.

Administrator menjaga sistem.

Tim keamanan melakukan pemantauan dan respons.

Semua bagian tersebut saling melengkapi.

NIST SP 800-50 Rev. 1 menekankan bahwa program

pembelajaran keamanan dan privasi harus dipandang sebagai program yang berkelanjutan, dapat dievaluasi, dan diarahkan pada perubahan perilaku serta pembentukan budaya keamanan organisasi. (Merritt et al., 2024).

Prinsip akhirnya adalah:

Teknologi dapat membantu melindungi organisasi, tetapi budaya keamanan menentukan bagaimana teknologi, manusia, dan proses tersebut digunakan.

Organisasi yang memiliki budaya keamanan yang baik bukan berarti organisasi yang tidak pernah mengalami insiden. Organisasi yang matang adalah organisasi yang mampu **mencegah, mengenali, melaporkan, merespons, memulihkan, dan belajar dari insiden secara terus-menerus.**

Dengan komitmen bersama tersebut, cyber security tidak lagi dipandang sebagai pekerjaan satu unit, tetapi menjadi bagian dari **budaya organisasi dan tanggung jawab setiap orang.**

7.8 Ringkasan Buku

Buku **Panduan Praktis Cyber Security Awareness: Melindungi Data, Sistem, dan Layanan Digital dari Ancaman Siber** disusun untuk membantu seluruh pengguna teknologi informasi memahami pentingnya keamanan siber dan menerapkan perilaku yang aman dalam aktivitas sehari-hari.

Buku ini tidak dimaksudkan sebagai manual konfigurasi teknis, standar operasional prosedur (SOP), atau panduan implementasi teknologi keamanan tertentu. Fokus utamanya adalah meningkatkan **kesadaran, pemahaman, dan perilaku keamanan** pengguna dalam melindungi informasi, sistem,

perangkat, dan layanan digital organisasi.

Pembahasan dimulai dari pengenalan terhadap ancaman siber, dilanjutkan dengan pemahaman penyebab insiden, konsep pertahanan siber, praktik menjadi pengguna yang aman, penanganan insiden, hingga pembentukan budaya keamanan siber.

Secara keseluruhan, pesan utama buku ini dapat dirangkum:

Keamanan siber bukan hanya tentang teknologi. Keamanan siber adalah kombinasi manusia, proses, teknologi, dan budaya.

BAB 1 – Pendahuluan

BAB 1 menjelaskan mengapa keamanan siber menjadi semakin penting seiring meningkatnya penggunaan teknologi informasi dan layanan digital.

Transformasi digital memberikan banyak manfaat bagi organisasi, tetapi pada saat yang sama meningkatkan ketergantungan terhadap sistem, aplikasi, jaringan, perangkat, dan data.

Semakin banyak aset digital yang digunakan, semakin besar pula kemungkinan munculnya risiko keamanan.

Buku ini memperkenalkan berbagai ancaman seperti:

- Phishing.
- Ransomware.
- Malware.
- Credential attack.

- DDoS.
- Eksploitasi aplikasi web.
- Business Email Compromise (BEC).
- Supply chain attack.

Pembahasan dilakukan secara konseptual agar dapat dipahami oleh pembaca dengan latar belakang teknis maupun nonteknis.

BAB 1 juga menegaskan bahwa faktor manusia merupakan bagian penting dalam keamanan siber. Karena itu, security awareness diperlukan agar pengguna mampu mengenali risiko dan menerapkan praktik keamanan dalam pekerjaan sehari-hari.

BAB 2 – Ancaman Siber dan Penyebab Utama Insiden

BAB 2 membahas berbagai ancaman dan penyebab terjadinya insiden keamanan siber.

Pembaca diperkenalkan pada cara serangan dapat terjadi, termasuk bagaimana penyerang memanfaatkan:

- Kelengahan pengguna.
- Password yang lemah.
- Tidak adanya MFA.
- Kerentanan sistem.
- Salah konfigurasi.
- Hak akses yang berlebihan.
- Social engineering.
- Kurangnya monitoring.

- Kelemahan proses organisasi.

Salah satu pesan penting dari pembahasan ini adalah bahwa insiden sering kali tidak disebabkan oleh satu kelemahan saja.

Sebagai contoh:

Kurang Awareness
↓
Membuka Phishing
↓
Password Dicuri
↓
Tidak Ada MFA
↓
Akun Diambil Alih
↓
Email Disalahgunakan

Studi kasus tersebut menunjukkan bahwa beberapa kelemahan dapat saling berhubungan dan menghasilkan dampak yang lebih besar.

Karena itu, organisasi membutuhkan pertahanan yang berlapis.

BAB 3 – Membangun Pertahanan Siber

BAB 3 memperkenalkan konsep dan teknologi yang digunakan untuk membangun pertahanan keamanan siber.

Pembahasan mencakup konsep:

- Defense in Depth.
- Least Privilege.

- Security by Design.
- Zero Trust.
- Confidentiality, Integrity, Availability (CIA Triad).

Selain itu, pembaca diperkenalkan pada berbagai teknologi keamanan seperti:

- Firewall.
- IDS.
- IPS.
- WAF.
- EDR.
- SIEM.
- Access Control List (ACL).

Buku tidak membahas konfigurasi teknis secara mendalam. Fokusnya adalah membantu pembaca memahami **fungsi dan manfaat** teknologi tersebut dalam strategi pertahanan organisasi.

Pesan utama dari BAB 3 adalah bahwa organisasi tidak seharusnya mengandalkan satu teknologi keamanan saja.

Firewall dapat membantu mengendalikan lalu lintas.

WAF dapat membantu melindungi aplikasi web.

EDR dapat membantu mendeteksi aktivitas pada endpoint.

SIEM dapat membantu mengumpulkan dan menganalisis log.

Namun seluruh teknologi tersebut tetap membutuhkan

manusia, proses, dan pengelolaan yang tepat.

BAB 4 – Membangun Pertahanan Siber

BAB 4 memperkuat konsep pertahanan berlapis.

Defense in Depth berarti organisasi menerapkan beberapa lapisan perlindungan untuk melindungi aset, sistem, jaringan, aplikasi, dan data.

Jika satu lapisan gagal, lapisan lainnya diharapkan dapat membatasi dampak.

Contohnya:

Phishing Lolos dari Email Security

↓

Pengguna Mengenali Phishing

↓

Tidak Memasukkan Password

↓

Serangan Berhenti

Atau:

Password Berhasil Dicuri

↓

MFA Aktif

↓

Pengambilalihan Akun Menjadi Lebih Sulit

Atau:

Akun Berhasil Diambil Alih

↓

Monitoring Mendeteksi Login Mencurigakan



Akun Diamankan



Dampak Dibatasi

Dengan demikian, keamanan siber harus dibangun sebagai sistem pertahanan yang saling melengkapi.

BAB 5 – Menjadi Pengguna yang Aman

BAB 5 merupakan bagian yang sangat penting bagi pengguna sehari-hari karena membahas praktik keamanan yang dapat langsung diterapkan.

Materinya mencakup:

- Password.
- Multi-Factor Authentication.
- Email.
- Phishing.
- Browsing internet.
- Media sosial.
- Laptop dan komputer.
- Smartphone.
- USB flashdisk.
- Backup.
- Perlindungan data organisasi.
- Remote working.
- Do's dan Don'ts.

Struktur BAB 5 memang dirancang untuk memberikan panduan praktis kepada pengguna.

Pesan utamanya sederhana:

Banyak risiko keamanan dapat dikurangi melalui kebiasaan pengguna yang benar.

Contohnya:

Jangan Klik
Jangan Berikan
Jangan Instal
Jangan Bagikan
Laporkan

Prinsip tersebut dapat diterapkan ketika pengguna menghadapi email, pesan, tautan, file, permintaan akses, maupun permintaan informasi yang mencurigakan.

BAB 5 juga menekankan bahwa perlindungan data merupakan tanggung jawab seluruh pengguna, bukan hanya administrator atau tim keamanan.

BAB 6 – Penanganan Insiden Keamanan Siber

BAB 6 menjelaskan bahwa tidak semua serangan dapat dicegah.

Walaupun organisasi telah memiliki firewall, WAF, antivirus, MFA, backup, dan kontrol keamanan lainnya, kemungkinan terjadinya insiden tetap ada.

Karena itu, organisasi perlu memiliki kemampuan **Incident Response**.

Tahapan utama yang dibahas adalah:

Preparation

→ mempersiapkan organisasi.

Identification

→ mengenali dan mengidentifikasi insiden.

Containment

→ membatasi penyebaran dan dampak.

Eradication

→ menghilangkan penyebab dan komponen serangan.

Recovery

→ memulihkan sistem dan layanan.

Lessons Learned

→ mengevaluasi dan mengambil pembelajaran.

Setelah itu, pembaca juga diberikan panduan mengenai:

- Pelaporan insiden.
- Apa yang harus dilakukan ketika terjadi serangan.

Tujuan Incident Response bukan hanya menghentikan serangan, tetapi juga mengurangi dampak, memulihkan layanan, melindungi data, dan mencegah kejadian serupa terulang kembali.

Hal yang sangat penting adalah **Incident Response bukan hanya tugas tim TI.**

Pengguna memiliki peran penting karena pengguna dapat menjadi pihak pertama yang mengetahui adanya kejadian mencurigakan.

BAB 7 – Membangun Budaya Keamanan Siber

BAB 7 membawa pembahasan dari aspek teknis dan prosedural menuju aspek **manusia dan budaya organisasi**.

Strukturnya mencakup:

- Cyber Security adalah Tanggung Jawab Bersama.
- Peran ASN.
- Peran Pegawai Non ASN.
- Peran Operator Aplikasi.
- Peran Helpdesk.
- Peran Administrator Sistem.
- Komitmen Membangun Budaya Cyber Security.
- Ringkasan Buku.

Pesan utama BAB 7 adalah:

Keamanan siber bukan pekerjaan satu orang atau satu unit.

Setiap peran memiliki tanggung jawab yang berbeda.

ASN menjaga keamanan dalam pelaksanaan tugas pemerintahan.

Pegawai Non ASN menjaga keamanan sesuai akses dan tugas yang diberikan.

Operator Aplikasi menjaga penggunaan aplikasi dan data sesuai kewenangan.

Helpdesk menerima, mencatat, mengklasifikasikan, dan meneruskan laporan.

Administrator Sistem menjaga keamanan teknis sistem dan

infrastruktur.

Pimpinan memberikan arah, kebijakan, sumber daya, dan contoh perilaku.

Semua peran tersebut membentuk satu kesatuan pertahanan organisasi.

Dari Pengguna Menjadi Bagian dari Pertahanan

Salah satu pesan terpenting buku ini adalah perubahan cara pandang terhadap pengguna.

Pengguna tidak seharusnya hanya dianggap sebagai:

"orang yang menggunakan sistem."

Pengguna juga merupakan:

"bagian dari pertahanan keamanan organisasi."

Seorang pegawai yang mampu mengenali phishing dan melaporkannya telah membantu organisasi mencegah serangan.

Operator yang menyadari perubahan data yang tidak normal dapat menjadi sumber deteksi awal.

Helpdesk yang mengenali laporan sebagai indikasi keamanan dapat mempercepat eskalasi.

Administrator yang melakukan monitoring dapat menemukan aktivitas mencurigakan.

Pimpinan yang mendukung budaya pelaporan dapat menciptakan lingkungan yang membuat pegawai berani melaporkan kesalahan.

Dengan demikian, setiap orang memiliki kontribusi terhadap keamanan.

Prinsip-Prinsip Utama yang Perlu Diingat

Setelah membaca seluruh buku, terdapat beberapa prinsip sederhana yang dapat dijadikan pegangan.

1. Lindungi Akun

Password adalah rahasia. OTP juga rahasia.

Jangan membagikan kredensial kepada orang lain.

2. Berhenti Sebelum Mengklik

Jangan langsung mempercayai email, pesan, tautan, atau lampiran.

Periksa sebelum bertindak.

3. Gunakan MFA

Password saja tidak selalu cukup.

MFA memberikan lapisan perlindungan tambahan terhadap akun.

4. Gunakan Akses Sesuai Kewenangan

Bisa mengakses bukan berarti boleh mengakses.

Gunakan data dan sistem hanya untuk kebutuhan pekerjaan.

5. Lindungi Data

Sebelum membagikan data, tanyakan:

- Apakah saya berhak mengaksesnya?
- Apakah saya berhak membagikannya?
- Apakah penerima berwenang?
- Apakah media yang digunakan aman?

Jika ragu, **jangan membagikan sebelum melakukan verifikasi.**

6. Jangan Mengabaikan Aktivitas Mencurigakan

Jika sesuatu terlihat tidak normal:

Jangan abaikan.

Catat informasi yang relevan dan laporkan.

7. Jangan Takut Melapor

Kesalahan yang segera dilaporkan lebih mudah ditangani daripada kesalahan yang disembunyikan.

8. Jangan Bertindak Sembarangan Saat Insiden

Ketika terjadi serangan:

Tetap Tenang → Hentikan Interaksi → Jangan Hapus Bukti → Laporkan → Ikuti Instruksi

9. Gunakan Pertahanan Berlapis

Jangan mengandalkan satu teknologi atau satu prosedur.

Manusia + Proses + Teknologi + Monitoring + Respons

harus saling melengkapi.

10. Belajar dari Insiden

Insiden tidak hanya harus diselesaikan.

Insiden harus menjadi sumber pembelajaran untuk memperbaiki:

- Teknologi.
- Proses.

- Kebijakan.
- Awareness.
- Monitoring.
- Respons.

Cyber Security adalah Tanggung Jawab Bersama

Pada akhirnya, keamanan siber kembali kepada prinsip yang menjadi salah satu pesan utama buku ini.

Keamanan bukan hanya tugas administrator.

Keamanan bukan hanya tugas tim TI.

Keamanan bukan hanya tugas security officer.

Keamanan merupakan tanggung jawab seluruh organisasi.

Setiap orang memiliki peran:

Pimpinan



ASN & Pegawai Non ASN



Operator



Helpdesk



Administrator



Tim Keamanan



Seluruh Organisasi

Semua lapisan tersebut harus bekerja bersama.

Tujuan Akhir: Membangun Budaya Keamanan

Tujuan akhir dari security awareness bukanlah membuat seluruh pegawai menjadi ahli keamanan siber.

Tujuannya adalah membuat setiap orang mampu:

Mengenali Risiko

↓

Mengambil Keputusan yang Aman

↓

Melindungi Informasi

↓

Menggunakan Sistem dengan Benar

↓

Melaporkan Kejadian

↓

Mendukung Respons Insiden

Jika kebiasaan tersebut dilakukan secara konsisten, awareness berkembang menjadi budaya.

Pengetahuan

↓

Kesadaran

↓

Perilaku

↓

Kebiasaan

↓

Budaya Keamanan

Ini adalah tujuan utama buku ini: membangun pemahaman, kepedulian, dan partisipasi seluruh pengguna sehingga

organisasi mampu mengurangi risiko serangan, melindungi aset informasi, dan menjaga kepercayaan terhadap layanan digital.

Penutup

Keamanan siber bukan kondisi yang dapat dicapai sekali kemudian dianggap selesai.

Ancaman akan terus berkembang.

Teknologi akan terus berubah.

Cara bekerja akan terus berubah.

Karena itu, keamanan juga harus terus berkembang.

Organisasi perlu terus:

Belajar → Menerapkan → Memantau → Mengevaluasi → Memperbaiki

Setiap pengguna memiliki kesempatan untuk menjadi bagian dari proses tersebut.

Tidak perlu menunggu menjadi administrator.

Tidak perlu menunggu terjadi serangan.

Keamanan dapat dimulai dari tindakan sederhana:

Gunakan password dengan baik.

Aktifkan MFA.

Periksa sebelum mengklik.

Jaga data.

Gunakan akses sesuai kewenangan.

Laporkan sesuatu yang mencurigakan.

Karena pada akhirnya:

Satu orang yang sadar keamanan dapat mencegah satu insiden.

Satu organisasi yang memiliki budaya keamanan dapat mengurangi banyak risiko.

Dan:

Cyber security adalah tanggung jawab kita bersama.

Dengan selesainya BAB 7, pembahasan utama buku **Panduan Praktis Cyber Security Awareness** telah lengkap, mulai dari memahami ancaman, membangun pertahanan, menjadi pengguna yang aman, menangani insiden, hingga membangun budaya keamanan siber yang berkelanjutan. Struktur buku kemudian dilanjutkan dengan lampiran berupa glosarium, daftar singkatan, checklist keamanan harian, checklist administrator sistem, dan referensi.

LAMPIRAN

Daftar Pustaka

Cybersecurity and Infrastructure Security Agency (CISA), National Security Agency (NSA), Federal Bureau of Investigation (FBI), & Multi-State Information Sharing and Analysis Center (MS-ISAC). (2023). *Phishing Guidance: Stopping the Attack Cycle at Phase One*. Washington, DC: U.S. Department of Homeland Security.

European Union Agency for Cybersecurity (ENISA). (2024). *ENISA Threat Landscape 2024*. Heraklion: European Union Agency for Cybersecurity.

Hutchins, E. M., Cloppert, M. J., & Amin, R. M. (2011). *Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains*. *Leading Issues in Information Warfare & Security Research*, 1(1), 80–? .

IBM Security. (2024). *Cost of a Data Breach Report 2024*. Armonk, NY: IBM Corporation.

International Organization for Standardization (ISO) & International Electrotechnical Commission (IEC). (2022). *ISO/IEC 27002:2022: Information Security, Cybersecurity and Privacy Protection — Information Security Controls*. Geneva: International Organization for Standardization.

Joint Task Force. (2020). *Security and Privacy Controls for Information Systems and Organizations (NIST Special Publication 800-53, Revision 5)*. Gaithersburg, MD: National Institute of Standards and Technology.

Merritt, M., Hansche, S., Ellis, B., Snyder, J. N., Sanchez-Cherry, K., & Walden, D. (2024). *Building a Cybersecurity and Privacy Learning Program (NIST Special Publication 800-50, Revision 1)*. Gaithersburg, MD: National Institute of Standards and Technology.

Nelson, A., Rekhi, S., Scarfone, K., & Souppaya, M. (2025). *Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile (NIST Special Publication 800-61, Revision 3)*. Gaithersburg, MD: National Institute of Standards and Technology.

Pascoe, C., Quinn, S., & Scarfone, K. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. Gaithersburg, MD: National Institute of Standards and Technology.

Republik Indonesia. (2019). *Peraturan Pemerintah Republik Indonesia Nomor 71 Tahun 2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik*. Jakarta: Pemerintah Republik Indonesia.

Republik Indonesia. (2022). *Undang-Undang Republik Indonesia Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi*. Jakarta: Pemerintah Republik Indonesia.

Republik Indonesia. (2023). *Undang-Undang Republik Indonesia Nomor 20 Tahun 2023 tentang Aparatur Sipil Negara*. Jakarta: Pemerintah Republik Indonesia.

Temoshok, D., Choong, Y.-Y., Regenscheid, A., Galluzzo, R., Fenton, J. L., Richer, J., & Lefkowitz, N. (2025). *Digital Identity Guidelines: Authentication and Authenticator Management (NIST Special Publication 800-63B-4)*. Gaithersburg, MD: National Institute of Standards and Technology.

Verizon. (2025). *2025 Data Breach Investigations Report*. New

York, NY: Verizon Business.

Verizon. (2026). *2026 Data Breach Investigations Report*. New York, NY: Verizon Business.